HW02 – Domain Testing on EShop: Báo cáo chính

Môn	Kiểm thử phần mềm, FIT@HCMUS, 2026
Sinh viên	Phạm Quang Vinh, MSSV **23120202**
SUT	EShop (`https://github.com/ttbhanh/eshop-sut` , commit `85af3ba`)
Kỹ thuật	Phân hoạch tương đương (Equivalence Partitioning, EP) và Phân tích giá trị biên (Boundary Value Analysis, BVA)
Công cụ AI	Claude Code, model Claude Opus 5.5 (xem AI Audit Report và AI Critique)
Repo và GitHub Issues	`https://github.com/vinh-code/HW02-Software-Testing` , Issues #1–#28

Mục lục

1. Tổng quan
2. Phương pháp
3. FR-01 Đăng ký tài khoản (Pool A)
4. FR-09 Mã giảm giá (Pool B)
5. FR-15 Quản lý sản phẩm CRUD (Pool C)
6. FR-20 Mobile: Giỏ hàng & Số lượng (Pool D)
7. Tổng hợp kết quả
8. Phân tích chung về AI và bài học
9. Giới hạn của bài làm
10. Danh mục tài liệu

1. Tổng quan

Pool	Mã	Tính năng	Kênh kiểm thử	TC	Pass	Fail	Bug
A	FR-01	Đăng ký tài khoản	Web `/register` + `POST /api/register`	42	1	41	7
B	FR-09	Mã giảm giá (Coupon)	Web `/checkout` + `POST /api/apply-coupon`	30	15	15	8
C	FR-15	Quản lý sản phẩm (CRUD)	Admin `:5174` + `/api/products`	37	13	24	7
D	FR-20	Mobile: Giỏ hàng & Số lượng	App Expo (Expo Web, mô phỏng Pixel 5)	31	7	24	6
		Tổng		**140**	**36**	**104**	**28**

Phân bố bug theo mức độ: 11 Critical, 11 Major, 6 Minor. Cả 28 bug đều được báo cáo trong Markdown và trên GitHub Issues, có ảnh minh chứng.

Kết luận nhanh:

- Cả 4 tính năng đều **không đạt** đặc tả.
- Điểm chung lớn nhất là **server gần như không có validation**: mọi kiểm tra (nếu có) chỉ nằm ở client, và có thể bỏ qua bằng cách gọi API trực tiếp.
- Các lỗi nghiêm trọng nhất:
  - Đăng ký không được bằng mật khẩu đúng chuẩn.
  - Coupon `percent` khiến khách bị tính **gấp 10 lần**.
  - API sản phẩm cho **người lạ** xóa/sửa toàn bộ sản phẩm.

- Bảng Admin ghi tên sai vào CSDL.
- Sửa số lượng trong giỏ mobile bị lưu thành **n + 1**.

---

2. Phương pháp

2.1 Quy trình 7 bước cho mỗi tính năng

Mỗi bước là **một file Markdown** trong thư mục tính năng và **một git commit** (xem `git_commit_log.txt`):

Bước	File	Nội dung	Commit
EP-B1	`01_input_output.md`	Trích yêu cầu (đối chiếu chéo toàn SRS), Input/Output, điều kiện C1…Cn kèm loại điều kiện, giả định A1…An	`FR-xx [EP-B1]`
EP-B2	`02_equivalence_classes.md`	Bảng nguyên tắc tạo lớp, bảng lớp tương đương EC (hợp lệ/không hợp lệ, cả lớp đầu ra), dữ liệu chuẩn bị	`[EP-B2]`
EP-B3	`03_ep_test_cases.md`	TC cho từng lớp → bảng rút gọn (nhiều lớp hợp lệ/TC, **1 lớp không hợp lệ/TC**) → ma trận độ phủ	`[EP-B3]`
BVA	`04_bva_test_cases.md`	Miền có thứ tự, biên LB/UB, chọn biến thể (Standard/Robustness/Worst-case) và lý do, bảng TC	`[BVA]`
EXEC	`05_test_execution.md`	Môi trường, tiêu chí Pass/Fail, kiểm tra masking, kết quả từng TC trên từng kênh, ảnh chụp	`[EXEC]`
BUG	`06_bug_report.md`	Bug gom theo nguyên nhân gốc, bước tái hiện, mong đợi/thực tế, severity, minh chứng, link Issue	`[BUG]`
GAP	`07_ai_gap_analysis.md`	Những gì AI bỏ sót/làm sai, nguyên nhân, TC bổ sung, rủi ro còn lại, bài học	`[GAP]`

2.2 Cách dùng AI

AI **không** được giao "sinh test case và tìm bug" trong một lần, mà được dẫn qua từng bước của kỹ thuật như trên. Sinh viên duyệt kết quả ở các điểm then chốt:

- Chấp nhận hoặc sửa giả định ở B1.
- Rà bảng lớp và độ phủ.
- Kiểm tra lại ảnh chụp và số liệu.
- Rà soát gap analysis.

Toàn bộ prompt và output được ghi trong AI Audit Report.

2.3 Thực thi tự động trên hai tầng

- **UI:** Playwright 1.49.1 (Chromium 131 headless). Mỗi TC chụp một ảnh.
- **API:** gọi trực tiếp endpoint bằng `fetch`. Validation phía client có thể bị bỏ qua, nên hệ thống đúng phải chặn dữ liệu sai ***ở cả hai tầng***.
- **Hậu kiểm:** đọc lại trạng thái hệ thống qua API trước và sau mỗi TC (đếm tài khoản, so sánh toàn bộ danh sách sản phẩm, xem đơn hàng), thay vì chỉ tin vào thông báo trên màn hình.
- **Thứ tự chạy:** TC hợp lệ chạy trước để phát hiện **masking** (lỗi che lỗi). Nếu bộ giá trị nền bị từ chối thì mọi TC không hợp lệ chạy sau đều có thể Pass giả.
- **Reset dữ liệu:** khởi động lại backend trước mỗi tính năng (DB được seed lại). Mỗi TC và mỗi kênh dùng dữ liệu riêng (email, mô tả làm nhãn nhận diện).
- **Minh chứng tầng API:** script `api_evidence.js` gửi request thật, rồi render request/response thành ảnh PNG.
- **Đồng bộ GitHub Issues:** `create_issues.py` đọc `06_bug_report.md`, tạo Issue với tiêu đề `[FR-xx] [Mã TC] …`, nhãn severity, ảnh nhúng.

2.4 Quy ước

- Lớp `EC1…`, TC `EP-01…` / `BVA-01…`. TC bổ sung sau gap analysis được đánh số tiếp. Lượt chạy lại có hậu tố `R`.
- Ký hiệu ✅ Pass, ❌ Fail, ⚠️ Pass giả (đúng kết quả nhưng sai lý do).
- Một TC chỉ Pass khi Pass trên **mọi kênh** đã chạy.

---

3. FR-01 Đăng ký tài khoản (Pool A)

Chi tiết: `features/FR-01_Register/`

3.1 EP: Input/Output và lớp tương đương

- **Input:**
  - I1 Họ tên, I2 Email, I3 Mật khẩu, I4 Xác nhận mật khẩu.
  - Trạng thái hệ thống: tập email đã tồn tại.
- **Output:**
  - O1: tạo tài khoản và chuyển sang `/login`.
  - O2: báo lỗi, không tạo tài khoản.
- **9 điều kiện:**
  - C1 họ tên khác rỗng.
  - C2 email đúng định dạng.
  - C3 email chưa tồn tại.
  - C4 độ dài mật khẩu ≥ 8.
  - C5–C7 mật khẩu có chữ hoa, chữ thường, chữ số.
  - C8 mật khẩu có ký tự đặc biệt thuộc `{@$!%*?&}`.
  - C9 xác nhận mật khẩu khớp.
- **Giả định:**
  - A1: không có độ dài tối đa.
  - A2: email có dạng `local@domain.tld`.
  - A3: ký tự ngoài tập vẫn hợp lệ nếu đã có ký tự trong tập.
  - A4: họ tên chỉ có khoảng trắng thì coi là rỗng.
  - A5: email không phân biệt hoa/thường.
- **25 lớp** (7 hợp lệ, 18 không hợp lệ). Một số lớp không hợp lệ được tách nhỏ:
  - Email sai định dạng: thiếu `@`, thiếu phần local, domain thiếu `.`.
  - Mật khẩu: thiếu từng loại ký tự.
  - Email trùng khác hoa/thường.
- **19 TC EP** (2 hợp lệ, 17 không hợp lệ), phủ 25/25 lớp.

3.2 BVA

Mấu chốt là nhận ra điều kiện "có ít nhất 1 chữ hoa/thường/số/ký tự đặc biệt" thực chất là điều kiện trên **biến đếm có thứ tự** (`count ≥ 1`). Vì vậy có thể áp dụng BVA cho 6 biến:

Biến	Miền hợp lệ	Điểm kiểm tra
V1 len(Họ tên)	[1..∞)	0, 1, 2
V2 len(Mật khẩu)	[8..∞)	7, 8, 9
V3–V6 số chữ hoa / chữ thường / chữ số / ký tự đặc biệt	[1..∞)	0, 1, 2

- Cả 6 biến **chỉ có biên dưới**, nên Robustness 6n+1 được điều chỉnh thành **3n+1 = 19 TC**.
- Mật khẩu nominal `ABCdef123@!$` có 3 ký tự mỗi loại, để điểm nominal không trùng LB+1.
- Thêm 2 TC độ bền (chuỗi 256 ký tự). Tổng **21 TC BVA**.

- Worst-case ($3^6 = 729$) bị loại.

3.3 Thực thi và phát hiện chính

- **Masking trên UI:** UI từ chối **mọi** mật khẩu đúng spec, kể cả TC hợp lệ EP-01. Vì vậy các TC không hợp lệ về họ tên/email trên UI ban đầu là ⚠️ Pass giả.
  - Lượt thăm dò cho thấy UI coi **khoảng trắng** là "ký tự đặc biệt" và **cấm** `@$!%*?&`.
  - Chạy lại 9 TC (hậu tố `R`) với mật khẩu `Abcdef1` mà UI chấp nhận, để mỗi TC chỉ còn một lớp không hợp lệ.
- **API:** không có validation nào. Họ tên, email, mật khẩu rỗng đều đăng ký được.
- **Kết quả:** 42 TC (19 EP + 21 BVA + 2 bổ sung). **1 Pass, 41 Fail.**

3.4 Bug

Bug	Tóm tắt	Severity	Issue
BUG-FR01-01	UI từ chối mọi mật khẩu hợp lệ, chỉ chấp nhận mật khẩu có khoảng trắng	Critical	#1
BUG-FR01-02	API không kiểm tra độ mạnh mật khẩu	Critical	#2
BUG-FR01-03	Cho đăng ký email trùng (kể cả khác hoa/thường)	Critical	#3
BUG-FR01-04	Không kiểm tra định dạng email (UI dùng `type="text"`)	Major	#4
BUG-FR01-05	Thiếu trường Xác nhận mật khẩu	Major	#5
BUG-FR01-06	API chấp nhận trường bắt buộc rỗng; họ tên toàn khoảng trắng được chấp nhận	Major	#6
BUG-FR01-07	**Stored XSS** qua Họ tên, thực thi trên header sau khi đăng nhập	Critical	#7

3.5 Gap analysis (tóm tắt)

AI bỏ sót 2 lớp:

- **Họ tên tiếng Việt:** AI có thiên lệch ASCII.
- **Họ tên chứa HTML:** prompt chỉ yêu cầu phân tích FR-01, nên AI bỏ qua SEC-04. Lớp này dẫn tới bug Critical BUG-FR01-07.

AI cũng không lường trước masking, và có ghi sai số liệu thống kê ở B2. Bài học áp dụng cho 3 tính năng sau:

- **Đối chiếu chéo toàn SRS** trước khi phân hoạch.
- **Chạy TC hợp lệ trước.**

---

4. FR-09 Mã giảm giá (Pool B)

Chi tiết: `features/FR-09_Coupon/`

4.1 EP

- **Yêu cầu được đối chiếu:**
  - 5 điều kiện C1–C5 của FR-09 và hai công thức `percent` / `fixed`.
  - FR-08: tổng tiền do hệ thống tính, không cho sửa.
  - SEC-02: API phải yêu cầu JWT.
- **Input:**
  - I1 mã giảm giá.
  - I2 tổng đơn (gián tiếp qua giỏ hàng).
  - I3 trạng thái đăng nhập.
  - I4 số lần đã dùng mã.

- **Output:**
  - O1a giảm theo `percent`, O1b giảm theo `fixed`.
  - O2 từ chối.
- **21 lớp** (10 hợp lệ, 11 không hợp lệ). Một số lớp đáng chú ý:
  - Mã bị vô hiệu hóa, mã hết hạn **đúng hôm nay**.
  - Không có token, token giả.
  - Đã dùng hết lượt nhưng **không gửi** `user_id`.
  - Tổng tiền bị người dùng sửa tay.
- **15 TC EP**, phủ 21/21 lớp.
- **Chuẩn bị dữ liệu:**
  - 8 sản phẩm test có giá chính xác (200.000, 299.999 … 1.000.000 ₫) để chạm đúng biên.
  - Coupon `EXP0D/EXP1D/EXP2D` (hết hạn hôm nay / ngày mai / ngày kia).
  - Coupon `OFF10` bị vô hiệu hóa.

4.2 BVA

Biến	Miền hợp lệ	Điểm
V1 tổng đơn với SAVE10 (min 300.000)	[300.000..∞)	299.999 / **300.000** / 300.001
V2 tổng đơn với BIGBUY (min 500.000)	[500.000..∞)	499.999 / **500.000** / 500.001
V3 số ngày còn hạn `d`	[1..∞) (giả định A2)	0 (hôm nay) / **1** / 2
V4 số lần đã dùng VIP100 (max 2)	[0..1]	0 / **1** / 2

- Dùng Robustness thu gọn: 1 nominal + 4 × 3 = **13 TC**.
- C3 được kiểm tra trên hai mã khác ngưỡng và khác công thức, để phát hiện ngưỡng gắn cứng và kiểm tra công thức ngay tại biên.

4.3 Thực thi và phát hiện chính

- **Không có masking về quyết định chấp nhận/từ chối.** Tuy vậy, mọi TC dùng mã `percent` đều sai **số tiền**. Vì vậy bảng kết quả tách hai cột **Quyết định** và **Số tiền**. Nhờ đó vẫn kết luận được biên ngày hết hạn đúng, dù công thức sai.
- **BVA bắt được lỗi off-by-one** mà EP không thấy: tổng đơn **bằng đúng** ngưỡng bị từ chối, trong khi ngưỡng + 1 ₫ thì được chấp nhận. Điều này cho thấy hệ thống dùng `>` thay vì `>=`.
- **Hậu kiểm đơn hàng:** lỗi công thức được ghi vào **đơn hàng thật**. Đơn 10.000.000 ₫ được tạo cho một giỏ 1.000.000 ₫.
- **Kết quả:** 30 TC (15 EP + 13 BVA + 2 bổ sung). **15 Pass, 15 Fail.**

4.4 Bug

Bug	Tóm tắt	Severity	Issue
BUG-FR09-01	Công thức `percent` sai (`total × (1 − v)`): giảm âm, khách trả gấp 10 lần	Critical	#8
BUG-FR09-02	Tổng đơn **= min_order_amount** bị từ chối (`>` thay vì `>=`)	Major	#9
BUG-FR09-03	Áp mã không cần đăng nhập/JWT (API, và route `/checkout` không được bảo vệ)	Critical	#10
BUG-FR09-04	Né giới hạn số lần dùng bằng cách bỏ `user_id`	Critical	#11
BUG-FR09-05	Ô tổng tiền ở Checkout sửa được, nên vượt được ngưỡng tối thiểu	Critical	#12
BUG-FR09-06	API phân biệt hoa/thường và không bỏ khoảng trắng của mã (UI thì có)	Minor	#13
BUG-FR09-07	Mã hết hạn "hôm nay" vẫn dùng được nếu `expired_at` có kèm giờ	Minor	#14
BUG-FR09-08	Thành tiền âm và đơn hàng tổng âm khi mức giảm > tổng đơn	Major	#15

4.5 Gap analysis (tóm tắt)

AI suy ra miền giá trị từ **bảng dữ liệu mẫu** trong SRS thay vì từ nơi dữ liệu thực sự được nhập. Hậu quả là bỏ sót 2 lớp:

- `expired_at` có kèm giờ.
- Mức giảm lớn hơn tổng đơn. AI đã **tự nêu ra rủi ro này rồi gạt đi**.

Hai lớp này dẫn tới 2 bug mới. Ngoài ra:

- Ghi nhận việc **rò rỉ kiến thức hộp trắng** (AI đã đọc mã nguồn trước khi thiết kế).
- Ghi nhận một lần Fail giả do công cụ: email trùng làm đăng nhập vào tài khoản cũ.

---

5. FR-15 Quản lý sản phẩm CRUD (Pool C)

Chi tiết: `features/FR-15_ProductCRUD/`

5.1 EP

- **Yêu cầu:**
  - Tên bắt buộc, ≤ 255 ký tự.
  - Giá bắt buộc, > 0.
  - Danh mục chọn từ danh sách có sẵn.
  - Sửa một sản phẩm thì chỉ sản phẩm đó thay đổi.
  - Đối chiếu chéo: FR-12/SEC-02/SEC-03 (phân quyền admin), SEC-04 (escape khi hiển thị).
- **Input:**
  - I0 thao tác (Thêm/Sửa/Xóa).
  - I1 tên, I2 giá, I3 danh mục.
  - I4 sản phẩm được chọn.
  - I5 quyền người gọi.
- **21 lớp** (9 hợp lệ, 12 không hợp lệ). Đáng chú ý:
  - Tên tiếng Việt + HTML (áp dụng bài học FR-01).
  - Giá rỗng / 0 / âm / chữ.
  - Danh mục thiếu / không tồn tại.
  - Không token / token user thường.
  - Hai lớp **đầu ra**: Sửa và Xóa chỉ ảnh hưởng đúng 1 sản phẩm.
- **22 TC EP.** Lớp không hợp lệ quan trọng được lặp lại trên **mỗi thao tác**, vì POST/PUT/DELETE là các đường xử lý riêng.

5.2 BVA

Biến	Miền hợp lệ	Điểm
V1 độ dài tên	[1..255] (hai biên)	0 / **1** / 2 / 254 / **255** / 256
V2 giá (bước 1 ₫)	[1..∞)	0 / **1** / 2, và độ bền 2^{31} = 2.147.483.648
V1 trên thao tác Sửa		**255** / 256

- Danh mục **không** dùng BVA, vì `category_id` là định danh, không có thứ tự nghiệp vụ.
- Tổng **13 TC**.

5.3 Thực thi và phát hiện chính

- **Mọi TC Pass đều là TC hợp lệ.** Không một lớp không hợp lệ nào bị server từ chối.
- Khả năng từ chối duy nhất của tính năng là thuộc tính HTML5 `required` của ô Tên trên UI.

- **Hậu kiểm toàn bộ danh sách** phát hiện: sau khi Sửa 1 sản phẩm, **bảng Admin đổi tên mọi sản phẩm**.
  - Thăm dò thêm "thao tác tiếp theo của admin" cho thấy lỗi này **ghi tên sai vào CSDL**: iPhone bị đổi tên thật thành Samsung.
  - Bug được nâng từ lỗi hiển thị lên **Critical**.
- **Kết quả:** 37 TC (22 EP + 13 BVA + 2 bổ sung). **13 Pass, 24 Fail.**

5.4 Bug

Bug	Tóm tắt	Severity	Issue
BUG-FR15-01	POST/PUT/DELETE `/api/products` không cần đăng nhập/quyền admin	Critical	#16
BUG-FR15-02	Sửa 1 SP thì bảng Admin đổi tên mọi SP; lần sửa tiếp ghi tên sai vào CSDL	Critical	#17
BUG-FR15-03	Không kiểm tra giá (0, âm, rỗng, chữ)	Major	#18
BUG-FR15-04	Không kiểm tra tên (> 255 ký tự, chỉ khoảng trắng; API nhận tên rỗng)	Major	#19
BUG-FR15-05	API chấp nhận danh mục rỗng / không tồn tại	Major	#20
BUG-FR15-06	Sửa/Xóa SP không tồn tại vẫn trả 200	Minor	#21
BUG-FR15-07	PUT thiếu trường thì xóa trắng tên, mô tả, ảnh, danh mục	Major	#22

5.5 Gap analysis (tóm tắt)

AI chưa phân biệt **trường vắng mặt** với **trường rỗng** ở API. Đây là chiều phân hoạch theo cấu trúc request, và khi bổ sung thì phát hiện BUG-FR15-07. Ngoài ra:

- AI né giả định "đếm theo ký tự" bằng cách chỉ dùng chuỗi ASCII. TC bổ sung với 255 ký tự tiếng Việt thì Pass.
- AI đánh giá severity thấp vì chỉ xét trạng thái ngay sau TC.
- Ghi nhận rò rỉ kiến thức hộp trắng.

---

6. FR-20 Mobile: Giỏ hàng & Số lượng (Pool D)

Chi tiết: `features/FR-20_Mobile_Cart/`

6.1 Cơ sở đặc tả và môi trường

FR-20 chỉ ghi app mobile phải có "đầy đủ chức năng … Giỏ hàng". Vì vậy quy tắc nghiệp vụ được lấy từ:

- **FR-06:** số lượng là số nguyên ≥ 1.
- **FR-07:** nút +/−, gộp dòng khi thêm cùng sản phẩm, dialog xác nhận xóa, nhãn "Tổng cộng", giỏ trống có hình minh họa.

Máy kiểm thử không có thiết bị hay emulator. App được chạy bằng **Expo Web** (react-native-web), mô phỏng **Pixel 5** qua Playwright.

- Thay đổi môi trường:
  - `API_URL` đổi sang IP LAN của máy.
  - Cài thêm `react-native-web`, `react-dom`, `@expo/metro-runtime`.
  - Không sửa logic app.
- Giới hạn: `Alert` không hiển thị trên web. Mọi kết luận dựa trên **hiệu ứng** lên giỏ hàng.

6.2 EP

- **Input:**

    - I1 số lượng ở trang chi tiết.
    - I2 số lượng sửa trong giỏ.
    - I3 nút +/−.
    - I4 số lần thêm cùng sản phẩm.
    - I5 thao tác Xóa (Đồng ý/Hủy).
    - I6 giỏ trống hay có hàng.
- **19 lớp** (9 hợp lệ, 10 không hợp lệ). Mỗi ô số lượng có 5 cách vi phạm: 0, âm, thập phân, chữ, rỗng.
- **18 TC EP.**
- Các TC sửa số lượng trong giỏ bắt đầu từ SL = 2 (không phải 1). Nhờ vậy phân biệt được "giữ nguyên" với "âm thầm đổi về 1".

6.3 BVA

Biến	Miền hợp lệ	Điểm
V1 SL ở trang chi tiết	[1..∞)	0 / **1** / 2, độ bền 999
V2 SL sửa trong giỏ	[1..∞)	0 / **1** / 2, độ bền 999
V3 SL sau khi bấm +/−	[1..∞)	− tại 1 / − tại 2 / + tại 1

Tổng **12 TC**.

6.4 Thực thi và phát hiện chính

- **Lỗi "+1":** sửa SL trong giỏ thì giá trị được lưu thành **n + 1**. Nhập 5 được 6, nhập 1 được 2, nhập 999 được 1000.
    - Thăm dò thao tác bàn phím như trên điện thoại: xóa số cũ thì ô nhảy về 1, gõ 5 thì thành **16**.
- **Pass giả EP-16:** nhập `1.5` thì app tính `parseInt(1.5) + 1 = 2`, trùng ngẫu nhiên với SL ban đầu là 2. Chạy lại EP-16R với SL ban đầu 3 → Fail.
- **Masking do gộp tiêu chí:** ở lượt chạy thử, lỗi nhãn "Tổng tạm tính" làm Fail mọi TC hợp lệ. Sau đó tiêu chí nhãn được tách riêng, chỉ tính ở EP-01.
- **Kết quả:** 31 TC (18 EP + 12 BVA + 1 bổ sung). **7 Pass, 24 Fail.**

6.5 Bug

Bug	Tóm tắt	Severity	Issue
BUG-FR20-01	Sửa SL trong giỏ bị lưu thành n + 1	Critical	#23
BUG-FR20-02	Không có nút +/−	Major	#24
BUG-FR20-03	Xóa ngay, không có dialog xác nhận	Major	#25
BUG-FR20-04	SL không hợp lệ bị âm thầm đổi thành 1, không thông báo	Minor	#26
BUG-FR20-05	Nhãn "Tổng tạm tính" thay vì "Tổng cộng"	Minor	#27
BUG-FR20-06	Giỏ trống không có hình minh họa	Minor	#28

6.6 Gap analysis (tóm tắt)

- **Độ trung thực của môi trường Expo Web:** bàn phím số trên web không chặn chữ.
- **Pass giả do trùng giá trị.**
- **Masking do gộp tiêu chí đầu ra.**
- **Chưa phân hoạch kiểu dữ liệu do API trả về:** giá trả về dạng chuỗi với id chẵn. TC bổ sung EP-19 Pass.

---

7. Tổng hợp kết quả

7.1 Test Summary

Tính năng	TC thiết kế	Đã thực thi	Pass	Fail	Chưa thực thi	Bug (C/M/m)
FR-01	42 (19 EP + 21 BVA + 2 bổ sung)	42	1	41	0	7 (4/3/0)
FR-09	30 (15 EP + 13 BVA + 2 bổ sung)	30	15	15	0	8 (4/2/2)
FR-15	37 (22 EP + 13 BVA + 2 bổ sung)	37	13	24	0	7 (2/4/1)
FR-20 Mobile	31 (18 EP + 12 BVA + 1 bổ sung)	31	7	24	0	6 (1/2/3)
Tổng	**140** (74 EP + 59 BVA + 7 bổ sung)	**140**	**36**	**104**	**0**	**28 (11/11/6)**

C = Critical, M = Major, m = Minor. Ngoài 140 TC còn có 11 lượt chạy lại (FR-01: 9 TC hậu tố `R`; FR-09: EP-17r; FR-20: EP-16R) và 3 kịch bản thăm dò (mật khẩu UI ở FR-01, hỏng dữ liệu ở FR-15, gõ phím ở FR-20).

7.2 Hiệu quả của từng kỹ thuật

Kỹ thuật / hoạt động	Bug tìm được nhờ nó (ví dụ)
EP: lớp không hợp lệ, chạy qua API	Thiếu validation server ở cả 3 tính năng web (FR01-02/06, FR15-01/03/04/05, FR09-03/04)
EP: lớp hợp lệ (chạy trước)	Lỗi chặn hoàn toàn chức năng chính: FR01-01 (không đăng ký được), FR09-01 (công thức sai), FR20-01 (+1)
EP: lớp đầu ra	FR15-02 (sửa 1 SP ảnh hưởng mọi SP), FR09-01
BVA	FR09-02 (`>` thay vì `>=`, **chỉ BVA phát hiện được**), FR15-04 (không có biên trên 255), FR20-01 tại LB
Đối chiếu chéo SRS (SEC/GUI/FR khác)	FR01-07 (XSS), FR09-05 (sửa tổng tiền), FR15-01 (phân quyền)
AI gap analysis + TC bổ sung	FR01-07, FR09-07, FR09-08, FR15-07
Hậu kiểm + thăm dò	FR09-01 ghi vào đơn hàng thật; FR15-02 hỏng dữ liệu thật; FR20-01 khi gõ phím

8. Phân tích chung về AI và bài học

Tổng hợp từ 4 file `07_ai_gap_analysis.md`. Ý kiến cá nhân về AI nằm ở AI Critique.

Loại sai sót của AI	Xuất hiện ở	Biện pháp đã áp dụng
Phạm vi phân tích theo đúng câu chữ của prompt, bỏ qua yêu cầu ở mục khác (SEC-04)	FR-01 G2	Từ FR-09: yêu cầu AI liệt kê **mọi yêu cầu liên quan trong toàn SRS**
Thiên lệch dữ liệu: ASCII, bảng dữ liệu mẫu	FR-01 G1, FR-09 G1/G2	Lớp bắt buộc: tiếng Việt, HTML; lấy miền theo nơi dữ liệu được nhập
Áp dụng nguyên tắc máy móc, không kiểm tra tiền đề (masking)	FR-01 G4	Chạy TC hợp lệ trước; thăm dò khi TC hợp lệ Fail
Pass giả do trùng giá trị; masking do gộp tiêu chí	FR-20 G2/G3	Chọn giá trị nền phân biệt được; mỗi tiêu chí đầu ra một TC
Chưa phân hoạch trên cấu trúc request (vắng mặt / `null` / sai kiểu)	FR-15 G1	Thêm chiều phân hoạch cho API
Tự nêu rủi ro rồi tự gạt đi; né giả định	FR-09 G2, FR-15 G2	Mỗi rủi ro phải thành TC hoặc có lý do loại; mỗi giả định ≥ 1 TC
Đánh giá severity thấp	FR-15 G5	Xét chuỗi thao tác tiếp theo của người dùng

Loại sai sót của AI	Xuất hiện ở	Biện pháp đã áp dụng
Rò rỉ kiến thức hộp trắng (đã đọc code trước khi thiết kế)	FR-09/15/20	Mỗi lớp phải có căn cứ từ spec; trong skill, B0–B4 cấm đọc code
Sai số liệu khi viết trước rồi mới đếm	FR-01 G5	Đếm lại bằng script trước khi ghi

Tất cả bài học trên được đóng gói thành **checklist 24 mục** trong Agent Skill `skills/domain-testing/`, để áp dụng lại cho tính năng khác.

---

9. Giới hạn của bài làm

- **FR-20 chạy trên Expo Web**, không trên thiết bị thật. Kết luận dựa trên hiệu ứng nên không phụ thuộc môi trường, nhưng EP-12 và EP-17 (nhập chữ) có thể không tái hiện được bằng bàn phím số của điện thoại.
- **Rò rỉ kiến thức hộp trắng:** AI đã đọc mã nguồn SUT khi tìm hiểu hệ thống, trước khi thiết kế FR-09, FR-15, FR-20. Mọi lớp tương đương đều đã được kiểm tra lại để có căn cứ từ đặc tả.
- **Một số giả định là diễn giải của AI**, đã được sinh viên chấp nhận (ví dụ FR-01 A3, A5; FR-09 A1, A2). Các bug phụ thuộc giả định được ghi rõ và xếp mức thấp hơn.
- **Ngoài phạm vi EP/BVA:** kiểm thử đồng thời, hiệu năng, khả năng truy cập. Các rủi ro còn lại được liệt kê ở mục 7.2 của từng tính năng.

---

10. Danh mục tài liệu

Tài liệu	Đường dẫn
Báo cáo chính (bản này, có PDF)	`REPORT.md`, `REPORT.pdf`
7 bước × 4 tính năng	`features/FR-01_Register/`, `features/FR-09_Coupon/`, `features/FR-15_ProductCRUD/`, `features/FR-20_Mobile_Cart/`
Bug report (Markdown) + GitHub Issues #1–#28	`features/*/06_bug_report.md`, `bugs/`
Ảnh minh chứng	`features/*/screenshots/`
Kết quả thô	`features/*/results_*.json`
Script thực thi (Playwright, API)	`scripts/`
Agent Skill	`skills/domain-testing/`
AI Audit Report, AI Critique (MD + PDF)	`ai-audit/`
Git commit log	`git_commit_log.txt`
README (tự đánh giá + test summary)	`README.md`

PHỤ LỤC

Phụ lục 1 — `features/FR-01_Register/01_input_output.md`

FR-01 Đăng ký tài khoản: Bước 1, Xác định Input & Output

> Kỹ thuật: Phân hoạch tương đương, bước 1/3 (slide Bài 4, tr.6–7). Cơ sở kiểm thử: SRS EShop, mục FR-01, và FR-22 cho phần ràng buộc form.

1.1 Trích yêu cầu từ SRS

Mã	Nội dung đặc tả (FR-01)
R1	Người dùng phải cung cấp **Họ Tên**, **Email**, **Mật khẩu**
R2	Email phải có **định dạng hợp lệ** (`user@domain.com`)
R3	Email phải **duy nhất** trong hệ thống
R4	Mật khẩu dài **tối thiểu 8 ký tự**
R5	Mật khẩu có **≥ 1 chữ hoa**, **≥ 1 chữ thường**, **≥ 1 chữ số**
R6	Mật khẩu có **≥ 1 ký tự đặc biệt** thuộc tập `{@, $, !, %, *, ?, &}`
R7	Có trường **Xác nhận mật khẩu**; hệ thống từ chối khi hai trường không khớp
R8	Đăng ký thành công thì **chuyển tới trang Đăng nhập**

1.2 Biến đầu vào (Input)

Mã	Input	Kiểu	Bắt buộc	Ràng buộc liên quan
I1	Họ Tên (`name`)	chuỗi	Có	R1
I2	Email (`email`)	chuỗi	Có	R1, R2, R3
I3	Mật khẩu (`password`)	chuỗi	Có	R1, R4, R5, R6
I4	Xác nhận mật khẩu (`confirmPassword`)	chuỗi	Có	R7

Trạng thái hệ thống (tiền điều kiện) ảnh hưởng tới kết quả: tập email đã tồn tại trong CSDL. Dữ liệu seed có sẵn `admin@eshop.com` và `test@eshop.com`. Biến I2 phụ thuộc vào trạng thái này vì ràng buộc R3.

1.3 Biến đầu ra (Output)

Mã	Output	Mô tả
O1	Đăng ký thành công	Tài khoản được tạo trong CSDL và giao diện chuyển sang trang `/login`
O2	Thông báo lỗi	Hiển thị lỗi phù hợp, **không** tạo tài khoản, người dùng vẫn ở trang đăng ký

1.4 Các điều kiện cần phân hoạch (đầu vào cho Bước 2)

Mỗi ràng buộc trong spec được tách thành một điều kiện độc lập để lập lớp tương đương ở Bước 2:

Điều kiện	Biến	Loại điều kiện (theo slide tr.10)
C1. Họ tên khác rỗng	I1	Boolean

Điều kiện	Biến	Loại điều kiện (theo slide tr.10)
C2. Email đúng định dạng	I2	Boolean
C3. Email chưa tồn tại	I2	Boolean
C4. Độ dài mật khẩu ≥ 8	I3	Dãy giá trị `[8..∞)`, **có thứ tự nên áp dụng được BVA**
C5. Có chữ hoa	I3	Boolean
C6. Có chữ thường	I3	Boolean
C7. Có chữ số	I3	Boolean
C8. Có ký tự đặc biệt thuộc tập `{@$!%*?&}`	I3	Tập giá trị
C9. Xác nhận mật khẩu khớp	I4	Boolean

1.5 Điểm mơ hồ trong đặc tả và giả định áp dụng

#	Điểm mơ hồ	Giả định áp dụng
A1	Spec không quy định độ dài tối đa của Họ tên, Email, Mật khẩu	Không có biên trên. Thêm 1 TC chuỗi rất dài (≥ 256 ký tự) để kiểm tra độ bền
A2	"Định dạng hợp lệ `user@domain.com`" không nêu chi tiết	Hợp lệ khi có dạng `local@domain.tld`: có đúng 1 ký tự `@`, phần local và domain khác rỗng, domain có dấu `.`
A3	Mật khẩu chứa ký tự đặc biệt **ngoài** tập (ví dụ `#`), nhưng vẫn có 1 ký tự trong tập	Spec chỉ yêu cầu "có ít nhất 1" ký tự trong tập, không cấm ký tự khác, nên coi là **hợp lệ**
A4	Họ tên chỉ chứa khoảng trắng	Coi như **rỗng**, tức là không hợp lệ
A5	Email khác chữ hoa/thường (`TEST@eshop.com`) so với email đã tồn tại	Email không phân biệt hoa/thường nên coi là **trùng**

1.6 Kênh thực thi & quan sát ban đầu (hộp đen)

- **UI:** `http://localhost:5173/register`. Form hiện có 3 trường: Họ Tên, Email, Mật khẩu. **Không có trường Xác nhận mật khẩu (I4).** Vì vậy các TC liên quan C9 sẽ Fail ngay từ thiết kế giao diện.
- **API:** `POST /api/register` với body `{name, email, password}`. API spec cũng **không có** trường xác nhận mật khẩu. Dùng API để kiểm tra validation phía server, vì validation phía client có thể bị bỏ qua.
- Mỗi TC sẽ được thực thi trên **cả UI và API** khi có thể, vì một hệ thống đúng phải chặn dữ liệu sai ở cả hai tầng.

Phụ lục 2 — `features/FR-01_Register/02_equivalence_classes.md`

FR-01 Đăng ký tài khoản: Bước 2, Xác định lớp tương đương

> Kỹ thuật: Phân hoạch tương đương, bước 2/3 (slide Bài 4, tr.8–10). Đầu vào là 9 điều kiện C1–C9 và các giả định A1–A5 ở Bước 1.

2.1 Cách phân hoạch

Lớp tương đương được xác định theo bảng nguyên tắc ở slide tr.10:

Loại điều kiện	Lớp hợp lệ	Lớp không hợp lệ	Áp dụng cho
Boolean	điều kiện đúng	điều kiện sai	C1, C2, C3, C5, C6, C7, C9
Dãy giá trị `[8..∞)`	8 ≤ len	len < 8	C4
Tập giá trị `{@$!%*?&}`	có ký tự thuộc tập	không có ký tự nào thuộc tập	C8

Một số lớp không hợp lệ được **tách nhỏ hơn**. Lý do là các cách vi phạm khác nhau có thể được hệ thống xử lý khác nhau, nên cần test riêng từng cách:

- **Email sai định dạng** được tách thành: thiếu `@`, thiếu phần local, domain thiếu `.`. Mỗi cách vi phạm một phần khác nhau của mẫu `local@domain.tld` (giả định A2).
- **Rỗng** được tách riêng cho từng trường bắt buộc, vì "bắt buộc" là một ràng buộc độc lập với định dạng.
- **Email trùng** có thêm lớp *trùng nhưng khác hoa/thường* (giả định A5).

2.2 Bảng tổng hợp lớp tương đương

STT	Input / Output	Điều kiện	Lớp tương đương	Loại	Giá trị đại diện
EC1	I1 Họ tên	C1	Họ tên khác rỗng	Hợp lệ	`Nguyen Van A`
EC2		C1	Họ tên rỗng	Không hợp lệ	`""`
EC3		C1	Họ tên chỉ chứa khoảng trắng (A4)	Không hợp lệ	`" "`
EC4	I2 Email	C2, C3	Đúng định dạng **và** chưa tồn tại	Hợp lệ	`vinh.tc01@gmail.com`
EC5		C2	Sai định dạng, thiếu `@`	Không hợp lệ	`vinh.gmail.com`
EC6		C2	Sai định dạng, thiếu phần local	Không hợp lệ	`@gmail.com`
EC7		C2	Sai định dạng, domain không có `.`	Không hợp lệ	`vinh@gmail`
EC8		C2	Email rỗng	Không hợp lệ	`""`
EC9		C3	Email đã tồn tại	Không hợp lệ	`test@eshop.com`
EC10		C3	Email đã tồn tại, khác hoa/thường (A5)	Không hợp lệ	`TEST@eshop.com`

STT	Input / Output	Điều kiện	Lớp tương đương	Loại	Giá trị đại diện
EC11	I3 Mật khẩu: độ dài	C4	len ≥ 8	Hợp lệ	`Abcdef1@` (8)
EC12		C4	len < 8 (vẫn đủ 4 loại ký tự)	Không hợp lệ	`Abcd1@x` (7)
EC13		C4	Mật khẩu rỗng (len = 0)	Không hợp lệ	`""`
EC14	I3 Mật khẩu: thành phần	C5–C8	Đủ chữ hoa, chữ thường, số, ký tự đặc biệt trong tập	Hợp lệ	`Abcdef1@`
EC15		C5	Thiếu chữ hoa	Không hợp lệ	`abcdef1@`
EC16		C6	Thiếu chữ thường	Không hợp lệ	`ABCDEF1@`
EC17		C7	Thiếu chữ số	Không hợp lệ	`Abcdefg@`
EC18		C8	Không có ký tự đặc biệt nào	Không hợp lệ	`Abcdefg1`
EC19		C8	Chỉ có ký tự đặc biệt **ngoài** tập	Không hợp lệ	`Abcdef1#`
EC20		C8	Có ký tự trong tập **và** ký tự ngoài tập (A3)	Hợp lệ	`Abcde1@#`
EC21	I4 Xác nhận MK	C9	Khớp với Mật khẩu	Hợp lệ	= Mật khẩu
EC22		C9	Không khớp	Không hợp lệ	`Abcdef1!` (khi MK = `Abcdef1@`)
EC23		C9	Rỗng	Không hợp lệ	`""`
EC24	Output	—	O1: Đăng ký thành công, chuyển sang `/login`	Hợp lệ	—
EC25	Output	—	O2: Thông báo lỗi, không tạo tài khoản	Không hợp lệ	—

Thống kê: 25 lớp, gồm:

- **7 lớp hợp lệ:** EC1, EC4, EC11, EC14, EC20, EC21, EC24.
- **18 lớp không hợp lệ:** 17 lớp đầu vào và lớp đầu ra EC25.

2.3 Ghi chú khi chọn giá trị đại diện

- Mỗi giá trị đại diện **chỉ vi phạm đúng một điều kiện**. Ví dụ, EC12 `Abcd1@x` vẫn có đủ 4 loại ký tự, chỉ thiếu độ dài. Nhờ vậy, khi TC thất bại, ta biết chắc nguyên nhân là độ dài.
- EC15–EC19 đều dài ≥ 8 ký tự, để tách biệt với điều kiện độ dài C4.
- Đại diện của EC4 sẽ được **đổi thành email riêng cho mỗi TC** ở Bước 3 (`vinh.tcNN@gmail.com`). Mục đích là để các TC không ảnh hưởng nhau qua điều kiện "email duy nhất" (C3).

Phụ lục 3 — `features/FR-01_Register/03_ep_test_cases.md`

FR-01 Đăng ký tài khoản: Bước 3, Xác định ca kiểm thử (EP)

> Kỹ thuật: Phân hoạch tương đương, bước 3/3 (slide Bài 4, tr.15–18). Đầu vào: 25 lớp tương đương ở Bước 2.

3.1 Nguyên tắc áp dụng (slide tr.15)

1. Khi xét một lớp của biến X, chọn giá trị đại diện của lớp đó cho X. Các biến còn lại lấy giá trị đại diện của **lớp hợp lệ**.
2. **Một TC được phủ nhiều lớp hợp lệ** của nhiều biến cùng lúc.
3. **Mỗi TC chỉ phủ đúng một lớp không hợp lệ.** Nếu một TC chứa hai lỗi, lỗi thứ nhất có thể che lỗi thứ hai và ta không biết hệ thống đã từ chối vì lỗi nào.

Ràng buộc bổ sung: mỗi TC dùng **email riêng** (`vinh.epNN@gmail.com`). Nhờ vậy, một TC lẽ ra bị từ chối nhưng lại được chấp nhận nhầm sẽ không làm hỏng điều kiện "email duy nhất" của các TC sau.

3.2 Bảng xác định ca kiểm thử cho từng lớp

Lớp	Lớp tương đương	Họ tên	Email	Mật khẩu	Xác nhận MK	Output mong đợi
EC1	Họ tên khác rỗng	`Nguyen Van A`	`vinh.ep01@gmail.com`	`Abcdef1@`	`Abcdef1@`	O1
EC2	Họ tên rỗng	`""`	`vinh.ep03@gmail.com`	`Abcdef1@`	`Abcdef1@`	O2
EC3	Họ tên chỉ khoảng trắng	`" "`	`vinh.ep04@gmail.com`	`Abcdef1@`	`Abcdef1@`	O2
EC4	Email hợp lệ, chưa tồn tại	`Nguyen Van A`	`vinh.ep01@gmail.com`	`Abcdef1@`	`Abcdef1@`	O1
EC5	Email thiếu `@`	`Nguyen Van A`	`vinh.gmail.com`	`Abcdef1@`	`Abcdef1@`	O2
EC6	Email thiếu phần local	`Nguyen Van A`	`@gmail.com`	`Abcdef1@`	`Abcdef1@`	O2
EC7	Email domain không có `.`	`Nguyen Van A`	`vinh@gmail`	`Abcdef1@`	`Abcdef1@`	O2
EC8	Email rỗng	`Nguyen Van A`	`""`	`Abcdef1@`	`Abcdef1@`	O2
EC9	Email đã tồn tại	`Nguyen Van A`	`test@eshop.com`	`Abcdef1@`	`Abcdef1@`	O2
EC10	Email đã tồn tại, khác hoa/thường	`Nguyen Van A`	`TEST@eshop.com`	`Abcdef1@`	`Abcdef1@`	O2
EC11	MK len ≥ 8	`Nguyen Van A`	`vinh.ep01@gmail.com`	`Abcdef1@`	`Abcdef1@`	O1
EC12	MK len < 8	`Nguyen Van A`	`vinh.ep11@gmail.com`	`Abcd1@x`	`Abcd1@x`	O2
EC13	MK rỗng	`Nguyen Van A`	`vinh.ep12@gmail.com`	`""`	`""`	O2

Lớp	Lớp tương đương	Họ tên	Email	Mật khẩu	Xác nhận MK	Output mong đợi
EC14	MK đủ 4 loại ký tự	`Nguyen Van A`	`vinh.ep01@gmail.com`	`Abcdef1@`	`Abcdef1@`	O1
EC15	Thiếu chữ hoa	`Nguyen Van A`	`vinh.ep13@gmail.com`	`abcdef1@`	`abcdef1@`	O2
EC16	Thiếu chữ thường	`Nguyen Van A`	`vinh.ep14@gmail.com`	`ABCDEF1@`	`ABCDEF1@`	O2
EC17	Thiếu chữ số	`Nguyen Van A`	`vinh.ep15@gmail.com`	`Abcdefg@`	`Abcdefg@`	O2
EC18	Không có ký tự đặc biệt	`Nguyen Van A`	`vinh.ep16@gmail.com`	`Abcdefg1`	`Abcdefg1`	O2
EC19	Ký tự đặc biệt ngoài tập	`Nguyen Van A`	`vinh.ep17@gmail.com`	`Abcdef1#`	`Abcdef1#`	O2
EC20	Ký tự trong tập + ngoài tập	`Nguyen Van A`	`vinh.ep02@gmail.com`	`Abcde1@#`	`Abcde1@#`	O1
EC21	Xác nhận MK khớp	`Nguyen Van A`	`vinh.ep01@gmail.com`	`Abcdef1@`	`Abcdef1@`	O1
EC22	Xác nhận MK không khớp	`Nguyen Van A`	`vinh.ep18@gmail.com`	`Abcdef1@`	`Abcdef1!`	O2
EC23	Xác nhận MK rỗng	`Nguyen Van A`	`vinh.ep19@gmail.com`	`Abcdef1@`	`""`	O2
EC24	Output O1	`Nguyen Van A`	`vinh.ep01@gmail.com`	`Abcdef1@`	`Abcdef1@`	O1
EC25	Output O2	`""`	`vinh.ep03@gmail.com`	`Abcdef1@`	`Abcdef1@`	O2

> O1 = đăng ký thành công, chuyển sang `/login`. O2 = hiển thị thông báo lỗi, **không** tạo tài khoản.

3.3 Bảng rút gọn các ca kiểm thử

Gộp các dòng có cùng bộ dữ liệu. EC1, EC4, EC11, EC14, EC21 và EC24 đều dùng chung một bộ dữ liệu hợp lệ nên gộp thành **EP-01**. EC25 phủ chung với EP-03.

TC	Lớp tương đương phủ	Họ tên	Email	Mật khẩu	Xác nhận MK	Output mong đợi
EP-01	EC1, EC4, EC11, EC14, EC21, EC24	`Nguyen Van A`	`vinh.ep01@gmail.com`	`Abcdef1@`	`Abcdef1@`	Thành công, chuyển `/login`
EP-02	EC20 (+ EC1, EC4, EC11, EC21, EC24)	`Nguyen Van A`	`vinh.ep02@gmail.com`	`Abcde1@#`	`Abcde1@#`	Thành công, chuyển `/login`
EP-03	EC2, EC25	`""`	`vinh.ep03@gmail.com`	`Abcdef1@`	`Abcdef1@`	Lỗi "Họ tên bắt buộc"
EP-04	EC3	`" "`	`vinh.ep04@gmail.com`	`Abcdef1@`	`Abcdef1@`	Lỗi "Họ tên bắt buộc"
EP-05	EC5	`Nguyen Van A`	`vinh.gmail.com`	`Abcdef1@`	`Abcdef1@`	Lỗi định dạng email
EP-06	EC6	`Nguyen Van A`	`@gmail.com`	`Abcdef1@`	`Abcdef1@`	Lỗi định dạng email
EP-07	EC7	`Nguyen Van A`	`vinh@gmail`	`Abcdef1@`	`Abcdef1@`	Lỗi định dạng email

TC	Lớp tương đương phủ	Họ tên	Email	Mật khẩu	Xác nhận MK	Output mong đợi
EP-08	EC8	`Nguyen Van A`	`""`	`Abcdef1@`	`Abcdef1@`	Lỗi "Email bắt buộc"
EP-09	EC9	`Nguyen Van A`	`test@eshop.com`	`Abcdef1@`	`Abcdef1@`	Lỗi "Email đã tồn tại"
EP-10	EC10	`Nguyen Van A`	`TEST@eshop.com`	`Abcdef1@`	`Abcdef1@`	Lỗi "Email đã tồn tại"
EP-11	EC12	`Nguyen Van A`	`vinh.ep11@gmail.com`	`Abcd1@x`	`Abcd1@x`	Lỗi mật khẩu yếu (< 8 ký tự)
EP-12	EC13	`Nguyen Van A`	`vinh.ep12@gmail.com`	`""`	`""`	Lỗi "Mật khẩu bắt buộc"
EP-13	EC15	`Nguyen Van A`	`vinh.ep13@gmail.com`	`abcdef1@`	`abcdef1@`	Lỗi mật khẩu yếu (thiếu chữ hoa)
EP-14	EC16	`Nguyen Van A`	`vinh.ep14@gmail.com`	`ABCDEF1@`	`ABCDEF1@`	Lỗi mật khẩu yếu (thiếu chữ thường)
EP-15	EC17	`Nguyen Van A`	`vinh.ep15@gmail.com`	`Abcdefg@`	`Abcdefg@`	Lỗi mật khẩu yếu (thiếu chữ số)
EP-16	EC18	`Nguyen Van A`	`vinh.ep16@gmail.com`	`Abcdefg1`	`Abcdefg1`	Lỗi mật khẩu yếu (thiếu ký tự đặc biệt)
EP-17	EC19	`Nguyen Van A`	`vinh.ep17@gmail.com`	`Abcdef1#`	`Abcdef1#`	Lỗi mật khẩu yếu (ký tự đặc biệt không thuộc tập)
EP-18	EC22	`Nguyen Van A`	`vinh.ep18@gmail.com`	`Abcdef1@`	`Abcdef1!`	Lỗi "Mật khẩu xác nhận không khớp"
EP-19	EC23	`Nguyen Van A`	`vinh.ep19@gmail.com`	`Abcdef1@`	`""`	Lỗi "Vui lòng xác nhận mật khẩu"

Tổng: 19 TC, gồm 2 TC hợp lệ và 17 TC không hợp lệ. Cả 25 lớp tương đương đều được phủ.

3.4 Kiểm tra độ phủ

Lớp	EC1	EC2	EC3	EC4	EC5	EC6	EC7	EC8	EC9	EC10	EC11	EC12	EC13
TC	01,02	03	04	01,02	05	06	07	08	09	10	01,02	11	12

Lớp	EC14	EC15	EC16	EC17	EC18	EC19	EC20	EC21	EC22	EC23	EC24	EC25
TC	01	13	14	15	16	17	02	01,02	18	19	01,02	03–19

3.5 Cách thực thi

- **UI:** nhập dữ liệu vào form `/register`. Vì form **không có** ô Xác nhận MK, các TC EP-18 và EP-19 không nhập được giá trị này. Với các TC còn lại, cột "Xác nhận MK" được bỏ qua trên UI.
- **API:** gửi `POST /api/register` với `{name, email, password, confirmPassword}`. Kết quả mong đợi khi dữ liệu không hợp lệ: HTTP 4xx và tài khoản **không** được tạo. Sau đó kiểm tra lại bằng cách đăng nhập với email vừa dùng.
- **Hậu kiểm O2:** với các TC lỗi, thử đăng nhập bằng email và mật khẩu của TC. Kết quả đúng là đăng nhập thất bại (tài khoản không tồn tại).

Phụ lục 4 — `features/FR-01_Register/04_bva_test_cases.md`

FR-01 Đăng ký tài khoản: Bước 4, Phân tích giá trị biên (BVA)

> Kỹ thuật: Phân tích giá trị biên (slide Bài 4, tr.20–26). Đầu vào: các lớp tương đương ở Bước 2.

4.1 Xác định các miền có thứ tự

BVA chỉ dùng được khi lớp tương đương **có thứ tự** (slide tr.21). Ta xét lần lượt từng điều kiện:

Điều kiện	Có thứ tự?	Áp dụng BVA?	Biến BVA
C1 Họ tên khác rỗng	Có. "Khác rỗng" nghĩa là **len(name) ≥ 1**	✅	V1 = len(Họ tên)
C2 Email đúng định dạng	Không, là mẫu cú pháp	❌ (đã phủ bằng EP)	—
C3 Email duy nhất	Không, là thuộc tính tập hợp	❌ (đã phủ bằng EP)	—
C4 len(MK) ≥ 8	Có	✅	V2 = len(Mật khẩu)
C5 Có chữ hoa	Có. "Ít nhất 1" nghĩa là **số chữ hoa ≥ 1**	✅	V3 = #chữ hoa
C6 Có chữ thường	Có, **số chữ thường ≥ 1**	✅	V4 = #chữ thường
C7 Có chữ số	Có, **số chữ số ≥ 1**	✅	V5 = #chữ số
C8 Có ký tự đặc biệt thuộc tập	Có, **số ký tự thuộc `{@$!%*?&}` ≥ 1**	✅	V6 = #ký tự đặc biệt
C9 Xác nhận MK khớp	Không	❌ (đã phủ bằng EP)	—

> **Phân tích:** điều kiện "có ít nhất 1 X" thoạt nhìn là boolean. Thực chất nó là điều kiện trên một **biến đếm có thứ tự** (`count ≥ 1`), nên có biên dưới LB = 1. Vì vậy ta có thể áp dụng BVA cho cả 4 điều kiện thành phần của mật khẩu.

4.2 Biên của từng biến

Biến	Miền hợp lệ	LB	UB	LB−1	LB	LB+1	Nominal
V1 len(Họ tên)	[1, ∞)	1	— (A1)	0	1	2	12 (`Nguyen Van A`)
V2 len(Mật khẩu)	[8, ∞)	8	— (A1)	7	8	9	12
V3 #chữ hoa	[1, ∞)	1	—	0	1	2	3
V4 #chữ thường	[1, ∞)	1	—	0	1	2	3
V5 #chữ số	[1, ∞)	1	—	0	1	2	3
V6 #ký tự đặc biệt	[1, ∞)	1	—	0	1	2	3

Mật khẩu nominal: `ABCdef123@!$` có độ dài 12, gồm 3 chữ hoa, 3 chữ thường, 3 chữ số và 3 ký tự đặc biệt. Mỗi đặc tính được chọn = 3 để giá trị nominal **khác** với LB+1 = 2. Như vậy điểm nominal không trùng với điểm biên.

4.3 Chọn biến thể BVA và tính số TC

- Slide nêu 4 biến thể: **Standard** (4n+1), **Robustness** (6n+1), **Worst-case** (5^n), **Robust worst-case** (7^n). Các công thức này giả định mỗi biến có **cả** min và max.

- Ở đây cả 6 biến **chỉ có biên dưới**, nên công thức được điều chỉnh như sau:
  - Standard (min, min+): 2n + 1 = 13 TC. **Không** kiểm tra phía không hợp lệ (LB−1).
  - **Robustness (min−, min, min+): 3n + 1 = 3×6 + 1 = 19 TC**. Có kiểm tra phía không hợp lệ. **→ Chọn biến thể này**, vì lỗi thường nằm ngay tại LB−1/LB (ví dụ viết nhầm `>` thành `>=`).
  - Worst-case (3^6 = 729 TC) được **loại**. Các điều kiện độc lập nhau (giả định lỗi đơn), và số TC tăng quá nhanh so với lợi ích.
- **Bổ sung 2 TC độ bền cho phía "∞"** theo giả định A1: Họ tên và Mật khẩu dài 256 ký tự. Hệ thống phải chấp nhận vì spec không đặt giới hạn trên.

Tổng: 19 + 2 = 21 TC.

4.4 Bảng ca kiểm thử giá trị biên

Nguyên tắc: tại mỗi TC chỉ **một biến** nhận giá trị biên, các biến còn lại giữ giá trị nominal (slide tr.22). Mỗi TC dùng một email riêng `vinh.bvaNN@gmail.com`, và Xác nhận MK luôn bằng Mật khẩu.

TC	Biến	Điểm	Họ tên	Mật khẩu	Đặc tính MK (len/U/L/D/S)	Output mong đợi
BVA-01	Nominal	—	`Nguyen Van A`	`ABCdef123@!$`	12/3/3/3/3	Thành công
BVA-02	V1 len(Họ tên)	LB−1 = 0	`""`	`ABCdef123@!$`	12/3/3/3/3	Lỗi họ tên bắt buộc
BVA-03	V1	LB = 1	`A`	`ABCdef123@!$`	12/3/3/3/3	Thành công
BVA-04	V1	LB+1 = 2	`An`	`ABCdef123@!$`	12/3/3/3/3	Thành công
BVA-05	V2 len(MK)	LB−1 = 7	`Nguyen Van A`	`ABcd1@!`	7/2/2/1/2	Lỗi MK yếu
BVA-06	V2	LB = 8	`Nguyen Van A`	`ABcd12@!`	8/2/2/2/2	Thành công
BVA-07	V2	LB+1 = 9	`Nguyen Van A`	`ABcde12@!`	9/2/3/2/2	Thành công
BVA-08	V3 #chữ hoa	LB−1 = 0	`Nguyen Van A`	`abcdef123@!$`	12/0/6/3/3	Lỗi MK yếu
BVA-09	V3	LB = 1	`Nguyen Van A`	`Abcdef123@!$`	12/1/5/3/3	Thành công
BVA-10	V3	LB+1 = 2	`Nguyen Van A`	`ABcdef123@!$`	12/2/4/3/3	Thành công
BVA-11	V4 #chữ thường	LB−1 = 0	`Nguyen Van A`	`ABCDEF123@!$`	12/6/0/3/3	Lỗi MK yếu
BVA-12	V4	LB = 1	`Nguyen Van A`	`ABCDEf123@!$`	12/5/1/3/3	Thành công
BVA-13	V4	LB+1 = 2	`Nguyen Van A`	`ABCDef123@!$`	12/4/2/3/3	Thành công
BVA-14	V5 #chữ số	LB−1 = 0	`Nguyen Van A`	`ABCdefghi@!$`	12/3/6/0/3	Lỗi MK yếu
BVA-15	V5	LB = 1	`Nguyen Van A`	`ABCdefgh1@!$`	12/3/5/1/3	Thành công
BVA-16	V5	LB+1 = 2	`Nguyen Van A`	`ABCdefg12@!$`	12/3/4/2/3	Thành công

TC	Biến	Điểm	Họ tên	Mật khẩu	Đặc tính MK (len/U/L/D/S)	Output mong đợi
BVA-17	V6 #ký tự đặc biệt	LB−1 = 0	`Nguyen Van A`	`ABCdef123ghi`	12/3/6/3/0	Lỗi MK yếu
BVA-18	V6	LB = 1	`Nguyen Van A`	`ABCdef123gh@`	12/3/5/3/1	Thành công
BVA-19	V6	LB+1 = 2	`Nguyen Van A`	`ABCdef123g@!`	12/3/4/3/2	Thành công
BVA-20	V1 (phía ∞)	256	`A` × 256	`ABCdef123@!$`	12/3/3/3/3	Thành công
BVA-21	V2 (phía ∞)	256	`Nguyen Van A`	`ABCdef123@!$` × 21 + `ABCd`	256/...	Thành công

4.5 Ghi chú

- **Ràng buộc giữa các biến:** khi thay đổi V2 (độ dài), số ký tự mỗi loại cũng buộc phải thay đổi. Đó là lý do BVA-05/06/07 dùng 2 ký tự mỗi loại thay cho 3. Dù vậy, tất cả các đặc tính khác vẫn nằm trong miền hợp lệ (≥ 1). Như thế mỗi TC vẫn chỉ có **một** biến nằm ở biên.
- **Trùng lặp với EP:** BVA-05 (len 7) cùng lớp với EP-11, và BVA-02 cùng lớp với EP-03. Hai bên vẫn được giữ lại vì giá trị chọn khác nhau: EP chọn một giá trị đại diện bất kỳ, còn BVA chọn giá trị **sát biên**.
- **Biên của đầu ra:** đầu ra O1/O2 không có thứ tự, nên không có biên đầu ra cần xét.

Phụ lục 5 — `features/FR-01_Register/05_test_execution.md`

FR-01 Đăng ký tài khoản: Bước 5, Thực thi kiểm thử

5.1 Môi trường

Mục	Giá trị
Thời điểm chạy	2026-10-13 12:19 (GMT+7). Dữ liệu thô: `results_fr01.json`
SUT	`eshop-sut` commit `85af3ba`. Backend `:3000`, Web `:5173`
Trạng thái DB	Khởi động lại backend ngay trước khi chạy, nên DB được seed lại với 2 tài khoản `admin@eshop.com` và `test@eshop.com`
Trình duyệt	Chromium 131 (headless) qua Playwright 1.49.1
Script	`scripts/fr01_register.js`. Chạy lại bằng `cd scripts && node fr01_register.js`
Cách tách dữ liệu	API dùng email `vinh.api.*`, UI dùng `vinh.ui.*`, lượt chạy lại dùng `*r@gmail.com`
Hậu kiểm	Đếm số tài khoản có email của TC qua `GET /api/admin/users` (so sánh không phân biệt hoa/thường), **trước và sau** khi gửi form

Tiêu chí Pass/Fail

- TC mong đợi **O1**: Pass khi API trả 2xx (UI chuyển sang `/login`) **và** có thêm 1 tài khoản.
- TC mong đợi **O2**: Pass khi API trả 4xx (UI vẫn ở trang đăng ký và có thông báo lỗi) **và** không có tài khoản mới.

5.2 Phát hiện trong khi chạy: lỗi che lỗi (masking)

Ở lượt chạy đầu, **UI từ chối toàn bộ mật khẩu đúng spec**, kể cả `Abcdef1@` của TC hợp lệ EP-01. Vì thế, mọi TC "không hợp lệ" về họ tên/email trên UI đều bị chặn bởi **lỗi mật khẩu** chứ không phải bởi lớp không hợp lệ đang được test. Đó là một kết quả Pass giả.

Để xác định UI thực sự chấp nhận mật khẩu nào, mình chạy thêm một lượt khám phá (exploratory probe), mỗi mật khẩu dùng một email mới:

Mật khẩu thử	Đúng spec?	UI xử lý
`Abcdef1@`	✅ hợp lệ	❌ Từ chối "Mật khẩu quá yếu"
`Abcdef1@ ` (có thêm khoảng trắng)	✅ hợp lệ	❌ Từ chối
`Abc def1@`	✅ hợp lệ	❌ Từ chối
`Abcdef1 ` (khoảng trắng, không có ký tự đặc biệt)	❌ không hợp lệ	✅ **Chấp nhận**, chuyển `/login`
`Abcdef 1`	❌ không hợp lệ	✅ **Chấp nhận**
`Abcdefg 1`	❌ không hợp lệ	✅ **Chấp nhận**

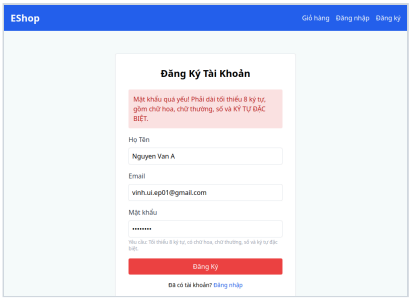
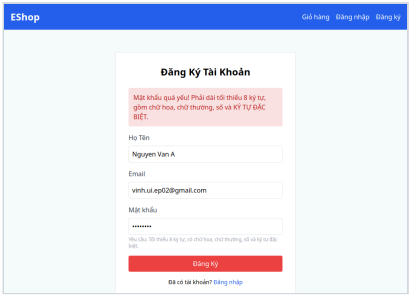
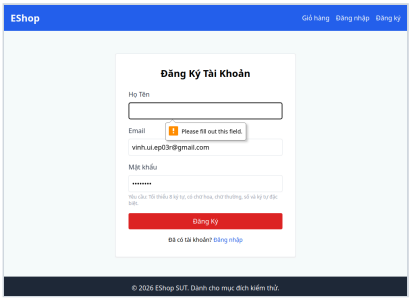
Kết luận: UI hiểu "ký tự đặc biệt" là **khoảng trắng**, và **cấm** mọi ký tự thuộc tập `@$!%*?&`. Quy tắc này ngược hẳn với spec.

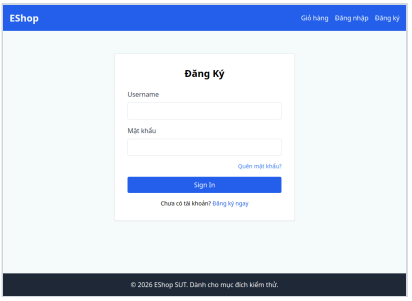
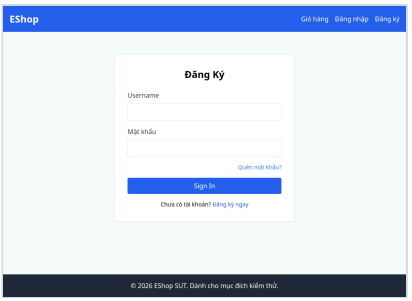
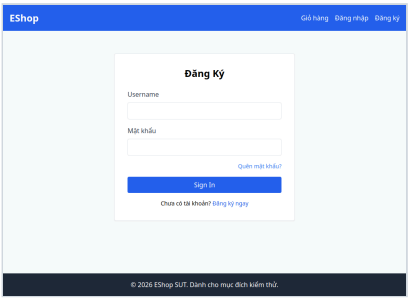
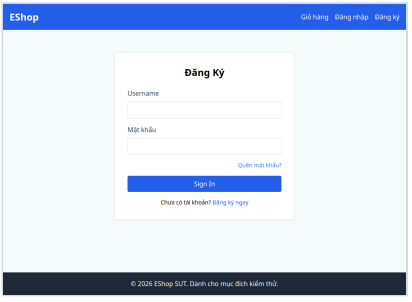
Cách xử lý: chạy lại 9 TC không hợp lệ về họ tên/email trên UI (đánh hậu tố `R`), dùng mật khẩu `Abcdef1` mà UI chấp nhận. Như vậy mỗi TC chỉ còn đúng **một** lớp không hợp lệ, đúng nguyên tắc ở slide tr.15. Kết quả lượt chạy lại được dùng làm **kết luận chính thức** cho kênh UI của các TC này.

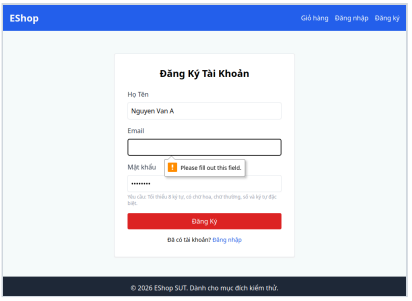
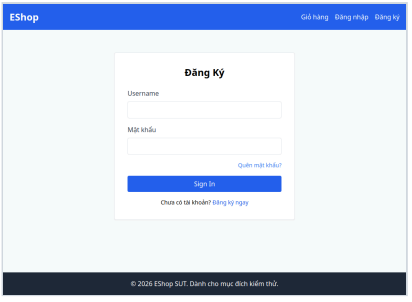
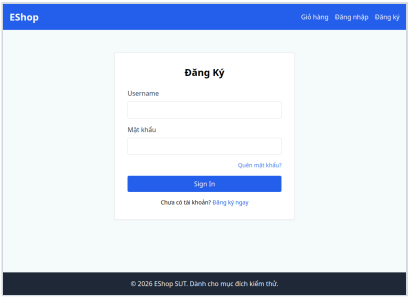
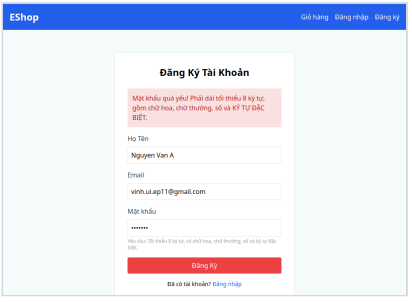
5.3 Kết quả: Phân hoạch tương đương (19 TC)

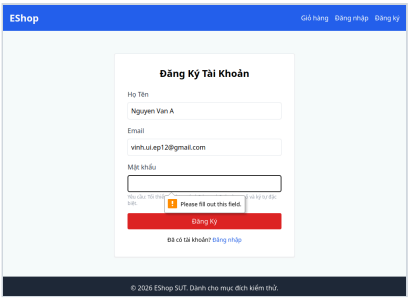
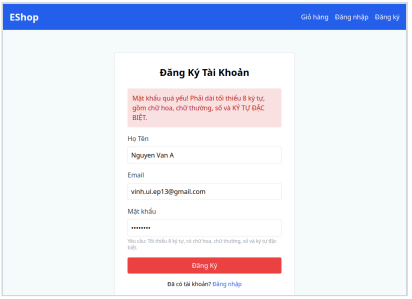
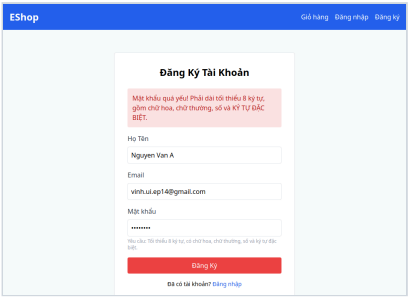
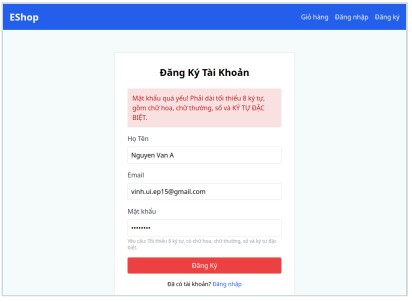
Chú thích:

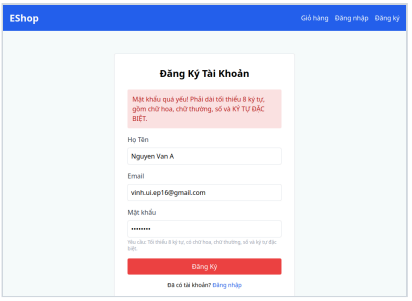
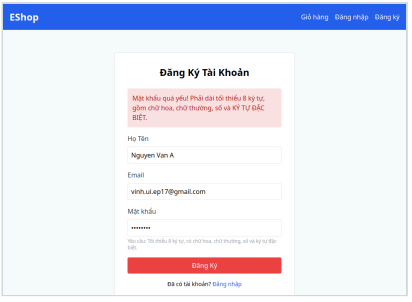
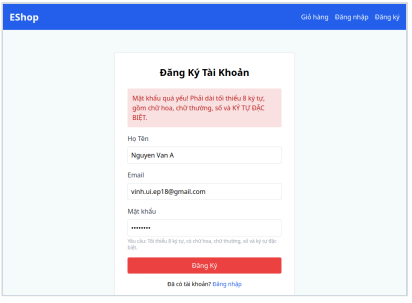
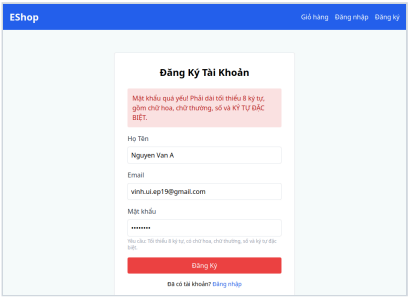
- ✅ PASS
- ❌ FAIL
- ⚠️ PASS*: kết quả đúng (bị từ chối), nhưng **lý do từ chối sai**. UI chặn vì quy tắc mật khẩu sai (mục 5.2), nên không xác nhận được rằng UI kiểm tra đúng lớp đang test.

TC	Lớp	Mong đợi	API: thực tế	API	UI: thực tế	UI	Screenshot
EP-01	EC1,4,11,14,21,24	O1	200, tạo TK	✅	Báo "Mật khẩu quá yếu", không tạo TK	❌	EP-01  EP-01
EP-02	EC20	O1	200, tạo TK	✅	Báo "Mật khẩu quá yếu", không tạo TK	❌	EP-02  EP-02
EP-03	EC2 Họ tên rỗng	O2	200, **tạo TK**	❌	Bị chặn bởi HTML5 `required` (lượt chạy lại cũng vậy)	✅	EP-03R  EP-03R

TC	Lớp	Mong đợi	API: thực tế	API	UI: thực tế	UI	Screenshot
EP-04	EC3 Họ tên toàn khoảng trắng	O2	200, **tạo TK**	❌	Lượt chạy lại: **chấp nhận**, chuyển `/login`, tạo TK	❌	EP-04R  EP-04R
EP-05	EC5 Email thiếu `@`	O2	200, **tạo TK**	❌	Lượt chạy lại: **chấp nhận**, tạo TK	❌	EP-05R  EP-05R
EP-06	EC6 Email thiếu phần local	O2	200, **tạo TK**	❌	Lượt chạy lại: **chấp nhận**, tạo TK	❌	EP-06R  EP-06R
EP-07	EC7 Domain không có `.`	O2	200, **tạo TK**	❌	Lượt chạy lại: **chấp nhận**, tạo TK	❌	EP-07R  EP-07R

TC	Lớp	Mong đợi	API: thực tế	API	UI: thực tế	UI	Screenshot
EP-08	EC8 Email rỗng	O2	200, **tạo TK**	❌	Bị chặn bởi HTML5 `required`	✅	EP-08R  EP-08R
EP-09	EC9 Email đã tồn tại	O2	200, **tạo TK trùng** `test@eshop.com`	❌	Lượt chạy lại: **chấp nhận**, tạo TK trùng	❌	EP-09R  EP-09R
EP-10	EC10 Trùng, khác hoa/thường	O2	200, **tạo TK** `TEST@eshop.com`	❌	Lượt chạy lại: **chấp nhận**, tạo TK	❌	EP-10R  EP-10R
EP-11	EC12 MK 7 ký tự	O2	200, **tạo TK**	❌	Báo "Mật khẩu quá yếu"	⚠️	EP-11  EP-11

TC	Lớp	Mong đợi	API: thực tế	API	UI: thực tế	UI	Screenshot
EP-12	EC13 MK rỗng	O2	200, **tạo TK**	❌	Bị chặn bởi HTML5 `required`	✅	EP-12  EP-12
EP-13	EC15 Thiếu chữ hoa	O2	200, **tạo TK**	❌	Báo "Mật khẩu quá yếu"	⚠️	EP-13  EP-13
EP-14	EC16 Thiếu chữ thường	O2	200, **tạo TK**	❌	Báo "Mật khẩu quá yếu"	⚠️	EP-14  EP-14
EP-15	EC17 Thiếu chữ số	O2	200, **tạo TK**	❌	Báo "Mật khẩu quá yếu"	⚠️	EP-15  EP-15

TC	Lớp	Mong đợi	API: thực tế	API	UI: thực tế	UI	Screenshot
EP-16	EC18 Không có ký tự đặc biệt	O2	200, **tạo TK**	❌	Báo "Mật khẩu quá yếu"	⚠️	EP-16  EP-16
EP-17	EC19 Ký tự đặc biệt ngoài tập	O2	200, **tạo TK**	❌	Báo "Mật khẩu quá yếu"	⚠️	EP-17  EP-17
EP-18	EC22 Xác nhận MK không khớp	O2	200, **tạo TK** (bỏ qua `confirmPassword`)	❌	**Không có ô Xác nhận MK**	❌	EP-18  EP-18
EP-19	EC23 Xác nhận MK rỗng	O2	200, **tạo TK**	❌	**Không có ô Xác nhận MK**	❌	EP-19  EP-19

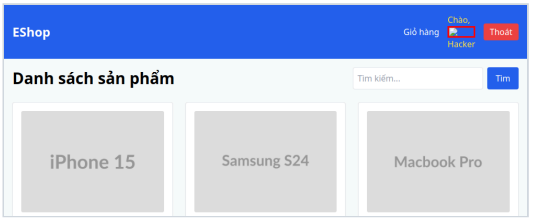
5.4 Kết quả: Phân tích giá trị biên (21 TC)

TC	Biến, điểm biên	Mong đợi	API	UI	Ghi chú
BVA-01	Nominal	O1	✅ 200	❌ báo MK yếu	UI từ chối MK hợp lệ
BVA-02	len(Họ tên) = 0	O2	❌ 200, tạo TK	✅ HTML5 `required`	Lượt chạy lại BVA-02R cũng ✅

TC	Biến, điểm biên	Mong đợi	API	UI	Ghi chú
BVA-03	len(Họ tên) = 1	O1	✅	❌	UI: lỗi mật khẩu
BVA-04	len(Họ tên) = 2	O1	✅	❌	UI: lỗi mật khẩu
BVA-05	len(MK) = 7	O2	❌ 200, tạo TK	⚠️	**API không có biên dưới 8**
BVA-06	len(MK) = 8	O1	✅	❌	UI: lỗi mật khẩu
BVA-07	len(MK) = 9	O1	✅	❌	UI: lỗi mật khẩu
BVA-08	#chữ hoa = 0	O2	❌ tạo TK	⚠️	
BVA-09	#chữ hoa = 1	O1	✅	❌	
BVA-10	#chữ hoa = 2	O1	✅	❌	
BVA-11	#chữ thường = 0	O2	❌ tạo TK	⚠️	
BVA-12	#chữ thường = 1	O1	✅	❌	
BVA-13	#chữ thường = 2	O1	✅	❌	
BVA-14	#chữ số = 0	O2	❌ tạo TK	⚠️	
BVA-15	#chữ số = 1	O1	✅	❌	
BVA-16	#chữ số = 2	O1	✅	❌	
BVA-17	#ký tự đặc biệt = 0	O2	❌ tạo TK	⚠️	
BVA-18	#ký tự đặc biệt = 1	O1	✅	❌	
BVA-19	#ký tự đặc biệt = 2	O1	✅	❌	
BVA-20	len(Họ tên) = 256	O1	✅	❌	UI: lỗi mật khẩu
BVA-21	len(MK) = 256	O1	✅	❌	UI: lỗi mật khẩu

Screenshot UI của từng TC: `screenshots/<TC>_ui.png`.

5.4b TC bổ sung sau AI gap analysis (chạy 2026-10-13, script `scripts/fr01_supplementary.js`)

TC	Lớp mới	Dữ liệu	Mong đợi	Thực tế	KQ
EP-20	EC26 Họ tên tiếng Việt có dấu (hợp lệ)	`Phạm Quang Vinh` (qua API)	Đăng ký thành công, header hiển thị đúng dấu	200, header hiển thị `Chào, Phạm Quang Vinh`	✅
EP-21	EC27 Họ tên chứa thẻ HTML	`<img src=x onerror=…>Hacker`	Đăng ký được, nhưng hiển thị dạng văn bản (SEC-04)	**Script được thực thi** trên header	❌ ảnh  ảnh

5.5 Tổng hợp

Kênh	Số TC	✅ PASS	⚠️ PASS*	❌ FAIL
API	40	17 (toàn bộ TC hợp lệ)	0	**23 (toàn bộ TC không hợp lệ)**
UI	40	4 (EP-03, EP-08, EP-12, BVA-02)	11	**25**

Kết luận theo TC (một TC chỉ Pass khi Pass trên **cả hai** kênh): **0/40 Pass**. Có thêm 2 TC bổ sung: EP-20 Pass, EP-21 Fail. **Tổng FR-01: 42 TC thiết kế, 42 TC thực thi, 1 Pass, 41 Fail.** Tính năng FR-01 không đáp ứng spec ở cả hai tầng:

- **Tầng API không có validation nào.** Mọi input đều được chấp nhận, kể cả họ tên/email/mật khẩu rỗng.
- **Tầng UI** chỉ kiểm tra "bắt buộc" (HTML5 `required`) và một quy tắc mật khẩu **sai**. UI không kiểm tra định dạng email, email trùng, họ tên toàn khoảng trắng, và không có trường Xác nhận MK.

Nhận xét về kỹ thuật:

- Các TC hợp lệ (EP-01, BVA-01) phát hiện ngay lỗi nghiêm trọng nhất: người dùng **không thể đăng ký** bằng mật khẩu đúng chuẩn.
- Các TC không hợp lệ chạy qua API phát hiện việc thiếu validation phía server.
- Nguyên tắc "mỗi TC chỉ một lớp không hợp lệ" đã giúp nhận ra hiện tượng lỗi che lỗi ở mục 5.2. Nếu bỏ qua, ta sẽ kết luận sai rằng UI có kiểm tra định dạng và tính duy nhất của email.

Phụ lục 6 — `features/FR-01_Register/06_bug_report.md`

FR-01 Đăng ký tài khoản: Bước 6, Báo cáo lỗi

Môi trường chung: EShop `85af3ba`, Backend `localhost:3000`, Web `localhost:5173`, Chromium 131, DB seed mặc định. Thời điểm phát hiện: 2026-10-13.

Bug ID	Tiêu đề	Severity	Priority	TC phát hiện	Issue
BUG-FR01-01	UI từ chối mọi mật khẩu hợp lệ theo spec, chỉ chấp nhận mật khẩu có khoảng trắng	**Critical**	P1	EP-01, EP-02, BVA-01/03/04/06/07/09/10/12/13/15/16/18/19/20/21	#1
BUG-FR01-02	API `/api/register` không kiểm tra độ mạnh mật khẩu	**Critical**	P1	EP-11, EP-13…EP-17, BVA-05/08/11/14/17	#2
BUG-FR01-03	Không kiểm tra email trùng, cho tạo nhiều tài khoản cùng email	**Critical**	P1	EP-09, EP-10, EP-09R, EP-10R	#3
BUG-FR01-04	Không kiểm tra định dạng email (API và UI)	Major	P2	EP-05…EP-07, EP-05R…EP-07R	#4
BUG-FR01-05	Thiếu trường "Xác nhận mật khẩu" (UI và API)	Major	P2	EP-18, EP-19	#5
BUG-FR01-06	API chấp nhận trường bắt buộc rỗng; họ tên chỉ có khoảng trắng được chấp nhận ở cả UI	Major	P2	EP-03, EP-04, EP-04R, EP-08, EP-12, BVA-02	#6
BUG-FR01-07	Stored XSS: Họ tên chứa HTML được thực thi trên header sau khi đăng nhập	**Critical**	P1	EP-21 (TC bổ sung sau gap analysis)	#7

BUG-FR01-01: UI từ chối mọi mật khẩu hợp lệ theo spec, chỉ chấp nhận mật khẩu có khoảng trắng

- **Tính năng & kỹ thuật:** FR-01, Phân hoạch tương đương (TC hợp lệ EP-01) và BVA (toàn bộ TC hợp lệ)
- **Severity:** Critical. Người dùng **không thể đăng ký** bằng bất kỳ mật khẩu đúng chuẩn nào.

Các bước tái hiện

1. Mở `http://localhost:5173/register`.
2. Nhập Họ Tên `Nguyen Van A`, Email `new01@gmail.com`, Mật khẩu `Abcdef1@`.
3. Bấm **Đăng Ký**.
4. Làm lại các bước 1–3 với Email `new02@gmail.com` và Mật khẩu `Abcdef1 ` (có khoảng trắng ở cuối, **không** có ký tự đặc biệt).

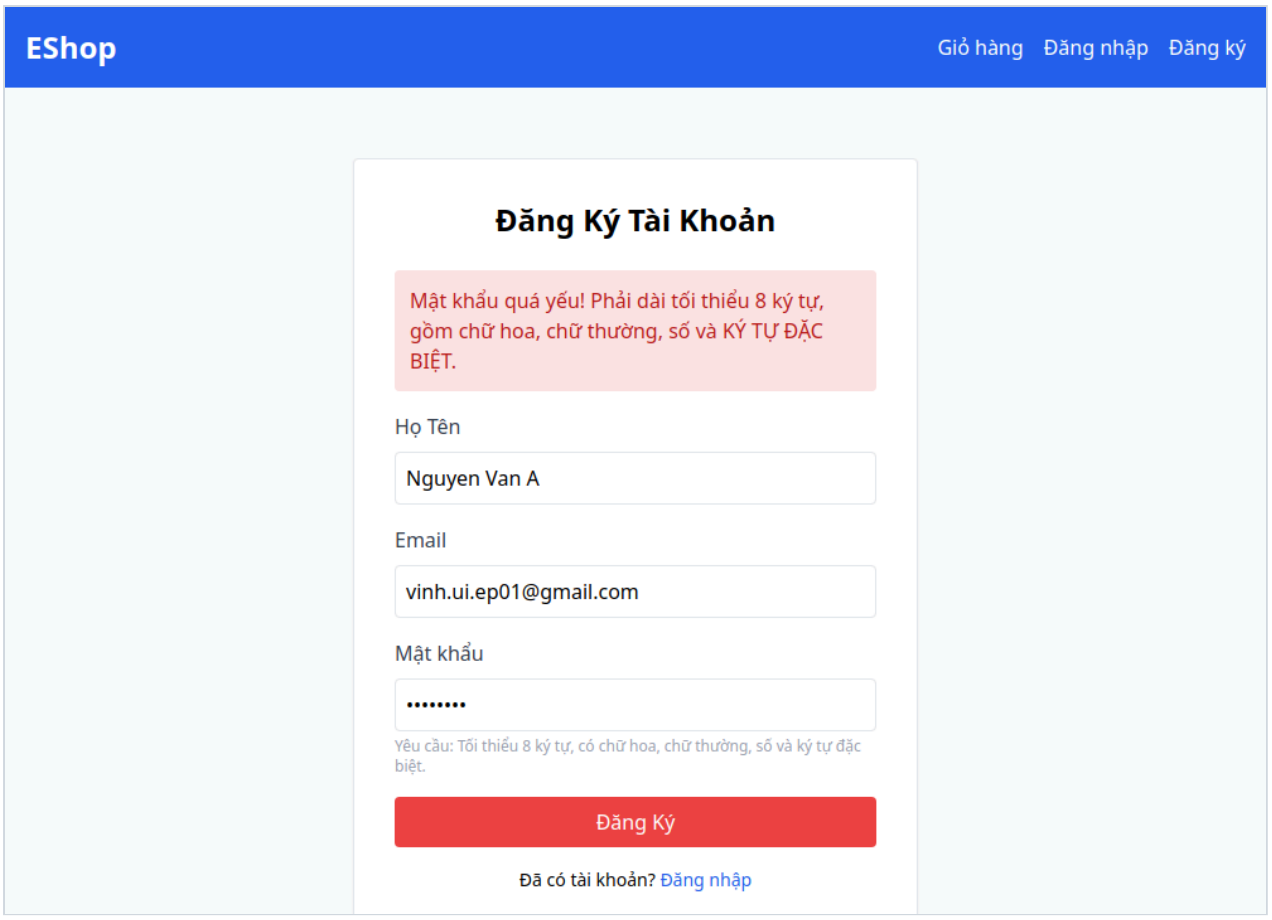
Kết quả mong đợi (SRS FR-01)

- Bước 3: đăng ký thành công và chuyển sang `/login`, vì `Abcdef1@` dài 8 ký tự và có đủ chữ hoa, chữ thường, chữ số, ký tự đặc biệt `@`.
- Bước 4: bị từ chối vì thiếu ký tự đặc biệt thuộc tập `@$!%*?&`.

Kết quả thực tế

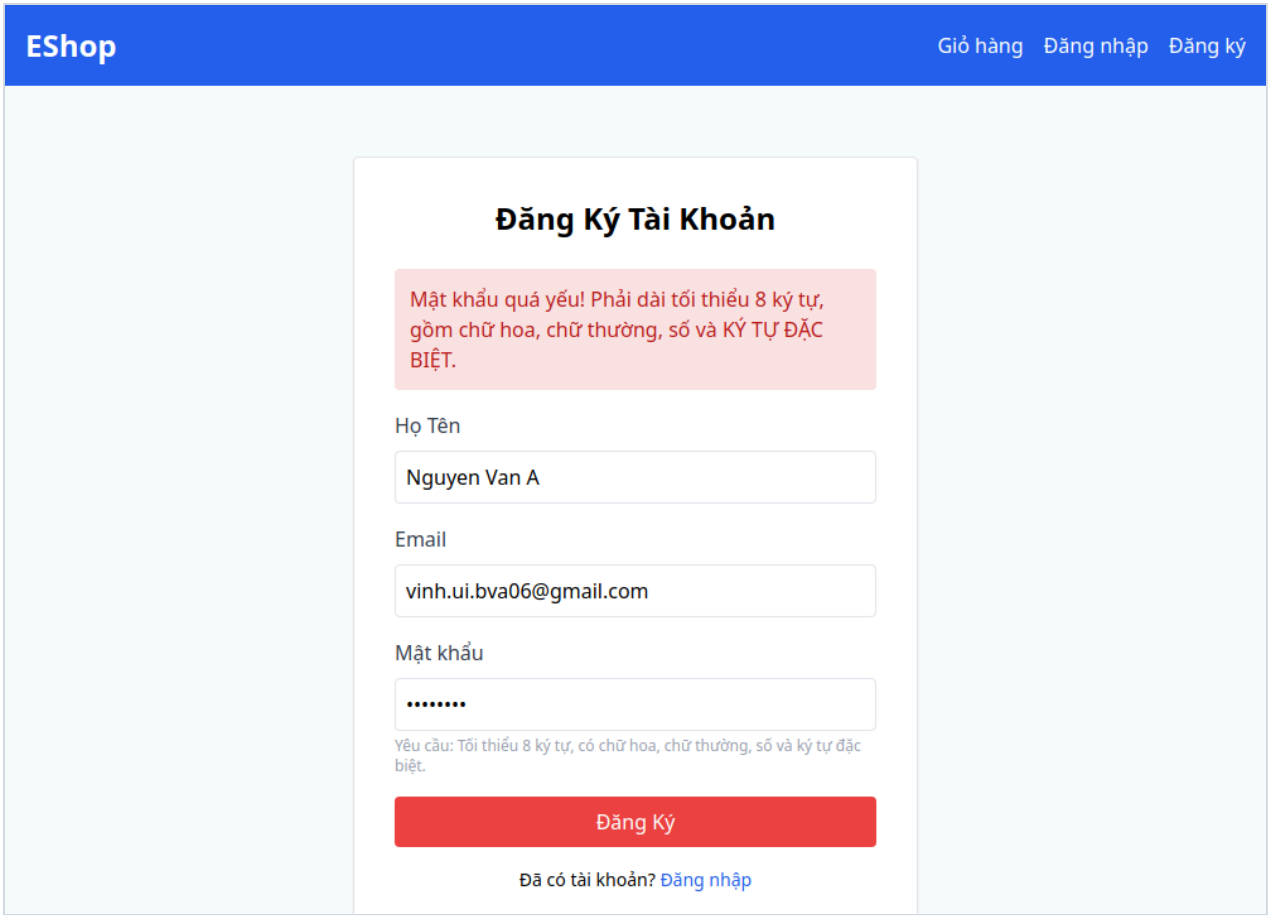
- Bước 3: hiện lỗi "*Mật khẩu quá yếu! ... và KÝ TỰ ĐẶC BIỆT*", không tạo tài khoản.
- Bước 4: **đăng ký thành công**.
- Thăm dò thêm cho thấy UI coi **khoảng trắng** là "ký tự đặc biệt" và **cấm** mọi ký tự trong tập `@$!%*?&`. Ví dụ, `Abcdef1@ ` (có cả `@` và khoảng trắng) vẫn bị từ chối.

Minh chứng: EP-01_ui.png



EP-01_ui.png

, BVA-06_ui.png



BVA-06_ui.png

(len = 8, đúng biên), bảng thăm dò trong 05_test_execution.md §5.2.

BUG-FR01-02: API `/api/register` không kiểm tra độ mạnh mật khẩu

- **Tính năng & kỹ thuật:** FR-01. EP với các lớp EC12, EC15–EC19; BVA với các biên LB−1 của V2–V6.
- **Severity:** Critical (bảo mật). Chỉ cần gọi thẳng API là bỏ qua được mọi validation ở client.

Các bước tái hiện

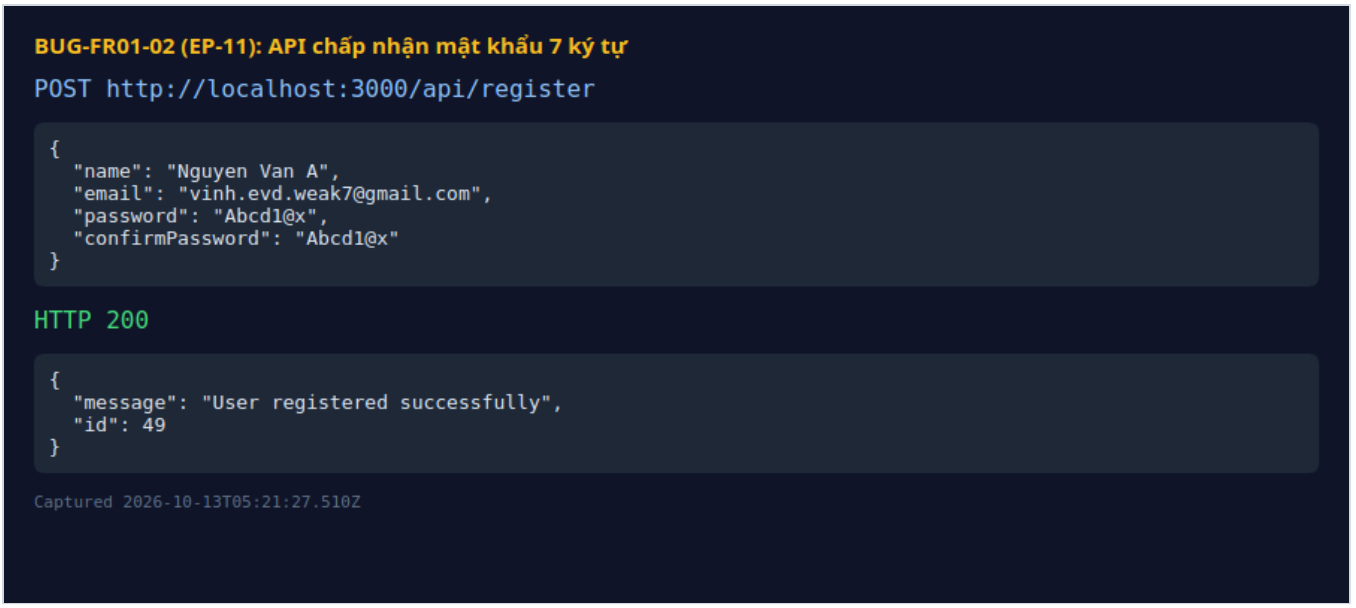
```
curl -X POST http://localhost:3000/api/register -H "Content-Type: application/json" \
  -d '{"name":"Nguyen Van A","email":"weak7@gmail.com","password":"Abcd1@x"}'
```

Kết quả mong đợi: HTTP 4xx kèm thông báo mật khẩu không đạt yêu cầu, và không tạo tài khoản.

Kết quả thực tế: HTTP 200 `{"message":"User registered successfully"}`. Tài khoản được tạo và đăng nhập được. Tất cả 11 mật khẩu yếu đều được chấp nhận:

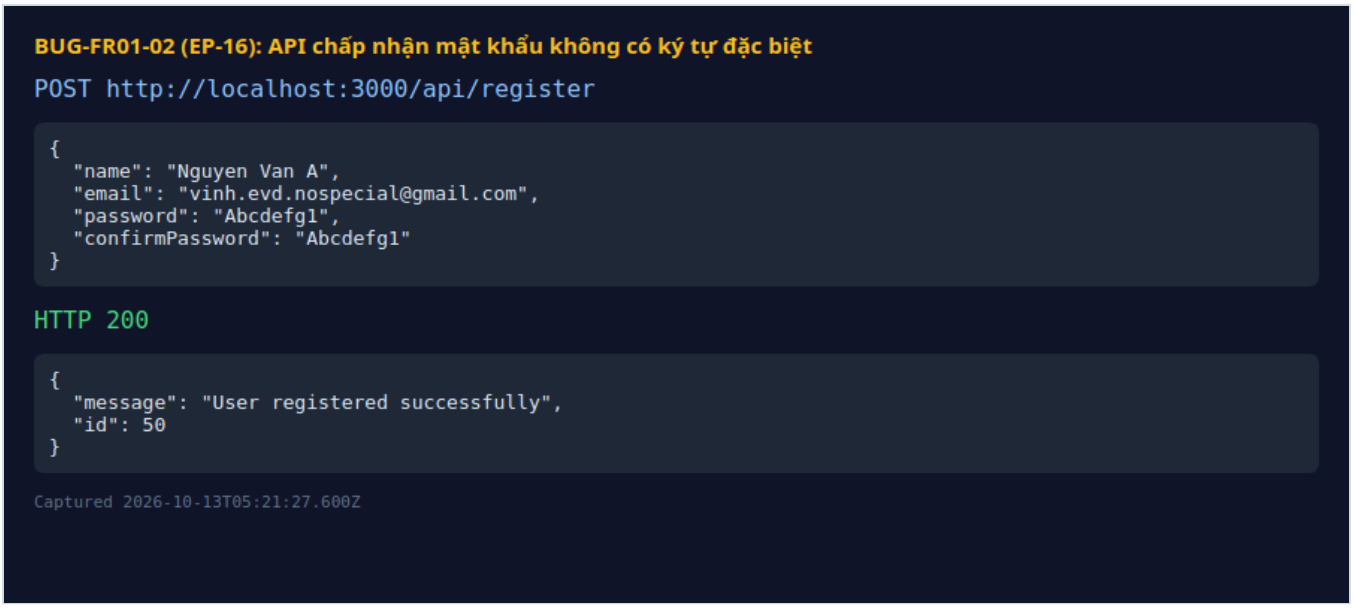
TC	Mật khẩu	Vi phạm
EP-11 / BVA-05	`Abcd1@x` / `ABcd1@!`	7 ký tự
EP-13 / BVA-08	`abcdef1@` / `abcdef123@!$`	0 chữ hoa
EP-14 / BVA-11	`ABCDEF1@` / `ABCDEF123@!$`	0 chữ thường
EP-15 / BVA-14	`Abcdefg@` / `ABCdefghi@!$`	0 chữ số
EP-16 / BVA-17	`Abcdefg1` / `ABCdef123ghi`	0 ký tự đặc biệt
EP-17	`Abcdef1#`	Ký tự đặc biệt ngoài tập

Minh chứng: BUG-FR01-02_api_weak_password.png



BUG-FR01-02_api_weak_password.png

, BUG-FR01-02_api_no_special.png



BUG-FR01-02_api_no_special.png

BUG-FR01-03: Không kiểm tra email trùng, cho tạo nhiều tài khoản cùng email

- **Tính năng & kỹ thuật:** FR-01, EP với các lớp EC9 và EC10
- **Severity:** Critical. Vi phạm ràng buộc "email duy nhất". Khi đăng nhập, hệ thống chỉ lấy một trong các bản ghi trùng, nên chủ tài khoản thật có thể bị nhầm lẫn danh tính hoặc bị chiếm tài khoản.

Các bước tái hiện

1. Mở `/register`. Nhập Họ Tên `Nguyen Van A`, Email `test@eshop.com` (tài khoản seed đã tồn tại), Mật khẩu `Abcdef1` (dùng mật khẩu UI chấp nhận, xem BUG-FR01-01). Bấm **Đăng Ký**.

2. Hoặc gọi thẳng API: `POST /api/register` với `{"name":"Nguyen Van A","email":"test@eshop.com","password":"Abcdef1@"}`.
3. Đăng nhập Admin, mở tab **Người dùng**.

Kết quả mong đợi: Hệ thống báo "Email đã được sử dụng" và không tạo tài khoản. `TEST@eshop.com` cũng phải bị coi là trùng (giả định A5).

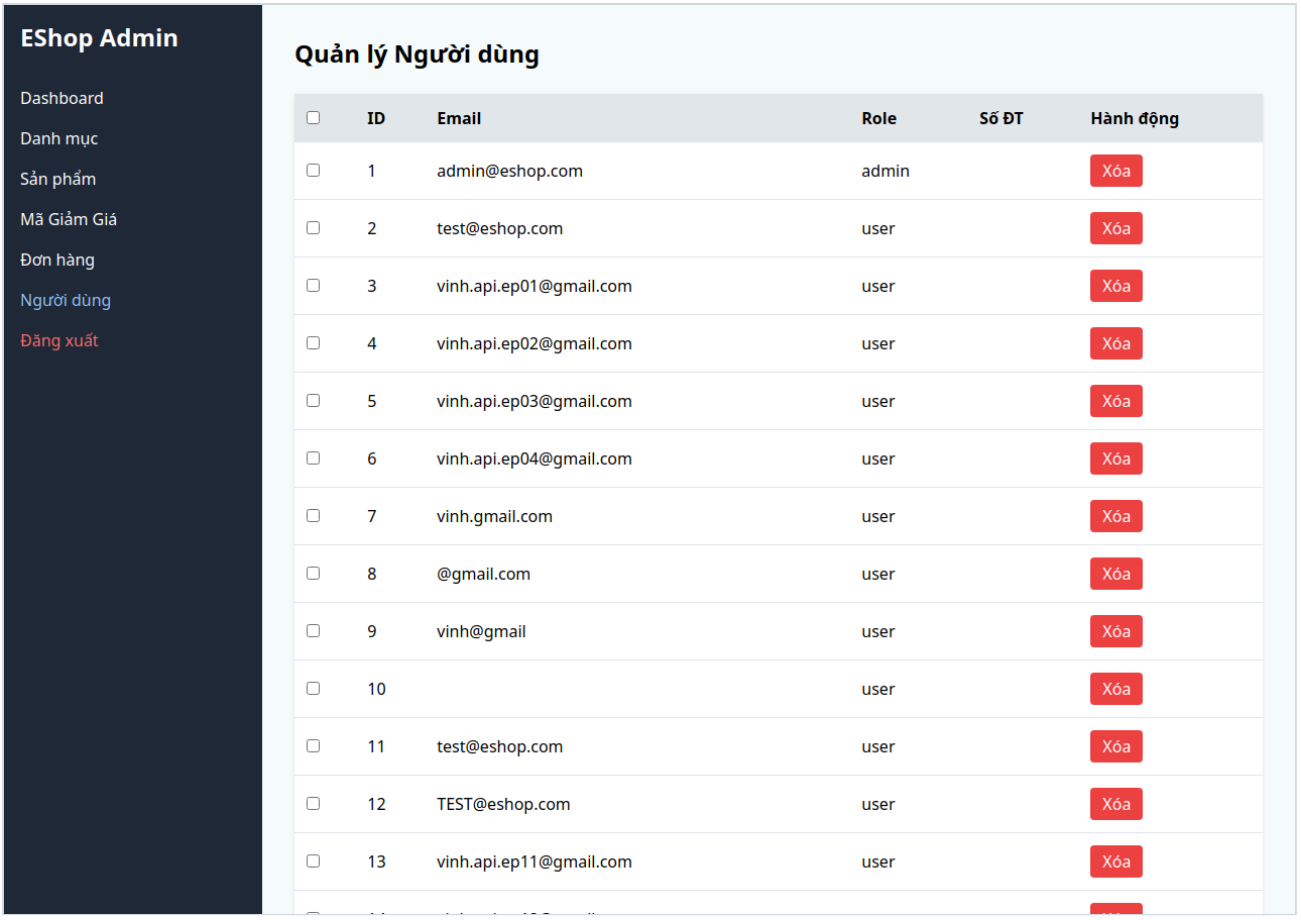
Kết quả thực tế: UI chuyển sang `/login`, API trả HTTP 200. Tab Người dùng có **nhiều dòng** **`test@eshop.com`** (id 2, 11, ...) và một dòng `TEST@eshop.com`.

Minh chứng: BUG-FR01-03_api_duplicate_email.png



BUG-FR01-03_api_duplicate_email.png

, BUG-FR01-03_admin_users_duplicates.png



BUG-FR01-03_admin_users_duplicates.png

BUG-FR01-04: Không kiểm tra định dạng email (API và UI)

- **Tính năng & kỹ thuật:** FR-01, EP với các lớp EC5, EC6, EC7
- **Severity:** Major

Các bước tái hiện

1. Mở `/register`. Nhập Họ Tên `Nguyen Van A`, Mật khẩu `Abcdef1`.
2. Lần lượt nhập Email: `vinh.gmail.com`, `@gmail.com`, `vinh@gmail`. Bấm **Đăng Ký**.

Kết quả mong đợi: Hiện lỗi "Email không đúng định dạng" và không tạo tài khoản.

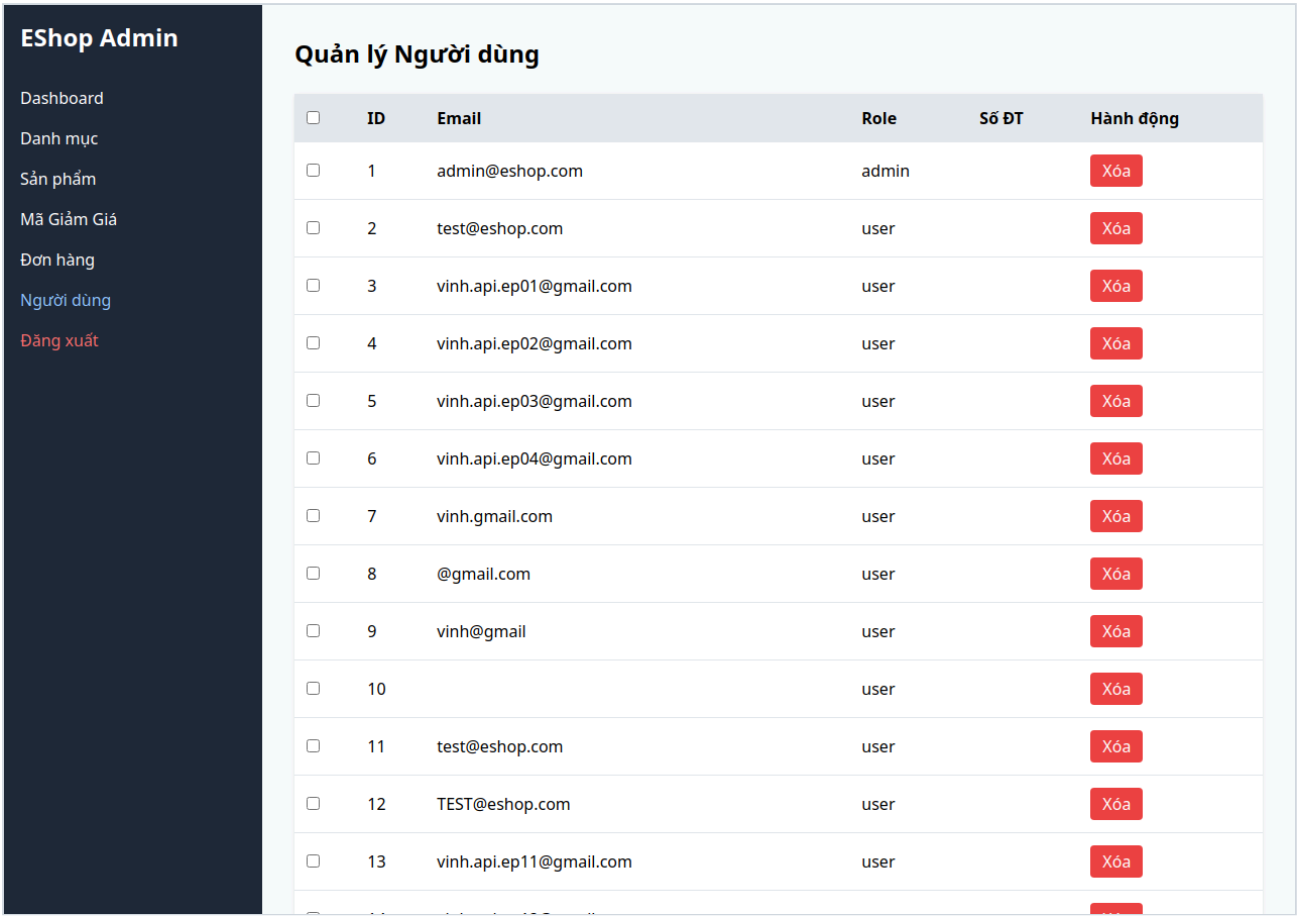
Kết quả thực tế: Cả 3 email đều được chấp nhận ở UI (sau khi chạy lại tách lỗi) và ở API. Ô Email trên UI dùng `type="text"`, nên không có validation HTML5. Điều này cũng vi phạm FR-22 ("Trường Email phải dùng `type="email"`").

Minh chứng: BUG-FR01-04_api_invalid_email.png



BUG-FR01-04_api_invalid_email.png

, BUG-FR01-03_admin_users_duplicates.png



BUG-FR01-03_admin_users_duplicates.png

(id 7, 8, 9)

BUG-FR01-05: Thiếu trường "Xác nhận mật khẩu" (UI và API)

- **Tính năng & kỹ thuật:** FR-01, EP với các lớp EC21, EC22, EC23

- **Severity:** Major. Thiếu chức năng được spec yêu cầu (R7). Người dùng có thể đăng ký với mật khẩu gõ nhầm mà không hề biết.

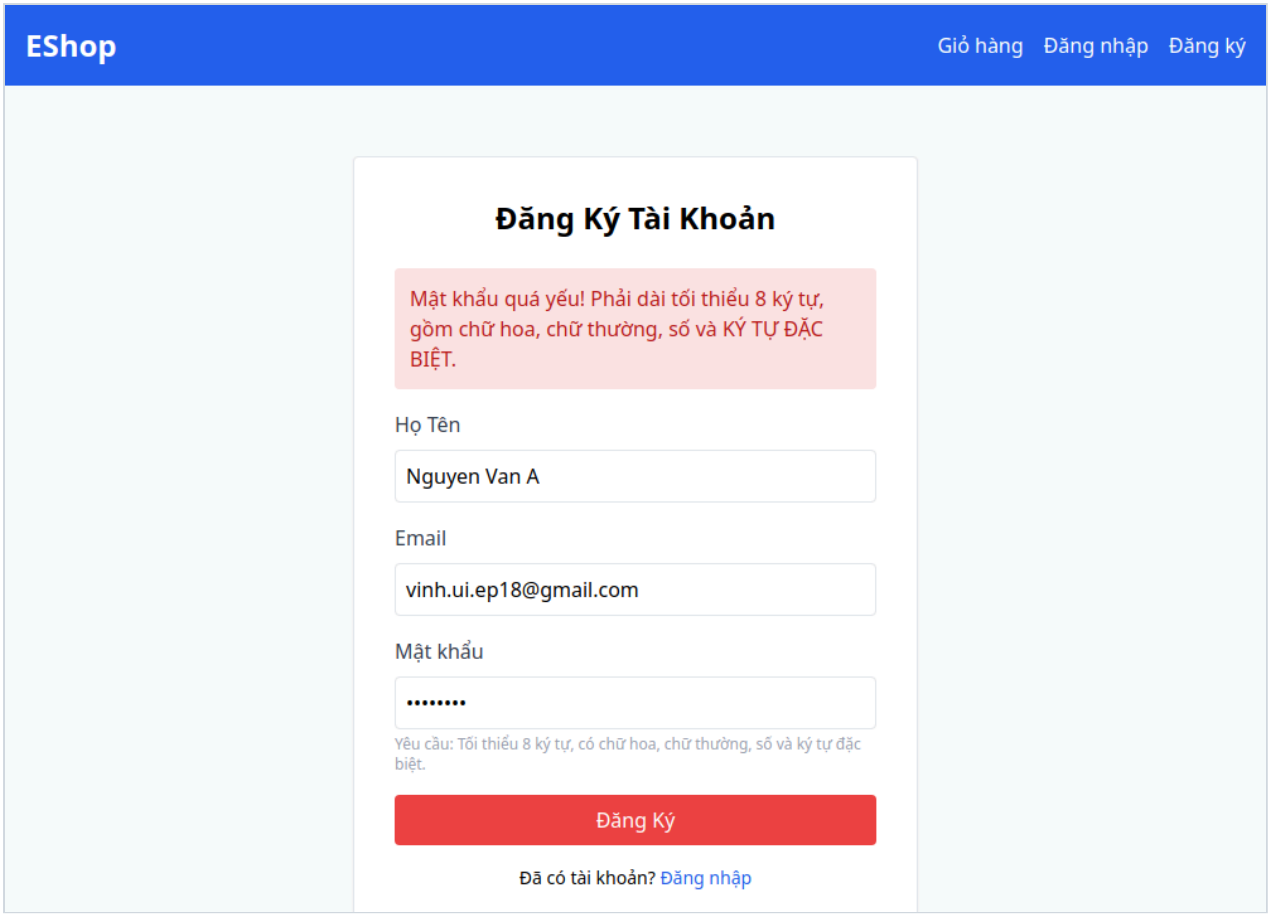
Các bước tái hiện

1. Mở `/register` và quan sát form.
2. Gọi `POST /api/register` với `password = "Abcdef1@"` và `confirmPassword = "Abcdef1!"`.

Kết quả mong đợi: Form có ô "Xác nhận mật khẩu". Hệ thống từ chối khi hai giá trị không khớp.

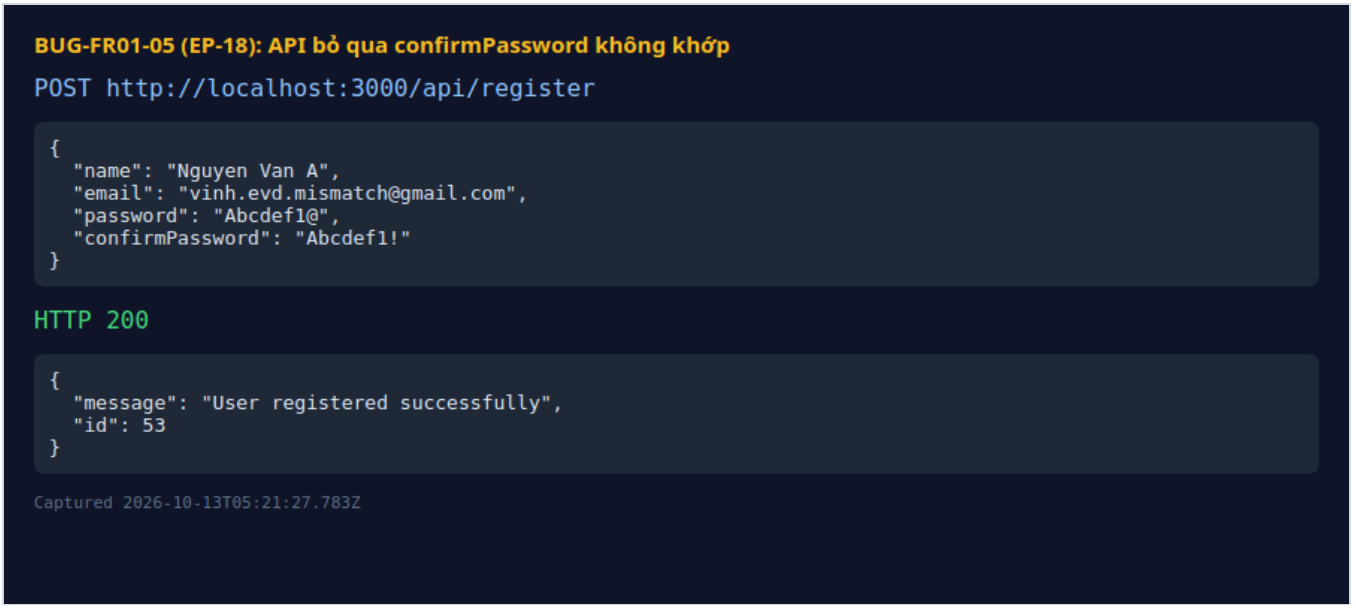
Kết quả thực tế: Form chỉ có 3 ô: Họ Tên, Email, Mật khẩu. API bỏ qua `confirmPassword`, trả HTTP 200 và tạo tài khoản.

Minh chứng: EP-18_ui.png



EP-18_ui.png

, BUG-FR01-05_api_confirm_mismatch.png



BUG-FR01-05_api_confirm_mismatch.png

BUG-FR01-06: API chấp nhận trường bắt buộc rỗng; họ tên chỉ có khoảng trắng được chấp nhận ở cả UI

- **Tính năng & kỹ thuật:** FR-01. EP với các lớp EC2, EC3, EC8, EC13; BVA với V1 = 0.
- **Severity:** Major

Các bước tái hiện

1. Gọi `POST /api/register` với body `{"name":"","email":"","password":""}`.
2. Trên UI `/register`: nhập Họ Tên `" "` (3 khoảng trắng), Email `ws@gmail.com`, Mật khẩu `Abcdef1` . Bấm **Đăng Ký**.

Kết quả mong đợi: Từ chối, kèm thông báo "Vui lòng nhập Họ tên / Email / Mật khẩu".

Kết quả thực tế

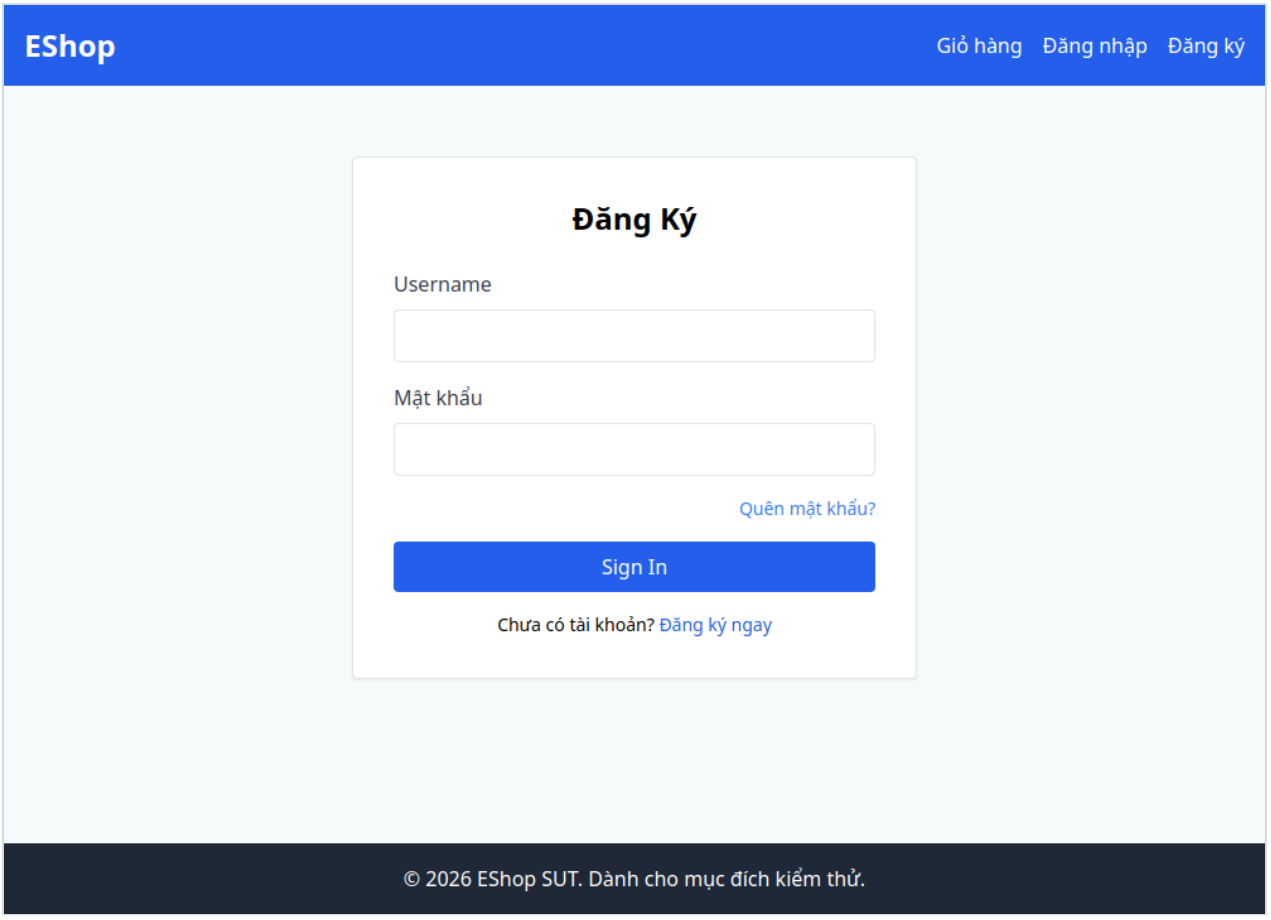
1. API trả HTTP 200 và tạo một tài khoản hoàn toàn rỗng (id 10 trong tab Người dùng).
2. UI chấp nhận họ tên chỉ có khoảng trắng và chuyển sang `/login`. UI chỉ chặn được trường **rỗng hoàn toàn** nhờ thuộc tính HTML5 `required`.

Minh chứng: BUG-FR01-06_api_all_empty.png



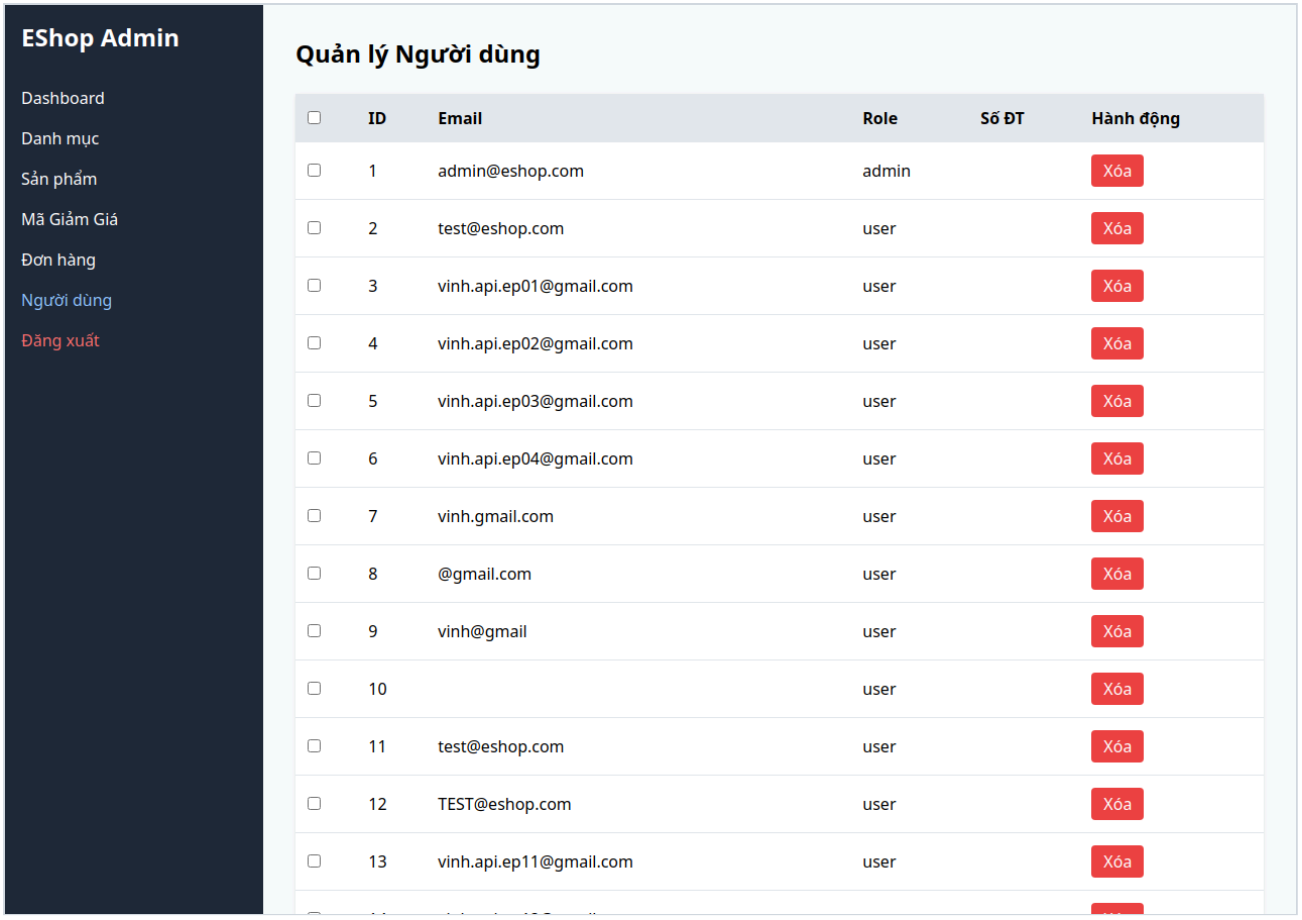
BUG-FR01-06_api_all_empty.png

, EP-04R_ui.png



EP-04R_ui.png

, BUG-FR01-03_admin_users_duplicates.png



BUG-FR01-03_admin_users_duplicates.png

(id 10)

BUG-FR01-07: Stored XSS, Họ tên chứa HTML được thực thi trên header sau khi đăng nhập

- **Tính năng & kỹ thuật:** FR-01, EP với lớp bổ sung EC27 "Họ tên chứa ký tự/thẻ HTML" (xem 07_ai_gap_analysis.md)
- **Severity:** Critical (bảo mật, vi phạm SEC-04). Kẻ tấn công đăng ký với họ tên chứa mã độc. Mã chạy trên trình duyệt của **bất kỳ ai** đăng nhập bằng tài khoản đó, và có thể đánh cắp token trong `localStorage`.

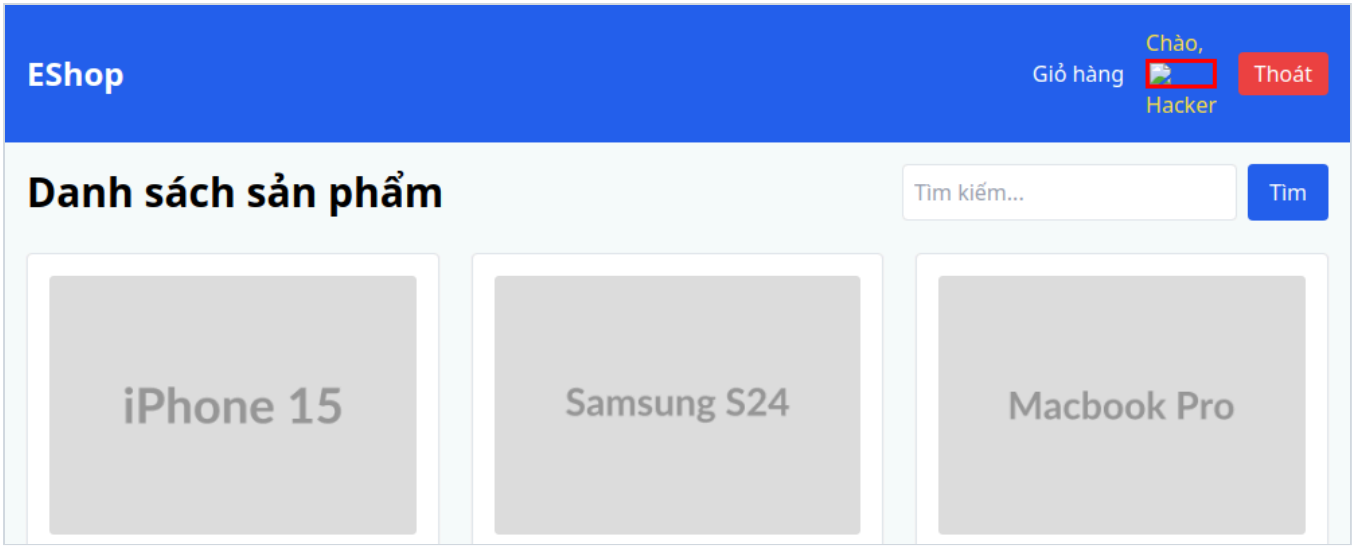
Các bước tái hiện

1. Gọi `POST /api/register` với `{"name":"<img src=x onerror=\"window.__xss=1;this.style.border='3px solid red'\">Hacker","email":"xss@gmail.com","password":"Abcdef1@"}`.
2. Mở `http://localhost:5173/login`, đăng nhập bằng `xss@gmail.com` / `Abcdef1@`.
3. Quan sát header (góc phải, phần "Chào, ..."). Mở Console và gõ `window.__xss`.

Kết quả mong đợi: Header hiển thị nguyên văn chuỗi `Chào, <img src=x …>Hacker` dưới dạng văn bản (đã escape). Không có script nào được thực thi.

Kết quả thực tế: Thẻ `<img>` được render thật, `onerror` chạy (`window.__xss === 1`), ảnh hỏng có viền đỏ. DOM của header chứa `Chào, <img src="x" onerror="…">`.

Minh chứng: EP-21_ui_header_xss.png



EP-21_ui_header_xss.png

Quan sát ngoài phạm vi FR-01 (không tính là bug của tính năng này)

- Nút **Đăng Ký** màu đỏ. FR-21 yêu cầu nút hành động tích cực dùng màu xanh dương.
- Các trường bắt buộc không có dấu `*` (FR-22).

Phụ lục 7 — `features/FR-01_Register/07_ai_gap_analysis.md`

FR-01 Đăng ký tài khoản: Bước 7, AI Gap Analysis

Công cụ AI: Claude Code (model Claude Opus 5.5), chạy trong terminal ngày 2026-10-13. Nhật ký đầy đủ: `ai-audit/`.

Cách làm việc: sinh viên ra lệnh theo từng bước của kỹ thuật (Input/Output → EC → TC EP → BVA → thực thi → bug → gap). AI tạo bản nháp, sinh viên duyệt các giả định A1–A5. Phần thực thi được tự động hóa bằng Playwright và gọi API.

7.1 Những gì AI bỏ sót hoặc làm sai

#	Gap	Loại	Phát hiện ở đâu	Nguyên nhân	Xử lý
G1	Không có lớp hợp lệ **"Họ tên tiếng Việt có dấu"**. Mọi giá trị đại diện đều là ASCII (`Nguyen Van A`)	Thiếu TC	Rà soát sau khi thực thi	**Thiên lệch của AI:** mặc định chọn dữ liệu mẫu tiếng Anh/ASCII, dù SUT là ứng dụng tiếng Việt	Thêm EC26 và TC EP-20 → Pass
G2	Không có lớp **"Họ tên chứa ký tự/thẻ HTML"**, nên bỏ lỡ một lỗi **Critical** (stored XSS, BUG-FR01-07)	Thiếu TC, **bỏ sót bug**	Rà soát sau khi thực thi, đối chiếu chéo với SEC-04	**Chất lượng prompt:** yêu cầu chỉ nói "phân tích FR-01", nên AI chỉ đọc mục FR-01. Ràng buộc escape dữ liệu lại nằm ở mục khác (SEC-04, FR-18). Ngoài ra, EP thuần theo spec chức năng vốn không sinh ra lớp "dữ liệu nguy hiểm"	Thêm EC27 và TC EP-21 → Fail, ghi thành BUG-FR01-07
G3	Không dự đoán được lớp **"Mật khẩu chứa khoảng trắng"**	Thiếu TC	Khi thực thi (thăm dò sau masking)	**Độ phức tạp của SUT:** spec không nhắc tới khoảng trắng. Không ai ngờ UI lại coi khoảng trắng là ký tự đặc biệt. EP dựa trên spec không thể sinh ra lớp mà spec không nói tới	Ghi nhận trong bảng thăm dò §5.2, gộp vào BUG-FR01-01
G4	Kế hoạch thực thi giả định **TC hợp lệ sẽ được chấp nhận**, nên không lường trước hiện tượng lỗi che lỗi trên UI	Thiết kế thực thi sai	Lượt chạy đầu tiên	**Hạn chế của AI:** áp dụng máy móc nguyên tắc "1 lớp không hợp lệ/TC" mà không kiểm tra tiền đề "bộ giá trị nền hợp lệ thật sự được chấp nhận"	Thêm lượt chạy lại 9 TC (hậu tố `R`) với mật khẩu UI chấp nhận được
G5	Ở Bước 2, AI viết dòng thống kê **tự mâu thuẫn**: lúc đầu ghi "8 lớp hợp lệ… 17 không hợp lệ", sau đó sửa thành 7 và 18	Sai số liệu	AI tự phát hiện trước khi commit, thấy được trong audit log	**Hạn chế của AI:** sinh văn bản trước rồi mới đếm lại	Sửa trước commit `167624b`
G6	Giả định A3 (ký tự ngoài tập vẫn hợp lệ) và A5 (email không phân biệt hoa/thường) là **diễn giải của AI**, spec không xác nhận	Rủi ro đánh giá sai	Bước 1	**Spec mơ hồ:** cần người viết spec xác nhận	Sinh viên chấp nhận và ghi rõ là giả định. Kết quả của EP-02 và EP-10 phụ thuộc vào các giả định này

7.2 Các TC vẫn chưa được thiết kế (rủi ro còn lại)

Lớp chưa phủ	Lý do chưa làm
Email có khoảng trắng ở đầu hoặc cuối (`" a@b.com "`)	Spec không quy định việc trim. Cần làm rõ

Lớp chưa phủ	Lý do chưa làm
Độ dài tối đa của email (RFC 5321: 254 ký tự)	Spec không quy định. Đã có TC chuỗi dài cho họ tên và mật khẩu
Gửi form 2 lần liên tiếp (double submit)	Thuộc kiểm thử đồng thời, ngoài phạm vi EP/BVA
Họ tên chứa emoji hoặc ký tự Unicode 4 byte	Chưa ưu tiên

7.3 Bài học

1. **EP/BVA theo spec chỉ tìm được những gì spec nói tới.** Các lỗi lớn nhất của FR-01 (khoảng trắng bị coi là ký tự đặc biệt, XSS) nằm **ngoài** câu chữ của FR-01. Cần đối chiếu chéo với các yêu cầu chung (SEC, GUI) và bổ sung kiểm thử khám phá.
2. **Chạy TC hợp lệ trước.** Nếu TC hợp lệ thất bại, mọi TC không hợp lệ chạy sau trên cùng kênh đều phải bị nghi ngờ là Pass giả.
3. **Kiểm thử ở hai tầng (UI và API)** cho bức tranh khác hẳn so với chỉ test UI. Toàn bộ validation phía server đều thiếu, điều này chỉ lộ ra khi gọi API trực tiếp.
4. **Prompt quyết định phạm vi.** Câu lệnh "phân tích FR-01" khiến AI bỏ qua SEC-04. Với các tính năng sau, prompt nên yêu cầu AI **liệt kê mọi yêu cầu liên quan trong toàn bộ SRS** trước khi phân hoạch.

Phụ lục 8 — `features/FR-09_Coupon/01_input_output.md`

FR-09 Mã giảm giá (Coupon): Bước 1, Xác định Input & Output

> Kỹ thuật: Phân hoạch tương đương, bước 1/3 (slide Bài 4, tr.6–7). Cơ sở kiểm thử: SRS EShop mục FR-09. Theo bài học của FR-01 (xem FR-01 §7.3), lần này AI được yêu cầu **liệt kê mọi yêu cầu liên quan trong toàn bộ SRS** trước khi phân hoạch.

1.1 Trích yêu cầu từ SRS

Mã	Nguồn	Nội dung đặc tả
R1	FR-09 C1	Mã phải **tồn tại** trong CSDL và đang hoạt động (`is_active = 1`)
R2	FR-09 C2	**Còn hạn:** ngày hiện tại phải **trước** `expired_at`
R3	FR-09 C3	**Đủ ngưỡng:** tổng đơn hàng **>=** `min_order_amount`
R4	FR-09 C4	**Đã đăng nhập:** người dùng phải có JWT Token hợp lệ
R5	FR-09 C5	**Chưa dùng hết lượt:** số lần user đã dùng mã < `max_uses_per_user`
R6	FR-09	Mã chỉ được áp dụng khi **tất cả** 5 điều kiện thỏa
R7	FR-09	`percent` : `discount_amount = total × discount_value / 100`
R8	FR-09	`fixed` : `discount_amount = discount_value` ; `final_amount = total − discount_amount`
R9	FR-08	Tổng tiền **tính tự động từ giỏ hàng**, người dùng **không được sửa trực tiếp**; backend tự tính lại, không tin `total_amount` từ client
R10	SEC-02	API có tính bảo mật phải yêu cầu JWT hợp lệ
R11	FR-21	Tiền tệ dùng ký hiệu `₫` , có phân cách hàng nghìn

Yêu cầu đã xem nhưng không đưa vào phạm vi: FR-17 (Admin CRUD coupon) chỉ dùng để **chuẩn bị dữ liệu** (tạo mã biên). SEC-04 (escape dữ liệu) không áp dụng vì người dùng không nhập dữ liệu nào được hiển thị lại, ngoài mã giảm giá. Mã được tra trong CSDL và không được render nếu không tồn tại.

Mã giảm giá mẫu (dữ liệu seed):

Mã	Loại	Giá trị	Ngưỡng tối thiểu	Hạn dùng	Số lần/người
`SAVE10`	percent	10%	300.000 ₫	2099-12-31	1
`BIGBUY`	fixed	50.000 ₫	500.000 ₫	2099-12-31	1
`VIP100`	fixed	100.000 ₫	300.000 ₫	2099-12-31	2
`EXPIRED`	percent	20%	100.000 ₫	2020-01-01	1

1.2 Biến đầu vào (Input)

Mã	Input	Kiểu	Ai kiểm soát	Ràng buộc
I1	Mã giảm giá (`code`)	chuỗi	Người dùng nhập ở ô "Mã Giảm Giá"	R1, R2, R6 (chọn mã nào thì chọn luôn bộ thuộc tính của coupon)

Mã	Input	Kiểu	Ai kiểm soát	Ràng buộc
I2	Tổng đơn hàng (`total`)	số nguyên ≥ 0 (đ)	**Gián tiếp:** người dùng chọn sản phẩm và số lượng trong giỏ	R3, R7, R8, R9
I3	Trạng thái đăng nhập (JWT)	token	Người dùng (đăng nhập hay không)	R4, R10
I4	Số lần user đã dùng mã (`used`)	số nguyên ≥ 0	Trạng thái hệ thống, tăng sau mỗi lần thanh toán có mã	R5

Thuộc tính của coupon ảnh hưởng tới kết quả (trạng thái hệ thống, được cố định khi chọn I1): `is_active`, `expired_at`, `min_order_amount`, `max_uses_per_user`, `type`, `discount_value`.

1.3 Biến đầu ra (Output)

Mã	Output	Mô tả
O1	Áp dụng thành công	Hiện thông báo thành công, số tiền giảm `discount_amount` và thành tiền `final_amount` đúng công thức R7/R8
O2	Từ chối	Hiện thông báo lỗi phù hợp với điều kiện bị vi phạm, **không** giảm giá, tổng thanh toán giữ nguyên

O1 có hai lớp đầu ra cần kiểm tra riêng theo slide tr.8 ("phân hoạch cả miền output"): **O1a** coupon loại `percent` và **O1b** coupon loại `fixed`.

1.4 Các điều kiện cần phân hoạch (đầu vào cho Bước 2)

Điều kiện	Biến	Loại điều kiện (slide tr.10)
C1. Mã tồn tại và đang hoạt động	I1	Tập giá trị: {mã đang hoạt động}
C2. `hôm nay < expired_at`	I1 (`expired_at`)	Dãy giá trị ngày `[ngày mai..∞)` , **có thứ tự nên áp dụng được BVA**
C3. `total >= min_order_amount`	I2	Dãy giá trị `[min..∞)` , **có thứ tự nên áp dụng được BVA**
C4. Có JWT hợp lệ	I3	Boolean
C5. `used < max_uses_per_user`	I4	Dãy giá trị `[0..max−1]` , **có thứ tự nên áp dụng được BVA**
C6. Loại coupon	I1 (`type`)	Tập giá trị { `percent` , `fixed` }, quyết định công thức đầu ra
C7. Tổng tiền do hệ thống tính, không do client gửi	I2	Boolean (R9)

1.5 Điểm mơ hồ trong đặc tả và giả định áp dụng

#	Điểm mơ hồ	Giả định áp dụng
A1	Spec không nói mã có phân biệt chữ hoa/thường hay có bỏ khoảng trắng 2 đầu	Người dùng nhập tay nên **không phân biệt hoa/thường** và **bỏ khoảng trắng 2 đầu**: `save10` , `" SAVE10 "` tương đương `SAVE10` . *(Diễn giải của AI, sinh viên chấp nhận)*
A2	"Ngày hiện tại phải trước `expired_at` " so sánh theo ngày hay theo thời điểm?	So sánh theo **ngày, giờ Việt Nam**. Mã hợp lệ khi `expired_at` ≥ ngày mai. `expired_at` = **hôm nay** thì đã hết hạn, vì hôm nay không "trước" hôm nay
A3	Kết quả `percent` có phần lẻ	Làm tròn xuống đồng (đ). Các giá trị test được chọn để chia hết, tránh phụ thuộc giả định này
A4	"Số lần đã dùng" tính khi nào	Tăng 1 sau mỗi lần **thanh toán thành công** có áp mã. Chỉ bấm "Áp dụng" thì không tính

#	Điểm mơ hồ	Giả định áp dụng
A5	C4 không nói user được xác định bằng gì	Theo SEC-02, user phải lấy từ **JWT**. Không có token thì phải từ chối, kể cả khi client gửi `user_id`
A6	Không có cách nào trên UI để vô hiệu hóa coupon (FR-17 chỉ có Thêm/Xem/Xóa)	Lớp `is_active = 0` được chuẩn bị bằng cách cập nhật trực tiếp CSDL (bước chuẩn bị dữ liệu, ghi rõ ở Bước 5)

1.6 Kênh thực thi & quan sát ban đầu (hộp đen)

- **UI:** `http://localhost:5173`. Đăng nhập → thêm sản phẩm vào giỏ → **Tiến hành thanh toán** → trang `/checkout` → nhập mã ở ô "Mã Giảm Giá" → **Áp dụng**. Kết quả hiện ngay dưới ô nhập.
- **API:** `POST /api/apply-coupon` với body `{code, total_amount, user_id}` theo API spec §5.1.
- **Quan sát ban đầu:**
  - Trang `/checkout` có ô **"Tổng tiền thanh toán (VND)" cho phép sửa trực tiếp** (`input type="number"`). Điều này mâu thuẫn với R9 và cho phép người dùng tự đặt tổng tiền để vượt ngưỡng C3. Được đưa vào phân hoạch dưới dạng điều kiện C7.
  - API spec yêu cầu client gửi `total_amount` và `user_id` trong body. Thiết kế này đã trái với R9 và A5 ngay từ API spec.
- **Chuẩn bị dữ liệu để chạm đúng biên tổng tiền:** sản phẩm seed có giá ≥ 4.000.000 ₫, không thể tạo giỏ hàng có tổng đúng bằng 299.999 / 300.000 / 300.001 ₫. Vì vậy sẽ tạo thêm **sản phẩm test có giá chính xác** qua API Admin. Đây chỉ là dữ liệu, không phải đối tượng kiểm thử.

Phụ lục 9 — `features/FR-09_Coupon/02_equivalence_classes.md`

FR-09 Mã giảm giá (Coupon): Bước 2, Xác định lớp tương đương

> Kỹ thuật: Phân hoạch tương đương, bước 2/3 (slide Bài 4, tr.8–10). Đầu vào là 7 điều kiện C1–C7 và các giả định A1–A6 ở Bước 1.

2.1 Cách phân hoạch

Loại điều kiện	Lớp hợp lệ	Lớp không hợp lệ	Áp dụng cho
Tập giá trị	mã thuộc tập "đang hoạt động"	mã ngoài tập (không tồn tại / rỗng / bị vô hiệu hóa)	C1
Dãy giá trị ngày `[ngày mai..∞)`	`expired_at` ≥ ngày mai	`expired_at` < ngày mai	C2
Dãy giá trị `[min..∞)`	`total` ≥ `min_order_amount`	`total` < `min_order_amount`	C3
Boolean	có JWT hợp lệ	không có / sai token	C4
Dãy giá trị `[0..max−1]`	`used` < `max_uses_per_user`	`used` ≥ `max_uses_per_user`	C5
Tập giá trị (output)	`percent`, `fixed`	–	C6
Boolean	`total` khớp giỏ hàng	`total` bị client sửa	C7

Một số lớp được **tách nhỏ hơn** vì hệ thống có thể xử lý mỗi cách khác nhau:

- **C1 không hợp lệ** tách thành 3 lớp: *không tồn tại*, *rỗng*, *tồn tại nhưng* `is_active = 0`. Lớp cuối khác lớp đầu vì mã vẫn có trong CSDL.
- **C1 hợp lệ** tách thêm 2 lớp *chữ thường* và *có khoảng trắng 2 đầu* theo giả định A1.
- **C2 không hợp lệ** tách *đã qua hạn* và *hết hạn đúng hôm nay*. Lớp sau là điểm mơ hồ A2 nên cần TC riêng.
- **C4 không hợp lệ** tách *không có token* và *token giả*.
- **C5 không hợp lệ** có thêm lớp *dùng hết lượt nhưng client không gửi* `user_id` (giả định A5). Nếu hệ thống đếm lượt theo `user_id` trong body thay vì theo token, người dùng có thể né C5.

2.2 Bảng tổng hợp lớp tương đương

Bộ giá trị nền dùng cho mọi lớp, trừ biến đang xét: user mới đăng ký và đã đăng nhập, chưa dùng mã nào (`used = 0`). Giỏ có 1 sản phẩm test giá **1.000.000 ₫**, nên `total = 1.000.000`. Mã là `SAVE10`.

STT	Input / Output	Điều kiện	Lớp tương đương	Loại	Giá trị đại diện
EC1	I1 Mã	C1	Mã tồn tại, đang hoạt động, nhập đúng chữ hoa	Hợp lệ	`SAVE10`
EC2		C1	Mã hợp lệ nhập chữ thường (A1)	Hợp lệ	`save10`
EC3		C1	Mã hợp lệ có khoảng trắng 2 đầu (A1)	Hợp lệ	`" VIP100 "`
EC4		C1	Mã không tồn tại	Không hợp lệ	`ABC123`

STT	Input / Output	Điều kiện	Lớp tương đương	Loại	Giá trị đại diện
EC5		C1	Mã rỗng	Không hợp lệ	`""`
EC6		C1	Mã tồn tại nhưng `is_active = 0` (A6)	Không hợp lệ	`OFF10` *(chuẩn bị)*
EC7	I1 `expired_at`	C2	Còn hạn: `expired_at` ≥ ngày mai	Hợp lệ	`SAVE10` (2099-12-31)
EC8		C2	Đã qua hạn: `expired_at` < hôm nay	Không hợp lệ	`EXPIRED` (2020-01-01)
EC9		C2	Hết hạn đúng hôm nay (A2)	Không hợp lệ	`EXP0D` *(chuẩn bị, `expired_at` = hôm nay)*
EC10	I2 Tổng tiền	C3	`total` ≥ `min_order_amount`	Hợp lệ	1.000.000 (SAVE10, min 300.000)
EC11		C3	`total` < `min_order_amount`	Không hợp lệ	200.000 (SAVE10)
EC12	I3 Đăng nhập	C4	Đã đăng nhập, JWT hợp lệ	Hợp lệ	token của user test
EC13		C4	Chưa đăng nhập (không có token)	Không hợp lệ	–
EC14		C4	Token không hợp lệ	Không hợp lệ	`Bearer abc.def.ghi`
EC15	I4 Số lần đã dùng	C5	`used` < `max`	Hợp lệ	`used = 0` (SAVE10, max 1)
EC16		C5	`used` = `max`	Không hợp lệ	`used = 1` (SAVE10)
EC17		C5	`used` = `max`, client không gửi `user_id` (A5)	Không hợp lệ	`used = 1`, body không có `user_id`
EC18	O1 Kết quả	C6	Coupon `percent`: giảm `total × v / 100`	Hợp lệ (output)	SAVE10, 1.000.000 → giảm 100.000, còn 900.000
EC19		C6	Coupon `fixed`: giảm `v`	Hợp lệ (output)	BIGBUY, 1.000.000 → giảm 50.000, còn 950.000
EC20	I2 Tổng tiền	C7	`total` do hệ thống tính từ giỏ	Hợp lệ	giữ nguyên tổng của giỏ
EC21		C7	`total` bị người dùng sửa tay (FR-08)	Không hợp lệ	giỏ 200.000, sửa thành 1.000.000

Thống kê: 21 lớp, gồm **10 lớp hợp lệ** (EC1, EC2, EC3, EC7, EC10, EC12, EC15, EC18, EC19, EC20) và **11 lớp không hợp lệ** (EC4, EC5, EC6, EC8, EC9, EC11, EC13, EC14, EC16, EC17, EC21).

2.3 Dữ liệu cần chuẩn bị

Dữ liệu seed không đủ để đại diện cho mọi lớp. Phần chuẩn bị sau thuộc **tiền điều kiện của TC**, không phải đối tượng kiểm thử:

Dữ liệu	Cách tạo	Dùng cho
Sản phẩm test giá 200.000 / 1.000.000 ₫	`POST /api/products` (quyền admin)	EC10, EC11, EC21 và bộ giá trị nền
Coupon `OFF10` (giống SAVE10) rồi đặt `is_active = 0`	`POST /api/admin/coupons`, sau đó `UPDATE` trực tiếp CSDL (A6)	EC6
Coupon `EXP0D` (giống SAVE10, `expired_at` = hôm nay)	`POST /api/admin/coupons`	EC9
User có `used = 1` với SAVE10	Thanh toán thật có áp SAVE10 trên UI, hoặc `POST /api/coupon-usage` (đúng lời gọi mà UI thực hiện sau khi thanh toán)	EC16, EC17

Phụ lục 10 — `features/FR-09_Coupon/03_ep_test_cases.md`

FR-09 Mã giảm giá (Coupon): Bước 3, Xác định ca kiểm thử (EP)

> Kỹ thuật: Phân hoạch tương đương, bước 3/3 (slide Bài 4, tr.15–18). Đầu vào: 21 lớp tương đương ở Bước 2.

3.1 Nguyên tắc áp dụng (slide tr.15)

1. Khi xét một lớp của biến X, chọn giá trị đại diện của lớp đó cho X. Các biến khác lấy **bộ giá trị nền hợp lệ**: user mới, đã đăng nhập, `used = 0`, giỏ 1.000.000 ₫, mã `SAVE10`.
2. **Một TC phủ nhiều lớp hợp lệ** cùng lúc.
3. **Mỗi TC chỉ phủ đúng một lớp không hợp lệ.**

Ràng buộc bổ sung: **mỗi TC dùng một user mới** (`vinh.<kênh>.f09.epNN@gmail.com`). Lý do là C5 phụ thuộc lịch sử dùng mã của user. Nếu các TC dùng chung user, một TC chạy trước có thể làm "hết lượt" và làm sai kết quả của TC sau.

3.2 Bảng xác định ca kiểm thử cho từng lớp

Lớp	Lớp tương đương	Mã	Tổng giỏ	Đăng nhập	used	Output mong đợi
EC1	Mã đúng, chữ hoa	`SAVE10`	1.000.000	Có	0	O1: giảm 100.000, còn 900.000
EC2	Mã chữ thường	`save10`	1.000.000	Có	0	O1: giảm 100.000, còn 900.000
EC3	Mã có khoảng trắng 2 đầu	`" VIP100 "`	1.000.000	Có	0	O1: giảm 100.000, còn 900.000
EC4	Mã không tồn tại	`ABC123`	1.000.000	Có	0	O2: mã không tồn tại
EC5	Mã rỗng	`""`	1.000.000	Có	0	O2: yêu cầu nhập mã / không cho áp dụng
EC6	Mã bị vô hiệu hóa	`OFF10`	1.000.000	Có	0	O2: mã không tồn tại hoặc bị vô hiệu hóa
EC7	Còn hạn	`SAVE10`	1.000.000	Có	0	O1
EC8	Đã qua hạn	`EXPIRED`	1.000.000	Có	0	O2: mã hết hạn
EC9	Hết hạn đúng hôm nay	`EXP0D`	1.000.000	Có	0	O2: mã hết hạn
EC10	Đủ ngưỡng	`SAVE10`	1.000.000	Có	0	O1
EC11	Dưới ngưỡng	`SAVE10`	200.000	Có	0	O2: chưa đủ giá trị tối thiểu
EC12	Đã đăng nhập	`SAVE10`	1.000.000	Có	0	O1
EC13	Chưa đăng nhập	`SAVE10`	1.000.000	**Không**	–	O2: yêu cầu đăng nhập
EC14	Token không hợp lệ	`SAVE10`	1.000.000	**Token giả**	–	O2: HTTP 401/403
EC15	`used` < max	`SAVE10`	1.000.000	Có	0	O1
EC16	`used` = max	`SAVE10`	1.000.000	Có	**1**	O2: đã dùng hết lượt
EC17	`used` = max, không gửi `user_id`	`SAVE10`	1.000.000	Có (token)	**1**	O2: đã dùng hết lượt

Lớp	Lớp tương đương	Mã	Tổng giỏ	Đăng nhập	used	Output mong đợi
EC18	Output `percent`	`SAVE10`	1.000.000	Có	0	O1a: giảm 100.000, còn 900.000
EC19	Output `fixed`	`BIGBUY`	1.000.000	Có	0	O1b: giảm 50.000, còn 950.000
EC20	Tổng do hệ thống tính	`SAVE10`	1.000.000	Có	0	O1
EC21	Tổng bị sửa tay	`SAVE10`	200.000, **sửa thành 1.000.000**	Có	0	O2: không sửa được tổng tiền, hoặc mã bị từ chối vì tổng thật là 200.000

3.3 Bảng rút gọn các ca kiểm thử

Gộp các lớp hợp lệ giống nhau (EC1, EC7, EC10, EC12, EC15, EC18, EC20 cùng dùng bộ giá trị nền), được **15 TC**:

TC	Lớp phủ	Mã	Tổng giỏ	Đăng nhập	used	Kênh	Output mong đợi
EP-01	EC1, EC7, EC10, EC12, EC15, EC18, EC20	`SAVE10`	1.000.000	Có	0	UI + API	O1a: giảm **100.000**, còn **900.000**
EP-02	EC1, EC7, EC10, EC12, EC15, **EC19**, EC20	`BIGBUY`	1.000.000	Có	0	UI + API	O1b: giảm **50.000**, còn **950.000**
EP-03	**EC2** + nền	`save10`	1.000.000	Có	0	UI + API	O1a: giảm 100.000, còn 900.000
EP-04	**EC3** + nền (fixed)	`" VIP100 "`	1.000.000	Có	0	UI + API	O1b: giảm 100.000, còn 900.000
EP-05	**EC4**	`ABC123`	1.000.000	Có	0	UI + API	O2
EP-06	**EC5**	`""`	1.000.000	Có	0	UI + API	O2 (UI: nút Áp dụng bị vô hiệu hóa cũng chấp nhận)
EP-07	**EC6**	`OFF10`	1.000.000	Có	0	UI + API	O2
EP-08	**EC8**	`EXPIRED`	1.000.000	Có	0	UI + API	O2: hết hạn
EP-09	**EC9**	`EXP0D`	1.000.000	Có	0	UI + API	O2: hết hạn
EP-10	**EC11**	`SAVE10`	200.000	Có	0	UI + API	O2: chưa đủ ngưỡng
EP-11	**EC13**	`SAVE10`	1.000.000	**Không**	–	UI + API	O2: yêu cầu đăng nhập
EP-12	**EC14**	`SAVE10`	1.000.000	**Token giả**	–	API	O2: HTTP 401/403
EP-13	**EC16**	`SAVE10`	1.000.000	Có	**1**	UI + API	O2: đã dùng hết lượt
EP-14	**EC17**	`SAVE10`	1.000.000	Có	**1**, không gửi `user_id`	API	O2: đã dùng hết lượt
EP-15	**EC21**	`SAVE10`	200.000 → sửa 1.000.000	Có	0	UI	O2

Lý do một số TC chỉ chạy trên một kênh:

- **EP-12, EP-14 chỉ chạy API.** Trên UI, token giả bị `AuthContext` phát hiện và tự đăng xuất. UI cũng luôn gửi `user_id` của user đang đăng nhập. Hai lớp này chỉ có thể xảy ra khi gọi API trực tiếp, nhưng đó chính là đường tấn công thật.
- **EP-15 chỉ chạy UI.** API `apply-coupon` không có giỏ hàng phía server, nên không có "tổng thật" để so sánh. Lớp này kiểm tra ô tổng tiền trên trang Checkout.
- **EP-11 trên UI:** người chưa đăng nhập bấm **Tiến hành thanh toán** sẽ bị chặn ở trang Giỏ hàng. TC kiểm tra thêm việc mở thẳng `/checkout` bằng điều hướng phía client (giữ nguyên giỏ) rồi áp mã.

3.4 Kiểm tra độ phủ

Lớp	TC phủ	Lớp	TC phủ	Lớp	TC phủ
EC1	EP-01, EP-02	EC8	EP-08	EC15	EP-01
EC2	EP-03	EC9	EP-09	EC16	EP-13
EC3	EP-04	EC10	EP-01	EC17	EP-14
EC4	EP-05	EC11	EP-10	EC18	EP-01, EP-03
EC5	EP-06	EC12	EP-01	EC19	EP-02, EP-04
EC6	EP-07	EC13	EP-11	EC20	EP-01
EC7	EP-01	EC14	EP-12	EC21	EP-15

Cả 21/21 lớp được phủ. Mỗi lớp không hợp lệ có **đúng 1 TC riêng**.

3.5 Cách thực thi

- **API:** `POST /api/apply-coupon` với `{code, total_amount, user_id}` đúng như API spec và đúng như UI gửi. Đối với C4, có gửi thêm header `Authorization` khi "đã đăng nhập". Với EP-11, không có token và không có `user_id`.
- **UI:** đăng nhập → mở trang sản phẩm test → **Thêm vào giỏ hàng** → **Giỏ hàng** → **Tiến hành thanh toán** → nhập mã → **Áp dụng**. Đọc thông báo, "Tiết kiệm" và "Thành tiền", rồi chụp màn hình.
- **Thứ tự chạy:** chạy EP-01 và EP-02 (TC hợp lệ) **trước**. Nếu TC hợp lệ đã Fail thì phải xem lại kết quả Pass của các TC không hợp lệ, đề phòng lỗi che lỗi (bài học FR-01 §5.2).

Phụ lục 11 — `features/FR-09_Coupon/04_bva_test_cases.md`

FR-09 Mã giảm giá (Coupon): Bước 4, Phân tích giá trị biên (BVA)

> Kỹ thuật: Boundary Value Analysis (slide Bài 4, phần BVA). Đầu vào: các điều kiện có thứ tự C2, C3, C5 ở Bước 1 và các lớp EC7–EC11, EC15–EC16 ở Bước 2.

4.1 Xác định các miền có thứ tự

BVA chỉ áp dụng được cho biến có **miền giá trị có thứ tự**. Xét 7 điều kiện của FR-09:

Điều kiện	Có thứ tự?	Dùng BVA?
C1 mã tồn tại	Không (tập chuỗi)	Không, đã phủ bằng EP
C2 `hôm nay < expired_at`	**Có** (ngày)	**Có**
C3 `total >= min_order_amount`	**Có** (số tiền)	**Có**. Đây là nơi spec nhấn mạnh **">= (lớn hơn hoặc bằng)"**
C4 đăng nhập	Không (boolean)	Không
C5 `used < max_uses_per_user`	**Có** (số nguyên)	**Có**
C6 loại coupon	Không (tập)	Không. Nhưng công thức đầu ra được kiểm tra lại tại mọi điểm biên hợp lệ
C7 tổng do hệ thống tính	Không (boolean)	Không

4.2 Biên của từng biến

Biến	Mô tả	Miền hợp lệ	LB	UB	Ghi chú
V1	`total` với `SAVE10` (percent 10%, min 300.000)	`[300.000..∞)`	300.000	–	Đơn vị nhỏ nhất là 1 ₫, nên LB±1 = ±1 ₫
V2	`total` với `BIGBUY` (fixed 50.000, min 500.000)	`[500.000..∞)`	500.000	–	Cùng điều kiện C3 nhưng khác ngưỡng và khác công thức
V3	`d = expired_at − hôm nay` (ngày)	`[1..∞)` theo A2	1 (ngày mai)	–	Coupon biên được tạo qua API Admin
V4	`used` của `VIP100` (max 2)	`[0..1]`	0	1	Biên hai phía, nhưng LB−1 = −1 không thể xảy ra

Tại sao test C3 với cả hai mã V1, V2? Nếu hệ thống so sánh sai (`>` thay vì `>=`) hoặc gắn cứng ngưỡng của một mã, chỉ test một mã có thể không phát hiện. Ngoài ra, mỗi mã cho phép kiểm tra công thức đầu ra (percent/fixed) **ngay tại biên**.

Giá trị danh nghĩa (nominal): `total = 1.000.000`, mã `SAVE10` (hết hạn 2099-12-31), `used = 0`, đã đăng nhập.

4.3 Chọn biến thể BVA và tính số TC

- Slide nêu 4 biến thể: **Standard** (4n+1), **Robustness** (6n+1), **Worst-case** (5^n), **Robust worst-case** (7^n).

- V1, V2, V3 **chỉ có biên dưới** (giống FR-01), nên Robustness được điều chỉnh thành **(LB−1, LB, LB+1) cho mỗi biến**.
- V4 có hai biên nhưng miền chỉ có 2 phần tử `{0, 1}`. Các điểm của Robustness trùng nhau: LB = UB−1 = 0, LB+1 = UB = 1, UB+1 = 2. LB−1 = −1 không tạo được. Còn **3 điểm phân biệt**.
- **Chọn Robustness**, vì lỗi cần tìm nằm đúng ở phía không hợp lệ ngay sát biên. Ví dụ spec nhấn mạnh `>=` cho C3.
- **Loại Worst-case**, vì các điều kiện độc lập (giả định lỗi đơn). Hơn nữa, tổ hợp ngày hết hạn × số lần dùng × tổng tiền đòi hỏi tạo rất nhiều coupon và user.

Tổng: 1 (nominal) + 3 (V1) + 3 (V2) + 3 (V3) + 3 (V4) = 13 TC.

4.4 Bảng ca kiểm thử giá trị biên

Mỗi TC dùng **một user mới**. Giỏ hàng chứa đúng 1 sản phẩm test có giá bằng `total` cần kiểm tra.

TC	Biến	Điểm	Mã	`total`	`expired_at`	`used`	Output mong đợi
BVA-01	–	nominal	`SAVE10`	1.000.000	2099-12-31	0	O1: giảm 100.000, còn 900.000
BVA-02	V1	LB−1	`SAVE10`	**299.999**	2099-12-31	0	**O2**: chưa đủ ngưỡng
BVA-03	V1	**LB**	`SAVE10`	**300.000**	2099-12-31	0	**O1**: giảm 30.000, còn 270.000
BVA-04	V1	LB+1	`SAVE10`	**300.001**	2099-12-31	0	O1: giảm 30.000 (làm tròn xuống, A3), còn 270.001
BVA-05	V2	LB−1	`BIGBUY`	**499.999**	2099-12-31	0	**O2**: chưa đủ ngưỡng
BVA-06	V2	**LB**	`BIGBUY`	**500.000**	2099-12-31	0	**O1**: giảm 50.000, còn 450.000
BVA-07	V2	LB+1	`BIGBUY`	**500.001**	2099-12-31	0	O1: giảm 50.000, còn 450.001
BVA-08	V3	LB−1 (d = 0)	`EXP0D`	1.000.000	**hôm nay**	0	**O2**: hết hạn
BVA-09	V3	**LB** (d = 1)	`EXP1D`	1.000.000	**ngày mai**	0	**O1**: giảm 100.000, còn 900.000
BVA-10	V3	LB+1 (d = 2)	`EXP2D`	1.000.000	**ngày kia**	0	O1: giảm 100.000, còn 900.000
BVA-11	V4	LB (= UB−1)	`VIP100`	1.000.000	2099-12-31	**0**	O1: giảm 100.000, còn 900.000
BVA-12	V4	**UB** (= LB+1)	`VIP100`	1.000.000	2099-12-31	**1**	**O1**: giảm 100.000, còn 900.000
BVA-13	V4	UB+1	`VIP100`	1.000.000	2099-12-31	**2**	**O2**: đã dùng hết lượt

`EXP0D`, `EXP1D`, `EXP2D` có cùng thuộc tính với `SAVE10` (percent 10%, min 300.000, 1 lần/người), chỉ khác `expired_at`. Nhờ vậy, khác biệt về kết quả chỉ có thể đến từ ngày hết hạn.

4.5 Ghi chú

- BVA-01 trùng giá trị với EP-01 nhưng vẫn chạy lại với user mới để làm điểm đối chứng cho bảng BVA.
- BVA-08 trùng lớp với EP-09 (EC9). Đây là điểm vừa là đại diện lớp, vừa là biên LB−1.

- Ngoài phạm vi BVA nhưng ghi nhận rủi ro: spec không nói gì về trường hợp `discount_amount > total` (coupon `fixed` lớn hơn tổng đơn). Với dữ liệu seed, ngưỡng tối thiểu luôn lớn hơn mức giảm, nên trường hợp này không xảy ra.

Phụ lục 12 — `features/FR-09_Coupon/05_test_execution.md`

FR-09 Mã giảm giá (Coupon): Bước 5, Thực thi kiểm thử

5.1 Môi trường

Mục	Giá trị
Thời điểm chạy	2026-10-13 14:17 (GMT+7), tức "hôm nay" = 2026-10-13. Dữ liệu thô: `results_fr09.json`
SUT	`eshop-sut` commit `85af3ba`. Backend `:3000`, Web `:5173`
Trạng thái DB	Khởi động lại backend ngay trước khi chạy để seed lại DB (4 coupon mẫu, 0 lượt dùng, 0 đơn hàng)
Trình duyệt	Chromium 131 (headless) qua Playwright 1.49.1
Script	`scripts/fr09_coupon.js`. Chạy lại bằng `cd scripts && node fr09_coupon.js`
Cách tách dữ liệu	Mỗi TC, mỗi kênh dùng **một user mới**: `vinh.api.f09.<tc>@gmail.com`, `vinh.ui.f09.<tc>@gmail.com`

Dữ liệu chuẩn bị (script tự tạo trước khi chạy, xem Bước 2 §2.3):

Dữ liệu	Giá trị thực tế
8 sản phẩm test `TEST-F09 <giá>` (danh mục Phụ kiện)	giá 200.000 / 299.999 / 300.000 / 300.001 / 499.999 / 500.000 / 500.001 / 1.000.000, id 6–13
Coupon biên (percent 10%, min 300.000, 1 lần/người)	`EXP0D` hết hạn 2026-10-13, `EXP1D` 2026-10-14, `EXP2D` 2026-10-15
Coupon bị vô hiệu hóa	`OFF10` (2099-12-31), sau đó `UPDATE coupons SET is_active = 0` trực tiếp trong SQLite (giả định A6)
Lượt dùng có sẵn (`used`)	EP-13 UI: **thanh toán thật** có áp SAVE10 một lần. EP-13/14 API, BVA-12/13: gọi `POST /api/coupon-usage`, đúng lời gọi UI thực hiện sau thanh toán

Tiêu chí Pass/Fail

- TC mong đợi **O1**: Pass khi hệ thống **chấp nhận** mã **và** `discount_amount`, `final_amount` đúng công thức R7/R8. Trên UI, đọc các dòng "Tiết kiệm" và "Thành tiền".
- TC mong đợi **O2**: Pass khi hệ thống **từ chối** mã. API trả 4xx; UI hiện thông báo lỗi hoặc không cho bấm **Áp dụng**.
- Một TC Pass khi **mọi kênh** được chạy đều Pass.

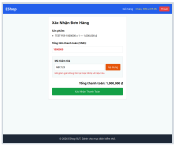
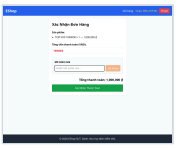
5.2 Kiểm tra lỗi che lỗi (masking) trước khi đọc kết quả

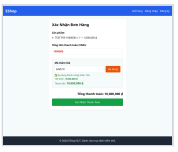
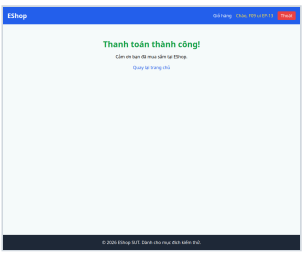
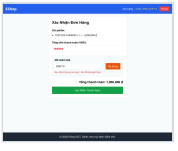
Bài học từ FR-01: chạy TC hợp lệ trước. Kết quả của EP-01 (SAVE10) là **mã được chấp nhận nhưng số tiền sai**: giảm **−9.000.000** ₫, thành tiền **10.000.000** ₫ cho giỏ 1.000.000 ₫. EP-02 (BIGBUY) Pass hoàn toàn.

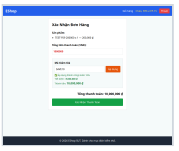
Kết luận: **không có masking** đối với quyết định chấp nhận/từ chối. Bộ giá trị nền (SAVE10, 1.000.000, đã đăng nhập, `used = 0`) vẫn được chấp nhận, nên khi một TC không hợp lệ bị từ chối, nguyên nhân chính là lớp không hợp lệ đang test. Tuy nhiên, mọi TC hợp lệ dùng mã `percent` sẽ Fail về **số tiền**. Vì vậy, các bảng dưới tách riêng hai cột **Quyết định** (chấp nhận/từ chối có đúng không) và **Số tiền**. Nhờ đó vẫn đánh giá được đúng điểm biên, ngay cả khi công thức sai.

5.3 Kết quả: Phân hoạch tương đương (15 TC)

Ký hiệu: "−a → b" nghĩa là giảm a, thành tiền b. ✅ đúng, ❌ sai so với mong đợi.

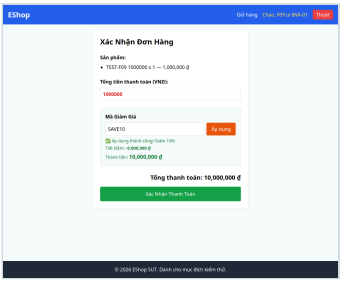
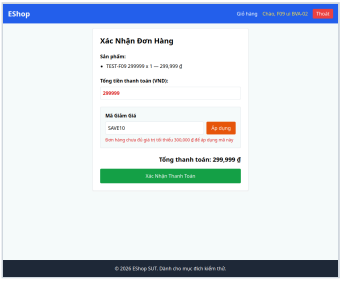
TC	Mã	Giỏ	Mong đợi	API: thực tế	API	UI: thực tế	UI	KQ
EP-01	`SAVE10`	1.000.000	O1: −100.000 → 900.000	200, **−(−9.000.000) → 10.000.000**	❌	Thành công, −(−9.000.000) → 10.000.000	❌	❌ ảnh  ảnh
EP-02	`BIGBUY`	1.000.000	O1: −50.000 → 950.000	200, −50.000 → 950.000	✅	Thành công, −50.000 → 950.000	✅	✅ ảnh  ảnh
EP-03	`save10`	1.000.000	O1: −100.000 → 900.000	**404** "Mã giảm giá không tồn tại..."	❌	Thành công (UI tự chuyển chữ hoa), nhưng −(−9.000.000) → 10.000.000	❌	❌ ảnh  ảnh
EP-04	`" VIP100 "`	1.000.000	O1: −100.000 → 900.000	**404** "Mã giảm giá không tồn tại..."	❌	Thành công (UI tự `trim`), −100.000 → 900.000	✅	❌ ảnh  ảnh
EP-05	`ABC123`	1.000.000	O2	404 "Mã giảm giá không tồn tại hoặc đã bị vô hiệu hóa"	✅	Thông báo như API	✅	✅ ảnh  ảnh
EP-06	`""`	1.000.000	O2	400 "Vui lòng nhập mã giảm giá"	✅	Nút **Áp dụng** bị vô hiệu hóa	✅	✅ ảnh  ảnh

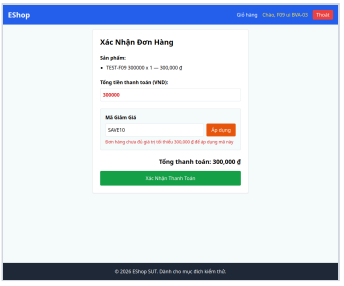
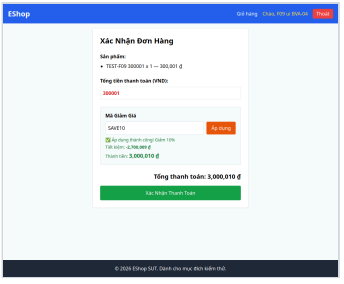
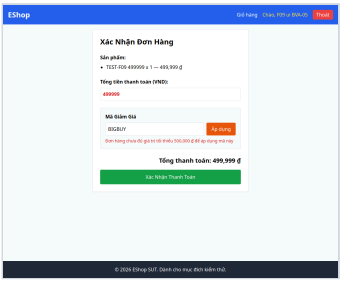
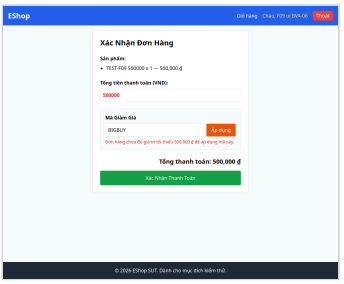
TC	Mã	Giỏ	Mong đợi	API: thực tế	API	UI: thực tế	UI	KQ
EP-07	`OFF10`	1.000.000	O2	404 "...hoặc đã bị vô hiệu hóa"	✅	Thông báo như API	✅	✅ ảnh  ảnh
EP-08	`EXPIRED`	1.000.000	O2	400 "Mã giảm giá đã hết hạn"	✅	Thông báo như API	✅	✅ ảnh  ảnh
EP-09	`EXP0D`	1.000.000	O2	400 "Mã giảm giá đã hết hạn"	✅	Thông báo như API	✅	✅ ảnh  ảnh
EP-10	`SAVE10`	200.000	O2	400 "Đơn hàng chưa đủ giá trị tối thiểu 300,000 ₫..."	✅	Thông báo như API	✅	✅ ảnh  ảnh
EP-11	`SAVE10`	1.000.000	O2: yêu cầu đăng nhập	**200**, áp dụng thành công khi **không có token,** `user_id = null`	❌	Trang Giỏ hàng chặn (alert "Bạn cần đăng nhập để thanh toán!"), **nhưng** mở thẳng `/checkout` vẫn hiển thị và **áp mã thành công**	❌	❌ ảnh  ảnh
EP-12	`SAVE10`	1.000.000	O2: 401/403	**200**, áp dụng thành công với `Authorization: Bearer abc.def.ghi`	❌	không áp dụng	–	❌
EP-13	`SAVE10`	1.000.000	O2: hết lượt	400 "Bạn đã sử dụng mã này 1 lần (đã đạt giới hạn)"	✅	Lần 1 thanh toán thành công (ảnh lần 1  ảnh lần 1); lần 2 bị từ chối, cùng thông báo	✅	✅ ảnh  ảnh

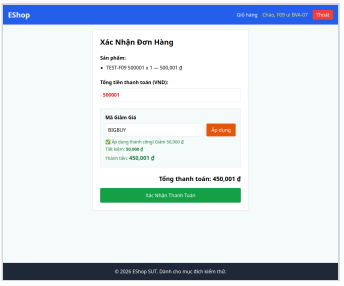
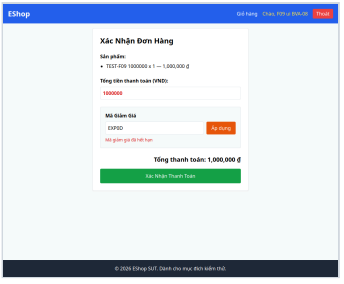
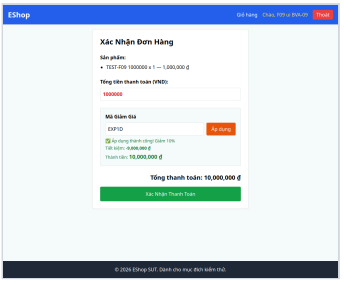
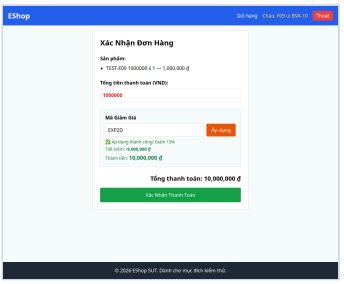
TC	Mã	Giỏ	Mong đợi	API: thực tế	API	UI: thực tế	UI	KQ
EP-14	`SAVE10`	1.000.000	O2: hết lượt	**200**, áp dụng thành công khi body **không có** `user_id` (token hợp lệ của user đã dùng hết lượt)	❌	không áp dụng	–	❌
EP-15	`SAVE10`	200.000 → **sửa 1.000.000**	O2	không áp dụng	–	Ô tổng tiền **sửa được**; mã được **chấp nhận** dù giỏ thật chỉ 200.000	❌	❌ ảnh  ảnh

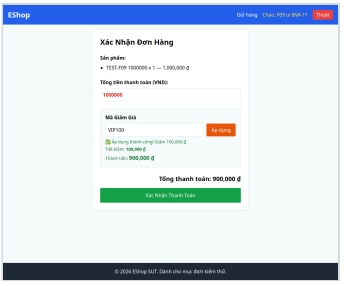
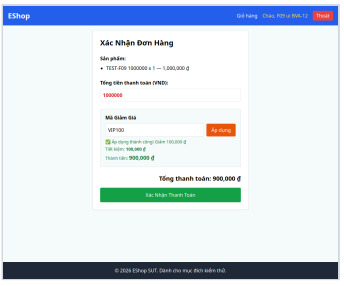
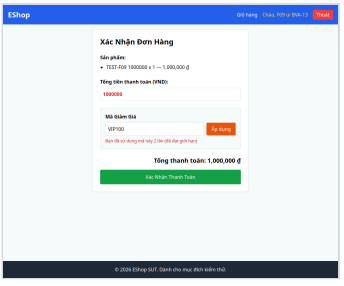
Hậu kiểm EP-13: sau lần thanh toán thứ nhất, `GET /api/admin/orders` cho thấy đơn #1 của user `F09 ui EP-13` có `total_amount = 10.000.000` cho giỏ 1.000.000 ₫. **Lỗi công thức không chỉ hiển thị sai mà còn ghi vào đơn hàng thật**, nên khách bị tính gấp 10 lần.

5.4 Kết quả: Phân tích giá trị biên (13 TC)

TC	Biến, điểm	Giá trị	Mong đợi	Quyết định (API / UI)	Số tiền (API = UI)	KQ
BVA-01	nominal	SAVE10, 1.000.000	O1: −100.000 → 900.000	chấp nhận ✅ / ✅	−(−9.000.000) → 10.000.000 ❌	❌ ảnh  ảnh
BVA-02	V1 LB−1	SAVE10, **299.999**	O2	từ chối ✅ / ✅	–	✅ ảnh  ảnh

TC	Biến, điểm	Giá trị	Mong đợi	Quyết định (API / UI)	Số tiền (API = UI)	KQ
BVA-03	V1 **LB**	SAVE10, **300.000**	O1: −30.000 → 270.000	**từ chối** ❌ / ❌ "chưa đủ giá trị tối thiểu 300,000 ₫"	–	❌ ảnh  ảnh
BVA-04	V1 LB+1	SAVE10, **300.001**	O1: −30.000 → 270.001	chấp nhận ✅ / ✅	−(−2.700.009) → 3.000.010 ❌	❌ ảnh  ảnh
BVA-05	V2 LB−1	BIGBUY, **499.999**	O2	từ chối ✅ / ✅	–	✅ ảnh  ảnh
BVA-06	V2 **LB**	BIGBUY, **500.000**	O1: −50.000 → 450.000	**từ chối** ❌ / ❌ "chưa đủ giá trị tối thiểu 500,000 ₫"	–	❌ ảnh  ảnh

TC	Biến, điểm	Giá trị	Mong đợi	Quyết định (API / UI)	Số tiền (API = UI)	KQ
BVA-07	V2 LB+1	BIGBUY, **500.001**	O1: −50.000 → 450.001	chấp nhận ✅ / ✅	−50.000 → 450.001 ✅	✅ ảnh  ảnh
BVA-08	V3 LB−1	`EXP0D` (hôm nay)	O2	từ chối ✅ / ✅ "đã hết hạn"	–	✅ ảnh  ảnh
BVA-09	V3 **LB**	`EXP1D` (ngày mai)	O1: −100.000 → 900.000	chấp nhận ✅ / ✅	−(−9.000.000) → 10.000.000 ❌	❌ ảnh  ảnh
BVA-10	V3 LB+1	`EXP2D` (ngày kia)	O1: −100.000 → 900.000	chấp nhận ✅ / ✅	−(−9.000.000) → 10.000.000 ❌	❌ ảnh  ảnh

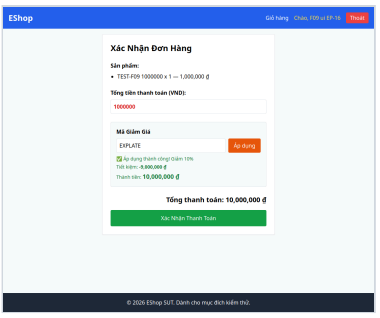
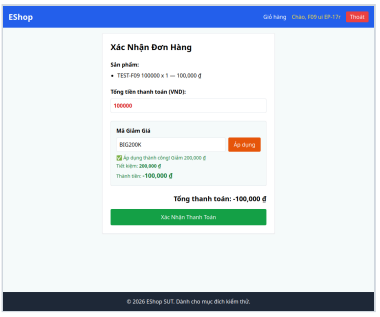
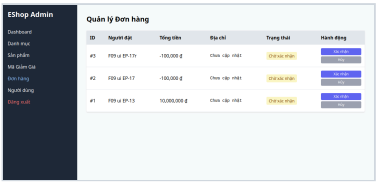
TC	Biến, điểm	Giá trị	Mong đợi	Quyết định (API / UI)	Số tiền (API = UI)	KQ
BVA-11	V4 LB	VIP100, `used = 0`	O1: −100.000 → 900.000	chấp nhận ✅ / ✅	−100.000 → 900.000 ✅	✅ ảnh  ảnh
BVA-12	V4 **UB**	VIP100, `used = 1`	O1: −100.000 → 900.000	chấp nhận ✅ / ✅	−100.000 → 900.000 ✅	✅ ảnh  ảnh
BVA-13	V4 UB+1	VIP100, `used = 2`	O2	từ chối ✅ / ✅ "đã sử dụng mã này 2 lần"	–	✅ ảnh  ảnh

Phân tích theo biến:

- **V1, V2 (ngưỡng tổng tiền):** cả hai mã đều từ chối **đúng tại LB**, nhưng chấp nhận tại LB+1. Như vậy hệ thống đang dùng phép so sánh `total > min` thay vì `total >= min`. Đây là lỗi off-by-one điển hình mà chỉ BVA phát hiện được. EP-10 (200.000) và EP-01 (1.000.000) đều Pass về quyết định, không lộ lỗi này.
- **V3 (ngày hết hạn):** quyết định đúng tại cả 3 điểm biên. BVA-09 và BVA-10 Fail **chỉ vì công thức percent**, không phải vì biên ngày.
- **V4 (số lần dùng):** đúng tại cả 3 điểm khi client gửi đúng `user_id` (nhưng xem EP-14).
- **Công thức `percent`:** sai ở mọi điểm. Từ các cặp (total, discount) đo được (1.000.000 → −9.000.000; 300.001 → −2.700.009), suy ra hệ thống tính `discount = total × (1 − 10)` thay vì `total × 10 / 100`.

5.4b TC bổ sung sau AI gap analysis (chạy 2026-10-13 14:22, script `scripts/fr09_supplementary.js`)

Hai lớp mới được thêm ở Bước 7. Dữ liệu thô: `results_fr09_supplementary.json`.

TC	Lớp mới	Dữ liệu	Mong đợi	Thực tế (API = UI)	KQ
EP-16	EC22: `expired_at` là hôm nay **kèm giờ** muộn hơn hiện tại	Coupon `EXPLATE` (như SAVE10), `expired_at = 2026-10-13 23:59:00`, giỏ 1.000.000	O2: hết hạn (A2: so sánh theo ngày)	HTTP 200, **áp dụng thành công**. Trong khi `EXP0D` (`2026-10-13` , không có giờ) bị từ chối ở EP-09	❌ ảnh  ảnh
EP-17	EC23: mức giảm `fixed` **lớn hơn** tổng đơn	Coupon `BIG200K` (fixed 200.000, min 0), giỏ 100.000	O1 với thành tiền ≥ 0	Thành tiền **−100.000 ₫**; bấm thanh toán thì tạo **đơn #3 có `total_amount = -100000`**	❌ ảnh  ảnh , đơn hàng  đơn hàng

Ghi chú: EP-17 được chạy lại với user mới (hậu tố `r`). Ở lần chạy đầu, email của TC trùng với lần thử trước. Vì FR-01 cho phép email trùng (BUG-FR01-03), lệnh đăng nhập lấy về tài khoản cũ đã dùng hết lượt mã.

5.5 Tổng hợp

Nhóm	Số TC	Pass	Fail	Không thực thi
EP	15	8 (EP-02, 05, 06, 07, 08, 09, 10, 13)	7 (EP-01, 03, 04, 11, 12, 14, 15)	0
BVA	13	7 (BVA-02, 05, 07, 08, 11, 12, 13)	6 (BVA-01, 03, 04, 06, 09, 10)	0
Bổ sung (gap)	2	0	2 (EP-16, EP-17)	0
Tổng	**30**	**15**	**15**	**0**

Theo kênh: API 27 lượt chạy (15 Pass, 12 Fail), UI 26 lượt chạy (16 Pass, 10 Fail) + 1 ảnh phụ (EP-13 lần 1). Tổng cộng 27 screenshot.

Các lỗi phát hiện (chi tiết ở Bước 6):

1. Công thức `percent` sai, khách bị tính gấp 10 lần: EP-01, EP-03, BVA-01, BVA-04, BVA-09, BVA-10.
2. Tổng tiền đúng bằng ngưỡng bị từ chối (`>` thay vì `>=`): BVA-03, BVA-06.
3. Không yêu cầu đăng nhập/JWT khi áp mã: EP-11, EP-12.

4. Né giới hạn số lần dùng bằng cách bỏ `user_id`: EP-14.
5. Tổng tiền trên Checkout sửa được, nên né được ngưỡng tối thiểu: EP-15.
6. API phân biệt hoa/thường và không bỏ khoảng trắng, không nhất quán với UI: EP-03, EP-04 (API).
7. Hết hạn được so theo thời điểm, không theo ngày: EP-16 (bổ sung).
8. Thành tiền âm khi mức giảm lớn hơn tổng đơn: EP-17 (bổ sung).

Phụ lục 13 — `features/FR-09_Coupon/06_bug_report.md`

FR-09 Mã giảm giá (Coupon): Bước 6, Báo cáo lỗi

Môi trường chung: EShop `85af3ba`, Backend `localhost:3000`, Web `localhost:5173`, Chromium 131, DB seed mặc định cộng dữ liệu chuẩn bị ở Bước 5 §5.1. Thời điểm phát hiện: 2026-10-13.

Bug ID	Tiêu đề	Severity	Priority	TC phát hiện	Issue
BUG-FR09-01	Coupon `percent` tính sai: số tiền giảm âm, khách bị tính gấp 10 lần	**Critical**	P1	EP-01, EP-03, BVA-01, BVA-04, BVA-09, BVA-10	#8
BUG-FR09-02	Tổng đơn **bằng đúng** `min_order_amount` bị từ chối (dùng `>` thay vì `>=`)	Major	P1	BVA-03, BVA-06	#9
BUG-FR09-03	Áp mã giảm giá không cần đăng nhập/JWT (API và trang `/checkout`)	**Critical**	P1	EP-11, EP-12	#10
BUG-FR09-04	Né giới hạn số lần dùng mã bằng cách bỏ `user_id` khỏi request	**Critical**	P1	EP-14	#11
BUG-FR09-05	Ô "Tổng tiền thanh toán" sửa được, nên áp được mã khi giỏ chưa đủ ngưỡng	**Critical**	P1	EP-15	#12
BUG-FR09-06	API phân biệt chữ hoa/thường và không bỏ khoảng trắng của mã, không nhất quán với UI	Minor	P3	EP-03, EP-04 (kênh API)	#13
BUG-FR09-07	Mã hết hạn "hôm nay" vẫn dùng được nếu `expired_at` có kèm giờ (so sánh theo thời điểm, không theo ngày)	Minor	P3	EP-16 (TC bổ sung sau gap analysis)	#14
BUG-FR09-08	Thành tiền âm và đơn hàng có tổng âm khi mức giảm `fixed` lớn hơn tổng đơn	Major	P2	EP-17 (TC bổ sung sau gap analysis)	#15

BUG-FR09-01: Coupon `percent` tính sai, số tiền giảm âm và khách bị tính gấp 10 lần

- **Tính năng & kỹ thuật:** FR-09, EP với lớp đầu ra EC18 (O1a `percent`); BVA tại mọi điểm hợp lệ của mã percent.
- **Severity:** Critical. Khách hàng bị **tính tiền gấp 10 lần** giá trị giỏ hàng, và số tiền sai được ghi vào đơn hàng thật.

Các bước tái hiện

1. Đăng nhập `http://localhost:5173` bằng một tài khoản chưa dùng SAVE10.
2. Thêm 1 sản phẩm giá 1.000.000 ₫ vào giỏ → **Giỏ hàng** → **Tiến hành thanh toán**.
3. Nhập mã `SAVE10` → **Áp dụng**.
4. Bấm **Xác Nhận Thanh Toán**, rồi đăng nhập Admin và mở tab **Đơn hàng**.

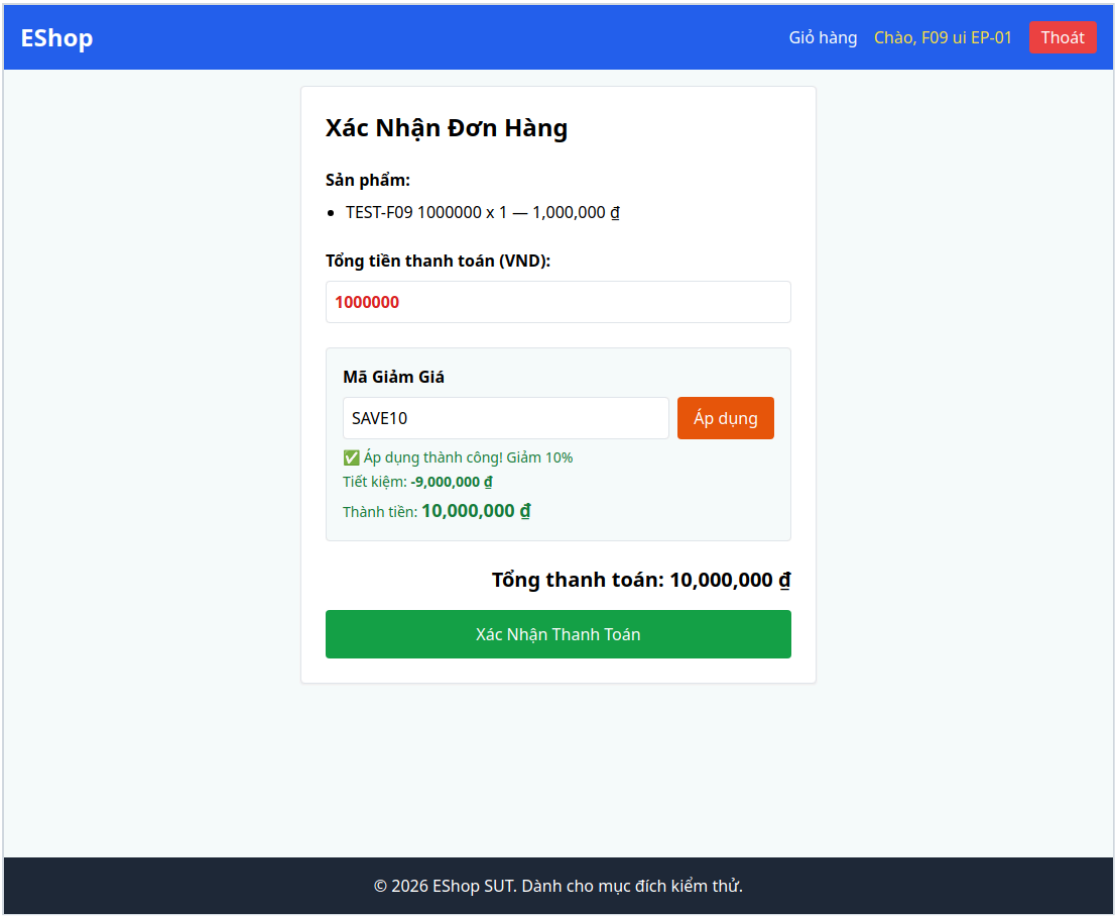
Kết quả mong đợi (SRS FR-09): `discount_amount = 1.000.000 × 10 / 100 = 100.000`, `final_amount = 900.000`. Đơn hàng có tổng 900.000 ₫.

Kết quả thực tế

- UI hiện "Tiết kiệm: **-9,000,000 ₫**", "Thành tiền: **10,000,000 ₫**". API trả `{"discount_amount": -9000000, "final_amount": 10000000}`.
- Đơn hàng #1 được lưu với tổng **10,000,000 ₫**.

- Từ các điểm đo, công thức thực tế là `total × (1 − discount_value)` : 300.001 → −2.700.009 → 3.000.010. Mã `fixed` (BIGBUY, VIP100) tính đúng.

Minh chứng: EP-01_ui.png



EP-01_ui.png

, BUG-FR09-01_api_percent_formula.png



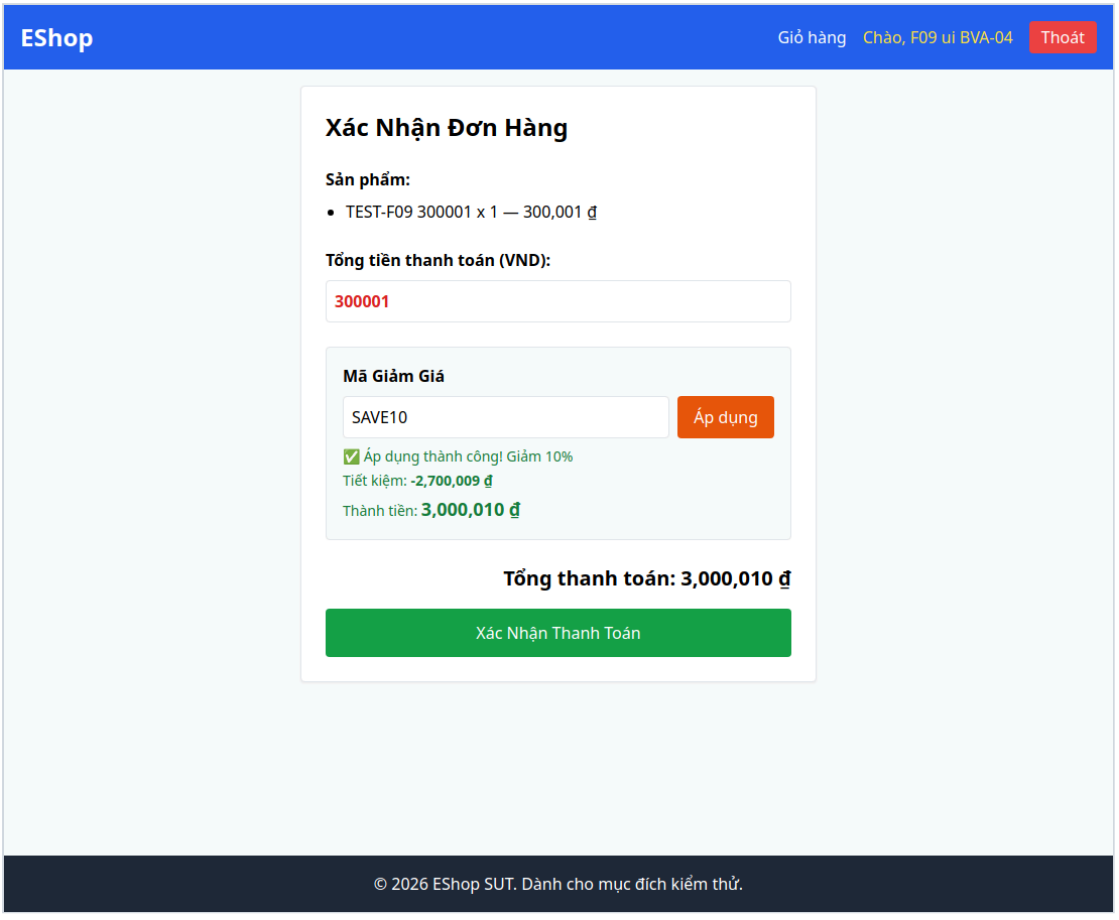
BUG-FR09-01_api_percent_formula.png

, BUG-FR09-01_admin_order_10x.png



BUG-FR09-01_admin_order_10x.png

, BVA-04_ui.png



BVA-04_ui.png

BUG-FR09-02: Tổng đơn bằng đúng `min_order_amount` bị từ chối (dùng `>` thay vì `>=`)

- **Tính năng & kỹ thuật:** FR-09 C3, **BVA** tại biên LB của V1 (SAVE10, min 300.000) và V2 (BIGBUY, min 500.000).

- **Severity:** Major. Spec nhấn mạnh **">= (lớn hơn hoặc bằng)"**. Khách có đơn đúng bằng ngưỡng (trường hợp phổ biến vì ngưỡng là số tròn) không dùng được mã.

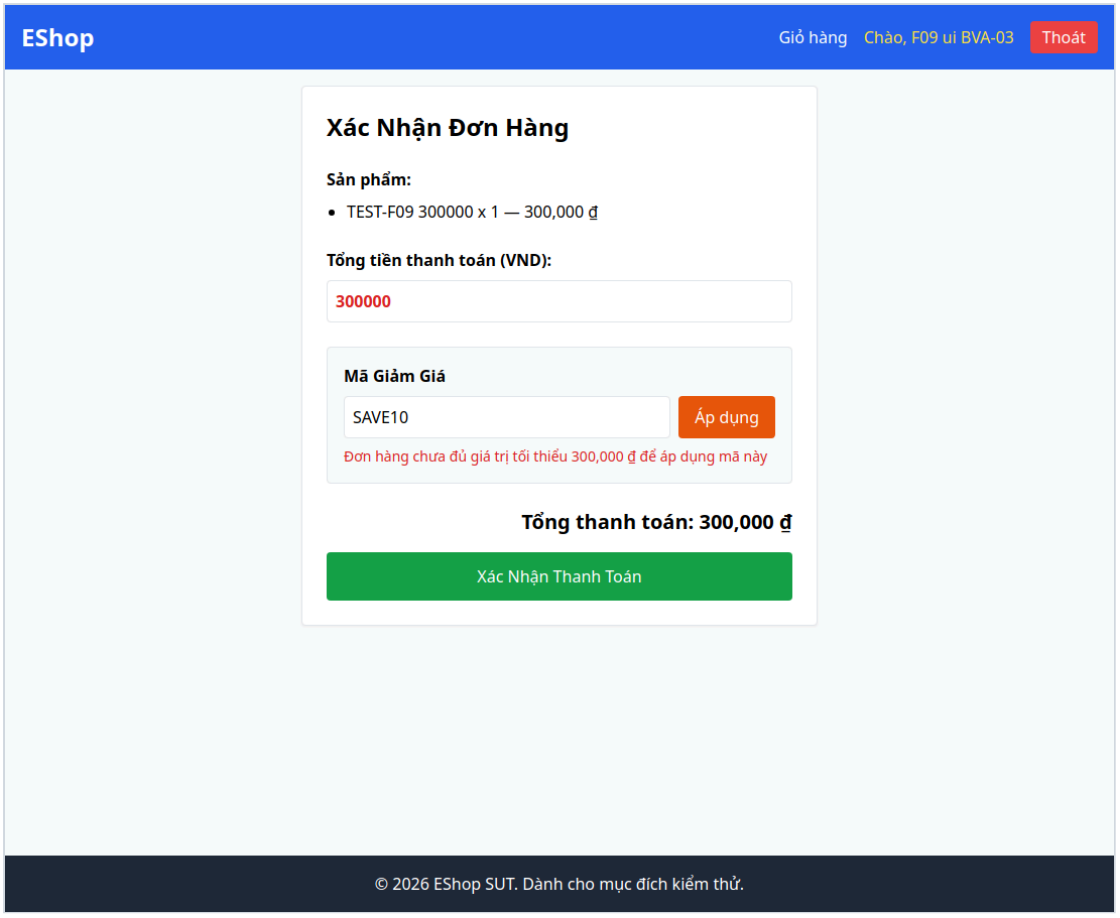
Các bước tái hiện

1. Đăng nhập, thêm 1 sản phẩm giá **300.000 ₫** vào giỏ, rồi vào trang thanh toán.
2. Nhập `SAVE10` → **Áp dụng**.
3. Làm lại với sản phẩm giá **500.000 ₫** và mã `BIGBUY`.

Kết quả mong đợi: Áp dụng thành công. SAVE10 giảm 30.000, còn 270.000. BIGBUY giảm 50.000, còn 450.000.

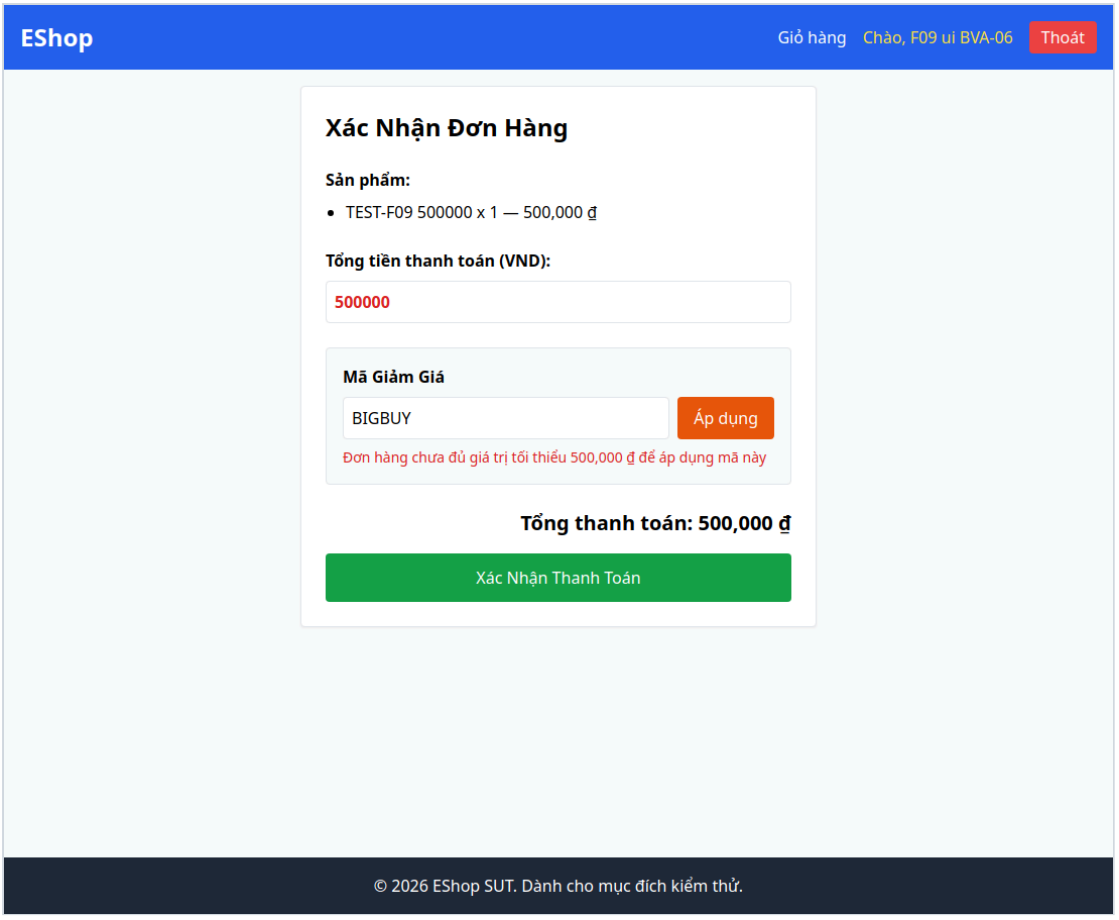
Kết quả thực tế: "*Đơn hàng chưa đủ giá trị tối thiểu 300,000 ₫ để áp dụng mã này*" (tương tự với 500,000 ₫). Thông báo tự mâu thuẫn, vì đơn đúng bằng 300.000 ₫. Tại LB+1 (300.001 / 500.001), mã được chấp nhận. Tại LB−1 (299.999 / 499.999), mã bị từ chối đúng.

Minh chứng: BVA-03_ui.png



BVA-03_ui.png

, BVA-06_ui.png



BVA-06_ui.png

, BUG-FR09-02_api_save10_equal_min.png



BUG-FR09-02_api_save10_equal_min.png

, BUG-FR09-02_api_bigbuy_equal_min.png



BUG-FR09-02_api_bigbuy_equal_min.png

BUG-FR09-03: Áp mã giảm giá không cần đăng nhập/JWT (API và trang `/checkout`)

- **Tính năng & kỹ thuật:** FR-09 C4, EP với các lớp EC13 (chưa đăng nhập) và EC14 (token không hợp lệ). Đối chiếu SEC-02.
- **Severity:** Critical (bảo mật). Điều kiện C4 hoàn toàn không được kiểm tra ở server.

Các bước tái hiện

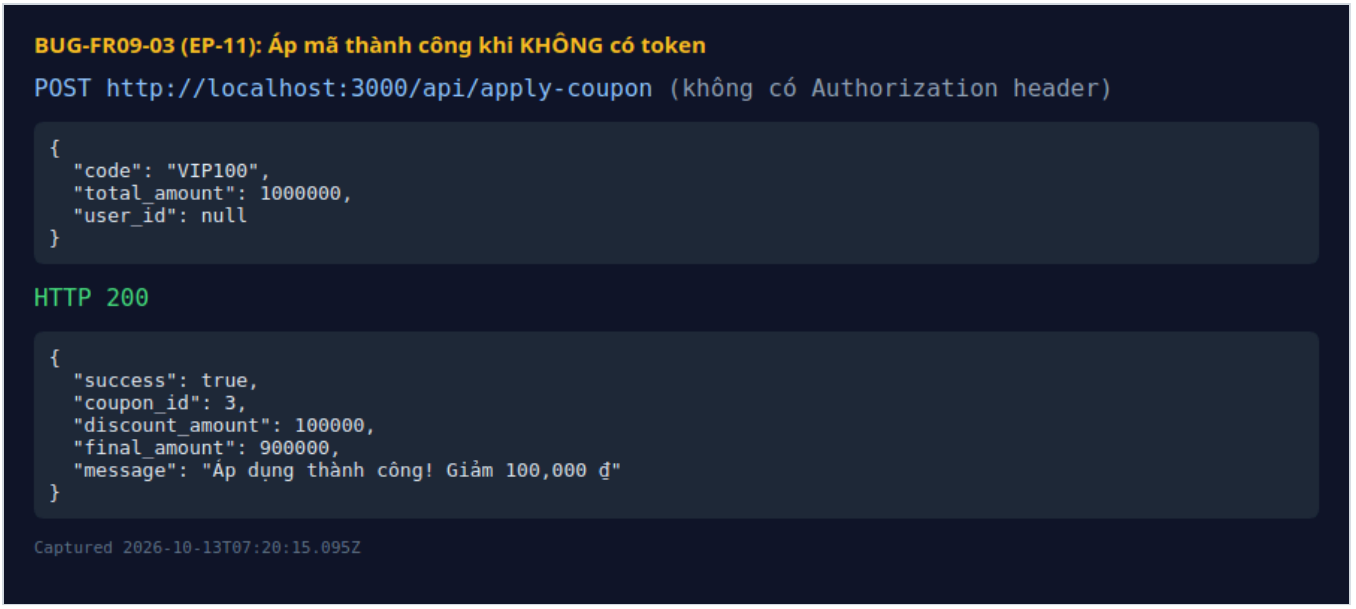
1. API: gửi `POST /api/apply-coupon` với body `{"code":"VIP100","total_amount":1000000,"user_id":null}` và **không có** header `Authorization`.
2. API: gửi lại request trên với header `Authorization: Bearer abc.def.ghi` (token giả).
3. UI: khi **chưa đăng nhập**, thêm sản phẩm vào giỏ, mở **Giỏ hàng**, bấm **Tiến hành thanh toán**. Thấy alert "Bạn cần đăng nhập để thanh toán!" và bị chuyển tới `/login`. Sau đó mở `/checkout` bằng điều hướng phía client (giỏ hàng vẫn còn), nhập `SAVE10` → **Áp dụng**.

Kết quả mong đợi: API trả 401/403. Trang `/checkout` chuyển hướng về đăng nhập, không cho áp mã.

Kết quả thực tế

- Bước 1 và 2: HTTP **200**, `success: true`, giảm 100.000 ₫.
- Bước 3: trang Giỏ hàng có chặn, nhưng **route `/checkout` không được bảo vệ**. Header vẫn hiện "Đăng nhập / Đăng ký", và mã được áp thành công.

Minh chứng: BUG-FR09-03_api_no_token.png



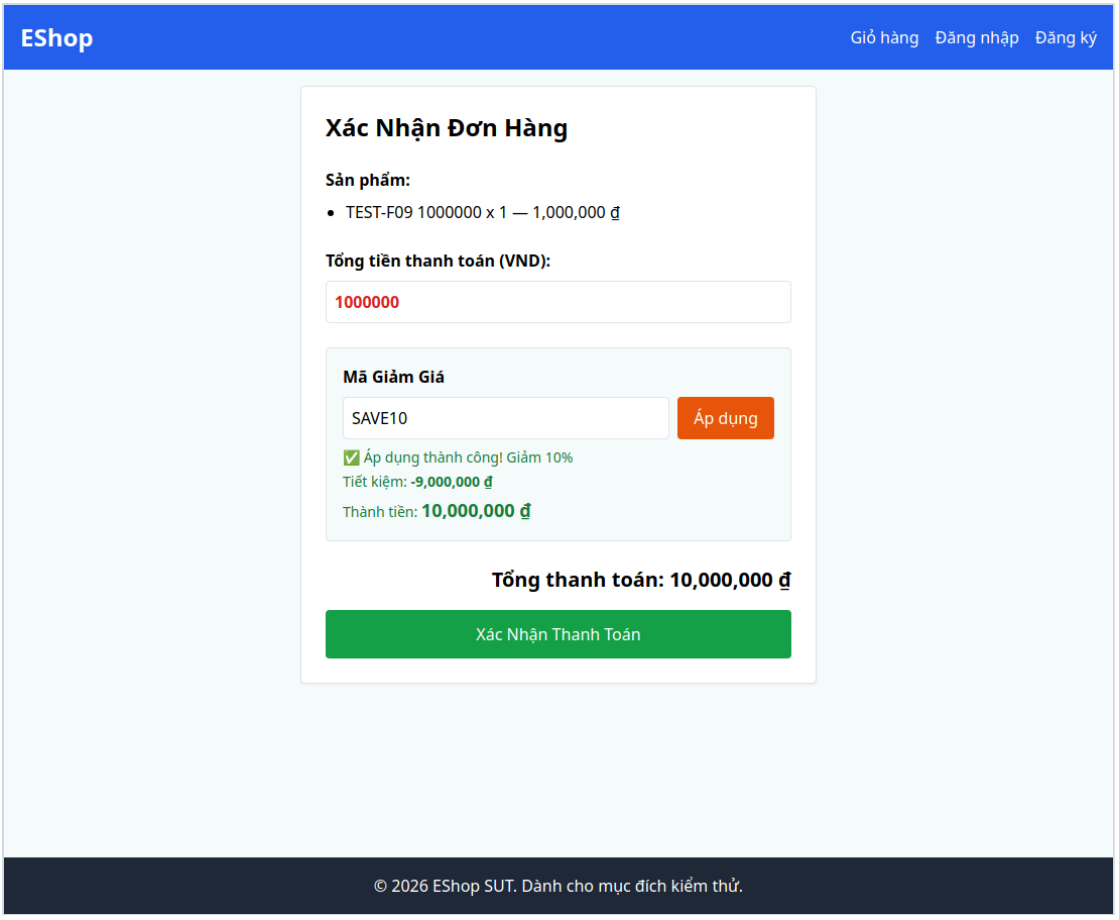
BUG-FR09-03_api_no_token.png

, BUG-FR09-03_api_fake_token.png



BUG-FR09-03_api_fake_token.png

, EP-11_ui.png



EP-11_ui.png

BUG-FR09-04: Né giới hạn số lần dùng mã bằng cách bỏ `user_id` khỏi request

- **Tính năng & kỹ thuật:** FR-09 C5, EP với lớp EC17 (giả định A5: user phải lấy từ JWT).
- **Severity:** Critical. Một user có thể dùng mã "1 lần/người" **không giới hạn**, gây thất thoát doanh thu.

Các bước tái hiện

1. Đăng nhập `test@eshop.com` và thanh toán một đơn có áp `SAVE10` (lượt dùng = 1/1). Có thể thay bằng `POST /api/coupon-usage {"coupon_id":1}` với token của user này, đây chính là lời gọi UI thực hiện sau khi thanh toán.
2. Gửi `POST /api/apply-coupon` với token của `test@eshop.com`, body `{"code":"SAVE10","total_amount":1000000,"user_id":2}`.
3. Gửi lại với **cùng token**, nhưng body **bỏ** `user_id`: `{"code":"SAVE10","total_amount":1000000}`.

Kết quả mong đợi: Cả bước 2 và 3 đều bị từ chối "đã sử dụng hết lượt", vì user được xác định từ token.

Kết quả thực tế: Bước 2 bị từ chối đúng (HTTP 400). Bước 3 trả **HTTP 200, áp dụng thành công**. Hệ thống đếm lượt dùng theo `user_id` do client gửi lên và **bỏ qua hẳn** việc kiểm tra C5 khi trường này vắng mặt.

Minh chứng: BUG-FR09-04_api_with_user_id.png



BUG-FR09-04_api_with_user_id.png

, BUG-FR09-04_api_without_user_id.png



BUG-FR09-04_api_without_user_id.png

BUG-FR09-05: Ô "Tổng tiền thanh toán" sửa được, nên áp được mã khi giỏ chưa đủ ngưỡng

- **Tính năng & kỹ thuật:** FR-09 C3 kết hợp FR-08, EP với lớp EC21 (tổng tiền bị client sửa).
- **Severity:** Critical. Người dùng tự quyết định tổng tiền dùng để xét ngưỡng (và cả số tiền thanh toán), nên điều kiện C3 vô nghĩa.

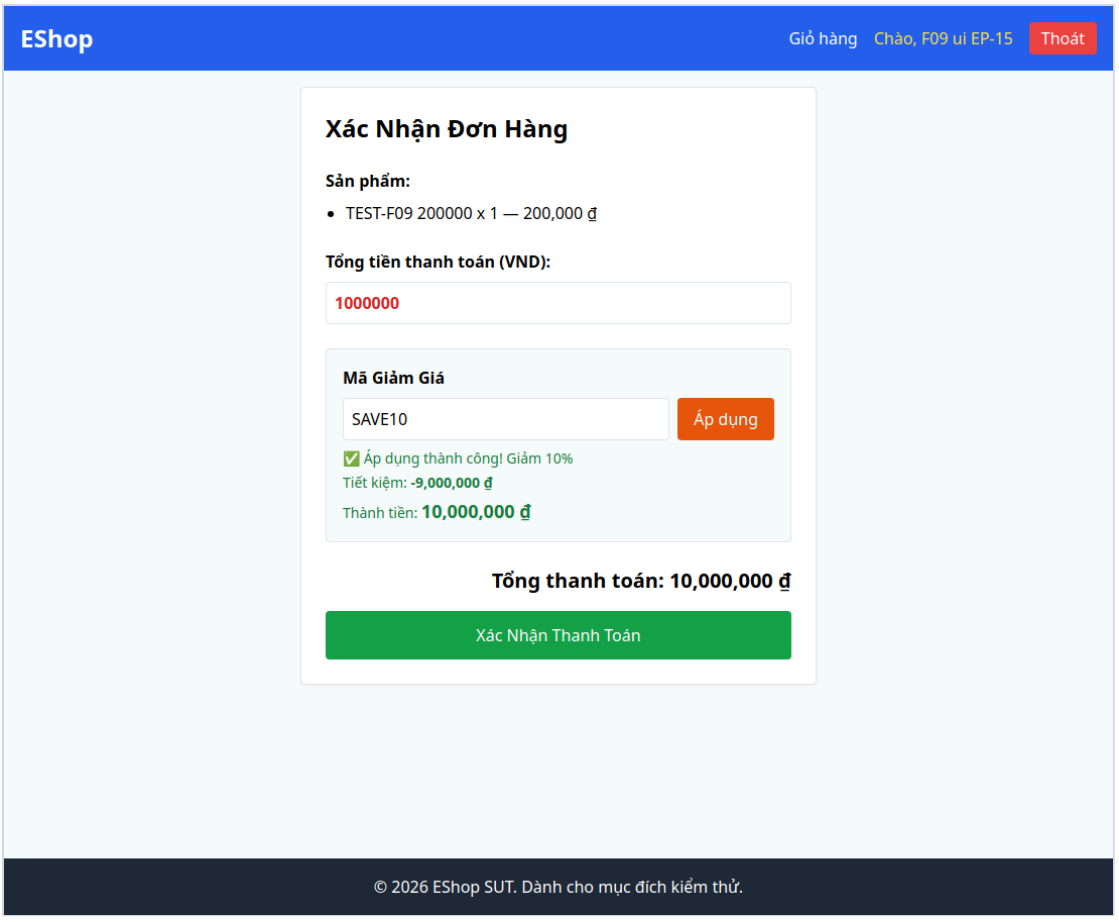
Các bước tái hiện

1. Đăng nhập, thêm 1 sản phẩm giá **200.000 ₫** (dưới ngưỡng 300.000 của SAVE10) vào giỏ, rồi vào trang thanh toán.
2. Ở ô **"Tổng tiền thanh toán (VND)"**, xóa `200000` và gõ `1000000`.
3. Nhập `SAVE10` → **Áp dụng**.

Kết quả mong đợi: Ô tổng tiền chỉ hiển thị, không cho sửa (FR-08). Nếu tổng bị sửa, mã vẫn phải bị từ chối vì giỏ thật chỉ có 200.000 ₫.

Kết quả thực tế: Ô cho sửa tự do. Mã được chấp nhận, "Thành tiền" hiển thị theo tổng đã sửa. Danh sách sản phẩm ngay phía trên vẫn ghi "TEST-F09 200000 x 1 — 200,000 ₫".

Minh chứng: EP-15_ui.png



EP-15_ui.png

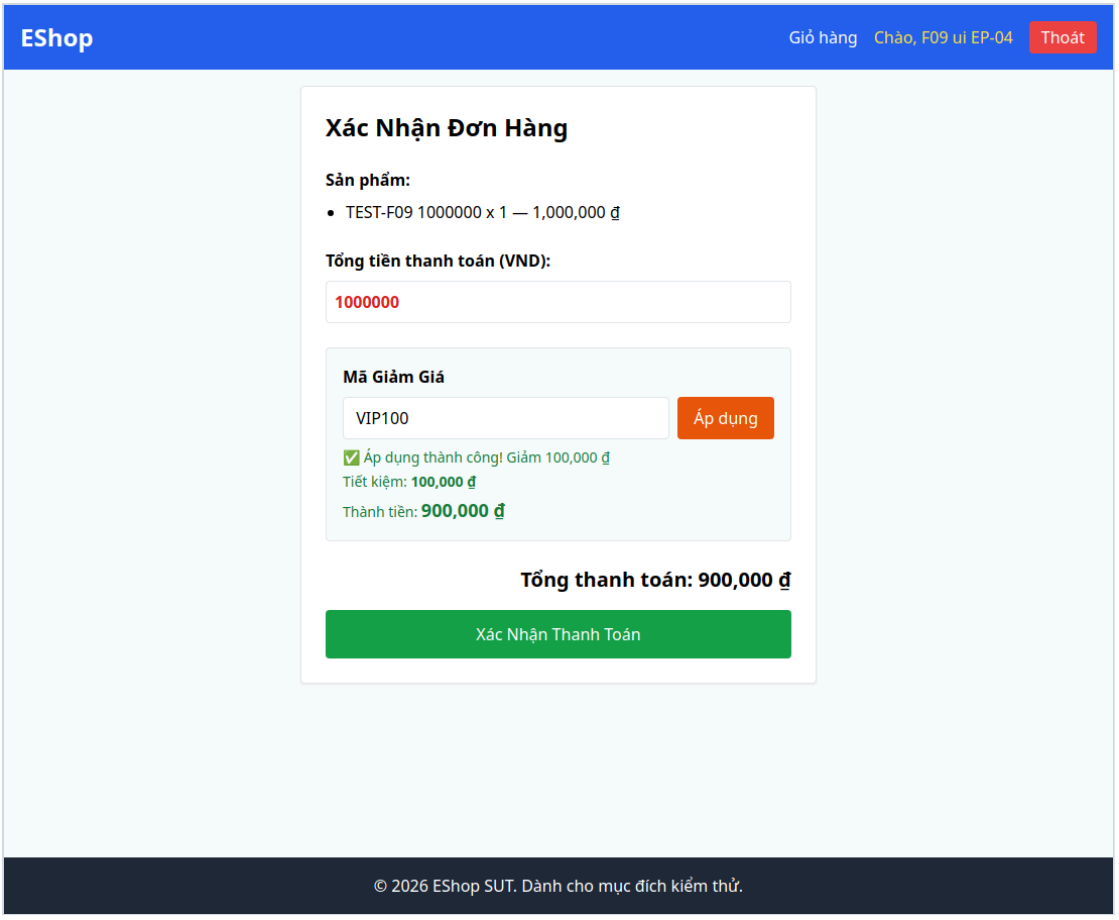
BUG-FR09-06: API phân biệt chữ hoa/thường và không bỏ khoảng trắng của mã, không nhất quán với UI

- **Tính năng & kỹ thuật:** FR-09 C1, EP với các lớp EC2, EC3 (giả định A1).
- **Severity:** Minor. Người dùng web không bị ảnh hưởng vì UI tự `trim()` và `toUpperCase()`. Nhưng các client khác (ví dụ ứng dụng mobile) gọi cùng API sẽ báo "không tồn tại" cho mã hợp lệ.

Các bước tái hiện: gửi `POST /api/apply-coupon` (có token) với `code` lần lượt là `"save10"` và `" VIP100 "`, `total_amount = 1000000`.

Kết quả mong đợi: Như với `SAVE10` / `VIP100`: áp dụng thành công.

Kết quả thực tế: HTTP **404** "*Mã giảm giá không tồn tại hoặc đã bị vô hiệu hóa*". Cùng dữ liệu nhập qua UI thì thành công (EP-04_ui.png



EP-04_ui.png

). Việc chuẩn hóa mã chỉ nằm ở phía client.

Minh chứng: BUG-FR09-06_api_lowercase.png



BUG-FR09-06_api_lowercase.png

, BUG-FR09-06_api_whitespace.png



BUG-FR09-06_api_whitespace.png

BUG-FR09-07: Mã hết hạn "hôm nay" vẫn dùng được nếu `expired_at` có kèm giờ

- **Tính năng & kỹ thuật:** FR-09 C2, EP với lớp bổ sung EC22 (xem 07_ai_gap_analysis.md), giả định A2
- **Severity:** Minor. Phụ thuộc vào cách hiểu "ngày hiện tại phải trước `expired_at`" (A2). Dù hiểu theo cách nào thì hành vi hiện tại vẫn **không nhất quán**: cùng hết hạn hôm nay, mã lưu `2026-10-13` bị từ chối, còn mã lưu `2026-10-13 23:59:00` lại được chấp nhận.

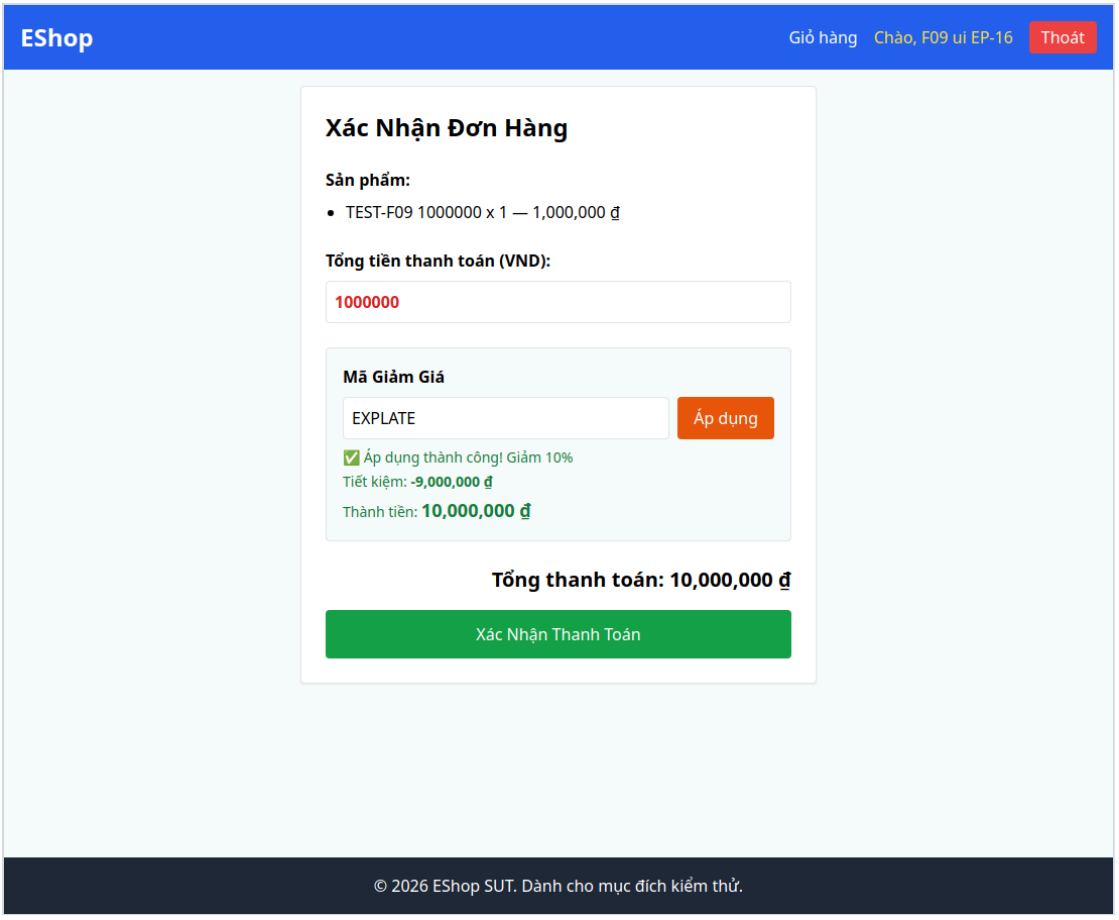
Các bước tái hiện

1. Admin tạo coupon: `POST /api/admin/coupons` với `{"code":"EXPLATE","type":"percent","discount_value":10,"min_order_amount":300000,"expired_at":"<hôm nay> 23:59:00","max_uses_per_user":1}`.
2. Đăng nhập user, giỏ 1.000.000 ₫, áp mã `EXPLATE` trước 23:59.
3. So sánh với mã `EXP0D` có `expired_at = "<hôm nay>"`.

Kết quả mong đợi: Cả hai mã đều bị từ chối "Mã giảm giá đã hết hạn", vì ngày hiện tại không trước ngày hết hạn.

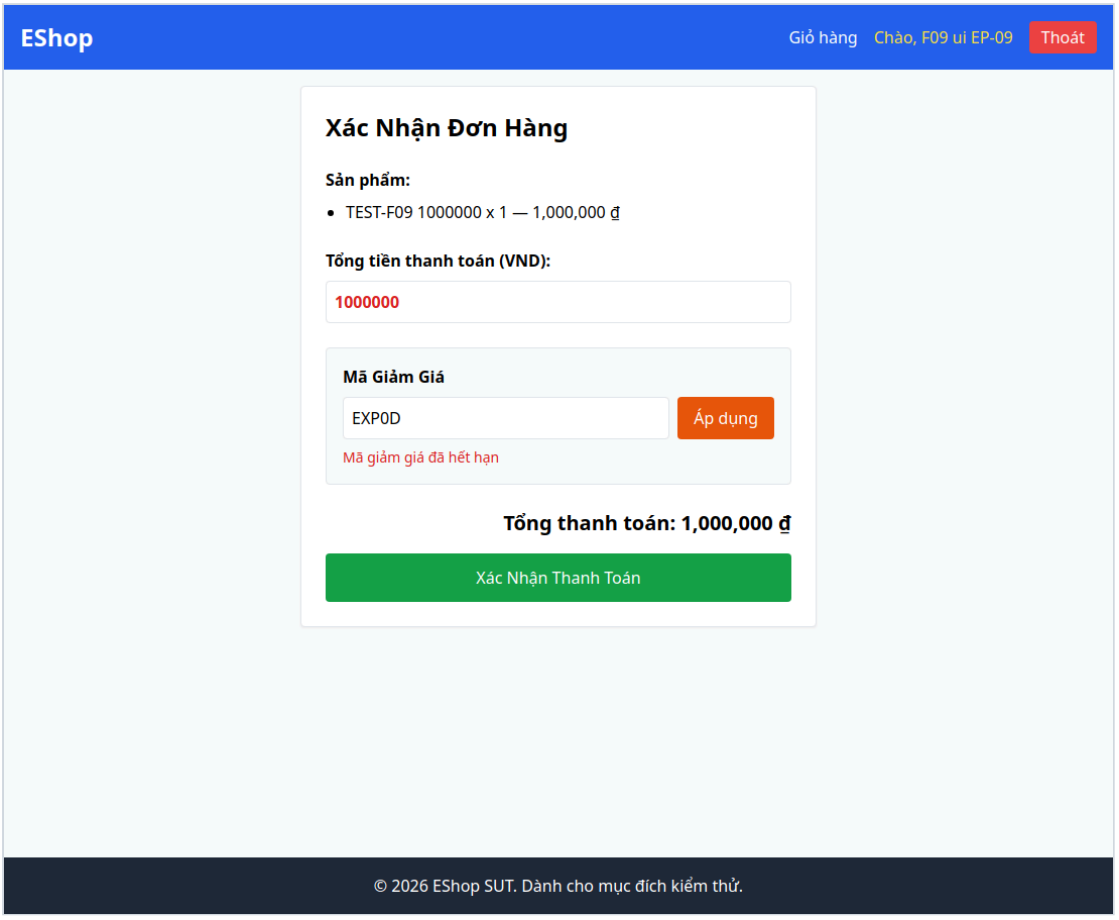
Kết quả thực tế: `EXPLATE` được áp dụng thành công, còn `EXP0D` bị từ chối. Hệ thống so sánh **thời điểm** hiện tại với `expired_at` thay vì so sánh **ngày**. Ngoài ra, chuỗi chỉ có ngày được hiểu là 00:00 **UTC** (07:00 giờ Việt Nam), nên kết quả của mã hết hạn hôm nay còn phụ thuộc giờ chạy test (rủi ro, chưa kiểm chứng trong khung 00:00–07:00).

Minh chứng: EP-16_ui.png



EP-16_ui.png

, EP-09_ui.png



EP-09_ui.png

BUG-FR09-08: Thành tiền âm và đơn hàng có tổng âm khi mức giảm `fixed` lớn hơn tổng đơn

- **Tính năng & kỹ thuật:** FR-09 công thức R8, EP với lớp đầu ra bổ sung EC23 (xem 07_ai_gap_analysis.md)
- **Severity:** Major. Hệ thống tạo đơn hàng với tổng tiền **âm**. FR-17 cho phép `min_order_amount = 0`, nên Admin tạo được coupon kiểu này một cách hợp lệ.

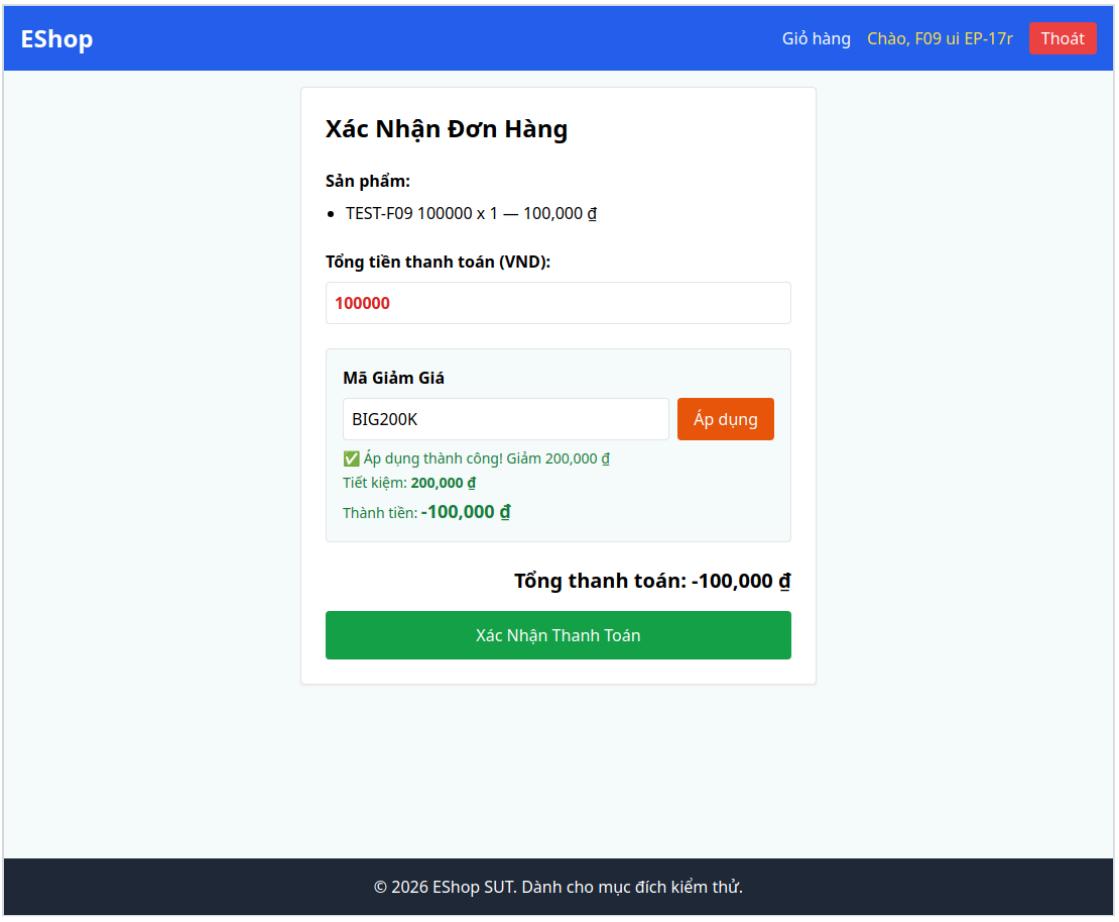
Các bước tái hiện

1. Admin tạo coupon `{"code":"BIG200K","type":"fixed","discount_value":200000,"min_order_amount":0,"expired_at":"2099-12-31","max_uses_per_user":1}`.
2. User đăng nhập, thêm sản phẩm giá 100.000 ₫ vào giỏ, vào trang thanh toán, áp `BIG200K`.
3. Bấm **Xác Nhận Thanh Toán**, rồi mở Admin → **Đơn hàng**.

Kết quả mong đợi: Mức giảm tối đa bằng tổng đơn (thành tiền 0 ₫), hoặc mã bị từ chối. Không bao giờ có thành tiền âm.

Kết quả thực tế: "Thành tiền: **-100,000 ₫**", "Tổng thanh toán: -100,000 ₫". Thanh toán thành công và tạo đơn #3 có `total_amount = -100000`.

Minh chứng: EP-17_ui.png



EP-17_ui.png

, BUG-FR09-08_admin_negative_order.png



BUG-FR09-08_admin_negative_order.png

Quan sát ngoài phạm vi FR-09 (không tính là bug của tính năng này)

- Nút **Áp dụng** màu cam và nút **Xác Nhận Thanh Toán** màu xanh lá. FR-21 yêu cầu nút hành động tích cực dùng màu xanh dương.
- Trang chi tiết sản phẩm phải bấm **"Thêm vào giỏ hàng" 2 lần** mới thêm được (lần đầu không có tác dụng). Lỗi này thuộc FR-06, đã được script xử lý khi chuẩn bị giỏ hàng.
- Trang Giỏ hàng ghi **"Tổng tạm tính"** thay vì "Tổng cộng" (FR-07).

Phụ lục 14 — `features/FR-09_Coupon/07_ai_gap_analysis.md`

FR-09 Mã giảm giá (Coupon): Bước 7, AI Gap Analysis

Công cụ AI: Claude Code (model Claude Opus 5.5), chạy trong terminal ngày 2026-10-13. Nhật ký đầy đủ: `ai-audit/`.

Thay đổi so với FR-01: áp dụng 2 bài học của FR-01 §7.3:

1. Prompt yêu cầu AI liệt kê **mọi yêu cầu liên quan trong toàn SRS** (FR-08, SEC-02, FR-17, FR-21).
2. Chạy TC hợp lệ trước để kiểm tra masking.

Kết quả là 2 bug Critical (BUG-FR09-03, BUG-FR09-05) được tìm thấy **ngay trong thiết kế EP ban đầu**, nhờ đối chiếu chéo với FR-08/SEC-02. Với FR-01, các lỗi tương tự chỉ lộ ra sau khi rà soát.

7.1 Những gì AI bỏ sót hoặc làm sai

#	Gap	Loại	Phát hiện ở đâu	Nguyên nhân	Xử lý
G1	Không có lớp "**`expired_at` là hôm nay nhưng có kèm giờ**". AI coi `expired_at` là một ngày thuần, giống bảng coupon mẫu	Thiếu TC, **bỏ sót bug**	Rà soát sau thực thi: kiểm tra kiểu dữ liệu `expired_at` (DATETIME) và form Admin FR-17	**Thiên lệch theo dữ liệu mẫu:** AI suy ra miền giá trị từ 4 dòng ví dụ trong SRS, thay vì từ miền mà Admin thực sự nhập được	Thêm EC22, TC EP-16 → Fail, ghi thành BUG-FR09-07
G2	Không có lớp đầu ra **"mức giảm > tổng đơn"**. AI đã **nhận ra** rủi ro này ở BVA §4.5 nhưng **gạt đi** với lý do "dữ liệu seed không tạo ra được"	Thiếu TC, **bỏ sót bug Major**	Rà soát sau thực thi	**Hạn chế của AI:** gắn miền kiểm thử với dữ liệu đang có. Thực tế FR-17 cho phép `min_order_amount = 0`, nên Admin hoàn toàn tạo được coupon kiểu này	Thêm EC23, TC EP-17 → Fail, ghi thành BUG-FR09-08 (đơn hàng tổng âm)
G3	**Rò rỉ kiến thức hộp trắng.** Trước khi thiết kế, AI đã đọc mã nguồn backend (khi tìm hiểu SUT ở đầu buổi). Lớp EC17 (bỏ `user_id`) và sự chú ý đặc biệt vào biên `>=` có thể đã bị ảnh hưởng bởi những gì AI thấy trong code, chứ không chỉ từ spec	Sai phương pháp (black-box không thuần)	Sinh viên tự rà soát quy trình	**Ngữ cảnh của AI:** mọi thứ AI đã đọc đều nằm trong ngữ cảnh; AI không thể "quên" có chủ đích	Mỗi lớp nghi vấn đã được kiểm tra lại để có **căn cứ từ spec**: EC17 dựa vào SEC-02 và A5; biên `>=` được chính FR-09 nhấn mạnh. Ghi nhận như một giới hạn trong AI Critique
G4	Giả định A1 (không phân biệt hoa/thường, bỏ khoảng trắng) và A2 (so theo ngày) là **diễn giải của AI**	Rủi ro đánh giá sai	Bước 1	**Spec mơ hồ**	Bug phụ thuộc giả định (BUG-FR09-06, BUG-FR09-07) chỉ được xếp Minor và ghi rõ là phụ thuộc giả định
G5	Hàm tạo user mới của AI **giả định email luôn duy nhất**. Lần chạy đầu của EP-17 dùng lại một email cũ, và vì BUG-FR01-03 (cho đăng ký email trùng), đăng nhập trả về tài khoản cũ đã dùng hết lượt. Kết quả là Fail giả ở kênh UI	Lỗi công cụ kiểm thử	Khi thực thi: kết quả API (thành công) và UI (hết lượt) mâu thuẫn nhau	**Hạn chế của AI:** không tính tới việc bug của tính năng khác ảnh hưởng tới dữ liệu kiểm thử	Chạy lại với email mới (hậu tố `r`), ghi chú ở §5.4b

#	Gap	Loại	Phát hiện ở đâu	Nguyên nhân	Xử lý
G6	Ở EP-11 trên UI, AI mở `/checkout` bằng **điều hướng phía client** (`history.pushState`). Người dùng thật gõ URL sẽ làm tải lại trang và mất giỏ hàng (giỏ chỉ nằm trong bộ nhớ)	Minh chứng yếu hơn	Rà soát kịch bản	Giỏ hàng web không được lưu lại, nên không còn đường nào khác để vào `/checkout` mà vẫn giữ giỏ	Ghi rõ cách tái hiện trong BUG-FR09-03. Phần API của bug không phụ thuộc điểm này

7.2 Những gì AI làm tốt hơn so với FR-01

- **Kiểm tra masking ngay từ đầu** (§5.2). Khi thấy EP-01 Fail về số tiền, AI tách hai tiêu chí "quyết định" và "số tiền". Nhờ đó vẫn đánh giá đúng các điểm biên ngày hết hạn (BVA-09, BVA-10), dù công thức sai.
- **Hậu kiểm ở tầng dữ liệu:** kiểm tra đơn hàng thật trong Admin, chứng minh lỗi công thức gây thiệt hại thật (đơn 10.000.000 ₫ cho giỏ 1.000.000 ₫), không chỉ hiển thị sai.
- **BVA đúng chỗ:** BUG-FR09-02 (`>` thay vì `>=`) **chỉ** BVA phát hiện được. Các TC EP (200.000 và 1.000.000) đều Pass về quyết định.

7.3 Các TC vẫn chưa được thiết kế (rủi ro còn lại)

Lớp chưa phủ	Lý do chưa làm
Áp mã hết hạn hôm nay trong khung 00:00–07:00 giờ VN (ngày được hiểu là 00:00 UTC)	Cần đổi giờ hệ thống hoặc chờ đúng khung giờ
Thanh toán qua API với `coupon_id` nhưng không gọi `/api/coupon-usage`	Lượt dùng chỉ được ghi khi **client** chủ động gọi API này, nên có thể né C5. Thuộc FR-08 nhiều hơn FR-09
Hai tab áp cùng mã và thanh toán đồng thời	Kiểm thử đồng thời, ngoài phạm vi EP/BVA
Mã bị Admin xóa giữa lúc người dùng đang ở trang Checkout	Kiểm thử chuyển trạng thái
Kết quả `percent` có phần lẻ (giả định A3)	Không đánh giá được khi công thức đang sai hoàn toàn (BUG-FR09-01)

7.4 Bài học

1. **Miền giá trị lấy từ đặc tả kiểu dữ liệu, không lấy từ dữ liệu mẫu.** Cả G1 và G2 đều do AI suy ra miền từ bảng ví dụ trong SRS. Khi prompt, nên yêu cầu AI xác định miền của từng thuộc tính theo **nơi nó được nhập** (form Admin FR-17), không theo dữ liệu seed.
2. **Rủi ro AI đã nêu ra thì phải thành TC hoặc được ghi rõ lý do loại.** Ở G2, AI nhận ra rủi ro nhưng tự gạt đi bằng một lý do sai.
3. **Bug của tính năng này có thể phá dữ liệu kiểm thử của tính năng khác** (G5). Khi kết quả hai kênh mâu thuẫn, phải nghi ngờ công cụ trước khi kết luận.
4. **Tách bạch kiến thức hộp trắng** (G3): nên cho AI thiết kế EP trong một phiên mới chỉ có SRS và API spec, rồi mới đọc code để xác nhận.

Phụ lục 15 — `features/FR-15_ProductCRUD/01_input_output.md`

FR-15 Quản lý sản phẩm (CRUD): Bước 1, Xác định Input & Output

> Kỹ thuật: Phân hoạch tương đương, bước 1/3 (slide Bài 4, tr.6–7). Cơ sở kiểm thử: SRS EShop mục FR-15. Như ở FR-09, AI được yêu cầu **liệt kê mọi yêu cầu liên quan trong toàn SRS** trước khi phân hoạch. Thêm bài học từ FR-09 §7.4: miền giá trị lấy theo **nơi dữ liệu được nhập** (form Admin, API), không theo dữ liệu mẫu.

1.1 Trích yêu cầu từ SRS

Mã	Nguồn	Nội dung đặc tả
R1	FR-15	Admin có thể **Thêm** / **Xem** / **Sửa** / **Xóa** sản phẩm
R2	FR-15	Tên sản phẩm: **bắt buộc**, **tối đa 255 ký tự**
R3	FR-15	Giá: **bắt buộc**, phải là **số dương (> 0)**
R4	FR-15	Danh mục: **bắt buộc**, phải **chọn từ danh sách có sẵn**
R5	FR-15	Khi Sửa một sản phẩm, **chỉ sản phẩm đó bị thay đổi**, các sản phẩm khác giữ nguyên
R6	FR-12, SEC-02, SEC-03	`POST/PUT/DELETE /api/products` phải yêu cầu **JWT hợp lệ** và `role = 'admin'`
R7	SEC-04	Dữ liệu người dùng nhập vào, khi hiển thị, phải được **escape** (không render HTML)
R8	SEC-05	Truy vấn CSDL phải dùng parameterized query
R9	FR-22	Trường bắt buộc có dấu `*`; thông báo lỗi hiển thị **trên** nút submit
R10	FR-21	Nút nguy hiểm (Xóa) màu đỏ; nút tích cực (Lưu) màu xanh dương; tiền dùng `đ` và có phân cách hàng nghìn

Yêu cầu đã xem nhưng không đưa vào phạm vi: FR-16 (import CSV) là tính năng riêng, có validation riêng. FR-14 (danh mục) chỉ dùng để biết "danh sách có sẵn" gồm những gì. FR-04 (tìm kiếm) dùng API `GET /api/products?search=`, không thuộc CRUD.

1.2 Biến đầu vào (Input)

Mã	Input	Kiểu	Thao tác	Ràng buộc
I0	Thao tác	{Thêm, Xem, Sửa, Xóa}	–	R1
I1	Tên sản phẩm (`name`)	chuỗi	Thêm, Sửa	R2, R7, R8
I2	Giá (`price`)	số	Thêm, Sửa	R3
I3	Danh mục (`category_id`)	id danh mục	Thêm, Sửa	R4
I4	Sản phẩm được chọn (`id`)	id sản phẩm	Sửa, Xóa	R1, R5
I5	Quyền của người gọi	{admin, user thường, không đăng nhập}	Thêm, Sửa, Xóa	R6
–	Mô tả, URL ảnh	chuỗi	Thêm, Sửa	Spec **không** ràng buộc. Chỉ dùng giá trị hợp lệ cố định và làm "nhãn" nhận diện bản ghi của TC

Trạng thái hệ thống:

- Danh sách danh mục seed: `1 Điện thoại`, `2 Laptop`, `3 Phụ kiện`.
- 5 sản phẩm seed có id 1–5.

1.3 Biến đầu ra (Output)

Mã	Output	Mô tả
O1a	Thêm thành công	Sản phẩm mới xuất hiện trong danh sách Admin và trong `GET /api/products` với đúng dữ liệu đã nhập
O1b	Sửa thành công	**Chỉ** sản phẩm được chọn thay đổi, mọi sản phẩm khác giữ nguyên (R5)
O1c	Xóa thành công	Sản phẩm biến mất khỏi danh sách, các sản phẩm khác giữ nguyên
O1d	Hiển thị an toàn	Tên chứa ký tự đặc biệt/HTML được lưu và hiển thị **nguyên văn dưới dạng chữ**
O2	Từ chối	Thông báo lỗi phù hợp (UI) hoặc HTTP 4xx (API); **dữ liệu không thay đổi**

1.4 Các điều kiện cần phân hoạch (đầu vào cho Bước 2)

Điều kiện	Biến	Loại điều kiện (slide tr.10)
C1. Tên khác rỗng	I1	Boolean
C2. `1 ≤ len(tên) ≤ 255`	I1	Dãy giá trị `[1..255]`, **có thứ tự nên áp dụng được BVA (hai biên)**
C3. Giá có mặt và là số	I2	Boolean
C4. Giá > 0	I2	Dãy giá trị `(0..∞)`, **có thứ tự nên áp dụng được BVA**
C5. Danh mục có mặt và thuộc danh sách có sẵn	I3	Tập giá trị {1, 2, 3}
C6. Sản phẩm được chọn tồn tại	I4	Boolean
C7. Người gọi là admin	I5	Tập giá trị {admin}
C8. Sửa chỉ ảnh hưởng 1 sản phẩm	O1b	Boolean (điều kiện trên **đầu ra**)

1.5 Điểm mơ hồ trong đặc tả và giả định áp dụng

#	Điểm mơ hồ	Giả định áp dụng
A1	Tên chỉ có khoảng trắng	Coi như **rỗng**, tức là không hợp lệ (nhất quán với FR-01 A4)
A2	"Tối đa 255 ký tự" đếm theo ký tự hay byte	Đếm theo **ký tự**. Giá trị test dùng ký tự ASCII nên hai cách đếm trùng nhau
A3	Giá có được là số thập phân không	Spec chỉ yêu cầu "số dương", nên số thập phân dương (`1500.5`) là **hợp lệ**. Đơn vị nhỏ nhất dùng cho BVA là **1 ₫**
A4	Spec không nêu giá tối đa	Không có biên trên. Thêm 1 TC giá trị rất lớn (vượt int32) để kiểm tra độ bền
A5	"Chọn từ danh sách có sẵn" chỉ được UI đảm bảo (dropdown)	API cũng phải từ chối `category_id` không tồn tại hoặc bị thiếu
A6	Sửa/Xóa sản phẩm không tồn tại	Trả lỗi 404, không thay đổi dữ liệu

1.6 Kênh thực thi & quan sát ban đầu (hộp đen)

- **UI:** `http://localhost:5174`, đăng nhập `admin@eshop.com`, tab **Sản phẩm**. Form "Thêm sản phẩm mới" có: Tên sản phẩm, Giá tiền (`type="number"`), URL Ảnh, Mô tả, Danh mục (dropdown). Nút **Lưu sản phẩm**. Mỗi dòng của bảng có nút **Sửa** (vàng) và **Xóa** (đỏ).

- **API:** `POST /api/products`, `PUT /api/products/:id`, `DELETE /api/products/:id`, `GET /api/products` (API spec §3).
- **Quan sát ban đầu:**
  - Không trường nào có dấu `*` (R9).
  - Dropdown Danh mục luôn có sẵn một giá trị, nên trên UI **không tạo được** lớp "thiếu danh mục" hay "danh mục không tồn tại". Các lớp này chỉ kiểm thử được qua API.
  - Ô Giá là `type="number"`, nên trên UI không gõ được chữ.
  - Nút **Xóa** không có hộp thoại xác nhận. Spec FR-15 không yêu cầu, nên chỉ ghi nhận.
- **Nhận diện bản ghi của TC:** mỗi TC đặt **Mô tả** = `F15-<TC>-<kênh>`. Nhờ vậy, có thể tìm đúng bản ghi kể cả khi tên rỗng hoặc bị cắt.

Phụ lục 16 — `features/FR-15_ProductCRUD/02_equivalence_classes.md`

FR-15 Quản lý sản phẩm (CRUD): Bước 2, Xác định lớp tương đương

> Kỹ thuật: Phân hoạch tương đương, bước 2/3 (slide Bài 4, tr.8–10). Đầu vào là 8 điều kiện C1–C8 và các giả định A1–A6 ở Bước 1.

2.1 Cách phân hoạch

Loại điều kiện	Lớp hợp lệ	Lớp không hợp lệ	Áp dụng cho
Boolean	điều kiện đúng	điều kiện sai	C1, C3, C6, C8
Dãy giá trị `[1..255]`	`1 ≤ len ≤ 255`	`len < 1` (tách: rỗng, chỉ khoảng trắng), `len > 255`	C2
Dãy giá trị `(0..∞)`	giá > 0	giá = 0, giá < 0	C4
Tập giá trị	thuộc tập	ngoài tập (tách: thiếu, không tồn tại)	C5, C7

Một số lớp được **tách nhỏ hơn**:

- **Giá không hợp lệ** tách 4 lớp: *thiếu*, *bằng 0*, *âm*, *không phải số*. Đây là 4 cách vi phạm C3/C4 khác nhau. Ngoài ra, 0 là điểm đặc biệt của "dương".
- **Giá hợp lệ** tách *số nguyên* và *số thập phân* (A3).
- **Tên hợp lệ** có thêm lớp *chứa ký tự tiếng Việt, ký tự đặc biệt và thẻ HTML*. Lớp này áp dụng bài học FR-01 (G1, G2): SUT là ứng dụng tiếng Việt, và R7 (SEC-04) yêu cầu dữ liệu hiển thị phải được escape.
- **Quyền không hợp lệ** tách *không có token* và *token của user thường*, vì SEC-03 yêu cầu kiểm tra **role** chứ không chỉ kiểm tra sự tồn tại của token.

2.2 Bảng tổng hợp lớp tương đương

Bộ giá trị nền: tên `Tai nghe Sony WH-1000XM5`, giá `1500000`, danh mục `2` (Laptop), quyền admin, mô tả `F15-<TC>-<kênh>`.

STT	Input / Output	Điều kiện	Lớp tương đương	Loại	Giá trị đại diện
EC1	I1 Tên	C1, C2	Tên thường, `1 ≤ len ≤ 255`	Hợp lệ	`Tai nghe Sony WH-1000XM5` (24 ký tự)
EC2		C1, C2, R7	Tên có tiếng Việt, ký tự đặc biệt và HTML	Hợp lệ	`Loa <img src=x onerror="window.__xss15=1"> JBL "Pro" & 'Bass' – Âm trầm`
EC3		C1	Tên rỗng	Không hợp lệ	`""`
EC4		C1	Tên chỉ có khoảng trắng (A1)	Không hợp lệ	`" "`
EC5		C2	Tên dài hơn 255 ký tự	Không hợp lệ	300 ký tự
EC6	I2 Giá	C3, C4	Số nguyên dương	Hợp lệ	`1500000`
EC7		C3, C4	Số thập phân dương (A3)	Hợp lệ	`1500.5`
EC8		C3	Giá rỗng/thiếu	Không hợp lệ	`""`

STT	Input / Output	Điều kiện	Lớp tương đương	Loại	Giá trị đại diện
EC9		C4	Giá bằng 0	Không hợp lệ	`0`
EC10		C4	Giá âm	Không hợp lệ	`-1000`
EC11		C3	Giá không phải số	Không hợp lệ	`"abc"`
EC12	I3 Danh mục	C5	Thuộc danh sách có sẵn	Hợp lệ	`2` (Laptop)
EC13		C5	Thiếu danh mục (A5)	Không hợp lệ	`null`
EC14		C5	Danh mục không tồn tại (A5)	Không hợp lệ	`999`
EC15	I4 Sản phẩm	C6	Sản phẩm tồn tại	Hợp lệ	sản phẩm do TC tạo sẵn
EC16		C6	Sản phẩm không tồn tại (A6)	Không hợp lệ	id `99999`
EC17	I5 Quyền	C7	Admin, JWT hợp lệ	Hợp lệ	token `admin@eshop.com`
EC18		C7	Không có token	Không hợp lệ	–
EC19		C7	Token của user thường	Không hợp lệ	token `test@eshop.com`
EC20	O1b Sửa	C8	Sửa 1 sản phẩm → chỉ sản phẩm đó đổi	Hợp lệ (output)	so sánh toàn bộ danh sách trước/sau
EC21	O1c Xóa	C8	Xóa 1 sản phẩm → chỉ sản phẩm đó mất	Hợp lệ (output)	so sánh toàn bộ danh sách trước/sau

Thống kê: 21 lớp, gồm **9 lớp hợp lệ** (EC1, EC2, EC6, EC7, EC12, EC15, EC17, EC20, EC21) và **12 lớp không hợp lệ** (EC3, EC4, EC5, EC8, EC9, EC10, EC11, EC13, EC14, EC16, EC18, EC19).

2.3 Biến "thao tác" (I0)

Validation (C1–C5) và phân quyền (C7) được cài đặt riêng cho từng endpoint (POST và PUT là hai đường xử lý khác nhau). Vì thế, một lớp không hợp lệ được kiểm tra trên **Thêm** là chưa đủ. Ở Bước 3, một số lớp đại diện (tên rỗng, giá 0, không có token) được kiểm tra lại trên **Sửa** và **Xóa**.

Phụ lục 17 — `features/FR-15_ProductCRUD/03_ep_test_cases.md`

FR-15 Quản lý sản phẩm (CRUD): Bước 3, Xác định ca kiểm thử (EP)

> Kỹ thuật: Phân hoạch tương đương, bước 3/3 (slide Bài 4, tr.15–18). Đầu vào: 21 lớp tương đương ở Bước 2.

3.1 Nguyên tắc áp dụng (slide tr.15)

1. Khi xét lớp của biến X, các biến khác lấy **bộ giá trị nền hợp lệ**: tên `Tai nghe Sony WH-1000XM5`, giá `1500000`, danh mục `2`, quyền admin.
2. **Một TC phủ nhiều lớp hợp lệ.**
3. **Mỗi TC chỉ phủ đúng một lớp không hợp lệ.**

Với TC Sửa/Xóa, script **tạo sẵn một sản phẩm riêng** cho TC đó (tiền điều kiện) rồi mới sửa/xóa. Sản phẩm seed (id 1–5) được giữ nguyên để làm "các sản phẩm khác" khi kiểm tra C8.

3.2 Bảng xác định ca kiểm thử cho từng lớp

Lớp	Lớp tương đương	Thao tác	Tên	Giá	DM	Quyền	Output mong đợi
EC1	Tên thường	Thêm	`Tai nghe Sony WH-1000XM5`	1500000	2	admin	O1a
EC2	Tên tiếng Việt + HTML	Thêm	`Loa <img …> JBL "Pro" & 'Bass' – Âm trầm`	1500000	2	admin	O1a + O1d
EC3	Tên rỗng	Thêm	`""`	1500000	2	admin	O2
EC4	Tên chỉ khoảng trắng	Thêm	`" "`	1500000	2	admin	O2
EC5	Tên > 255	Thêm	300 ký tự	1500000	2	admin	O2
EC6	Giá nguyên dương	Thêm	nền	1500000	2	admin	O1a
EC7	Giá thập phân dương	Thêm	nền	1500.5	2	admin	O1a
EC8	Giá rỗng	Thêm	nền	`""`	2	admin	O2
EC9	Giá = 0	Thêm	nền	0	2	admin	O2
EC10	Giá âm	Thêm	nền	-1000	2	admin	O2
EC11	Giá không phải số	Thêm	nền	`"abc"`	2	admin	O2
EC12	DM có sẵn	Thêm	nền	1500000	2	admin	O1a
EC13	Thiếu DM	Thêm	nền	1500000	`null`	admin	O2
EC14	DM không tồn tại	Thêm	nền	1500000	999	admin	O2
EC15	SP tồn tại	Sửa / Xóa	–	–	–	admin	O1b / O1c
EC16	SP không tồn tại	Sửa / Xóa id 99999	nền	1500000	2	admin	O2: 404
EC17	Admin	Thêm	nền	1500000	2	admin	O1a

Lớp	Lớp tương đương	Thao tác	Tên	Giá	DM	Quyền	Output mong đợi
EC18	Không token	Thêm / Sửa / Xóa	nền	1500000	2	–	O2: 401
EC19	Token user thường	Thêm	nền	1500000	2	user	O2: 403
EC20	Sửa chỉ 1 SP	Sửa	`… (đã sửa)`	1600000	2	admin	O1b
EC21	Xóa chỉ 1 SP	Xóa	–	–	–	admin	O1c

3.3 Bảng rút gọn các ca kiểm thử (22 TC)

TC	Lớp phủ	Thao tác	Dữ liệu (khác nền)	Kênh	Output mong đợi
EP-01	EC1, EC6, EC12, EC17	Thêm	–	UI + API	O1a: có SP mới, đúng tên/giá/DM
EP-02	EC1, EC6, EC12, EC15, EC17, **EC20**	Sửa	tên `… (đã sửa)`, giá 1600000	UI + API	O1b: SP được sửa đổi, **mọi SP khác giữ nguyên**
EP-03	EC15, EC17, **EC21**	Xóa	–	UI + API	O1c: SP bị xóa, SP khác giữ nguyên
EP-04	**EC2** + nền	Thêm	tên có HTML	UI + API	O1a + O1d: tên hiển thị nguyên văn ở Admin, trang chủ và trang chi tiết; không có script nào chạy
EP-05	**EC7** + nền	Thêm	giá 1500.5	UI + API	O1a
EP-06	**EC3**	Thêm	tên `""`	UI + API	O2
EP-07	**EC4**	Thêm	tên `" "`	UI + API	O2
EP-08	**EC5**	Thêm	tên 300 ký tự	UI + API	O2
EP-09	**EC8**	Thêm	giá `""`	UI + API	O2
EP-10	**EC9**	Thêm	giá 0	UI + API	O2
EP-11	**EC10**	Thêm	giá -1000	UI + API	O2
EP-12	**EC11**	Thêm	giá `"abc"`	UI + API	O2 (UI: ô số không nhận chữ cũng tính là chặn)
EP-13	**EC13**	Thêm	DM `null`	API	O2
EP-14	**EC14**	Thêm	DM 999	API	O2
EP-15	**EC16**	Sửa	id 99999	API	O2: 404
EP-16	**EC16**	Xóa	id 99999	API	O2: 404
EP-17	**EC18**	Thêm	không token	API	O2: 401
EP-18	**EC19**	Thêm	token user	API	O2: 403
EP-19	**EC18**	Sửa	không token	API	O2: 401, SP không đổi

TC	Lớp phủ	Thao tác	Dữ liệu (khác nền)	Kênh	Output mong đợi
EP-20	**EC18**	Xóa	không token	API	O2: 401, SP vẫn còn
EP-21	**EC3**	Sửa	tên `""`	UI + API	O2, SP không đổi
EP-22	**EC9**	Sửa	giá 0	UI + API	O2, SP không đổi

Lý do một số TC chỉ chạy API:

- EP-13, EP-14: dropdown luôn có giá trị thuộc danh sách.
- EP-15, EP-16: UI chỉ cho sửa/xóa SP đang hiển thị.
- EP-17 đến EP-20: kiểm tra phân quyền ở server. Trên UI, admin luôn có token.

3.4 Kiểm tra độ phủ

Lớp	TC	Lớp	TC	Lớp	TC
EC1	EP-01, EP-02	EC8	EP-09	EC15	EP-02, EP-03
EC2	EP-04	EC9	EP-10, EP-22	EC16	EP-15, EP-16
EC3	EP-06, EP-21	EC10	EP-11	EC17	EP-01…EP-05
EC4	EP-07	EC11	EP-12	EC18	EP-17, EP-19, EP-20
EC5	EP-08	EC12	EP-01	EC19	EP-18
EC6	EP-01	EC13	EP-13	EC20	EP-02
EC7	EP-05	EC14	EP-14	EC21	EP-03

Cả 21/21 lớp được phủ. Mỗi TC không hợp lệ chỉ chứa **đúng 1** lớp không hợp lệ.

3.5 Cách thực thi và hậu kiểm

- **API:** gọi endpoint tương ứng với header `Authorization` theo cột Quyền.
- **UI:** đăng nhập Admin `:5174` → tab **Sản phẩm** → điền form và bấm **Lưu sản phẩm**, hoặc bấm **Sửa** / **Xóa** trên dòng của SP.
- **Hậu kiểm (cả hai kênh):**
  - Chụp `GET /api/products` trước và sau mỗi TC.
  - Thêm: tìm SP theo mô tả `F15-<TC>-<kênh>`.
  - Sửa/Xóa: so sánh **từng** SP còn lại với ảnh chụp trước.
  - Với UI: đọc thêm bảng sản phẩm **ngay trên màn hình** sau khi lưu, vì người dùng nhìn thấy bảng này (C8).
- **Thứ tự chạy:** EP-01 đến EP-03 (hợp lệ) chạy trước để kiểm tra masking.

Phụ lục 18 — `features/FR-15_ProductCRUD/04_bva_test_cases.md`

FR-15 Quản lý sản phẩm (CRUD): Bước 4, Phân tích giá trị biên (BVA)

> Kỹ thuật: Boundary Value Analysis (slide Bài 4, phần BVA). Đầu vào: điều kiện C2, C4 ở Bước 1, các lớp EC1, EC3, EC5, EC6, EC9 ở Bước 2.

4.1 Xác định các miền có thứ tự

Điều kiện	Có thứ tự?	Dùng BVA?
C1 tên khác rỗng	gộp vào độ dài (len = 0)	Có, qua V1
C2 `1 ≤ len(tên) ≤ 255`	**Có**	**Có, hai biên**
C3 giá là số	Không (boolean)	Không
C4 giá > 0	**Có**	**Có**
C5 danh mục thuộc danh sách	**Không**. `category_id` là định danh, thứ tự 1 < 2 < 3 không mang nghĩa nghiệp vụ, và danh sách có thể thưa (khi xóa danh mục)	Không. Đã phủ bằng EP (EC12–EC14)
C6, C7, C8	Không (boolean / tập)	Không

4.2 Biên của từng biến

Biến	Mô tả	Miền hợp lệ	LB	UB	Bước nhảy
V1	Độ dài tên (ký tự, A2)	`[1..255]`	1	255	1 ký tự
V2	Giá	`(0..∞)`, theo đơn vị 1 ₫ (A3) là `[1..∞)`	1	– (A4)	1 ₫

Giá trị danh nghĩa: tên 24 ký tự (`Tai nghe Sony WH-1000XM5`), giá 1.500.000, danh mục 2.

4.3 Chọn biến thể BVA và tính số TC

- **V1 có hai biên.** Robustness cho đủ 6 điểm: LB−1 = 0, LB = 1, LB+1 = 2, UB−1 = 254, UB = 255, UB+1 = 256.
- **V2 chỉ có biên dưới.** Dùng LB−1 = 0, LB = 1, LB+1 = 2, cộng 1 điểm độ bền phía "∞" (A4): **2.147.483.648** = 2^{31}. Giá trị này vượt kiểu số nguyên 32-bit, nên phát hiện được tràn số nếu hệ thống lưu giá bằng int32.
- Standard BVA (4n+1 = 9) không kiểm tra LB−1/UB+1, mà đây lại là nơi validation hay sai, nên **chọn Robustness**. Worst-case bị loại vì tên và giá độc lập nhau.
- **Lặp lại biên trên của V1 cho thao tác Sửa** (255 và 256 ký tự), lý do giống EP §2.3: POST và PUT là hai đường xử lý riêng.

Tổng: 1 (nominal) + 6 (V1, Thêm) + 4 (V2, Thêm) + 2 (V1, Sửa) = 13 TC.

4.4 Bảng ca kiểm thử giá trị biên

Tên test có dạng `"BVA15-xxxx…"`, cắt đúng độ dài cần thiết (chỉ ký tự ASCII). Độ dài được script kiểm tra lại trước khi gửi.

TC	Thao tác	Biến	Điểm	Tên (len)	Giá	Output mong đợi
BVA-01	Thêm	–	nominal	24	1500000	O1a
BVA-02	Thêm	V1	LB−1	**0**	1500000	**O2**
BVA-03	Thêm	V1	**LB**	**1**	1500000	**O1a**
BVA-04	Thêm	V1	LB+1	2	1500000	O1a
BVA-05	Thêm	V1	UB−1	254	1500000	O1a
BVA-06	Thêm	V1	**UB**	**255**	1500000	**O1a**, lưu đủ 255 ký tự (không bị cắt)
BVA-07	Thêm	V1	UB+1	**256**	1500000	**O2**
BVA-08	Thêm	V2	LB−1	24	**0**	**O2**
BVA-09	Thêm	V2	**LB**	24	**1**	**O1a**
BVA-10	Thêm	V2	LB+1	24	2	O1a
BVA-11	Thêm	V2	độ bền "∞"	24	**2147483648**	O1a, giá lưu và hiển thị đúng, không tràn số
BVA-12	Sửa	V1	**UB**	**255**	1500000	**O1b**, chỉ SP đó đổi
BVA-13	Sửa	V1	UB+1	**256**	1500000	**O2**, SP không đổi

4.5 Ghi chú

- BVA-02 (len 0) trùng giá trị với EP-06, BVA-08 (giá 0) trùng với EP-10. Theo slide, điểm biên vừa là đại diện lớp vừa là biên. Vẫn giữ trong bảng BVA để đủ bộ điểm.
- Trên UI, ô Tên có thuộc tính `required`. BVA-02 trên UI dự kiến bị chặn bởi validation HTML5. Kết quả này vẫn được tính là Pass, vì đó là đúng hành vi từ chối.

Phụ lục 19 — `features/FR-15_ProductCRUD/05_test_execution.md`

FR-15 Quản lý sản phẩm (CRUD): Bước 5, Thực thi kiểm thử

5.1 Môi trường

Mục	Giá trị
Thời điểm chạy	2026-10-13 14:29 (GMT+7). Dữ liệu thô: `results_fr15.json`
SUT	`eshop-sut` commit `85af3ba`. Backend `:3000`, Admin `:5174`, Web `:5173`
Trạng thái DB	Khởi động lại backend ngay trước khi chạy (5 SP seed id 1–5, 3 danh mục)
Trình duyệt	Chromium 131 (headless) qua Playwright 1.49.1
Script	`scripts/fr15_products.js`; thăm dò bổ sung `scripts/fr15_mass_rename_probe.js`
Nhận diện bản ghi	Mô tả = `F15-<TC>-<kênh>`. SP cần sửa/xóa được tạo riêng với tên `F15 target F15-<TC>-<kênh>`
Hậu kiểm	`GET /api/products` trước và sau mỗi TC. So sánh **từng** SP khác SP đích. Với UI, đọc thêm cột "Tên SP" trên màn hình sau khi lưu

Tiêu chí Pass/Fail

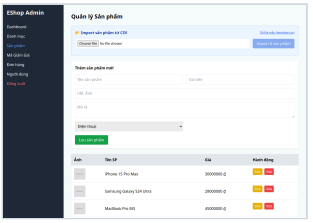
- **O1a:** API 2xx và có đúng 1 SP mới mang mô tả của TC, đúng tên/giá/danh mục.
- **O1b:** SP đích có giá trị mới. **Không** SP nào khác thay đổi, xét cả trong CSDL lẫn trên bảng UI.
- **O1c:** SP đích không còn, các SP khác giữ nguyên.
- **O2:** API 4xx (UI: có thông báo lỗi/bị chặn), và CSDL **không** thay đổi.

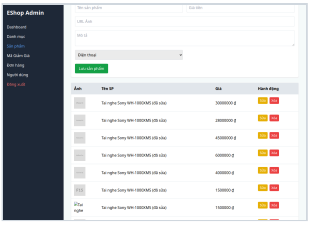
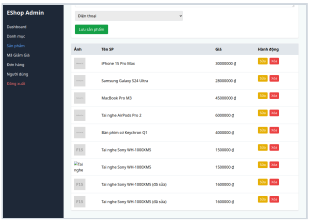
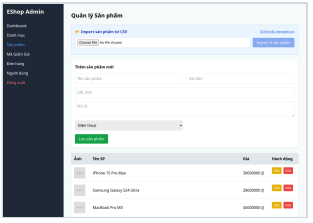
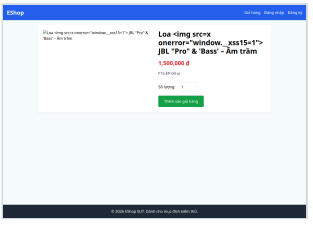
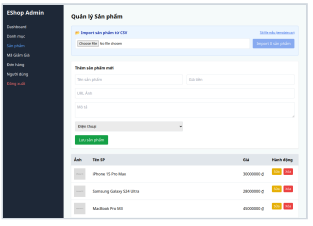
5.2 Kiểm tra masking

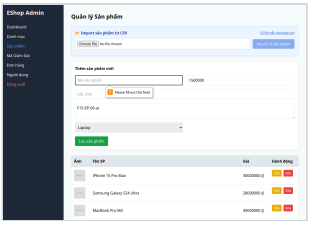
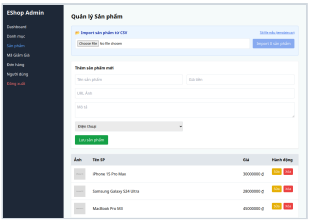
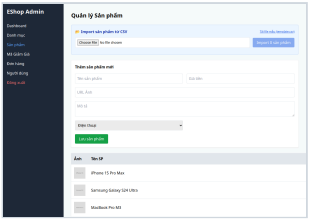
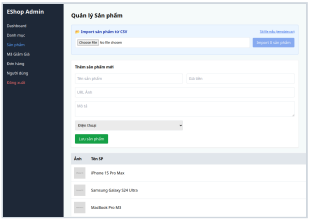
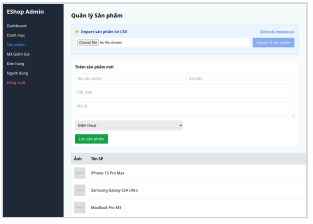
Các TC hợp lệ EP-01 (Thêm), EP-02 (Sửa), EP-03 (Xóa) được chạy trước. Kết quả: Thêm và Xóa Pass trên cả hai kênh. Sửa Pass ở tầng API/CSDL, nhưng Fail ở bảng UI (xem BUG-FR15-02).

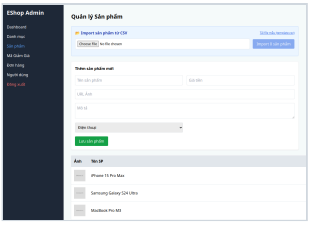
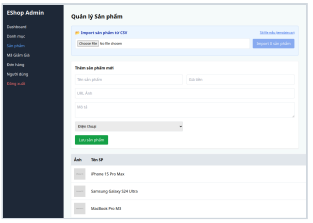
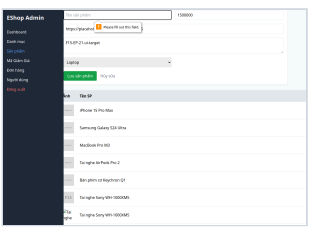
Bộ giá trị nền được chấp nhận, nên các TC không hợp lệ phía sau **không bị masking**: nếu một TC bị từ chối, nguyên nhân chỉ có thể là lớp không hợp lệ đang test. Thực tế gần như không TC không hợp lệ nào bị từ chối.

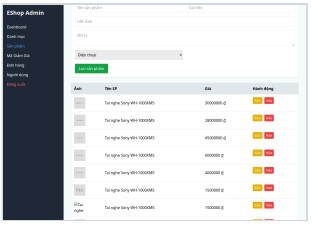
5.3 Kết quả: Phân hoạch tương đương (22 TC)

TC	Thao tác	Dữ liệu (khác nền)	Mong đợi	API: thực tế	API	UI: thực tế	UI	KQ
EP-01	Thêm	–	O1a	200, tạo SP đúng dữ liệu	✅	tạo SP đúng dữ liệu	✅	✅ ảnh  ảnh

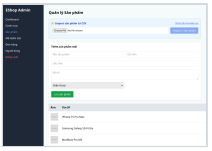
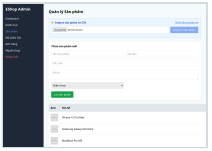
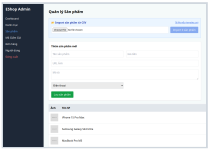
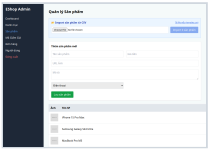
TC	Thao tác	Dữ liệu (khác nền)	Mong đợi	API: thực tế	API	UI: thực tế	UI	KQ
EP-02	Sửa	tên `…(đã sư˙a)`, giá 1.600.000	O1b	200, SP đích đổi đúng, 0 SP khác đổi	✅	CSDL đúng, nhưng **bảng UI hiển thị cả 7 SP khác mang tên mới**	❌	❌ ảnh  ảnh
EP-03	Xóa	–	O1c	200, SP bị xóa, 0 SP khác đổi	✅	như API (không có hộp thoại xác nhận)	✅	✅ ảnh  ảnh
EP-04	Thêm	tên chứa HTML/tiếng Việt	O1a + O1d	200, tên lưu nguyên văn (71 ký tự)	✅	Tên hiển thị dạng chữ ở Admin, trang chủ, trang chi tiết; `window.__xss15` không được gán	✅	✅ admin  admin , web  web
EP-05	Thêm	giá 1500.5	O1a	200, giá 1500.5	✅	như API	✅	✅ ảnh  ảnh

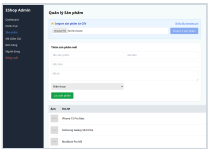
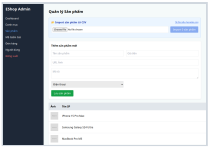
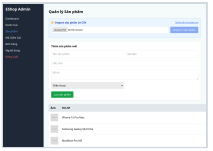
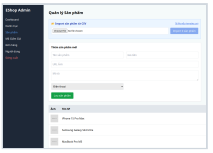
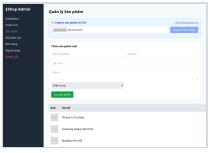
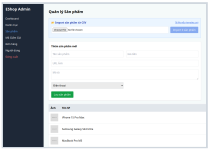
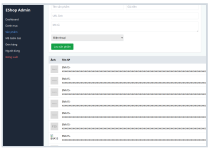
TC	Thao tác	Dữ liệu (khác nền)	Mong đợi	API: thực tế	API	UI: thực tế	UI	KQ
EP-06	Thêm	tên `""`	O2	**200, tạo SP tên rỗng**	❌	HTML5 chặn "Please fill out this field."	✅	❌ ảnh  ảnh
EP-07	Thêm	tên `" "`	O2	**200, tạo SP**	❌	**tạo SP**	❌	❌ ảnh  ảnh
EP-08	Thêm	tên 300 ký tự	O2	**200, tạo SP tên 300 ký tự**	❌	**tạo SP**	❌	❌ ảnh  ảnh
EP-09	Thêm	giá `""`	O2	**200, tạo SP, giá `""`**	❌	**tạo SP, giá `""`**	❌	❌ ảnh  ảnh
EP-10	Thêm	giá 0	O2	**200, tạo SP giá 0**	❌	**tạo SP giá 0**	❌	❌ ảnh  ảnh

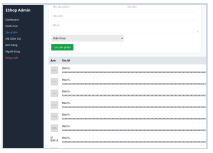
TC	Thao tác	Dữ liệu (khác nền)	Mong đợi	API: thực tế	API	UI: thực tế	UI	KQ
EP-11	Thêm	giá -1000	O2	**200, tạo SP giá -1.000**	❌	**tạo SP giá -1.000**	❌	❌ ảnh  ảnh
EP-12	Thêm	giá `"abc"`	O2	**200, tạo SP, giá `"abc"`**	❌	Ô Giá không nhận chữ (giá trị = `""`), nhưng form vẫn lưu SP với giá rỗng	❌	❌ ảnh  ảnh
EP-13	Thêm	DM `null`	O2	**200, tạo SP không có danh mục**	❌	không áp dụng	–	❌
EP-14	Thêm	DM 999	O2	**200, tạo SP thuộc DM 999 (không tồn tại)**	❌	không áp dụng	–	❌
EP-15	Sửa	id 99999	O2: 404	**200 `"Product updated"`** dù SP không tồn tại	❌	không áp dụng	–	❌
EP-16	Xóa	id 99999	O2: 404	**200 `"Product deleted"`** dù SP không tồn tại	❌	không áp dụng	–	❌
EP-17	Thêm	**không token**	O2: 401	**200, tạo SP**	❌	không áp dụng	–	❌
EP-18	Thêm	**token user thường**	O2: 403	**200, tạo SP**	❌	không áp dụng	–	❌
EP-19	Sửa	**không token**	O2: 401	**200, SP bị đổi tên** thành "Bị sửa khi không có token"	❌	không áp dụng	–	❌
EP-20	Xóa	**không token**	O2: 401	**200, SP bị xóa**	❌	không áp dụng	–	❌
EP-21	Sửa	tên `""`	O2	**200, SP đổi thành tên rỗng**	❌	HTML5 chặn, SP giữ nguyên	✅	❌ ảnh  ảnh

TC	Thao tác	Dữ liệu (khác nền)	Mong đợi	API: thực tế	API	UI: thực tế	UI	KQ
EP-22	Sửa	giá 0	O2	**200, SP đổi giá thành 0**	❌	**SP đổi giá thành 0**, bảng UI còn đổi tên 17 SP khác	❌	❌ ảnh  ảnh

5.4 Kết quả: Phân tích giá trị biên (13 TC)

TC	Thao tác	Biến, điểm	Giá trị	Mong đợi	API	UI	Ghi chú	KQ
BVA-01	Thêm	nominal	len 24, giá 1.500.000	O1a	✅	✅		✅ ảnh  ảnh
BVA-02	Thêm	V1 LB−1	**len 0**	O2	❌ 200, tạo SP	✅ HTML5 chặn	Validation chỉ có ở client	❌ ảnh  ảnh
BVA-03	Thêm	V1 **LB**	**len 1**	O1a	✅	✅		✅ ảnh  ảnh
BVA-04	Thêm	V1 LB+1	len 2	O1a	✅	✅		✅ ảnh  ảnh
BVA-05	Thêm	V1 UB−1	len 254	O1a	✅	✅		✅ ảnh  ảnh

TC	Thao tác	Biến, điểm	Giá trị	Mong đợi	API	UI	Ghi chú	KQ
BVA-06	Thêm	V1 **UB**	**len 255**	O1a, đủ 255 ký tự	✅	✅	Lưu đủ 255 ký tự	✅ ảnh  ảnh
BVA-07	Thêm	V1 UB+1	**len 256**	O2	❌ 200, tạo SP 256 ký tự	❌ tạo SP	Không có giới hạn trên	❌ ảnh  ảnh
BVA-08	Thêm	V2 LB−1	**giá 0**	O2	❌ 200, tạo SP	❌ tạo SP		❌ ảnh  ảnh
BVA-09	Thêm	V2 **LB**	**giá 1**	O1a	✅	✅		✅ ảnh  ảnh
BVA-10	Thêm	V2 LB+1	giá 2	O1a	✅	✅		✅ ảnh  ảnh
BVA-11	Thêm	V2 độ bền	**giá 2.147.483.648**	O1a, không tràn số	✅	✅	Lưu đúng 2147483648. Bảng Admin hiển thị `2147 483648 ₫`, không có phân cách hàng nghìn (FR-21, ngoài phạm vi)	✅ ảnh  ảnh
BVA-12	Sửa	V1 **UB**	**len 255**	O1b	✅	❌ bảng UI đổi tên 54 SP khác	CSDL đúng, hiển thị sai	❌ ảnh  ảnh

TC	Thao tác	Biến, điểm	Giá trị	Mong đợi	API	UI	Ghi chú	KQ
BVA-13	Sửa	V1 UB+1	**len 256**	O2	❌ 200, SP đổi tên 256 ký tự	❌		❌ ảnh  ảnh

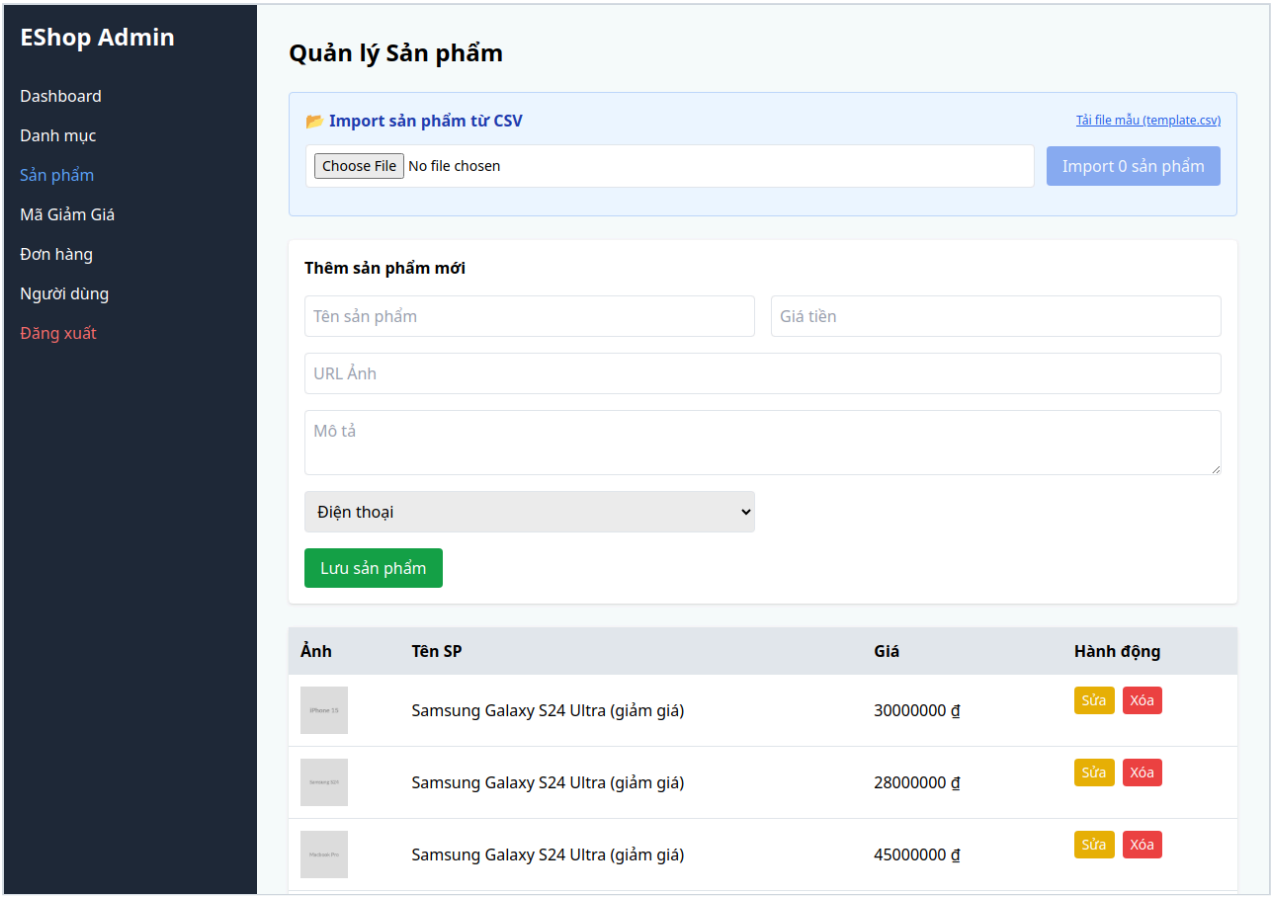
Phân tích theo biến:

- **V1 (độ dài tên):** chỉ có **biên dưới** được kiểm soát, và chỉ ở **client** (HTML5 `required`). Biên trên 255 không được kiểm soát ở đâu cả: 256 và 300 ký tự đều được lưu.
- **V2 (giá):** không có biên nào được kiểm soát. 0, số âm, rỗng, chữ đều được lưu. Tại LB/LB+1, kết quả Pass chỉ vì đó là giá trị hợp lệ.

5.5 Thăm dò bổ sung: hậu quả của lỗi bảng UI (BUG-FR15-02)

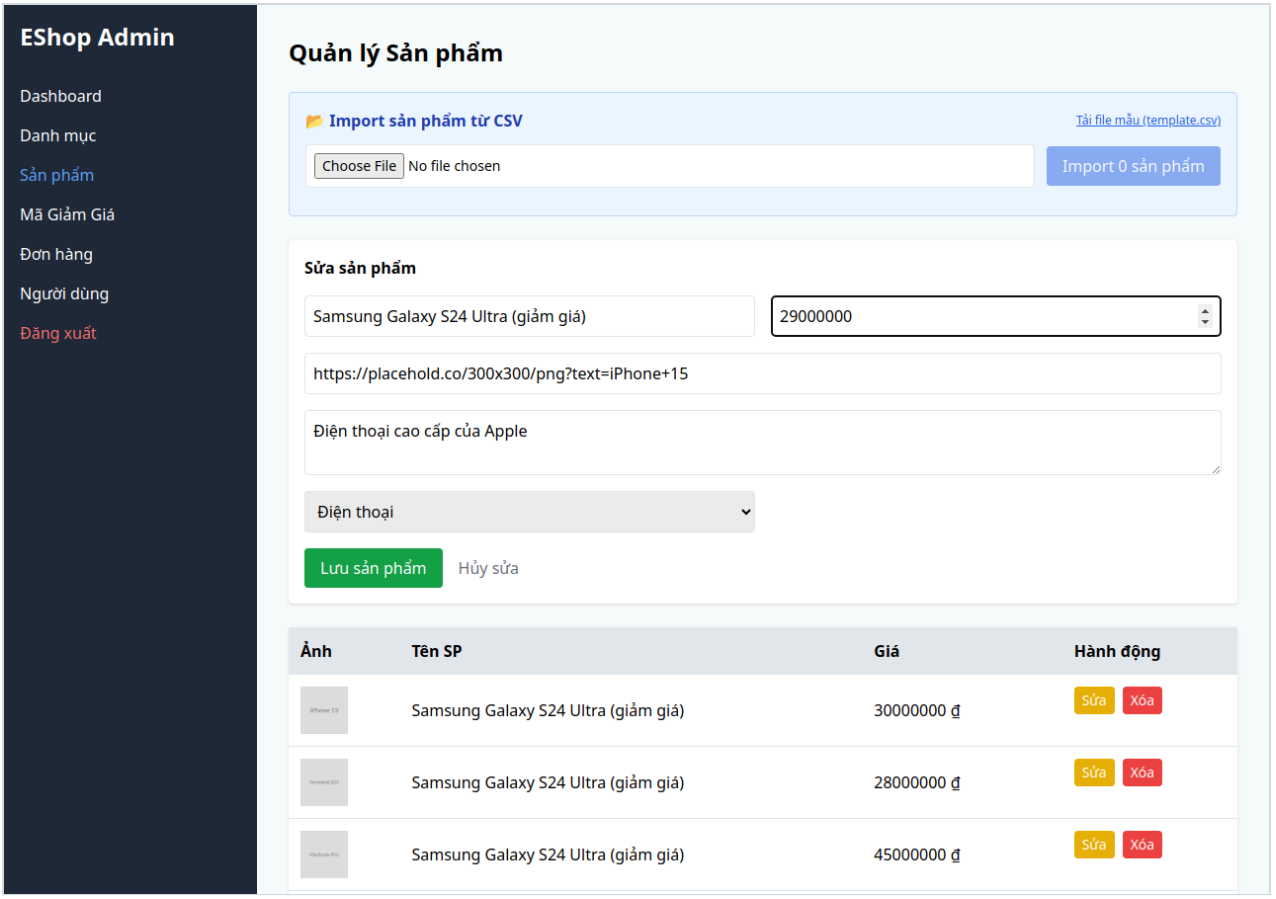
EP-02 cho thấy CSDL đúng, chỉ bảng hiển thị sai. Để đánh giá mức độ nghiêm trọng, mình chạy thêm một kịch bản admin làm việc bình thường (`fr15_mass_rename_probe.js`):

1. Sửa SP id 2: đổi tên thành "Samsung Galaxy S24 Ultra (giảm giá)" → Lưu. Bảng đổi tên **mọi** SP (ảnh



ảnh

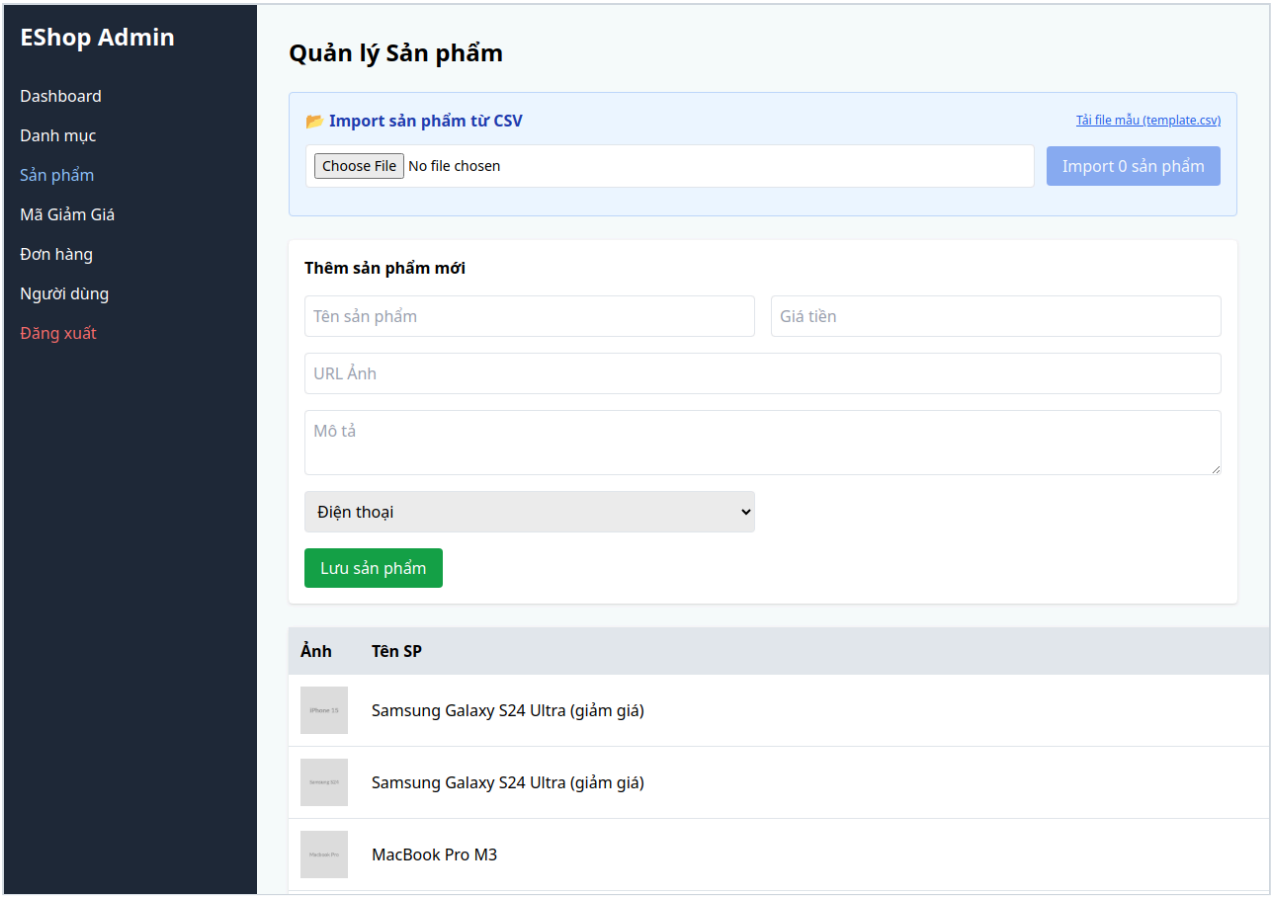
).
2. Bấm **Sửa** ở dòng đầu tiên (SP id 1, iPhone). Form điền sẵn tên **sai** "Samsung Galaxy S24 Ultra (giảm giá)". Admin chỉ đổi giá thành 29.000.000 → Lưu (ảnh



ảnh

).

3. Kết quả trong CSDL: SP id 1 đổi từ `iPhone 15 Pro Max` thành **`Samsung Galaxy S24 Ultra (giảm giá)`**. Sau khi tải lại trang, hai dòng đầu đều mang tên Samsung (ảnh



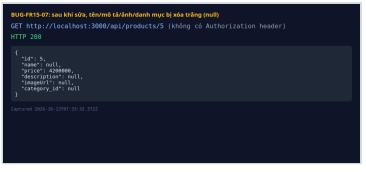
ảnh

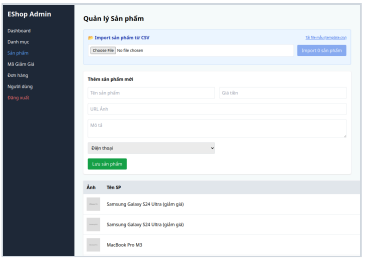
).

→ Lỗi hiển thị dẫn tới **hỏng dữ liệu thật** trong một thao tác rất bình thường của admin.

5.5b TC bổ sung sau AI gap analysis (chạy 2026-10-13, script `scripts/fr15_supplementary.js`)

Hai lớp/điểm mới được thêm ở Bước 7. Dữ liệu thô: `results_fr15_supplementary.json`.

TC	Lớp / điểm mới	Dữ liệu	Mong đợi	Thực tế	KQ
EP-23	EC22: Sửa **thiếu trường** (trường vắng mặt, khác với chuỗi rỗng)	`PUT /api/products/<id>` body `{"price":1700000}`	O2 (thiếu tên/danh mục bắt buộc), hoặc chỉ đổi giá và giữ nguyên các trường khác	HTTP 200. Giá đổi, nhưng **tên, mô tả, ảnh, danh mục đều thành `null`**	❌ ảnh  ảnh

TC	Lớp / điểm mới	Dữ liệu	Mong đợi	Thực tế	KQ
BVA-14	V1 UB với **ký tự tiếng Việt có dấu** (kiểm tra giả định A2)	Tên 255 ký tự `Tai nghe chống ồn – …` (329 byte UTF-8), UI + API	O1a, lưu đủ 255 ký tự	Lưu đủ 255 ký tự trên cả hai kênh	✅ ảnh  ảnh

5.6 Tổng hợp

Nhóm	Số TC	Pass	Fail	Không thực thi
EP	22	4 (EP-01, 03, 04, 05)	18	0
BVA	13	8 (BVA-01, 03, 04, 05, 06, 09, 10, 11)	5 (BVA-02, 07, 08, 12, 13)	0
Bổ sung (gap)	2	1 (BVA-14)	1 (EP-23)	0
Tổng	**37**	**13**	**24**	**0**

Theo kênh: API 35 lượt (14 Pass, 21 Fail), UI 27 lượt (15 Pass, 12 Fail). Có 27 ảnh UI, 2 ảnh trang web (EP-04) và 3 ảnh thăm dò.

Nhận xét: Mọi TC Pass đều là TC hợp lệ. Không một lớp không hợp lệ nào bị server từ chối. Toàn bộ khả năng từ chối của tính năng chỉ đến từ thuộc tính `required` của ô Tên trên UI.

Phụ lục 20 — `features/FR-15_ProductCRUD/06_bug_report.md`

FR-15 Quản lý sản phẩm (CRUD): Bước 6, Báo cáo lỗi

Môi trường chung: EShop `85af3ba`, Backend `localhost:3000`, Admin `localhost:5174`, Web `localhost:5173`, Chromium 131, DB seed mặc định. Thời điểm phát hiện: 2026-10-13.

Bug ID	Tiêu đề	Severity	Priority	TC phát hiện	Issue
BUG-FR15-01	API Thêm/Sửa/Xóa sản phẩm không yêu cầu đăng nhập và quyền admin	**Critical**	P1	EP-17, EP-18, EP-19, EP-20	#16
BUG-FR15-02	Sửa 1 sản phẩm thì bảng Admin đổi tên **mọi** sản phẩm, lần sửa tiếp theo ghi tên sai vào CSDL	**Critical**	P1	EP-02, EP-22, BVA-12, BVA-13	#17
BUG-FR15-03	Không kiểm tra giá: chấp nhận 0, số âm, rỗng, chữ (API và UI)	Major	P1	EP-09, EP-10, EP-11, EP-12, EP-22, BVA-08	#18
BUG-FR15-04	Không kiểm tra tên: chấp nhận tên dài hơn 255 ký tự, tên chỉ có khoảng trắng; API chấp nhận tên rỗng	Major	P2	EP-06, EP-07, EP-08, EP-21, BVA-02, BVA-07, BVA-13	#19
BUG-FR15-05	API chấp nhận danh mục rỗng hoặc không tồn tại	Major	P2	EP-13, EP-14	#20
BUG-FR15-06	Sửa/Xóa sản phẩm không tồn tại vẫn trả về thành công (HTTP 200)	Minor	P3	EP-15, EP-16	#21
BUG-FR15-07	Sửa sản phẩm mà thiếu trường trong request thì xóa trắng tên, mô tả, ảnh, danh mục	Major	P2	EP-23 (TC bổ sung sau gap analysis)	#22

BUG-FR15-01: API Thêm/Sửa/Xóa sản phẩm không yêu cầu đăng nhập và quyền admin

- **Tính năng & kỹ thuật:** FR-15 kết hợp FR-12/SEC-02/SEC-03. EP với các lớp EC18 (không token) và EC19 (token user thường), kiểm tra trên cả 3 thao tác.
- **Severity:** Critical (bảo mật). **Bất kỳ ai** biết địa chỉ API đều có thể tạo, sửa giá, đổi tên hoặc xóa toàn bộ sản phẩm của cửa hàng mà không cần đăng nhập.

Các bước tái hiện

1. `POST /api/products` **không có** header `Authorization`, body `{"name":"SP tạo bởi người lạ","price":1000,"category_id":1}`.
2. `POST /api/products` với token của `test@eshop.com` (role `user`).
3. `PUT /api/products/<id>` không có token, body đổi tên.
4. `DELETE /api/products/6` không có token, rồi `GET /api/products/6`.

Kết quả mong đợi (FR-12): Bước 1, 3, 4 trả **401**. Bước 2 trả **403**. Dữ liệu không đổi.

Kết quả thực tế: Cả 4 request đều trả **HTTP 200**. Sản phẩm được tạo/đổi tên/xóa thật. `GET /api/products/6` trả `{}`.

Minh chứng: BUG-FR15-01_api_create_no_token.png

BUG-FR15-01 (EP-17): POST /api/products KHÔNG có token vẫn tạo được sản phẩm

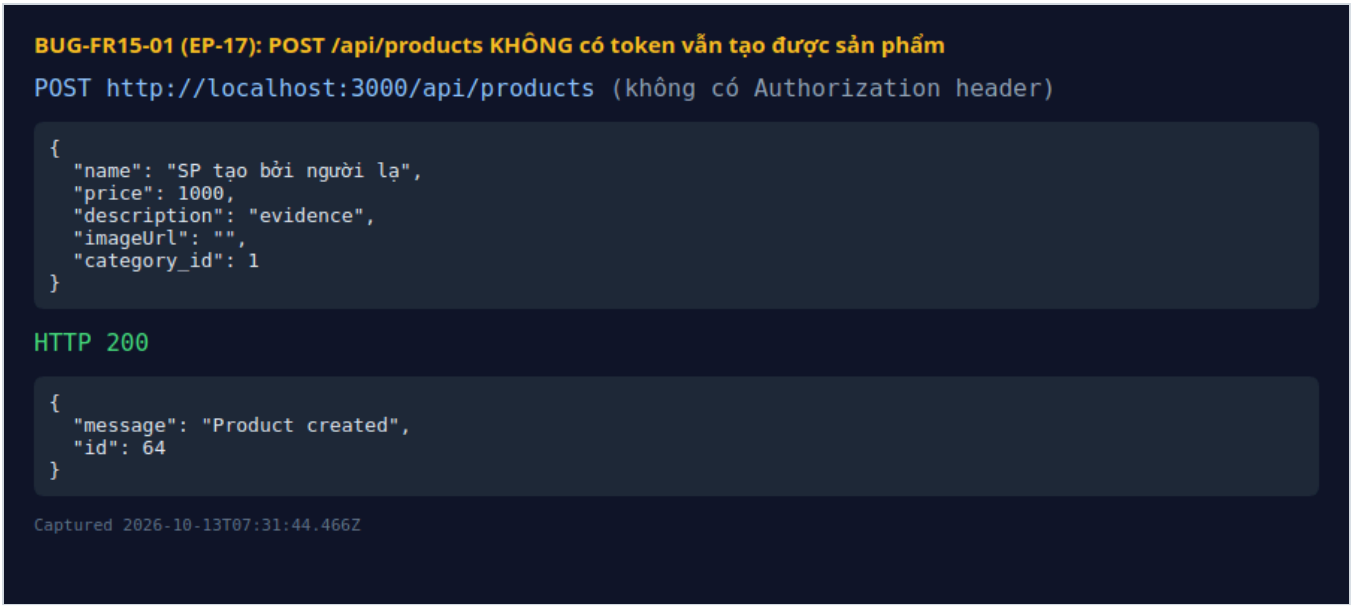
POST http://localhost:3000/api/products (không có Authorization header)

```
{
  "name": "SP tạo bởi người lạ",
  "price": 1000,
  "description": "evidence",
  "imageUrl": "",
  "category_id": 1
}
```

HTTP 200

```
{
  "message": "Product created",
  "id": 64
}
```

Captured 2026-10-13T07:31:44.466Z



BUG-FR15-01_api_create_no_token.png

, BUG-FR15-01_api_create_user_token.png

BUG-FR15-01 (EP-18): token của user thường (role=user) vẫn tạo được sản phẩm

POST http://localhost:3000/api/products (Bearer token: user)

```
{
  "name": "SP tạo bởi user thường",
  "price": 1000,
  "description": "evidence",
  "imageUrl": "",
  "category_id": 1
}
```

HTTP 200

```
{
  "message": "Product created",
  "id": 65
}
```

Captured 2026-10-13T07:31:44.536Z



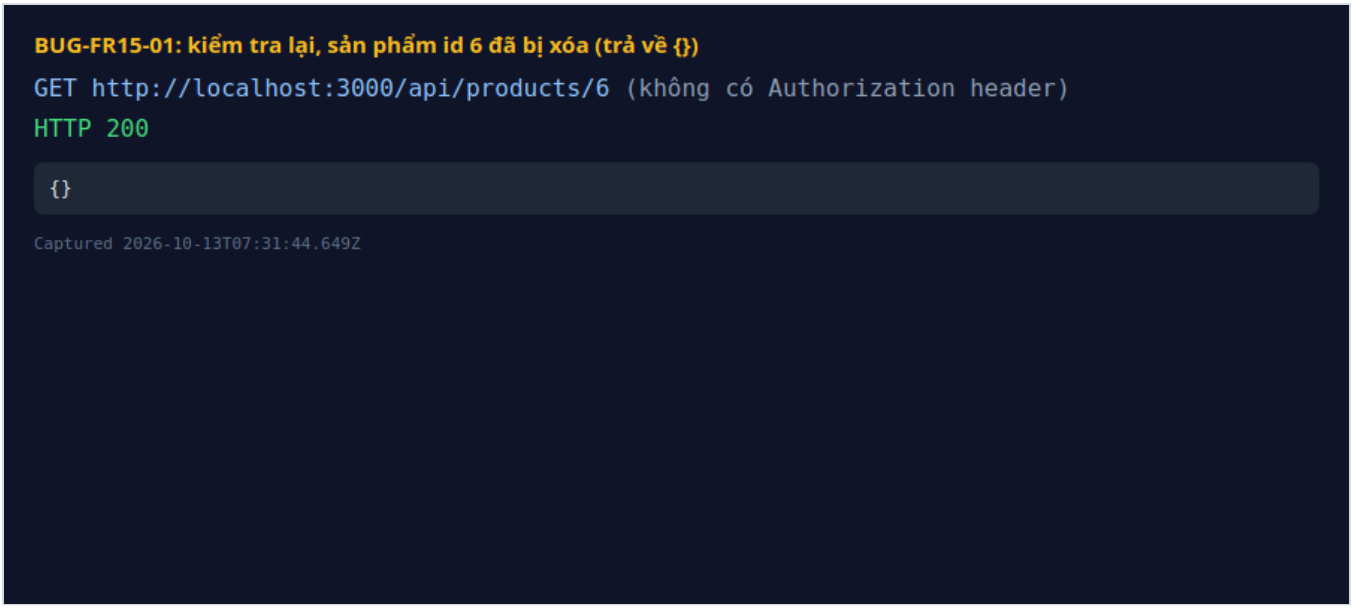
BUG-FR15-01_api_create_user_token.png

, BUG-FR15-01_api_delete_no_token.png



BUG-FR15-01_api_delete_no_token.png

, BUG-FR15-01_api_after_delete.png



BUG-FR15-01_api_after_delete.png

BUG-FR15-02: Sửa 1 sản phẩm thì bảng Admin đổi tên mọi sản phẩm, lần sửa tiếp theo ghi tên sai vào CSDL

- **Tính năng & kỹ thuật:** FR-15 ràng buộc R5 ("chỉ sản phẩm đó bị thay đổi"). EP với lớp đầu ra EC20, phát hiện nhờ hậu kiểm so sánh **toàn bộ** bảng trước/sau.
- **Severity:** Critical. Lỗi hiển thị dẫn tới **hỏng dữ liệu thật** trong thao tác bình thường của admin (xem bước 4–6).

Các bước tái hiện

1. Đăng nhập Admin `http://localhost:5174` (`admin@eshop.com`), mở tab **Sản phẩm**.
2. Bấm **Sửa** ở dòng "Samsung Galaxy S24 Ultra". Đổi tên thành `Samsung Galaxy S24 Ultra (giảm giá)` → **Lưu sản phẩm** → OK ở alert "Cập nhật thành công!".
3. Quan sát cột **Tên SP**.

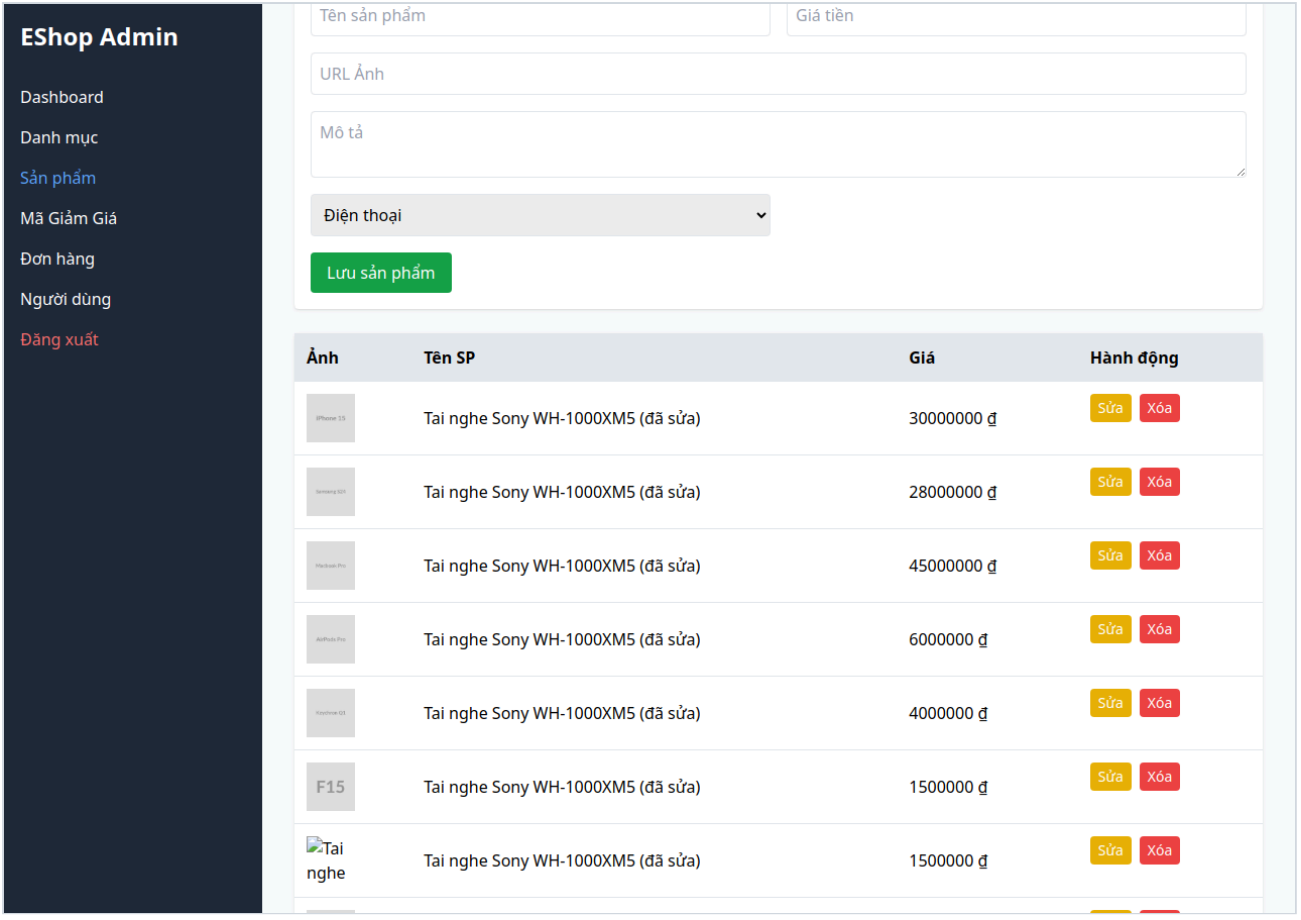
4. Không tải lại trang, bấm **Sửa** ở dòng đầu tiên (iPhone 15 Pro Max, id 1).
5. Chỉ đổi Giá thành `29000000` → **Lưu sản phẩm**.
6. Tải lại trang (F5) và xem lại bảng.

Kết quả mong đợi: Bước 3: chỉ dòng Samsung đổi tên. Bước 4: form hiện tên "iPhone 15 Pro Max". Bước 6: SP id 1 vẫn tên "iPhone 15 Pro Max", giá 29.000.000.

Kết quả thực tế

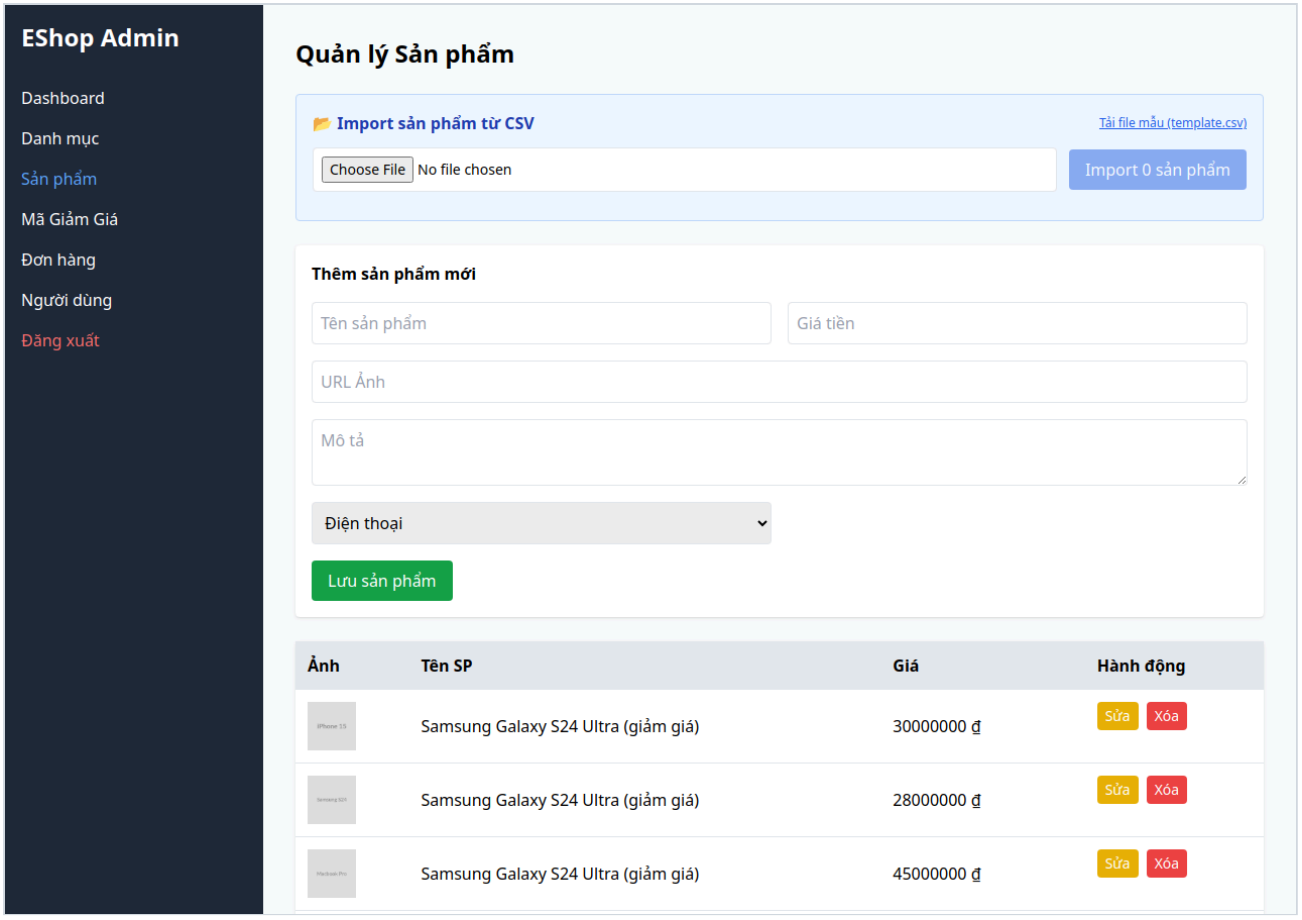
- Bước 3: **mọi** dòng trong bảng đều mang tên `Samsung Galaxy S24 Ultra (giảm giá)`. Trong CSDL, chỉ SP được sửa thay đổi.
- Bước 4: form điền sẵn tên **sai** `Samsung Galaxy S24 Ultra (giảm giá)`.
- Bước 6: SP id 1 bị **đổi tên thật** trong CSDL thành `Samsung Galaxy S24 Ultra (giảm giá)`.

Minh chứng: EP-02_ui.png



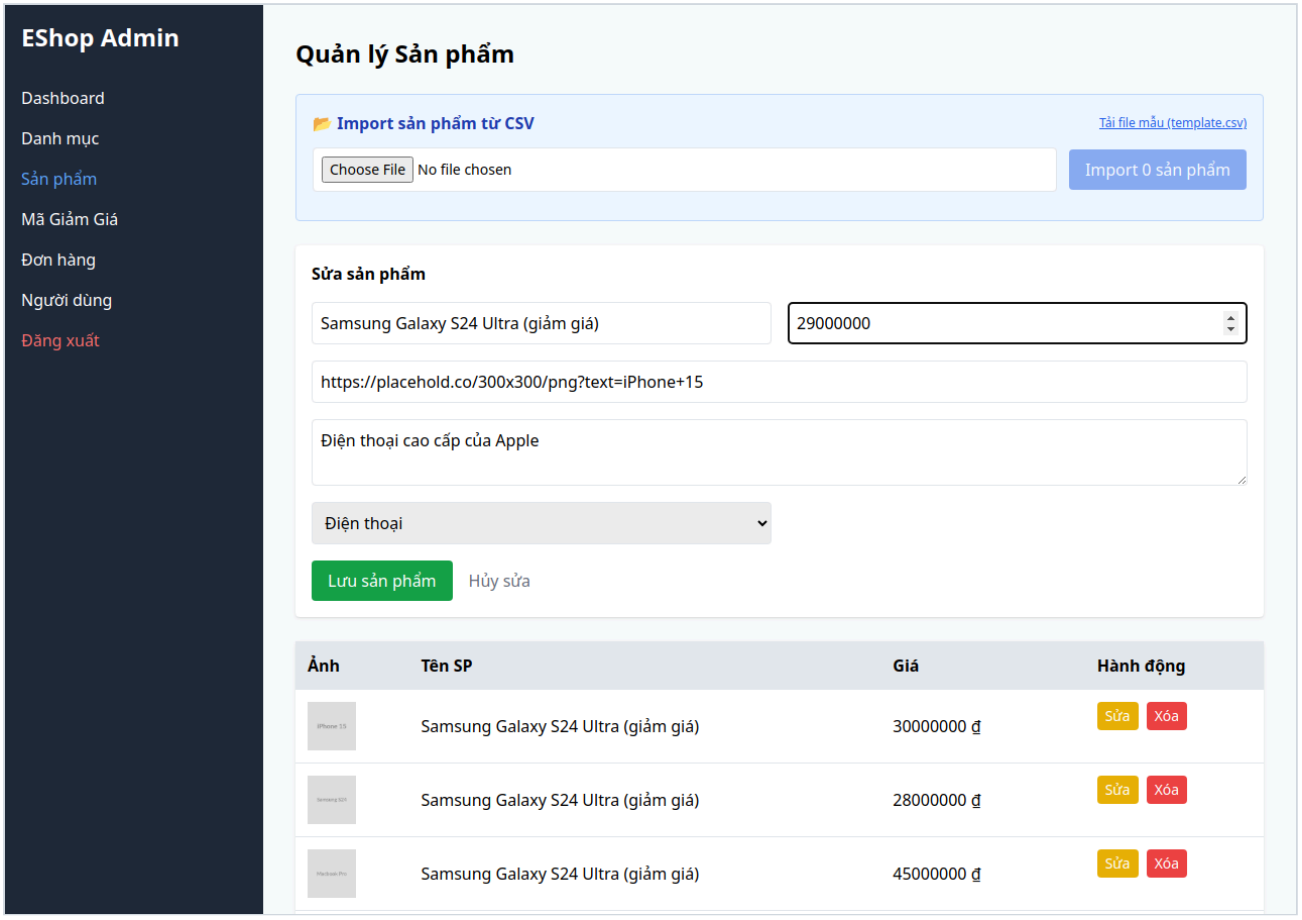
EP-02_ui.png

, BUG-FR15-02_step1_table_after_edit.png



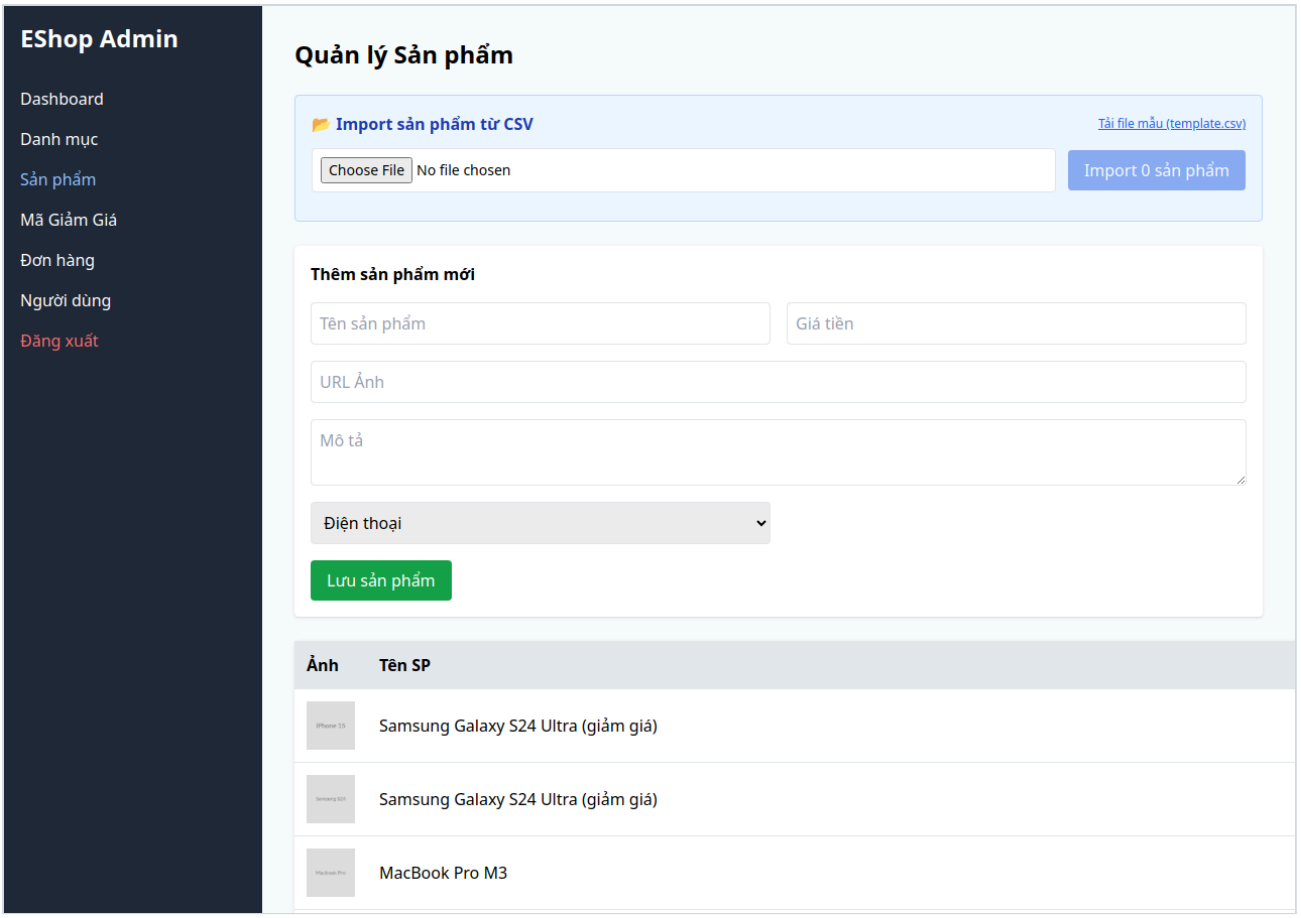
BUG-FR15-02_step1_table_after_edit.png

, BUG-FR15-02_step2_edit_iphone_form.png



BUG-FR15-02_step2_edit_iphone_form.png

, BUG-FR15-02_step3_after_reload.png



BUG-FR15-02_step3_after_reload.png

BUG-FR15-03: Không kiểm tra giá, chấp nhận 0, số âm, rỗng, chữ (API và UI)

- **Tính năng & kỹ thuật:** FR-15 R3. EP với các lớp EC8–EC11; BVA tại LB−1 = 0 của V2. Kiểm tra trên cả Thêm và Sửa.
- **Severity:** Major. Sản phẩm giá 0 hoặc âm xuất hiện trên cửa hàng. Khách có thể "mua" với giá âm, và tổng đơn hàng bị sai.

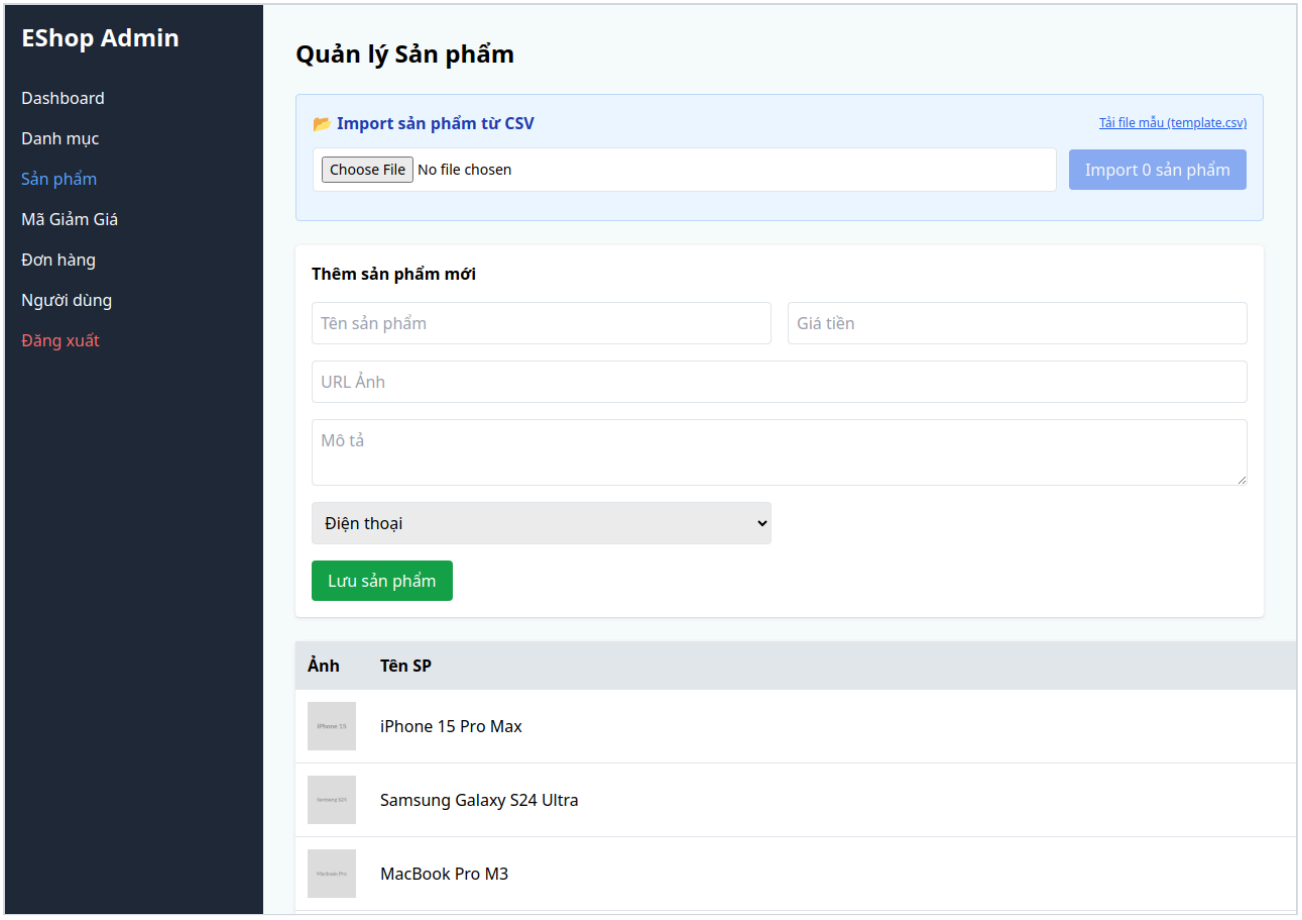
Các bước tái hiện

1. Admin → **Sản phẩm** → Thêm: Tên `Tai nghe Sony WH-1000XM5`, Giá lần lượt `0`, `-1000`, để trống; Danh mục Laptop → **Lưu sản phẩm**.
2. Bấm **Sửa** một sản phẩm, đổi Giá thành `0` → **Lưu sản phẩm**.
3. API: `POST /api/products` (token admin) với `"price": -1000` và `"price": "abc"`.

Kết quả mong đợi: Từ chối và báo "Giá phải là số dương". Không tạo hay sửa sản phẩm.

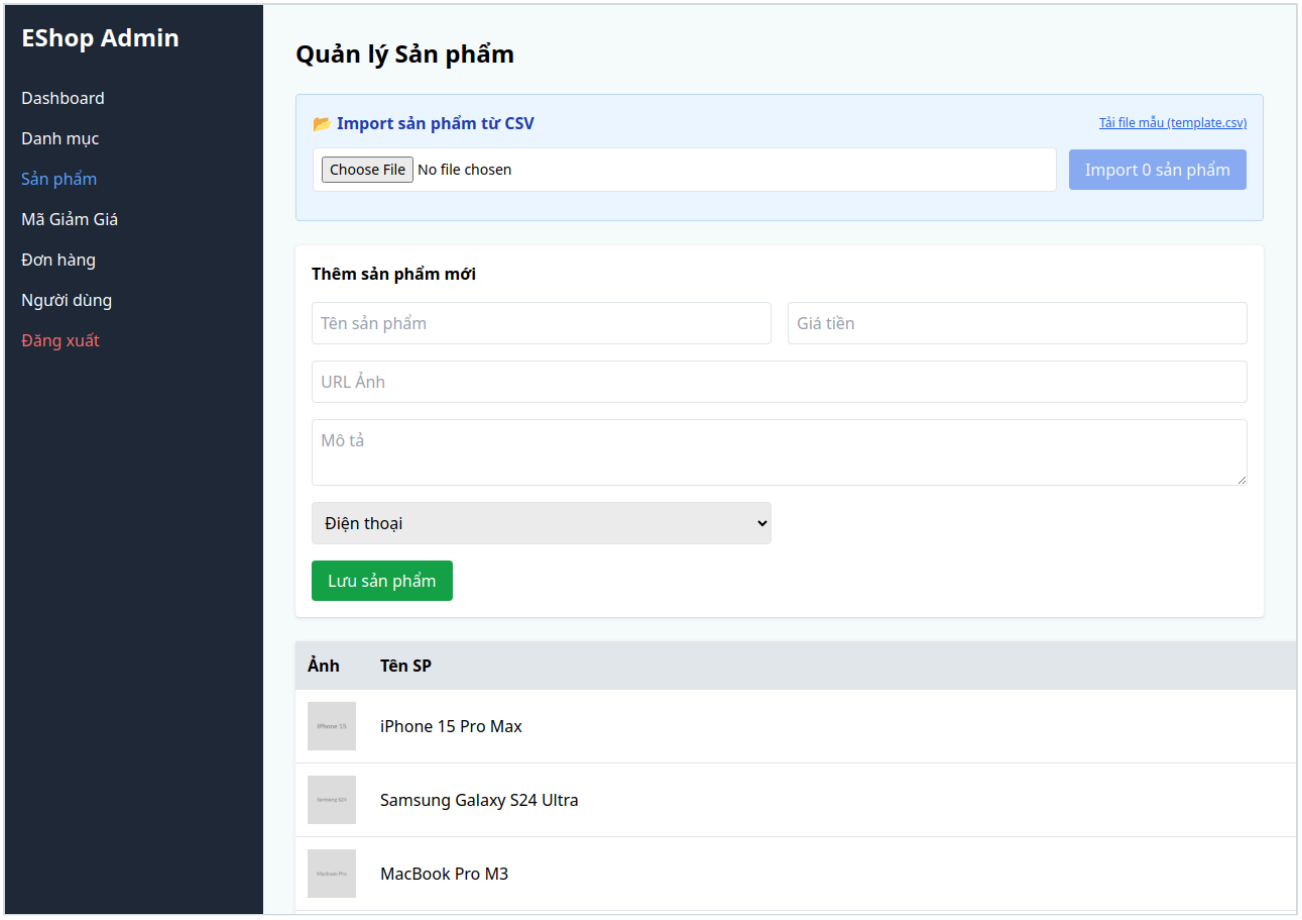
Kết quả thực tế: Mọi trường hợp đều được lưu: giá `0`, `-1000`, `""`, `"abc"`. Ô Giá trên UI không có `required` / `min`. Với ô `type="number"`, gõ chữ thì ô thành rỗng, và form vẫn lưu SP với giá rỗng.

Minh chứng: EP-10_ui.png



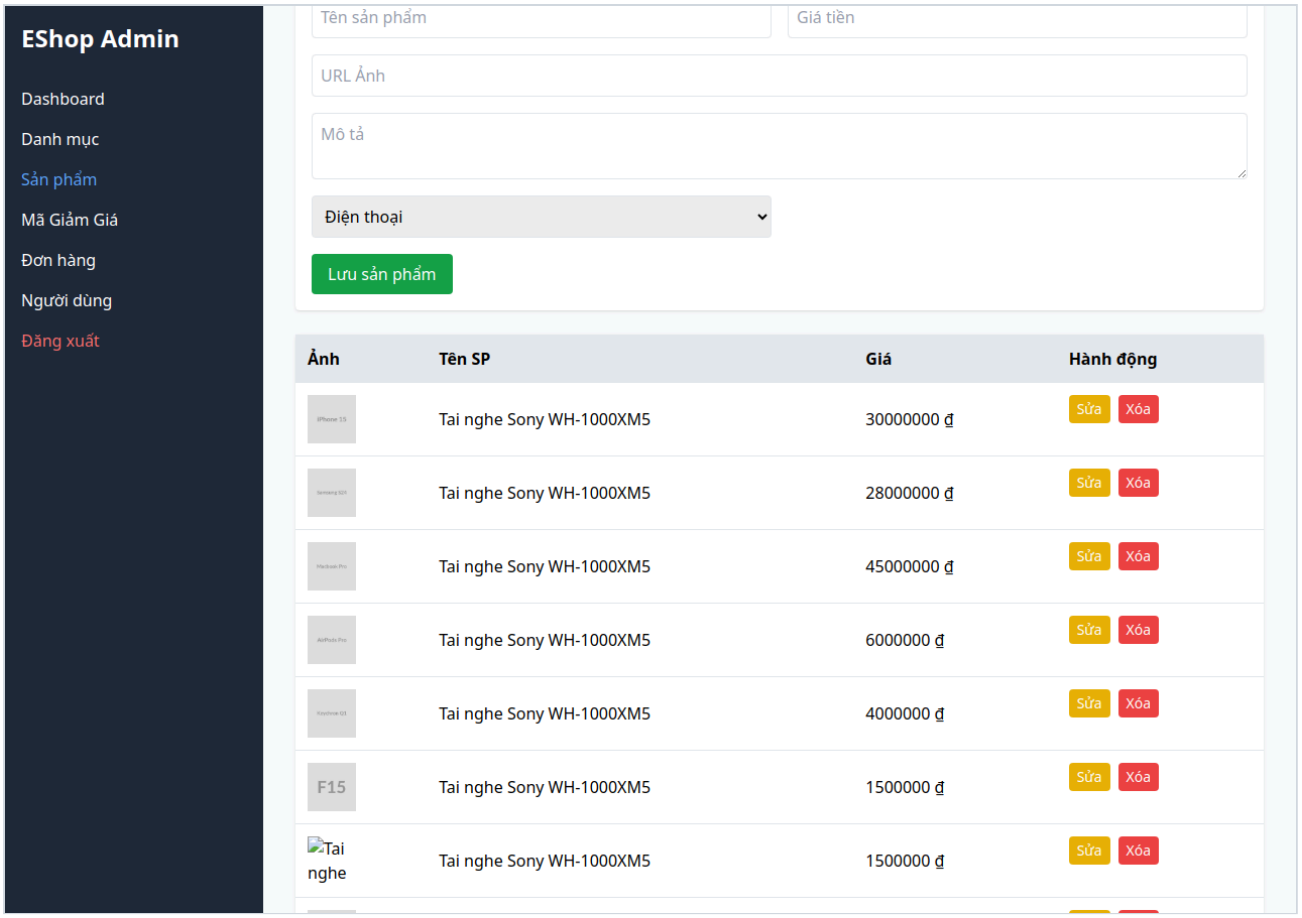
EP-10_ui.png

, EP-11_ui.png



EP-11_ui.png

, EP-22_ui.png



EP-22_ui.png

, BUG-FR15-03_api_negative_price.png



BUG-FR15-03_api_negative_price.png

, BUG-FR15-03_api_text_price.png



BUG-FR15-03_api_text_price.png

BUG-FR15-04: Không kiểm tra tên, chấp nhận > 255 ký tự và chỉ khoảng trắng; API chấp nhận tên rỗng

- **Tính năng & kỹ thuật:** FR-15 R2. EP với các lớp EC3, EC4, EC5; BVA V1 tại LB−1 = 0 và UB+1 = 256, trên cả Thêm và Sửa.
- **Severity:** Major

Các bước tái hiện

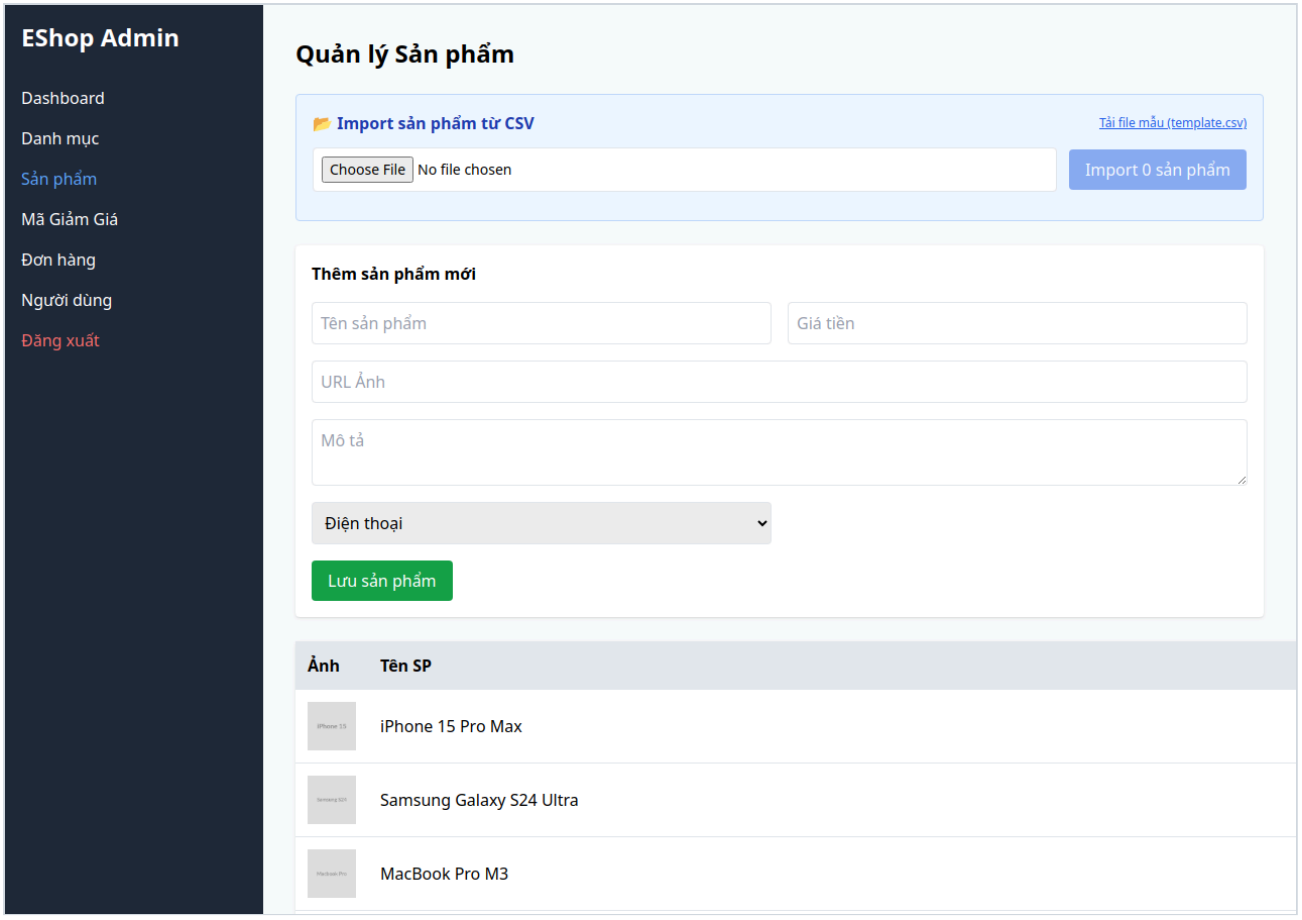
1. Admin → Thêm: Tên là chuỗi **256** ký tự (`BVA15-xxx…`) → **Lưu sản phẩm**.
2. Thêm với Tên `" "` (3 khoảng trắng).
3. API: `POST /api/products` (token admin) với `"name": ""`. Lặp lại với `PUT` trên một SP có sẵn.

Kết quả mong đợi: Từ chối cả 3 trường hợp, kèm thông báo "Tên bắt buộc, tối đa 255 ký tự".

Kết quả thực tế

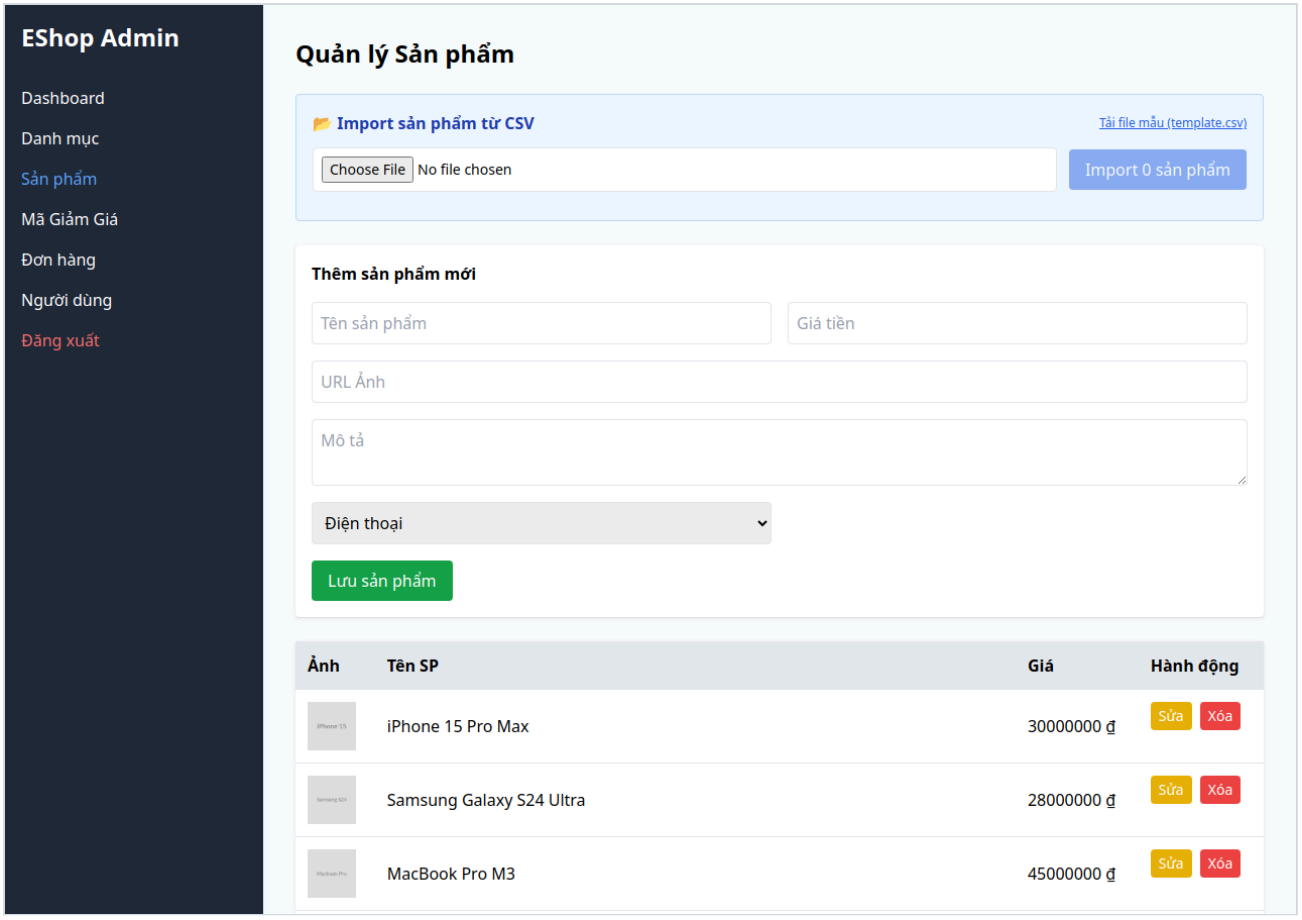
- Tên 256 và 300 ký tự được lưu đầy đủ, không bị cắt hay báo lỗi. Trong khi đó 255 ký tự (UB) cũng lưu bình thường, tức là **không có biên trên**.
- Tên chỉ khoảng trắng được lưu trên cả UI lẫn API.
- Tên rỗng: UI chặn nhờ HTML5 `required`, nhưng **API chấp nhận** cả khi Thêm lẫn khi Sửa.

Minh chứng: BVA-07_ui.png



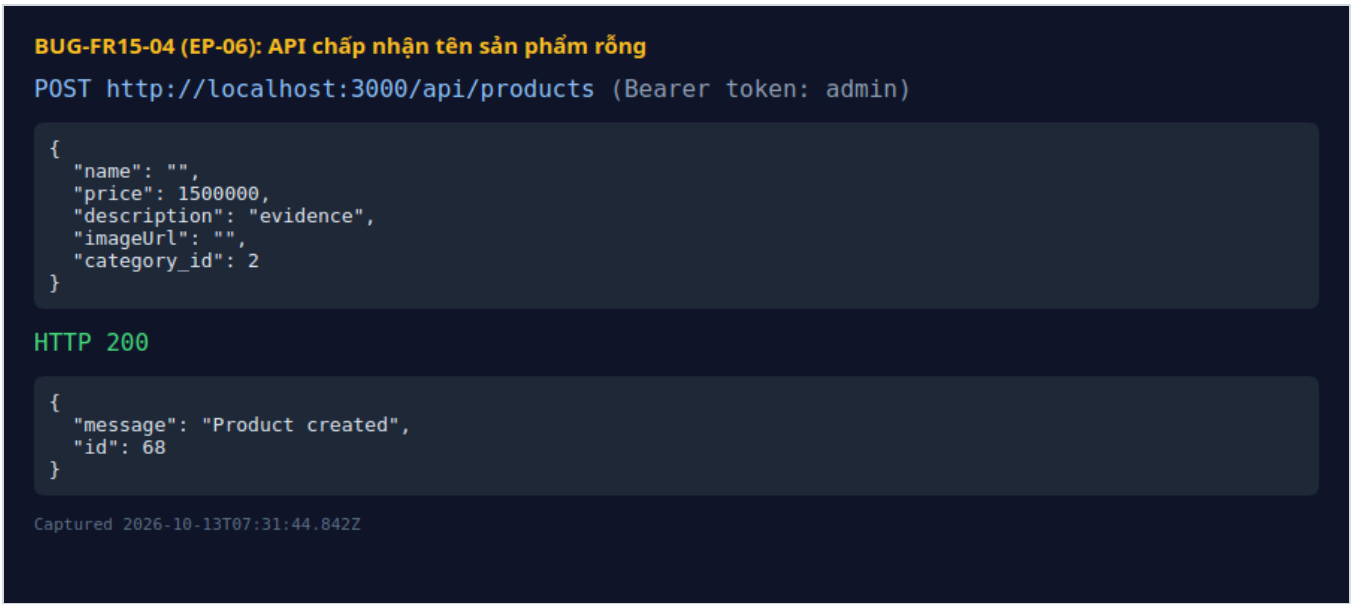
BVA-07_ui.png

, EP-07_ui.png



EP-07_ui.png

, BUG-FR15-04_api_empty_name.png



BUG-FR15-04_api_empty_name.png

BUG-FR15-05: API chấp nhận danh mục rỗng hoặc không tồn tại

- **Tính năng & kỹ thuật:** FR-15 R4, EP với các lớp EC13, EC14 (giả định A5)
- **Severity:** Major. Sản phẩm "mồ côi" không thuộc danh mục nào, nên không xuất hiện khi lọc theo danh mục.

Các bước tái hiện: `POST /api/products` (token admin) với `"category_id": 999`, rồi với `"category_id": null`.

Kết quả mong đợi: HTTP 400 "Danh mục không hợp lệ".

Kết quả thực tế: HTTP 200, sản phẩm được tạo với `category_id = 999` / `null`. Chỉ có dropdown trên UI ngăn được lỗi này.

Minh chứng: BUG-FR15-05_api_category_999.png



BUG-FR15-05_api_category_999.png

BUG-FR15-06: Sửa/Xóa sản phẩm không tồn tại vẫn trả về thành công (HTTP 200)

- **Tính năng & kỹ thuật:** FR-15, EP với lớp EC16 (giả định A6)
- **Severity:** Minor. Không làm hỏng dữ liệu, nhưng client nhận phản hồi "thành công" sai sự thật.

Các bước tái hiện: `PUT /api/products/99999` và `DELETE /api/products/99999` (token admin).

Kết quả mong đợi: HTTP 404 "Không tìm thấy sản phẩm".

Kết quả thực tế: HTTP 200 `{"message":"Product updated"}` / `{"message":"Product deleted"}`.

Minh chứng: BUG-FR15-06_api_update_missing.png



BUG-FR15-06_api_update_missing.png

BUG-FR15-07: Sửa sản phẩm mà thiếu trường trong request thì xóa trắng tên, mô tả, ảnh, danh mục

- **Tính năng & kỹ thuật:** FR-15 R2, R4, R5. EP với lớp bổ sung EC22 "thiếu trường khi Sửa" (xem 07_ai_gap_analysis.md).
- **Severity:** Major. Một client chỉ muốn đổi giá (ví dụ một công cụ cập nhật giá hàng loạt) sẽ **mất dữ liệu** tên và danh mục của sản phẩm. Kết quả là một sản phẩm vi phạm R2/R4 tồn tại trong CSDL.

Các bước tái hiện

1. `GET /api/products/5`: SP "Bàn phím cơ Keychron Q1", danh mục 3.
2. `PUT /api/products/5` (token admin), body chỉ có `{"price": 4200000}`.
3. `GET /api/products/5`.

Kết quả mong đợi: Từ chối (HTTP 400, thiếu tên/danh mục bắt buộc), **hoặc** chỉ cập nhật giá và giữ nguyên các trường khác.

Kết quả thực tế: HTTP 200 `"Product updated"`. SP id 5 còn `price = 4200000`, nhưng `name`, `description`, `imageUrl`, `category_id` đều thành `null`.

Minh chứng: BUG-FR15-07_api_before.png



BUG-FR15-07_api_before.png

, BUG-FR15-07_api_partial_put.png



BUG-FR15-07_api_partial_put.png

, BUG-FR15-07_api_after.png



BUG-FR15-07_api_after.png

Quan sát ngoài phạm vi FR-15 (không tính là bug của tính năng này)

- Form không có dấu `*` cho các trường bắt buộc (FR-22). Nút **Lưu sản phẩm** màu xanh lá, **Sửa** màu vàng (FR-21: nút tích cực màu xanh dương).
- Cột Giá hiển thị `1500000 ₫`, không có phân cách hàng nghìn (FR-21).
- Nút **Xóa** xóa ngay, không có hộp thoại xác nhận. FR-15 không yêu cầu, nhưng đây là thao tác không hoàn tác được.
- Lỗi lưu được báo bằng `alert()` thay vì thông báo phía trên nút submit (FR-22).

Phụ lục 21 — `features/FR-15_ProductCRUD/07_ai_gap_analysis.md`

FR-15 Quản lý sản phẩm (CRUD): Bước 7, AI Gap Analysis

Công cụ AI: Claude Code (model Claude Opus 5.5), chạy trong terminal ngày 2026-10-13. Nhật ký đầy đủ: `ai-audit/`.

Các bài học đã áp dụng từ FR-01, FR-09:

- Đối chiếu chéo toàn SRS (FR-12, SEC-02/03/04). Nhờ đó BUG-FR15-01 (Critical) được thiết kế sẵn trong EP.
- Có lớp tên tiếng Việt và HTML (EC2) ngay từ Bước 2.
- Chạy TC hợp lệ trước để kiểm tra masking.
- Hậu kiểm **toàn bộ** danh sách sản phẩm, không chỉ bản ghi của TC. Nhờ đó tìm ra BUG-FR15-02.

7.1 Những gì AI bỏ sót hoặc làm sai

#	Gap	Loại	Phát hiện ở đâu	Nguyên nhân	Xử lý
G1	Không phân biệt **"trường vắng mặt"** với **"trường rỗng"**. EC3 chỉ dùng `name: ""`, chưa bao giờ gửi request **thiếu hẳn** trường `name` khi Sửa	Thiếu TC, **bỏ sót bug Major**	Rà soát sau thực thi: đọc lại API spec (PUT dùng chung body với POST)	**Hạn chế của AI:** phân hoạch trên giá trị của trường, mà không phân hoạch trên **cấu trúc** của request. Ở API, "có mặt hay không" là một chiều độc lập	Thêm EC22, TC EP-23 → Fail, ghi thành BUG-FR15-07 (xóa trắng tên/danh mục)
G2	Giả định A2 (đếm theo ký tự) đã nêu ra, nhưng mọi giá trị BVA đều **cố ý dùng ASCII để né** giả định này. Vì vậy biên 255 chưa từng được thử với ký tự nhiều byte	Thiếu điểm biên	Rà soát sau thực thi	**AI chọn cách an toàn** là tránh sự mơ hồ, thay vì kiểm thử nó	Thêm BVA-14 (255 ký tự tiếng Việt, 329 byte) → Pass
G3	Ở EP-12 trên UI, AI dự kiến "ô số không nhận chữ" là đủ để Pass. Thực tế ô thành rỗng và form vẫn lưu, tức lớp EC11 trên UI **sụp thành** EC8 (giá rỗng). Một TC rơi vào 2 lớp	Thiết kế TC chưa chặt	Khi thực thi	**Thiếu hiểu biết về hành vi trình duyệt:** `type="number"` biến chữ thành chuỗi rỗng	Ghi rõ ở §5.3. Kết quả UI của EP-12 được giải thích là trùng EP-09
G4	**Rò rỉ kiến thức hộp trắng.** Lỗi đổi tên hàng loạt trên bảng Admin (BUG-FR15-02) đã lộ ra khi AI đọc mã nguồn frontend lúc tìm hiểu SUT. Yêu cầu so sánh **cả bảng UI** sau khi sửa có thể đã bị ảnh hưởng bởi điều này	Sai phương pháp	Sinh viên tự rà soát	**Ngữ cảnh của AI** chứa mã nguồn	Lớp EC20 có căn cứ trực tiếp từ R5 của spec ("các sản phẩm khác giữ nguyên"). Phần thăm dò §5.5 (hỏng dữ liệu thật) là phát hiện mới, không có sẵn trong code
G5	Ban đầu AI xếp BUG-FR15-02 là **lỗi hiển thị** (Major). Chỉ khi thử thêm "thao tác tiếp theo của admin" mới thấy lỗi gây **hỏng dữ liệu thật**, và nâng lên Critical	Đánh giá severity thấp	Thăm dò §5.5	**Hạn chế của AI:** đánh giá mức độ dựa trên trạng thái ngay sau TC, không xét chuỗi thao tác tiếp theo	Bổ sung kịch bản thăm dò và nâng severity

7.2 Các TC vẫn chưa được thiết kế (rủi ro còn lại)

Lớp chưa phủ	Lý do chưa làm
HTML/script trong **Mô tả** và **URL Ảnh** (SEC-04)	FR-15 không ràng buộc hai trường này. Chỉ kiểm tra tên
Ảnh hưởng dây chuyền của dữ liệu sai: SP giá âm/rỗng xuất hiện ở trang chủ, giỏ hàng, thanh toán	Thuộc FR-05/FR-07/FR-08. Nên test hồi quy sau khi sửa BUG-FR15-03
Hai admin sửa cùng một SP đồng thời	Kiểm thử đồng thời
Xóa danh mục đang có sản phẩm (FR-14 ↔ FR-15)	Thuộc FR-14
Tên trùng nhau giữa các SP	Spec không yêu cầu tên duy nhất

7.3 Bài học

1. **API có thêm một chiều phân hoạch là cấu trúc request.** Ngoài giá trị của trường, cần xét: trường có mặt / vắng mặt / `null` / sai kiểu (G1).
2. **Đừng né giả định, hãy kiểm thử nó** (G2). Mỗi giả định ở Bước 1 nên có ít nhất 1 TC chạm vào nó.
3. **Severity phải xét cả chuỗi thao tác của người dùng thật**, không chỉ trạng thái ngay sau TC (G5).
4. **EP thuần trên tính năng toàn lỗi validation cho kết quả "hiển nhiên"**: mọi lớp không hợp lệ đều Fail. Giá trị thật nằm ở các lớp **đầu ra** (EC20, EC21) và ở hậu kiểm, vì đây mới là nơi tìm ra lỗi Critical không hiển nhiên.

Phụ lục 22 — `features/FR-20_Mobile_Cart/01_input_output.md`

FR-20 Mobile: Giỏ hàng & Số lượng, Bước 1: Xác định Input & Output

> Kỹ thuật: Phân hoạch tương đương, bước 1/3 (slide Bài 4, tr.6–7). Cơ sở kiểm thử: SRS EShop mục **FR-20**: ứng dụng mobile phải có "đầy đủ các chức năng: ... Giỏ hàng ...". Vì FR-20 không mô tả lại giỏ hàng, các quy tắc nghiệp vụ được lấy từ **FR-07** (Giỏ hàng) và **FR-06** (ô Số lượng), đúng như phạm vi "Quản lý giỏ hàng & Số lượng" của Pool D.

1.1 Trích yêu cầu từ SRS

Mã	Nguồn	Nội dung đặc tả
R1	FR-06	Ô **Số lượng** chỉ nhận **số nguyên dương, tối thiểu là 1**
R2	FR-06	Sau khi bấm **Thêm vào giỏ hàng** phải có phản hồi trực quan (toast hoặc badge cập nhật)
R3	FR-07	Giỏ hiển thị các cột **Sản phẩm, Đơn giá, Số lượng (có nút +/- để chỉnh), Thành tiền, Thao tác**
R4	FR-07	Thêm **cùng một sản phẩm** thì **tăng số lượng**, không tạo dòng mới
R5	FR-07	Nút **Xóa sản phẩm** phải có **dialog xác nhận** trước khi xóa
R6	FR-07	Có nút **Tiếp tục mua sắm** để quay về trang chủ
R7	FR-07	Tổng tiền dùng nhãn chính xác **"Tổng cộng"** (không phải "Tổng tạm tính")
R8	FR-07	Giỏ trống có **hình minh họa** và **thông báo rõ ràng**
R9	FR-07 (ngầm định)	Thành tiền = Đơn giá × Số lượng; Tổng cộng = Σ Thành tiền
R10	FR-21	Tiền dùng `₫` và có phân cách hàng nghìn

Yêu cầu đã xem nhưng không đưa vào phạm vi: FR-08 (thanh toán) và FR-20 phần Hủy đơn thuộc tính năng khác. Riêng việc giỏ hàng được gửi đúng khi thanh toán liên quan trực tiếp đến dữ liệu giỏ, nên được ghi vào phần rủi ro ở Bước 7.

1.2 Biến đầu vào (Input)

Mã	Input	Kiểu	Nơi nhập	Ràng buộc
I1	Số lượng khi thêm từ **trang chi tiết**	ô nhập (bàn phím số)	Chi tiết sản phẩm	R1
I2	Số lượng khi **sửa trong giỏ**	ô nhập trên từng dòng	Giỏ hàng	R1, R9
I3	Nút **+ / −**	thao tác	Giỏ hàng	R3, R1 (không xuống dưới 1)
I4	Số lần thêm **cùng một** sản phẩm	số nguyên ≥ 1	Danh sách / Chi tiết	R4
I5	Thao tác **Xóa** và lựa chọn trong dialog (Đồng ý / Hủy)	thao tác	Giỏ hàng	R5
I6	Trạng thái giỏ (trống / có hàng)	trạng thái	–	R8

1.3 Biến đầu ra (Output)

Mã	Output	Mô tả
O1	Giỏ cập nhật đúng	Số dòng, số lượng, Thành tiền và Tổng cộng đúng theo R4, R9; nhãn và định dạng đúng R7, R10
O2	Từ chối giá trị không hợp lệ	Số lượng sai **không** được đưa vào giỏ; có thông báo (hoặc ô nhập không nhận ký tự đó); giỏ giữ nguyên giá trị hợp lệ trước đó
O3	Xác nhận xóa	Hiện dialog. Đồng ý thì xóa dòng; Hủy thì giữ nguyên
O4	Giỏ trống	Hình minh họa, thông báo, nút Tiếp tục mua sắm

1.4 Các điều kiện cần phân hoạch

Điều kiện	Biến	Loại điều kiện (slide tr.10)
C1. Số lượng là số nguyên ≥ 1	I1, I2	Dãy giá trị `[1..∞)`, **có thứ tự nên áp dụng được BVA**
C2. Nút +/− tồn tại và chỉnh đúng ±1, không xuống dưới 1	I3	Dãy giá trị (qty sau khi bấm), **có biên tại 1**
C3. Cùng sản phẩm thì gộp dòng	I4	Boolean (cùng / khác sản phẩm)
C4. Xóa phải qua xác nhận	I5	Tập giá trị {Đồng ý, Hủy}
C5. Giỏ trống / có hàng	I6	Boolean
C6. Thành tiền, Tổng cộng, nhãn, định dạng đúng	O1	Điều kiện trên **đầu ra**

1.5 Điểm mơ hồ và giả định

#	Điểm mơ hồ	Giả định áp dụng
A1	Gặp số lượng không hợp lệ thì làm gì? Báo lỗi hay tự sửa?	Hệ thống phải **từ chối có thông báo** hoặc **không cho nhập** ký tự đó. **Âm thầm** đổi `0`, `-2`, `abc` thành 1 rồi vẫn thêm vào giỏ là **không đạt**, vì người dùng không biết giá trị đã bị đổi
A2	Không có số lượng tối đa	Không có biên trên. Dùng 1 TC giá trị lớn (999) để kiểm tra độ bền và định dạng tiền
A3	"Cột" trên màn hình điện thoại	Mỗi dòng giỏ có đủ 5 thông tin của R3 (có thể xếp dọc), kể cả nút +/−
A4	Hình minh họa giỏ trống	Phải có ít nhất một hình ảnh/biểu tượng, không chỉ có chữ

1.6 Kênh thực thi & môi trường (hộp đen)

- **Ứng dụng:** `frontend-mobile` (Expo SDK 54, React Native 0.81). Máy kiểm thử không có Android SDK/emulator. Vì vậy app được chạy bằng **Expo Web** (`npx expo start --web`, react-native-web), **mô phỏng thiết bị Pixel 5** (393×851, touch, user-agent mobile) qua Playwright.
- **Thay đổi môi trường (không sửa logic app):**
  1. `App.js` dòng 16: `API_URL` đổi thành IP LAN của máy chạy backend (`192.168.1.11`). Đây là thao tác cấu hình mà `setup_guide.md` yêu cầu.
  2. Cài thêm `react-native-web`, `react-dom`, `@expo/metro-runtime` bằng `npx expo install` để render được bản web.
- **Giới hạn của Expo Web:** `Alert.alert` của React Native **không hiển thị** trên web. Các TC chỉ quan sát **hiệu ứng** (giỏ thay đổi hay không), không dựa vào việc có thấy hộp thoại Alert hay không. Với R5: nếu app có xác nhận bằng Alert, trên web bấm **Xóa** sẽ *không xóa gì*, vì callback không bao giờ được gọi. Ngược lại, nếu dòng bị xóa ngay lập tức, điều đó chứng minh **không có bước xác nhận**.

- Người dùng có thể kiểm tra lại các kết quả chính trên thiết bị thật bằng Expo Go (xem README).

Phụ lục 23 — `features/FR-20_Mobile_Cart/02_equivalence_classes.md`

FR-20 Mobile: Giỏ hàng & Số lượng, Bước 2: Xác định lớp tương đương

> Kỹ thuật: Phân hoạch tương đương, bước 2/3 (slide Bài 4, tr.8–10). Đầu vào: điều kiện C1–C6 và giả định A1–A4 ở Bước 1.

2.1 Cách phân hoạch

Loại điều kiện	Lớp hợp lệ	Lớp không hợp lệ	Áp dụng cho
Dãy giá trị `[1..∞)` (số nguyên)	số nguyên ≥ 1	= 0, < 0, thập phân, chữ, rỗng	C1 (I1 và I2)
Dãy giá trị sau khi bấm +/−	kết quả ≥ 1	kết quả < 1	C2
Boolean	cùng SP thì gộp, khác SP thì tách dòng	–	C3
Tập giá trị {Đồng ý, Hủy}	mỗi lựa chọn là một lớp	–	C4
Boolean	giỏ trống / có hàng	–	C5

Tách C1 thành 5 lớp không hợp lệ. "Số nguyên dương" có thể bị vi phạm theo 5 cách: bằng 0 (biên của "dương"), âm, không nguyên, không phải số, rỗng. Ô nhập trên điện thoại dùng bàn phím số, nhưng một số bàn phím vẫn có `-` và `.`, và người dùng có thể dán chữ vào. Hệ thống có thể xử lý mỗi cách một khác.

Phân hoạch C1 trên hai biến I1 và I2. Ô Số lượng ở trang chi tiết và ô Số lượng trong giỏ là **hai nơi nhập khác nhau**, nên mỗi nơi phải được kiểm tra riêng.

2.2 Bảng tổng hợp lớp tương đương

Dữ liệu nền: sản phẩm A = "Bàn phím cơ Keychron Q1" (4.000.000 ₫), sản phẩm B = "Tai nghe AirPods Pro 2" (6.000.000 ₫).

STT	Input / Output	Điều kiện	Lớp tương đương	Loại	Giá trị đại diện
EC1	I1 SL ở trang chi tiết	C1	Số nguyên ≥ 1	Hợp lệ	`3`
EC2		C1	Bằng 0	Không hợp lệ	`0`
EC3		C1	Số âm	Không hợp lệ	`-2`
EC4		C1	Số thập phân	Không hợp lệ	`1.5`
EC5		C1	Không phải số	Không hợp lệ	`abc`
EC6		C1	Rỗng	Không hợp lệ	`""`
EC7	I2 SL sửa trong giỏ	C1	Số nguyên ≥ 1	Hợp lệ	`5`
EC8		C1	Bằng 0	Không hợp lệ	`0`

STT	Input / Output	Điều kiện	Lớp tương đương	Loại	Giá trị đại diện
EC9		C1	Số âm	Không hợp lệ	`-2`
EC10		C1	Số thập phân	Không hợp lệ	`1.5`
EC11		C1	Không phải số	Không hợp lệ	`abc`
EC12		C1	Rỗng	Không hợp lệ	`""`
EC13	I3 Nút +/−	C2	Có nút, bấm thì đổi ±1	Hợp lệ	`+` khi SL = 1
EC14	I4 Thêm SP	C3	Thêm **cùng** SP lần 2 → gộp dòng, cộng SL	Hợp lệ	A (từ danh sách) + A (SL 2 từ chi tiết)
EC15		C3	Thêm **khác** SP → dòng mới	Hợp lệ	A + B
EC16	I5 Xóa	C4	Bấm Xóa → dialog → **Đồng ý** → dòng bị xóa	Hợp lệ	–
EC17		C4	Bấm Xóa → dialog → **Hủy** → dòng giữ nguyên	Hợp lệ	–
EC18	I6 Giỏ	C5	Giỏ trống → hình + thông báo + Tiếp tục mua sắm	Hợp lệ	–
EC19	O1	C6	Thành tiền = giá × SL; Tổng cộng = Σ; nhãn "Tổng cộng"; định dạng `đ`	Hợp lệ (output)	–

Thống kê: 19 lớp, gồm **9 lớp hợp lệ** (EC1, EC7, EC13–EC19) và **10 lớp không hợp lệ** (EC2–EC6, EC8–EC12).

Phụ lục 24 — `features/FR-20_Mobile_Cart/03_ep_test_cases.md`

FR-20 Mobile: Giỏ hàng & Số lượng, Bước 3: Xác định ca kiểm thử (EP)

> Kỹ thuật: Phân hoạch tương đương, bước 3/3 (slide Bài 4, tr.15–18). Đầu vào: 19 lớp tương đương ở Bước 2.

3.1 Nguyên tắc áp dụng

- Mỗi TC bắt đầu từ **một phiên app mới**, nên giỏ luôn trống lúc đầu (giỏ chỉ nằm trong bộ nhớ của app).
- Mỗi TC chỉ chứa **đúng 1 lớp không hợp lệ**.
- Với các TC sửa số lượng trong giỏ (EP-14 → EP-18), giỏ được chuẩn bị với **SL = 2** chứ không phải 1. Nhờ vậy phân biệt được 3 khả năng: "giữ nguyên" (2), "âm thầm đổi về 1" (1), và "nhận giá trị sai".

3.2 Bảng rút gọn các ca kiểm thử (18 TC)

A = Keychron Q1 (4.000.000 ₫), B = AirPods Pro 2 (6.000.000 ₫).

TC	Lớp phủ	Tiền điều kiện	Bước thực hiện	Output mong đợi
EP-01	EC1, EC19	giỏ trống	Chi tiết A → SL `3` → **Thêm vào giỏ hàng** → mở Giỏ	1 dòng A, SL 3, Thành tiền **12.000.000 ₫**, nhãn **"Tổng cộng"** 12.000.000 ₫; có phản hồi sau khi thêm (R2)
EP-02	**EC14**, EC19	giỏ trống	Danh sách: **Thêm vào giỏ** A → Chi tiết A, SL `2` → Thêm → Giỏ	**1 dòng** A, SL **3**
EP-03	**EC15**, EC19	giỏ trống	Danh sách: thêm A, thêm B → Giỏ	**2 dòng**, Tổng cộng **10.000.000 ₫**
EP-04	**EC7**, EC19	giỏ: A×1	Sửa SL trong giỏ thành `5`	SL **5**, Thành tiền **20.000.000 ₫**
EP-05	**EC13**	giỏ: A×1	Bấm **+**	SL **2** (có nút +/− ở mỗi dòng, R3)
EP-06	**EC16**	giỏ: A×1	Bấm **Xóa** → chọn **Đồng ý**	Có dialog xác nhận; sau Đồng ý thì giỏ trống
EP-07	**EC17**	giỏ: A×1	Bấm **Xóa** → chọn **Hủy**	Có dialog; sau Hủy thì A **vẫn còn**
EP-08	**EC18**	giỏ trống	Mở Giỏ	Hình minh họa, thông báo giỏ trống, nút **Tiếp tục mua sắm**
EP-09	**EC2**	giỏ trống	Chi tiết A → SL `0` → Thêm	O2: không thêm, có thông báo; giỏ trống
EP-10	**EC3**	giỏ trống	Chi tiết A → SL `-2` → Thêm	O2
EP-11	**EC4**	giỏ trống	Chi tiết A → SL `1.5` → Thêm	O2
EP-12	**EC5**	giỏ trống	Chi tiết A → SL `abc` → Thêm	O2 (hoặc ô không nhận chữ)

TC	Lớp phủ	Tiền điều kiện	Bước thực hiện	Output mong đợi
EP-13	**EC6**	giỏ trống	Chi tiết A → SL rỗng → Thêm	O2
EP-14	**EC8**	giỏ: A×2	Sửa SL trong giỏ thành `0`	O2: SL giữ **2** (hoặc có thông báo), Thành tiền 8.000.000
EP-15	**EC9**	giỏ: A×2	Sửa SL thành `-2`	O2
EP-16	**EC10**	giỏ: A×2	Sửa SL thành `1.5`	O2
EP-17	**EC11**	giỏ: A×2	Sửa SL thành `abc`	O2
EP-18	**EC12**	giỏ: A×2	Xóa trắng ô SL	O2 (cho phép ô tạm rỗng khi đang gõ, nhưng SL trong giỏ không được thành giá trị khác 2 nếu người dùng không nhập số hợp lệ)

3.3 Kiểm tra độ phủ

Lớp	TC	Lớp	TC	Lớp	TC	Lớp	TC
EC1	EP-01	EC6	EP-13	EC11	EP-17	EC16	EP-06
EC2	EP-09	EC7	EP-04	EC12	EP-18	EC17	EP-07
EC3	EP-10	EC8	EP-14	EC13	EP-05	EC18	EP-08
EC4	EP-11	EC9	EP-15	EC14	EP-02	EC19	EP-01…EP-04
EC5	EP-12	EC10	EP-16	EC15	EP-03		

Cả 19/19 lớp được phủ.

3.4 Cách thực thi và quan sát

- **Kênh:** chỉ có ứng dụng mobile (không có API giỏ hàng: giỏ chỉ nằm trong bộ nhớ của app). App chạy trên Expo Web, mô phỏng Pixel 5 (xem Bước 1 §1.6).
- **Quan sát:**
  - Đọc từng dòng giỏ: tên, "Giá", giá trị trong ô Số lượng, "Thành tiền".
  - Đọc dòng tổng và nhãn của nó.
  - Đọc số trên nút "Giỏ (n)" ở header.
  - Chụp màn hình điện thoại sau mỗi TC.
- **Thứ tự chạy:** EP-01 → EP-04 (hợp lệ) chạy trước để kiểm tra masking.

Phụ lục 25 — `features/FR-20_Mobile_Cart/04_bva_test_cases.md`

FR-20 Mobile: Giỏ hàng & Số lượng, Bước 4: Phân tích giá trị biên (BVA)

> Kỹ thuật: Boundary Value Analysis (slide Bài 4, phần BVA). Đầu vào: điều kiện C1, C2 ở Bước 1.

4.1 Xác định các miền có thứ tự

Điều kiện	Có thứ tự?	Dùng BVA?
C1 SL nguyên ≥ 1 (I1 ở trang chi tiết, I2 trong giỏ)	**Có**	**Có**, cho cả 2 ô nhập
C2 SL sau khi bấm +/−	**Có**	**Có**, biên tại 1 (nút − không được đưa SL xuống 0)
C3 gộp dòng, C4 xóa, C5 giỏ trống	Không (boolean / tập)	Không

4.2 Biên của từng biến

Biến	Mô tả	Miền hợp lệ	LB	UB
V1	SL nhập ở trang chi tiết	`[1..∞)`	1	– (A2)
V2	SL sửa trong giỏ	`[1..∞)`	1	– (A2)
V3	SL **sau khi** bấm − / +	`[1..∞)`	1	–

Nominal: SL 3 (giống EP-01).

4.3 Chọn biến thể BVA và tính số TC

- V1, V2, V3 chỉ có biên dưới, nên dùng Robustness thu gọn **(LB−1, LB, LB+1)** cho mỗi biến, giống FR-01/09/15.
- Thêm **1 điểm độ bền** phía "∞" cho V1 và V2: SL = **999**, để kiểm tra phép nhân và định dạng tiền với số lớn (999 × 4.000.000 = 3.996.000.000 ₫).
- **V3:** tạo SL kết quả bằng LB−1/LB/LB+1 như sau:
  - Bấm **−** khi SL = 1: kết quả mong muốn là 0, nên phải bị chặn (LB−1).
  - Bấm **−** khi SL = 2: kết quả 1 (LB).
  - Bấm **+** khi SL = 1: kết quả 2 (LB+1).

Tổng: 1 (nominal) + 4 (V1) + 4 (V2) + 3 (V3) = 12 TC.

4.4 Bảng ca kiểm thử giá trị biên

TC	Biến	Điểm	Tiền điều kiện	Thao tác	Output mong đợi
BVA-01	–	nominal	giỏ trống	Chi tiết A, SL `3` → Thêm	A×3, Thành tiền 12.000.000 ₫
BVA-02	V1	LB−1	giỏ trống	Chi tiết A, SL `0` → Thêm	**O2**: không thêm
BVA-03	V1	**LB**	giỏ trống	Chi tiết A, SL `1` → Thêm	A×**1**, 4.000.000 ₫
BVA-04	V1	LB+1	giỏ trống	Chi tiết A, SL `2` → Thêm	A×**2**, 8.000.000 ₫

TC	Biến	Điểm	Tiền điều kiện	Thao tác	Output mong đợi
BVA-05	V1	độ bền	giỏ trống	Chi tiết A, SL `999` → Thêm	A×999, **3.996.000.000 ₫**
BVA-06	V2	LB−1	giỏ A×2	Sửa SL thành `0`	**O2**: SL giữ 2
BVA-07	V2	**LB**	giỏ A×2	Sửa SL thành `1`	SL **1**, 4.000.000 ₫
BVA-08	V2	LB+1	giỏ A×1	Sửa SL thành `2`	SL **2**, 8.000.000 ₫
BVA-09	V2	độ bền	giỏ A×1	Sửa SL thành `999`	SL 999, 3.996.000.000 ₫
BVA-10	V3	LB−1	giỏ A×1	Bấm **−**	SL **giữ 1** (nút − bị vô hiệu hoặc không giảm)
BVA-11	V3	**LB**	giỏ A×2	Bấm **−**	SL **1**
BVA-12	V3	LB+1	giỏ A×1	Bấm **+**	SL **2**

Ghi chú:

- BVA-02 trùng giá trị với EP-09, và BVA-06 trùng với EP-14. Vẫn giữ để đủ bộ điểm biên.
- Ở BVA-07, giỏ được chuẩn bị là A×2 (không phải A×1). Lý do: nếu giỏ đã là 1 thì khi sửa thành 1, kết quả "đúng" có thể chỉ là ngẫu nhiên.

Phụ lục 26 — `features/FR-20_Mobile_Cart/05_test_execution.md`

FR-20 Mobile: Giỏ hàng & Số lượng, Bước 5: Thực thi kiểm thử

5.1 Môi trường

Mục	Giá trị
Thời điểm chạy	2026-10-13 (GMT+7). Dữ liệu thô: `results_fr20.json`
SUT	`eshop-sut/frontend-mobile` commit `85af3ba` (Expo SDK 54, React Native 0.81.5). Backend `:3000` khởi động lại để seed DB
Cách chạy app	**Expo Web** (`npx expo start --web --port 8081`), Playwright 1.49.1 + Chromium 131 **mô phỏng Pixel 5** (393×851, DPR 2.75, touch, UA Android)
Thay đổi môi trường	(1) `App.js` dòng 16: `API_URL = "http://192.168.1.11:3000/api"` (IP LAN của máy). (2) Cài thêm `react-native-web`, `react-dom`, `@expo/metro-runtime` để render web. **Không sửa logic nào của app**
Script	`scripts/fr20_mobile_cart.js`, thăm dò `scripts/fr20_typing_probe.js`
Dữ liệu	A = Bàn phím cơ Keychron Q1 (id 5, 4.000.000 ₫), B = Tai nghe AirPods Pro 2 (id 4, 6.000.000 ₫)
Cách ly	Mỗi TC mở **một phiên app mới** (browser context mới), nên giỏ luôn bắt đầu trống

Tiêu chí Pass/Fail

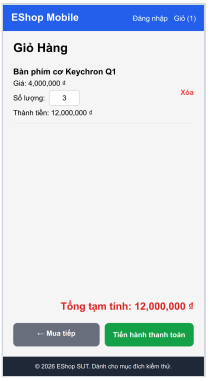
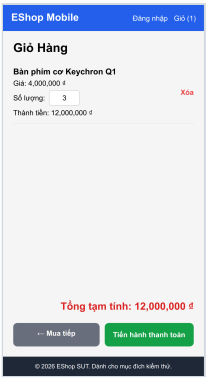
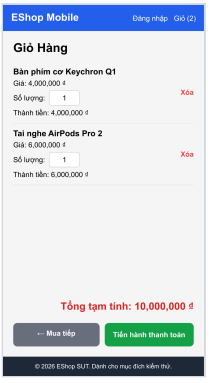
- **TC hợp lệ:** số dòng, SL, Thành tiền, Tổng đúng như mong đợi. Riêng nhãn "Tổng cộng" (R7) chỉ được tính vào EP-01 (TC phủ EC19), để lỗi nhãn không che kết quả số lượng ở các TC khác.
- **TC không hợp lệ:** giỏ giữ nguyên trạng thái trước đó (trang chi tiết: giỏ vẫn trống; trong giỏ: SL vẫn bằng SL ban đầu).

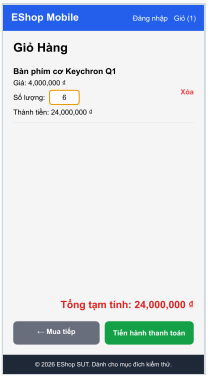
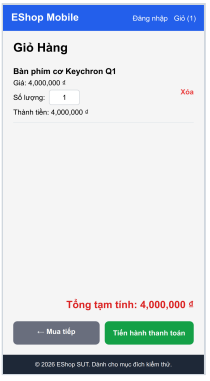
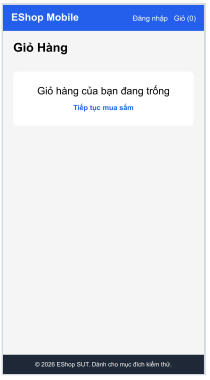
Giới hạn của Expo Web: `Alert.alert` không hiển thị trên web. Mình không kết luận dựa trên việc có thấy Alert hay không, mà dựa trên **hiệu ứng**. Ví dụ ở EP-06, nếu có bước xác nhận bằng Alert, dòng sẽ không bị xóa; dòng bị xóa ngay chứng tỏ không có bước xác nhận.

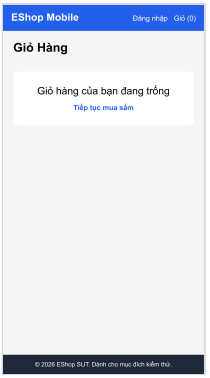
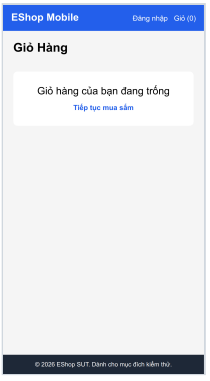
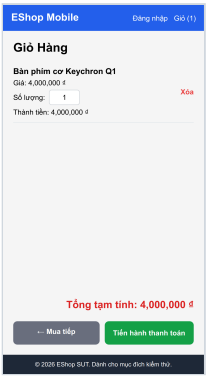
5.2 Kiểm tra masking và Pass giả

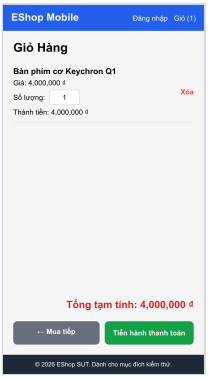
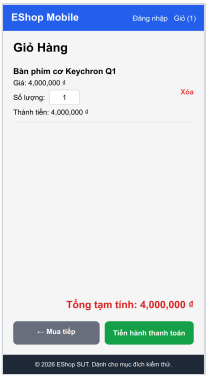
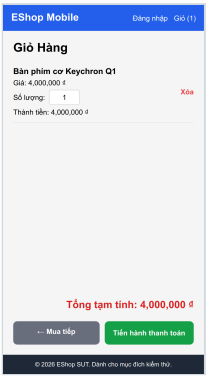
- Các TC hợp lệ EP-01 → EP-04 chạy trước.
- **EP-01 Fail chỉ vì nhãn.** SL 3 và 12.000.000 ₫ đều đúng, nhưng nhãn là "Tổng tạm tính". Vì vậy mình tách tiêu chí nhãn ra khỏi các TC khác (xem §5.1).
- **EP-04 Fail vì SL sai**: nhập 5 thì ô thành **6**. Mọi TC sửa SL trong giỏ đều bị ảnh hưởng bởi lỗi "+1" này. Do đó mỗi TC sửa SL được thiết kế với SL ban đầu khác với giá trị mà lỗi có thể tạo ra.
- **EP-16 là Pass giả:** ⚠️ nhập `1.5` thì app tính `parseInt("1.5") + 1 = 2`, **trùng ngẫu nhiên** với SL ban đầu là 2, nên trông như "giữ nguyên". Chạy lại **EP-16R** với SL ban đầu là 3: SL thành **2**, tức là Fail. Kết quả cuối của EP-16 lấy theo EP-16R.

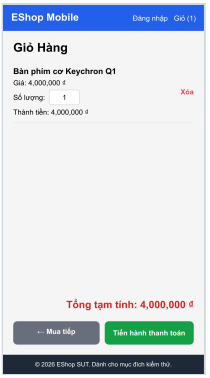
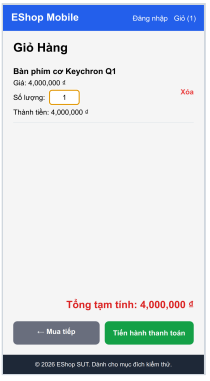
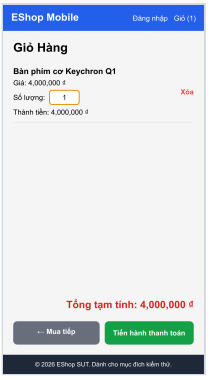
5.3 Kết quả: Phân hoạch tương đương (18 TC)

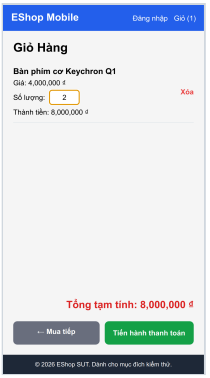
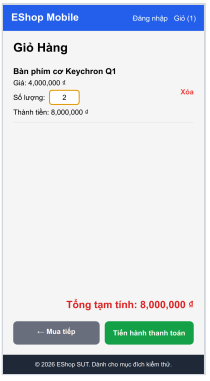
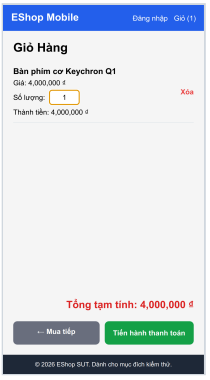
TC	Lớp	Bước chính	Mong đợi	Thực tế	KQ
EP-01	EC1, EC19	Chi tiết A, SL `3` → Thêm → Giỏ	A×3, 12.000.000 ₫, nhãn "Tổng cộng"	A×3, Thành tiền 12,000,000 ₫. Nút đổi thành "Đã thêm". Nhãn tổng là **"Tổng tạm tính"**	❌ ảnh  ảnh
EP-02	EC14	Thêm A từ danh sách + A (SL 2) từ chi tiết	1 dòng, SL 3	1 dòng, SL 3	✅ ảnh  ảnh
EP-03	EC15	Thêm A, B	2 dòng, tổng 10.000.000	2 dòng, tổng 10,000,000 ₫	✅ ảnh  ảnh

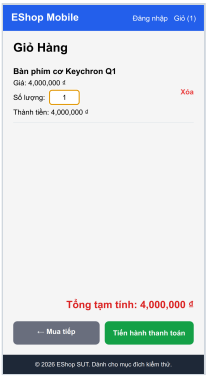
TC	Lớp	Bước chính	Mong đợi	Thực tế	KQ
EP-04	EC7	Giỏ A×1, sửa SL thành `5`	SL 5, 20.000.000	ô hiện **6**, Thành tiền **24,000,000 ₫**	❌ ảnh  ảnh
EP-05	EC13	Bấm **+**	SL 2	**Không có nút +/−** trên dòng giỏ	❌ ảnh  ảnh
EP-06	EC16	Bấm **Xóa** → Đồng ý	Có dialog, sau đó xóa	Dòng bị xóa **ngay lập tức**, không có bước xác nhận	❌ ảnh  ảnh

TC	Lớp	Bước chính	Mong đợi	Thực tế	KQ
EP-07	EC17	Bấm **Xóa** → Hủy	Có dialog, Hủy thì giữ dòng	Không có cơ hội Hủy, dòng đã bị xóa	❌ ảnh  ảnh
EP-08	EC18	Mở giỏ trống	Hình minh họa + thông báo + Tiếp tục mua sắm	Có thông báo và link "Tiếp tục mua sắm", **không có hình minh họa** (0 ảnh)	❌ ảnh  ảnh
EP-09	EC2	Chi tiết A, SL `0` → Thêm	Không thêm, có thông báo	Ô nhận `0`, nút báo "Đã thêm", giỏ có **A×1**	❌ ảnh  ảnh

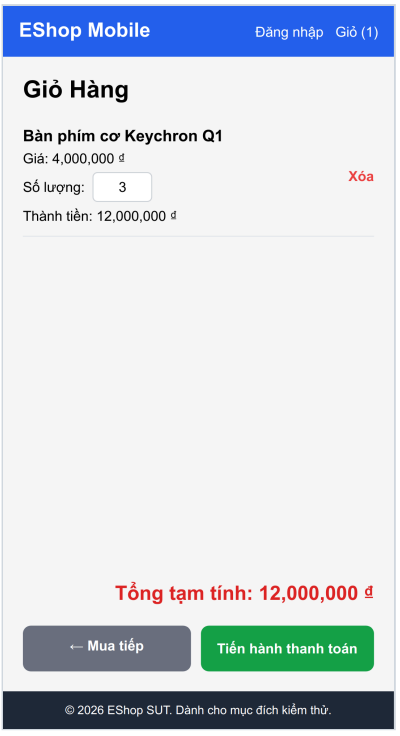
TC	Lớp	Bước chính	Mong đợi	Thực tế	KQ
EP-10	EC3	SL `-2`	như trên	Ô nhận `-2`, giỏ có **A×1**	❌ ảnh  ảnh
EP-11	EC4	SL `1.5`	như trên	Ô nhận `1.5`, giỏ có **A×1**	❌ ảnh  ảnh
EP-12	EC5	SL `abc`	như trên	Ô nhận `abc`, giỏ có **A×1**	❌ ảnh  ảnh

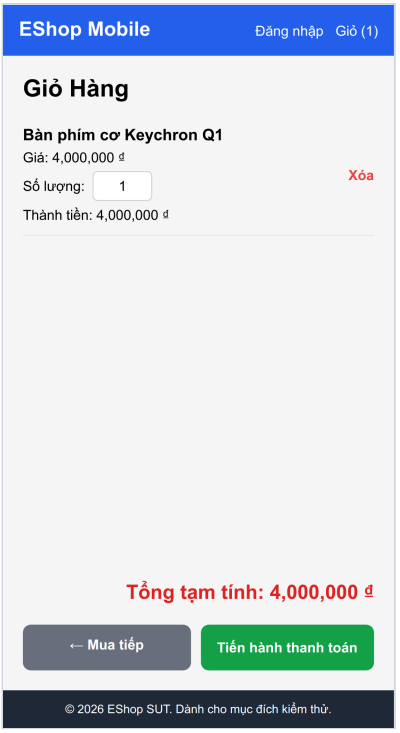
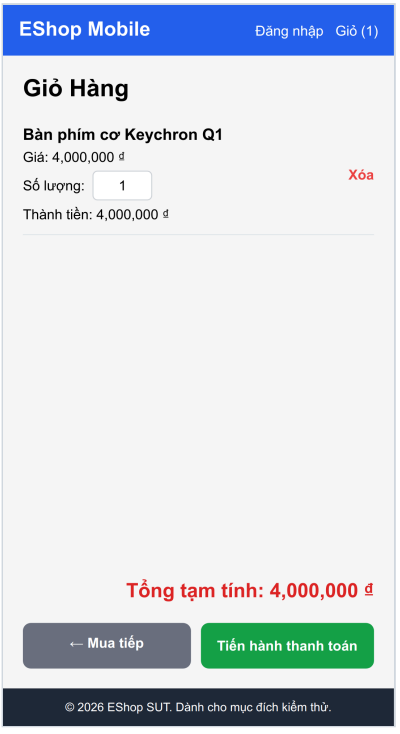
TC	Lớp	Bước chính	Mong đợi	Thực tế	KQ
EP-13	EC6	SL rỗng	như trên	giỏ có **A×1**	❌ ảnh  ảnh
EP-14	EC8	Giỏ A×2, sửa SL `0`	SL giữ 2	ô thành **1**, SL = 1, không có thông báo	❌ ảnh  ảnh
EP-15	EC9	Giỏ A×2, sửa `-2`	SL giữ 2	SL = **1**	❌ ảnh  ảnh

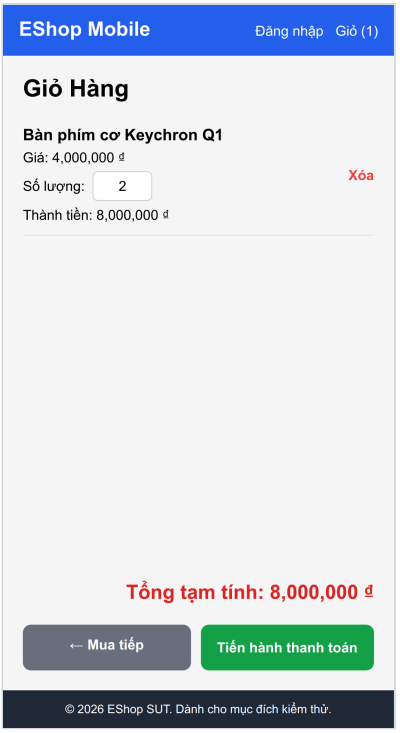
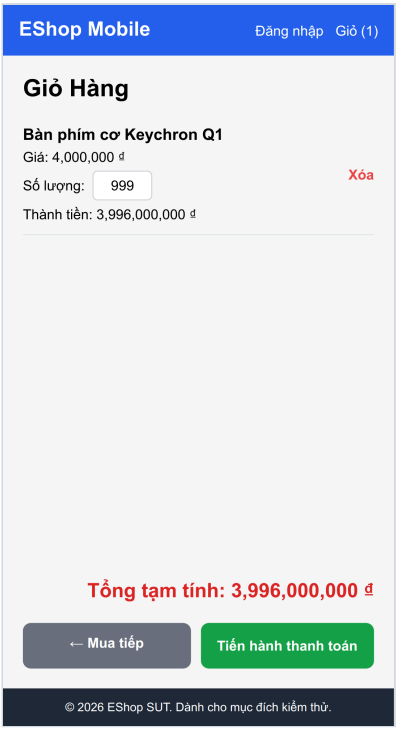
TC	Lớp	Bước chính	Mong đợi	Thực tế	KQ
EP-16	EC10	Giỏ A×2, sửa `1.5`	SL giữ 2	⚠️ SL = 2 (**Pass giả**, xem §5.2)	– ảnh  ảnh
EP-16R	EC10	Giỏ **A×3**, sửa `1.5`	SL giữ 3	SL = **2**	❌ ảnh  ảnh
EP-17	EC11	Giỏ A×2, sửa `abc`	SL giữ 2	SL = **1**	❌ ảnh  ảnh

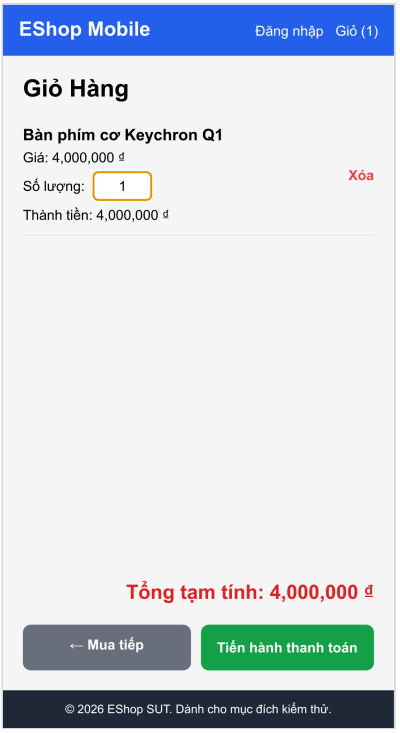
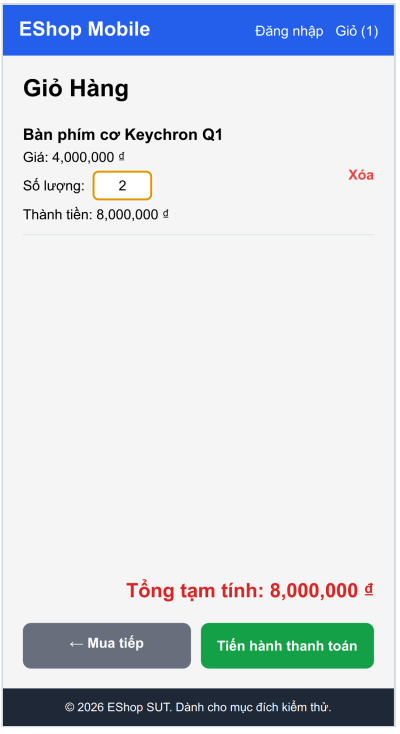
TC	Lớp	Bước chính	Mong đợi	Thực tế	KQ
EP-18	EC12	Giỏ A×2, xóa trắng ô	SL giữ 2	ô **ngay lập tức** thành 1, SL = **1**	❌ ảnh  ảnh

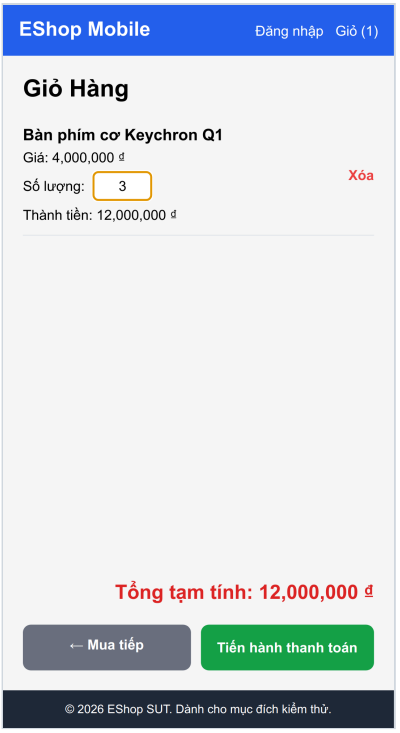
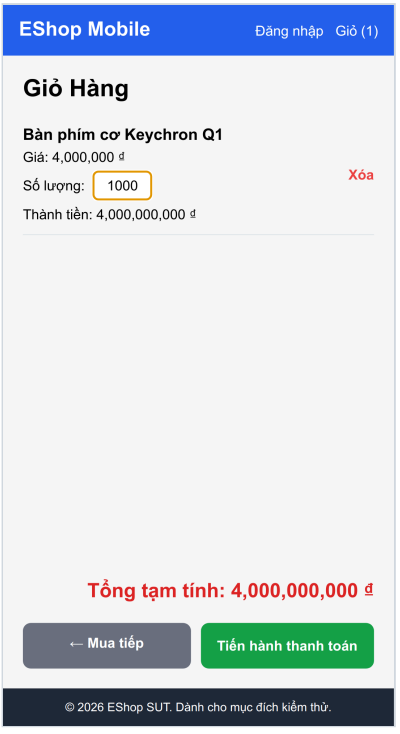
5.4 Kết quả: Phân tích giá trị biên (12 TC)

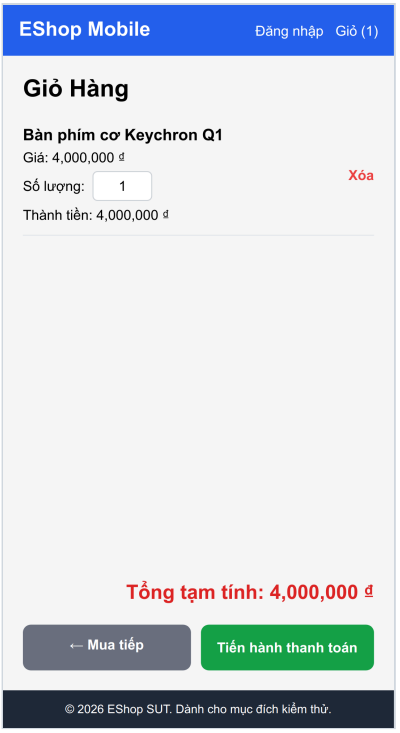
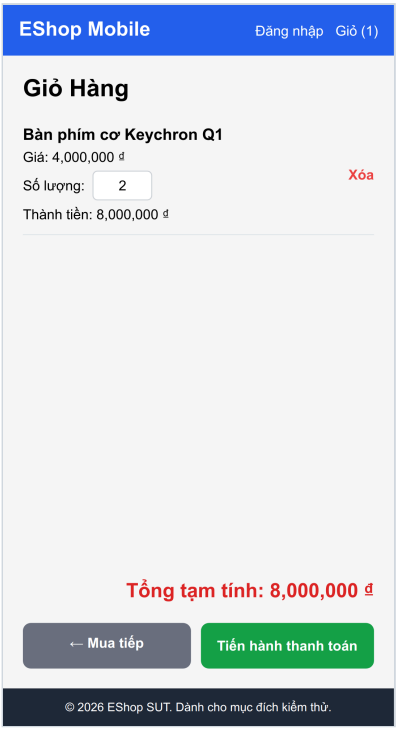
TC	Biến, điểm	Thao tác	Mong đợi	Thực tế	KQ
BVA-01	nominal	Chi tiết, SL 3	A×3, 12.000.000	A×3, 12,000,000 ₫	✅ ảnh  ảnh

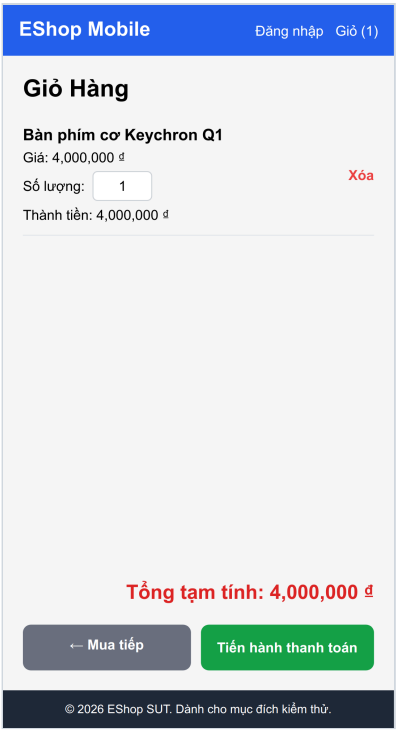
TC	Biến, điểm	Thao tác	Mong đợi	Thực tế	KQ
BVA-02	V1 LB−1	Chi tiết, SL **0**	không thêm	thêm **A×1**	❌ ảnh  ảnh
BVA-03	V1 **LB**	Chi tiết, SL **1**	A×1	A×1, 4,000,000 ₫	✅ ảnh  ảnh

TC	Biến, điểm	Thao tác	Mong đợi	Thực tế	KQ
BVA-04	V1 LB+1	Chi tiết, SL 2	A×2	A×2, 8,000,000 ₫	✅ ảnh  ảnh
BVA-05	V1 độ bền	Chi tiết, SL 999	A×999, 3.996.000.000	A×999, 3,996,000,000 ₫	✅ ảnh  ảnh

TC	Biến, điểm	Thao tác	Mong đợi	Thực tế	KQ
BVA-06	V2 LB−1	Giỏ A×2, sửa **0**	giữ 2	SL **1**	❌ ảnh  ảnh
BVA-07	V2 **LB**	Giỏ A×2, sửa **1**	SL 1	SL **2**	❌ ảnh  ảnh

TC	Biến, điểm	Thao tác	Mong đợi	Thực tế	KQ
BVA-08	V2 LB+1	Giỏ A×1, sửa 2	SL 2	SL **3**	❌ ảnh  ảnh
BVA-09	V2 độ bền	Giỏ A×1, sửa 999	SL 999	SL **1000**, 4,000,000,000 ₫	❌ ảnh  ảnh

TC	Biến, điểm	Thao tác	Mong đợi	Thực tế	KQ
BVA-10	V3 LB−1	A×1, bấm −	giữ 1	không có nút	❌ ảnh  ảnh
BVA-11	V3 **LB**	A×2, bấm −	SL 1	không có nút	❌ ảnh  ảnh

TC	Biến, điểm	Thao tác	Mong đợi	Thực tế	KQ
BVA-12	V3 LB+1	A×1, bấm +	SL 2	không có nút	❌ ảnh  ảnh

Phân tích theo biến:

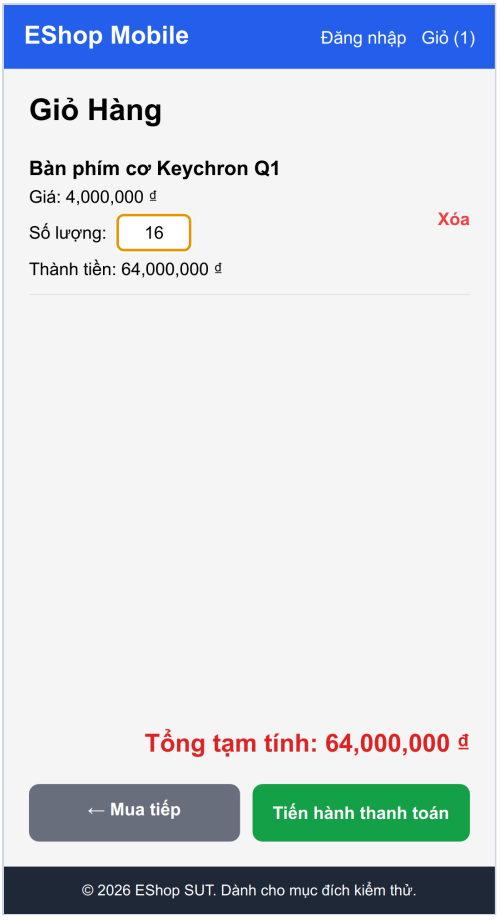
- **V1 (ô SL ở trang chi tiết):** đúng tại LB, LB+1 và giá trị lớn. Tại LB−1 (0), ô không chặn mà **âm thầm đổi thành 1**. Ô nhận mọi ký tự, kể cả chữ.
- **V2 (ô SL trong giỏ): sai tại mọi điểm**. Giá trị hợp lệ n bị lưu thành **n+1**. Giá trị không hợp lệ (≤ 0, chữ, rỗng) bị đổi thành 1. Do đó **không thể** đặt SL = 1 bằng cách nhập trong giỏ, vì nhập 1 sẽ thành 2.
- **V3 (nút +/−):** không có nút nên không có biên nào để kiểm tra. Fail theo R3.

5.5 Thăm dò: sửa SL bằng bàn phím như trên điện thoại

Script `fr20_typing_probe.js` mô phỏng thao tác thật: chạm vào ô SL (đang là 1), bấm **Backspace**, gõ **5**.

Bước	Giá trị trong ô
Ban đầu	`1`
Sau Backspace	`1` (ô rỗng lập tức bị đổi lại thành 1)
Sau khi gõ `5`	**16**

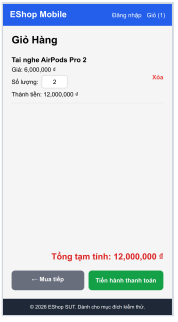
→ Trên điện thoại, người dùng **không thể** nhập số lượng mong muốn bằng bàn phím: muốn 5 thì nhận 16. Ảnh



Ảnh

5.5b TC bổ sung sau AI gap analysis

Lớp mới được thêm ở Bước 7. Dữ liệu thô: `results_fr20_supplementary.json`.

TC	Lớp mới	Bước chính	Mong đợi	Thực tế	KQ
EP-19	EC20: SP mà API chi tiết trả `price` **kiểu chuỗi** (`GET /api/products/4` → `"6000000"`, còn API danh sách trả số)	Chi tiết B (AirPods, id 4), SL 1 → Thêm; danh sách → Thêm B	1 dòng, SL 2, Thành tiền 12.000.000	1 dòng, SL 2, 12,000,000 ₫	✅ ảnh  ảnh

5.6 Tổng hợp

Nhóm	Số TC	Pass	Fail	Không thực thi
EP	18	2 (EP-02, EP-03)	16 (EP-16 tính theo EP-16R)	0
BVA	12	4 (BVA-01, 03, 04, 05)	8	0
Bổ sung (gap)	1	1 (EP-19)	0	0
Tổng	**31**	**7**	**24**	**0**

Có 31 lượt chạy (30 TC và EP-16R), 31 ảnh TC và 1 ảnh thăm dò. EP-05 và BVA-10 → BVA-12 được tính là **Fail** (không phải "chưa thực thi"), vì việc thiếu nút +/− chính là lỗi so với R3.

Đề xuất cho sinh viên: kiểm tra lại nhanh EP-04, EP-06, EP-08 trên điện thoại thật bằng Expo Go, rồi chụp ảnh bổ sung. Cần đổi `API_URL` trong `App.js` sang IP LAN hiện tại.

Phụ lục 27 — `features/FR-20_Mobile_Cart/06_bug_report.md`

FR-20 Mobile: Giỏ hàng & Số lượng, Bước 6: Báo cáo lỗi

Môi trường chung: `eshop-sut/frontend-mobile` `85af3ba` (Expo SDK 54), chạy bằng Expo Web, mô phỏng Pixel 5 (Playwright/Chromium 131). Backend `localhost:3000`, DB seed. Thời điểm phát hiện: 2026-10-13. Chi tiết môi trường ở 05_test_execution.md §5.1.

Bug ID	Tiêu đề	Severity	Priority	TC phát hiện	Issue
BUG-FR20-01	Sửa số lượng trong giỏ bị lưu thành **n + 1** (nhập 5 được 6, nhập 1 được 2)	**Critical**	P1	EP-04, BVA-07, BVA-08, BVA-09, EP-16R	#23
BUG-FR20-02	Dòng giỏ hàng không có nút **+ / −** để chỉnh số lượng	Major	P2	EP-05, BVA-10, BVA-11, BVA-12	#24
BUG-FR20-03	Bấm **Xóa** sản phẩm trong giỏ xóa ngay, không có dialog xác nhận	Major	P2	EP-06, EP-07	#25
BUG-FR20-04	Số lượng không hợp lệ (0, âm, thập phân, chữ, rỗng) bị âm thầm đổi thành 1, không có thông báo	Minor	P3	EP-09…EP-15, EP-17, EP-18, BVA-02, BVA-06	#26
BUG-FR20-05	Nhãn tổng tiền là "Tổng tạm tính" thay vì "Tổng cộng"	Minor	P3	EP-01	#27
BUG-FR20-06	Giỏ hàng trống không có hình minh họa	Minor	P4	EP-08	#28

BUG-FR20-01: Sửa số lượng trong giỏ bị lưu thành n + 1 (nhập 5 được 6, nhập 1 được 2)

- **Tính năng & kỹ thuật:** FR-20/FR-07, EP với lớp EC7 (SL hợp lệ trong giỏ); BVA trên biến V2 tại LB, LB+1 và giá trị lớn.
- **Severity:** Critical. Số lượng và **tổng tiền sai** so với ý người dùng. Người dùng **không thể** đặt SL = 1 bằng cách nhập trong giỏ. Khi gõ trên bàn phím điện thoại, muốn 5 thì nhận được **16**.

Các bước tái hiện

1. Mở app EShop Mobile. Ở danh sách, bấm **Thêm vào giỏ** cho "Bàn phím cơ Keychron Q1" (4.000.000 ₫).
2. Bấm **Giỏ (1)**.
3. Ở ô **Số lượng** của dòng, thay giá trị bằng `5`.
4. *(Cách nhập như trên điện thoại)* Chạm vào ô, bấm Backspace một lần, rồi gõ `5`.

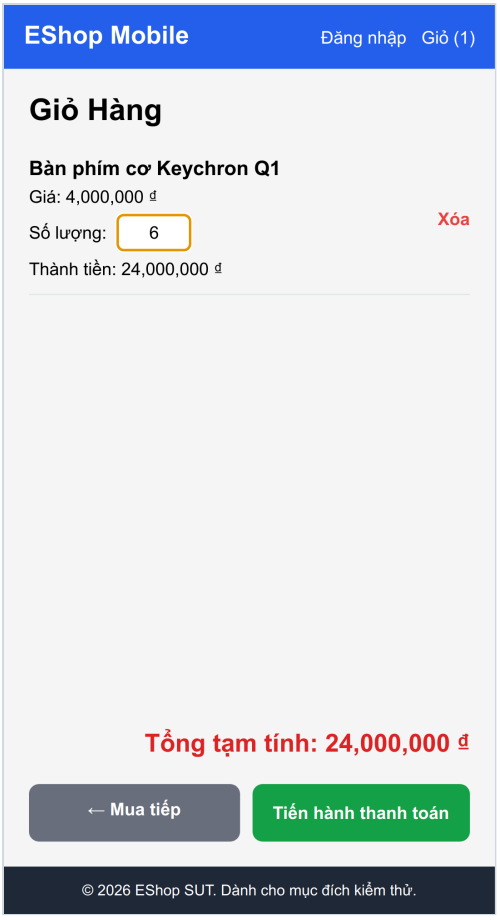
Kết quả mong đợi: Bước 3: SL 5, Thành tiền 20.000.000 ₫. Bước 4: SL 5.

Kết quả thực tế:

- Bước 3: ô hiện **6**, Thành tiền **24,000,000 ₫**, Tổng **24,000,000 ₫**.
- Bước 4: Backspace làm ô **nhảy lại 1**, gõ 5 thì thành **16**.

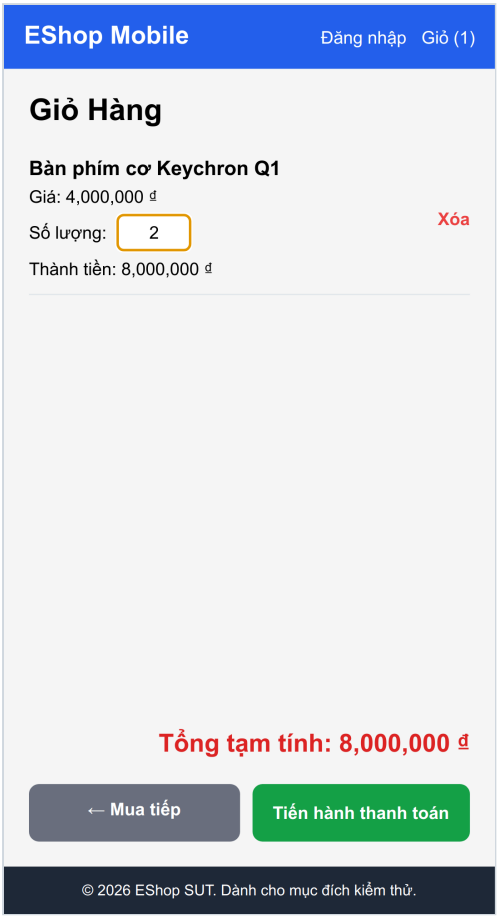
Các điểm biên khác: nhập 1 → 2, nhập 2 → 3, nhập 999 → 1000 (4.000.000.000 ₫).

Minh chứng: EP-04_mobile.png



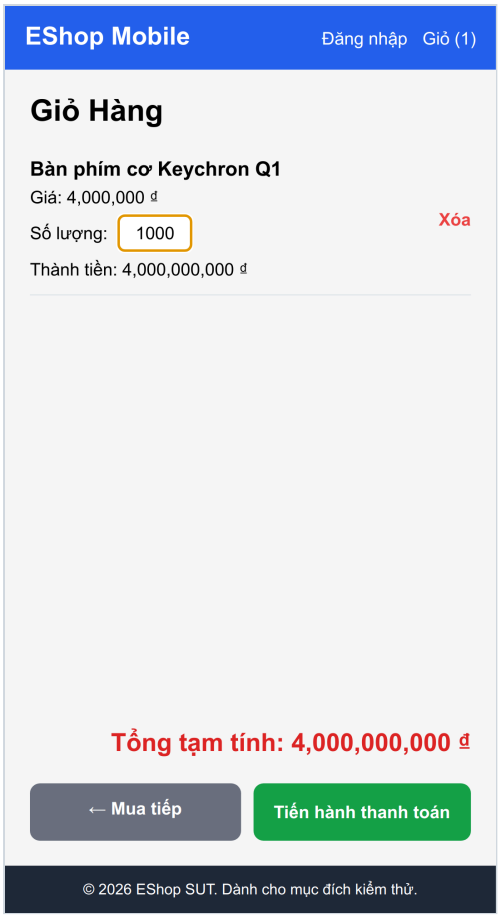
EP-04_mobile.png

, BVA-07_mobile.png



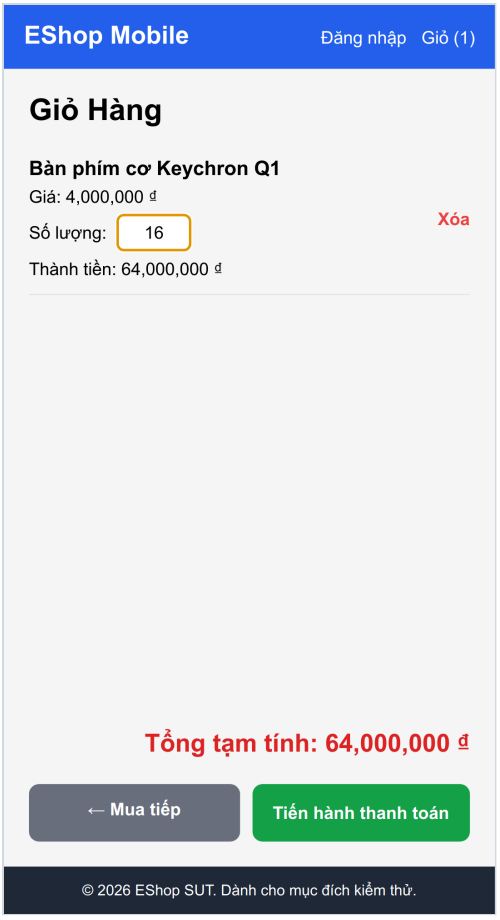
BVA-07_mobile.png

, BVA-09_mobile.png



BVA-09_mobile.png

, PROBE_typing_mobile.png



PROBE_typing_mobile.png

BUG-FR20-02: Dòng giỏ hàng không có nút + / − để chỉnh số lượng

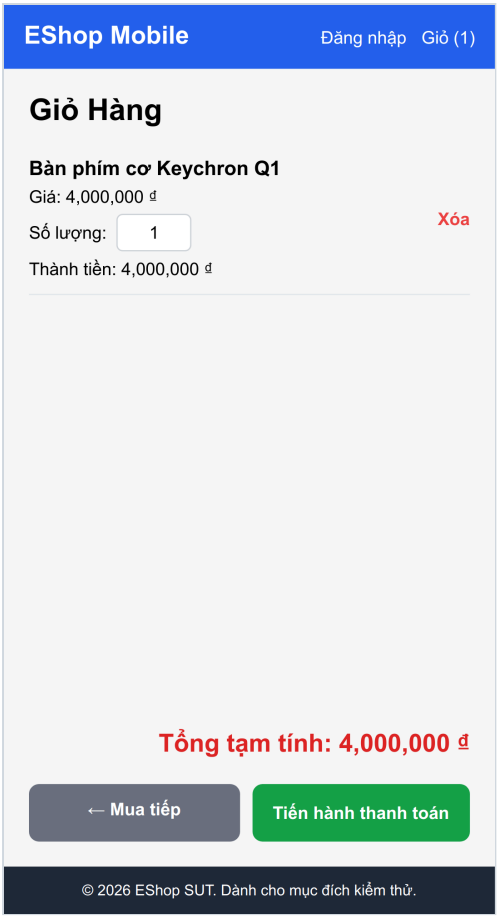
- **Tính năng & kỹ thuật:** FR-07 R3 ("Số lượng (có nút +/- để chỉnh)"), EP với lớp EC13; BVA biến V3.
- **Severity:** Major. Thiếu chức năng được spec yêu cầu. Kết hợp với BUG-FR20-01, người dùng **không còn cách nào** để chỉnh đúng số lượng trong giỏ.

Các bước tái hiện: thêm 1 sản phẩm vào giỏ → mở **Giỏ** → quan sát dòng sản phẩm.

Kết quả mong đợi: Mỗi dòng có nút **−** và **+** quanh ô số lượng. − không giảm xuống dưới 1.

Kết quả thực tế: Dòng chỉ có tên, "Giá", ô "Số lượng", "Thành tiền" và nút "Xóa". Không có nút +/−.

Minh chứng: EP-05_mobile.png



EP-05_mobile.png

BUG-FR20-03: Bấm Xóa sản phẩm trong giỏ xóa ngay, không có dialog xác nhận

- **Tính năng & kỹ thuật:** FR-07 R5, EP với các lớp EC16 (Đồng ý) và EC17 (Hủy).
- **Severity:** Major. Chạm nhầm là mất sản phẩm, và không có cách hoàn tác. Trên điện thoại, chạm nhầm rất dễ xảy ra.

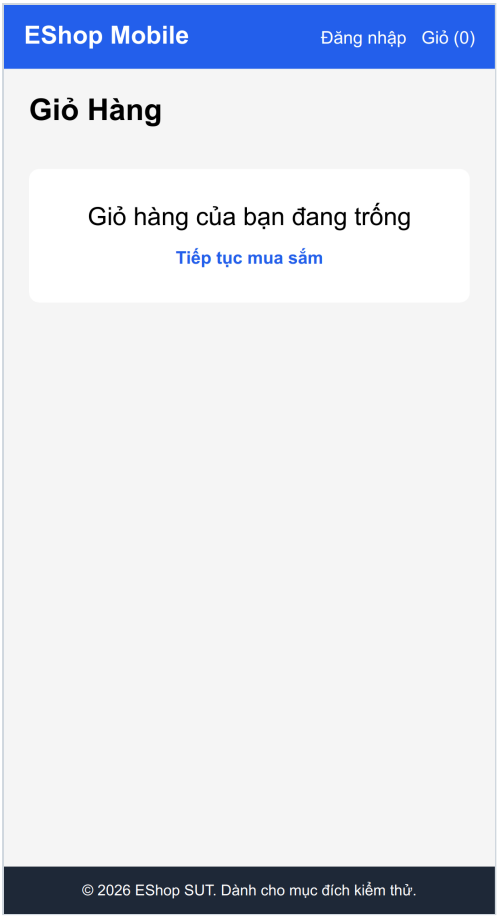
Các bước tái hiện: thêm 1 sản phẩm → mở **Giỏ** → bấm **Xóa**.

Kết quả mong đợi: Hiện hộp thoại "Bạn có chắc muốn xóa?" với 2 lựa chọn Đồng ý / Hủy.

Kết quả thực tế: Dòng biến mất **ngay lập tức** và giỏ chuyển sang trạng thái trống.

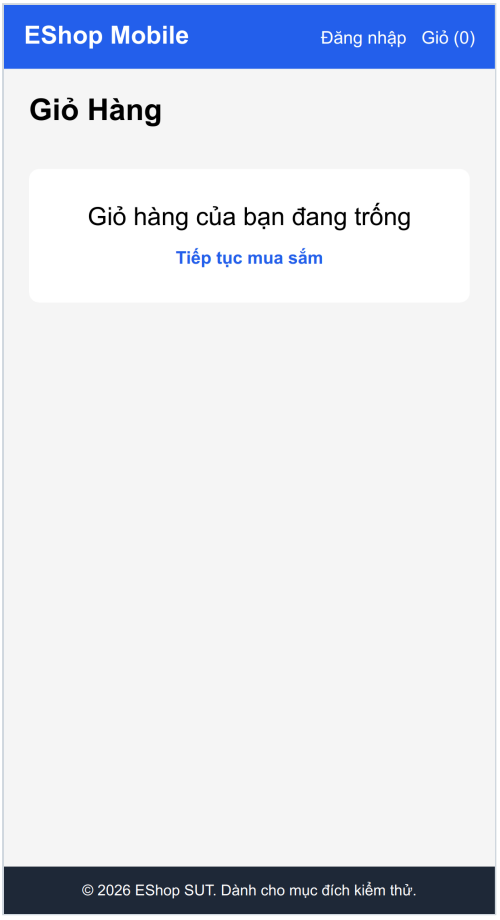
- **Lưu ý về môi trường:** trên Expo Web, `Alert.alert` không hiển thị. Nhưng nếu app có bước xác nhận bằng Alert, callback xóa sẽ không bao giờ được gọi và dòng phải **còn nguyên**.
- Việc dòng bị xóa ngay chứng tỏ thao tác xóa **không đi qua** bất kỳ bước xác nhận nào. Nên kiểm tra lại trên thiết bị thật.

Minh chứng: EP-06_mobile.png



EP-06_mobile.png

, EP-07_mobile.png



EP-07_mobile.png

BUG-FR20-04: Số lượng không hợp lệ bị âm thầm đổi thành 1, không có thông báo

- **Tính năng & kỹ thuật:** FR-06 R1 ("chỉ nhận số nguyên dương, tối thiểu là 1"). EP với các lớp EC2–EC6 (trang chi tiết) và EC8–EC12 (trong giỏ); BVA tại LB−1 = 0 của V1, V2. Đánh giá theo giả định A1.
- **Severity:** Minor. Giỏ vẫn ở trạng thái hợp lệ (SL ≥ 1), nhưng khác với giá trị người dùng nhập mà không báo gì.

Các bước tái hiện

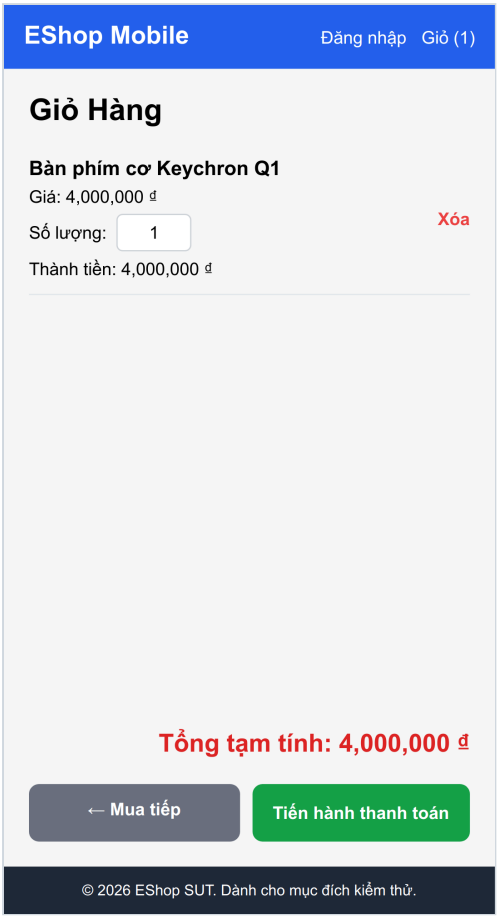
1. Mở chi tiết "Bàn phím cơ Keychron Q1", nhập Số lượng `0` (hoặc `-2`, `1.5`, `abc`, để trống) → **Thêm vào giỏ hàng**.
2. Trong giỏ có dòng SL = 2, sửa ô Số lượng thành `0` (hoặc `-2`, `abc`, xóa trắng).

Kết quả mong đợi: Ô không nhận ký tự không hợp lệ, hoặc có thông báo "Số lượng phải là số nguyên ≥ 1". Giỏ giữ nguyên.

Kết quả thực tế

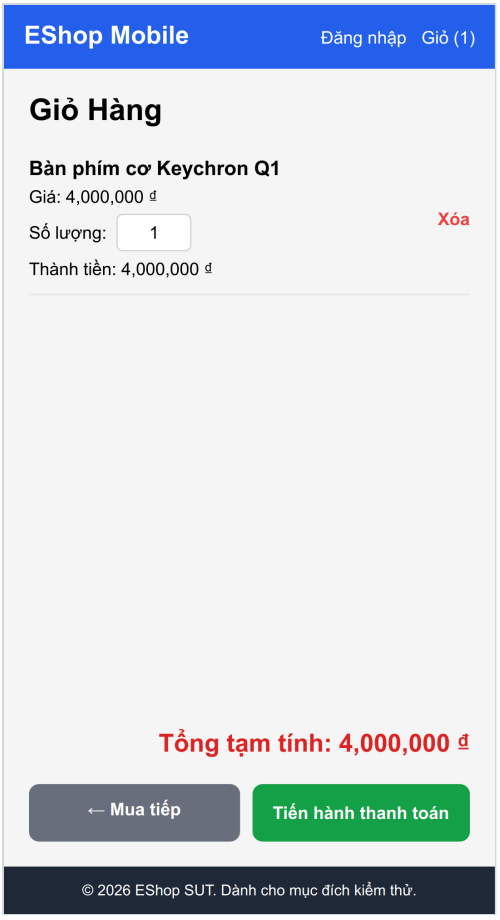
1. Ô nhận mọi ký tự (kể cả `abc`). Nút đổi thành "Đã thêm", và giỏ có sản phẩm với **SL 1**.
2. Ô lập tức đổi thành **1**, SL giảm từ 2 xuống 1, không có thông báo nào. Riêng `1.5` cho kết quả 2, do lỗi "+1" của BUG-FR20-01.

Minh chứng: EP-09_mobile.png



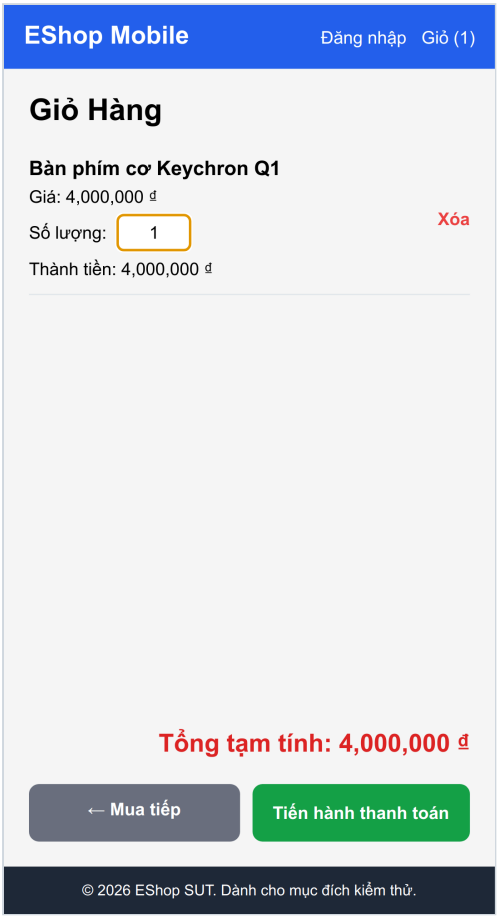
EP-09_mobile.png

, EP-12_mobile.png



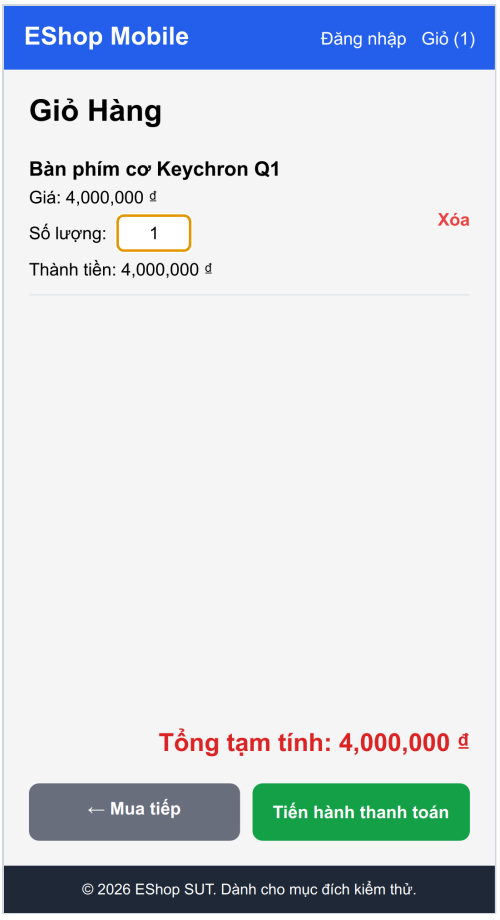
EP-12_mobile.png

, EP-14_mobile.png



EP-14_mobile.png

, EP-17_mobile.png



EP-17_mobile.png

BUG-FR20-05: Nhãn tổng tiền là "Tổng tạm tính" thay vì "Tổng cộng"

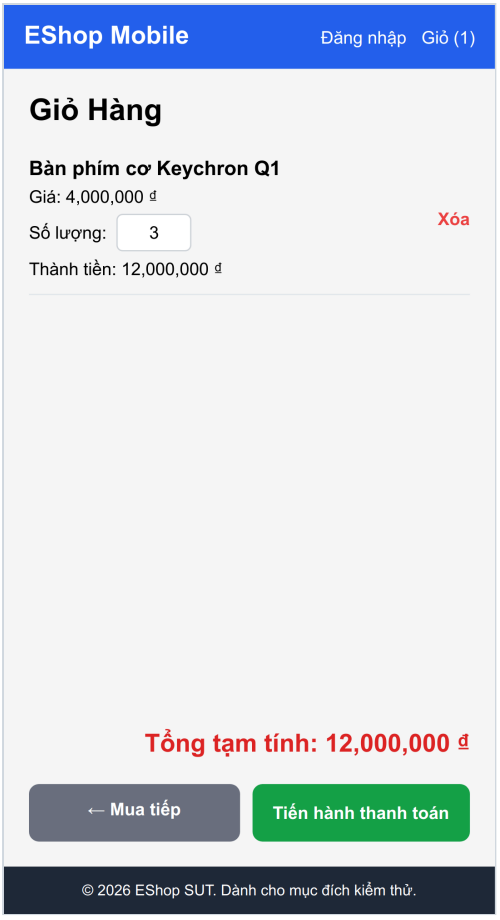
- **Tính năng & kỹ thuật:** FR-07 R7, EP với lớp đầu ra EC19.
- **Severity:** Minor

Các bước tái hiện: thêm sản phẩm bất kỳ → mở **Giỏ** → xem dòng tổng phía dưới.

Kết quả mong đợi: "Tổng cộng: 12,000,000 ₫".

Kết quả thực tế: "**Tổng tạm tính**: 12,000,000 ₫". Spec ghi rõ "(không phải 'Tổng tạm tính')".

Minh chứng: EP-01_mobile.png



EP-01_mobile.png

BUG-FR20-06: Giỏ hàng trống không có hình minh họa

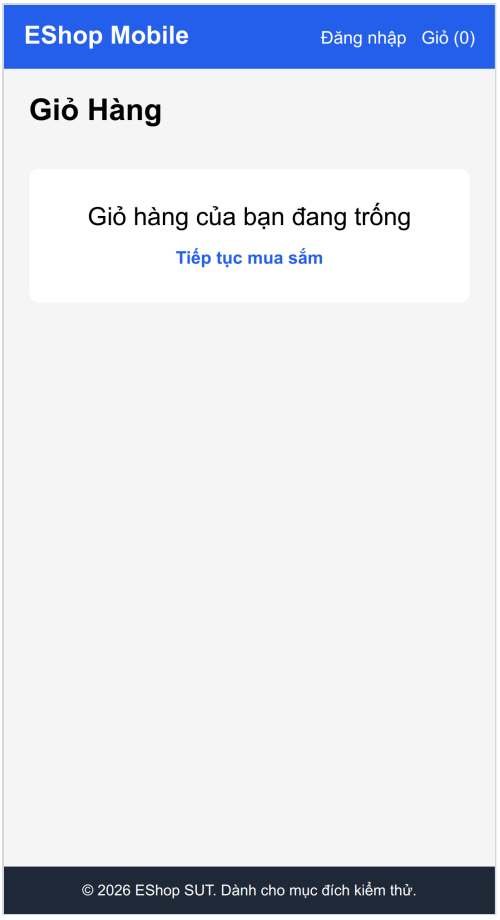
- **Tính năng & kỹ thuật:** FR-07 R8, EP với lớp EC18 (giả định A4).
- **Severity:** Minor

Các bước tái hiện: mở app → bấm **Giỏ (0)**.

Kết quả mong đợi: Hình minh họa giỏ trống, thông báo, nút Tiếp tục mua sắm.

Kết quả thực tế: Có thông báo "Giỏ hàng của bạn đang trống" và link "Tiếp tục mua sắm", nhưng **không có hình ảnh** nào (0 phần tử ảnh).

Minh chứng: EP-08_mobile.png



EP-08_mobile.png

Quan sát ngoài phạm vi (không tính là bug của tính năng này)

- Nút **Tiến hành thanh toán** màu xanh lá (FR-21: nút tích cực màu xanh dương).
- Badge header "Giỏ (n)" đếm **số dòng**, không đếm tổng số lượng. Spec không quy định nên chỉ ghi nhận.

Phụ lục 28 — `features/FR-20_Mobile_Cart/07_ai_gap_analysis.md`

FR-20 Mobile: Giỏ hàng & Số lượng, Bước 7: AI Gap Analysis

Công cụ AI: Claude Code (model Claude Opus 5.5), chạy trong terminal ngày 2026-10-13. Nhật ký đầy đủ: `ai-audit/`.

Bối cảnh đặc biệt của Pool D:

- FR-20 chỉ ghi "đầy đủ chức năng ... Giỏ hàng". AI phải **tự xác định nguồn đặc tả**, ở đây là FR-06 và FR-07.
- Máy kiểm thử không có thiết bị hay emulator, nên AI chọn chạy app bằng **Expo Web**. Lựa chọn này giúp tự động hóa được hoàn toàn, nhưng có giới hạn (G1).

7.1 Những gì AI bỏ sót hoặc làm sai

#	Gap	Loại	Phát hiện ở đâu	Nguyên nhân	Xử lý
G1	**Độ trung thực của môi trường.** Expo Web ≠ thiết bị thật: `Alert` không hiển thị; `keyboardType="numeric"` trên web không chặn chữ. Trên điện thoại, bàn phím số thường không có chữ, nên EP-12 và EP-17 có thể **không tái hiện được bằng bàn phím** (nhưng vẫn tái hiện được bằng cách dán)	Rủi ro kết luận sai	Bước 1 (đã lường trước một phần), rà soát sau thực thi	**Ràng buộc môi trường** cộng **AI ưu tiên khả năng tự động hóa**	Ghi rõ giới hạn ở §1.6 và §5.1. Với R5, kết luận dựa trên hiệu ứng (dòng bị xóa ngay) chứ không dựa trên việc thấy Alert. Đề xuất sinh viên kiểm tra lại EP-04, EP-06, EP-08 trên Expo Go
G2	**Pass giả do trùng giá trị (EP-16).** AI chọn SL ban đầu = 2 cho mọi TC sửa SL không hợp lệ. Lỗi "+1" biến `1.5` thành `parseInt(1.5)+1 = 2`, trùng đúng giá trị "giữ nguyên"	Thiết kế dữ liệu test	Khi đọc kết quả: EP-16 Pass trong khi EP-14, 15, 17, 18 đều Fail	**Hạn chế của AI:** chọn giá trị nền mà không kiểm tra xem **các kết quả sai có thể xảy ra** có trùng kết quả đúng hay không	Chạy lại EP-16R với SL ban đầu = 3 → Fail. Đánh dấu ⚠️ trong §5.3
G3	Ở lần chạy đầu, tiêu chí nhãn "Tổng cộng" được gộp vào **mọi** TC hợp lệ. Vì thế BVA-03/04/05 Fail vì nhãn, **che mất** kết quả đúng về số lượng	Masking do tiêu chí Pass	Lượt chạy thử EP-01…05	**Hạn chế của AI:** gộp nhiều điều kiện đầu ra vào một tiêu chí	Chỉ kiểm tra nhãn ở EP-01 (TC phủ EC19). Các TC khác đánh giá riêng số lượng/tiền
G4	Không có lớp cho **kiểu dữ liệu của giá**. `GET /api/products/:id` trả `price` dạng **chuỗi** với id chẵn, còn danh sách trả số. Một giỏ trộn hai nguồn có thể cộng chuỗi thay vì cộng số	Thiếu TC	Rà soát dữ liệu API khi viết bug report	**EP chỉ xét input người dùng nhập**, không xét dạng dữ liệu hệ thống trả về	Thêm EC20, TC EP-19 → **Pass** (app nhân với SL nên ép kiểu đúng)
G5	**Rò rỉ kiến thức hộp trắng.** Trước khi thiết kế, AI đã đọc `App.js` khi tìm hiểu SUT, nên đã biết các lỗi "+1", thiếu nút +/−, nhãn "Tổng tạm tính". Việc chọn SL ban đầu khác 1 cho các TC sửa SL có thể bị ảnh hưởng	Sai phương pháp	Sinh viên tự rà soát	**Ngữ cảnh của AI** chứa mã nguồn	Mọi lớp đều có căn cứ từ FR-06/FR-07. Lỗi "+1" cũng lộ ra ngay ở TC hợp lệ EP-04 với dữ liệu tự nhiên nhất

7.2 Các TC vẫn chưa được thiết kế (rủi ro còn lại)

Lớp chưa phủ	Lý do chưa làm
Giỏ được gửi đúng và đủ khi **thanh toán** từ mobile	Thuộc FR-08. Server không lưu chi tiết sản phẩm của đơn, nên không quan sát được hộp đen qua UI/API
Giỏ còn hay mất khi **đóng/mở lại app**	Spec không nói. Hiện giỏ chỉ nằm trong bộ nhớ
Nhập SL bằng **dán** (paste) và **bàn phím số thật** trên Android/iOS	Cần thiết bị thật
Xoay ngang màn hình, cỡ chữ lớn (accessibility)	Ngoài phạm vi EP/BVA
SL cực lớn (≥ 10^{16}, vượt độ chính xác của số thực)	Spec không có biên trên; đã kiểm tra 999

7.3 Bài học

1. **Chọn giá trị nền sao cho mọi kết quả sai đều phân biệt được với kết quả đúng** (G2). Khi đã biết một lỗi có quy luật (ví dụ +1), phải kiểm tra lại các TC có thể "đúng do trùng hợp".
2. **Mỗi tiêu chí đầu ra nên có TC riêng** (G3). Gộp tiêu chí khiến một lỗi nhỏ (nhãn) che các lỗi lớn hơn, cũng giống masking ở đầu vào.
3. **Môi trường mô phỏng phải được ghi rõ giới hạn**, và kết luận nên dựa trên những hiệu ứng không phụ thuộc môi trường (G1).
4. **Dữ liệu do hệ thống trả về cũng là một miền cần phân hoạch** (G4), nhất là khi API không nhất quán về kiểu dữ liệu.

Phụ lục 29 — `bugs/README.md`

Danh mục bug (28 bug, GitHub Issues #1–#28)

Báo cáo chi tiết từng bug (bước tái hiện, mong đợi/thực tế, ảnh minh chứng) nằm trong `06_bug_report.md` của mỗi tính năng. Mỗi bug được đồng bộ thành một Issue trên `vinh-code/HW02-Software-Testing`, có tiêu đề `[FR-xx] [Mã TC] …`, nhãn `bug`, `severity:*`, `FR-xx` và ảnh nhúng.

Tính năng	Bug ID	Tiêu đề	Severity	TC phát hiện	Issue
FR-01	BUG-FR01-01	UI từ chối mọi mật khẩu hợp lệ theo spec, chỉ chấp nhận mật khẩu có khoảng trắng	Critical	EP-01, EP-02, BVA-01/03/04/06/07/09/10/12/13/15/16/18/19/20/21	#1
FR-01	BUG-FR01-02	API `/api/register` không kiểm tra độ mạnh mật khẩu	Critical	EP-11, EP-13…EP-17, BVA-05/08/11/14/17	#2
FR-01	BUG-FR01-03	Không kiểm tra email trùng, cho tạo nhiều tài khoản cùng email	Critical	EP-09, EP-10, EP-09R, EP-10R	#3
FR-01	BUG-FR01-04	Không kiểm tra định dạng email (API và UI)	Major	EP-05…EP-07, EP-05R…EP-07R	#4
FR-01	BUG-FR01-05	Thiếu trường "Xác nhận mật khẩu" (UI và API)	Major	EP-18, EP-19	#5
FR-01	BUG-FR01-06	API chấp nhận trường bắt buộc rỗng; họ tên chỉ có khoảng trắng được chấp nhận ở cả UI	Major	EP-03, EP-04, EP-04R, EP-08, EP-12, BVA-02	#6
FR-01	BUG-FR01-07	Stored XSS: Họ tên chứa HTML được thực thi trên header sau khi đăng nhập	Critical	EP-21 (TC bổ sung sau gap analysis)	#7
FR-09	BUG-FR09-01	Coupon `percent` tính sai: số tiền giảm âm, khách bị tính gấp 10 lần	Critical	EP-01, EP-03, BVA-01, BVA-04, BVA-09, BVA-10	#8
FR-09	BUG-FR09-02	Tổng đơn **bằng đúng** `min_order_amount` bị từ chối (dùng `>` thay vì `>=`)	Major	BVA-03, BVA-06	#9
FR-09	BUG-FR09-03	Áp mã giảm giá không cần đăng nhập/JWT (API và trang `/checkout`)	Critical	EP-11, EP-12	#10
FR-09	BUG-FR09-04	Né giới hạn số lần dùng mã bằng cách bỏ `user_id` khỏi request	Critical	EP-14	#11
FR-09	BUG-FR09-05	Ô "Tổng tiền thanh toán" sửa được, nên áp được mã khi giỏ chưa đủ ngưỡng	Critical	EP-15	#12
FR-09	BUG-FR09-06	API phân biệt chữ hoa/thường và không bỏ khoảng trắng của mã, không nhất quán với UI	Minor	EP-03, EP-04 (kênh API)	#13
FR-09	BUG-FR09-07	Mã hết hạn "hôm nay" vẫn dùng được nếu `expired_at` có kèm giờ (so sánh theo thời điểm, không theo ngày)	Minor	EP-16 (TC bổ sung sau gap analysis)	#14

Tính năng	Bug ID	Tiêu đề	Severity	TC phát hiện	Issue
FR-09	BUG-FR09-08	Thành tiền âm và đơn hàng có tổng âm khi mức giảm `fixed` lớn hơn tổng đơn	Major	EP-17 (TC bổ sung sau gap analysis)	#15
FR-15	BUG-FR15-01	API Thêm/Sửa/Xóa sản phẩm không yêu cầu đăng nhập và quyền admin	Critical	EP-17, EP-18, EP-19, EP-20	#16
FR-15	BUG-FR15-02	Sửa 1 sản phẩm thì bảng Admin đổi tên **mọi** sản phẩm, lần sửa tiếp theo ghi tên sai vào CSDL	Critical	EP-02, EP-22, BVA-12, BVA-13	#17
FR-15	BUG-FR15-03	Không kiểm tra giá: chấp nhận 0, số âm, rỗng, chữ (API và UI)	Major	EP-09, EP-10, EP-11, EP-12, EP-22, BVA-08	#18
FR-15	BUG-FR15-04	Không kiểm tra tên: chấp nhận tên dài hơn 255 ký tự, tên chỉ có khoảng trắng; API chấp nhận tên rỗng	Major	EP-06, EP-07, EP-08, EP-21, BVA-02, BVA-07, BVA-13	#19
FR-15	BUG-FR15-05	API chấp nhận danh mục rỗng hoặc không tồn tại	Major	EP-13, EP-14	#20
FR-15	BUG-FR15-06	Sửa/Xóa sản phẩm không tồn tại vẫn trả về thành công (HTTP 200)	Minor	EP-15, EP-16	#21
FR-15	BUG-FR15-07	Sửa sản phẩm mà thiếu trường trong request thì xóa trắng tên, mô tả, ảnh, danh mục	Major	EP-23 (TC bổ sung sau gap analysis)	#22
FR-20	BUG-FR20-01	Sửa số lượng trong giỏ bị lưu thành **n + 1** (nhập 5 được 6, nhập 1 được 2)	Critical	EP-04, BVA-07, BVA-08, BVA-09, EP-16R	#23
FR-20	BUG-FR20-02	Dòng giỏ hàng không có nút **+ / −** để chỉnh số lượng	Major	EP-05, BVA-10, BVA-11, BVA-12	#24
FR-20	BUG-FR20-03	Bấm **Xóa** sản phẩm trong giỏ xóa ngay, không có dialog xác nhận	Major	EP-06, EP-07	#25
FR-20	BUG-FR20-04	Số lượng không hợp lệ (0, âm, thập phân, chữ, rỗng) bị âm thầm đổi thành 1, không có thông báo	Minor	EP-09…EP-15, EP-17, EP-18, BVA-02, BVA-06	#26
FR-20	BUG-FR20-05	Nhãn tổng tiền là "Tổng tạm tính" thay vì "Tổng cộng"	Minor	EP-01	#27
FR-20	BUG-FR20-06	Giỏ hàng trống không có hình minh họa	Minor	EP-08	#28

Thống kê: Critical 11, Major 11, Minor 6

Ảnh chụp trang GitHub Issues

(Sinh viên chụp màn hình trang Issues của repo và đặt vào `bugs/github_issues_*.png`.)